



CHAPTER 1

Introduction to Forensics

© phyZick/Shutterstock

THIS CHAPTER INTRODUCES YOU TO THE FIELD of computer forensics. It covers some legal issues, the basic concepts of the forensic process, and a review of the basic computer and networking knowledge you will need. This chapter forms the basis for the subsequent chapters. It is important to be comfortable with the material in this chapter before proceeding.

Chapter 1 Topics

This chapter covers the following topics and concepts:

- What is computer forensics?
- What do you need to know about the field of digital forensics?
- What do you need to know for computer forensic analysis?
- What is the Daubert standard?
- What are the relevant laws?
- What are the federal guidelines?

Chapter 1 Goals

When you complete this chapter, you will be able to:

- Understand the basic concepts of forensics
- Maintain the chain of custody
- Understand basic hardware and networking knowledge needed for forensics
- Know the basic laws related to computer forensics

What Is Computer Forensics?

Before you can answer the question, “What is computer forensics?”, you should address the question, “What is forensics?” *The American Heritage Dictionary* defines *forensics* as “the use of science and technology to investigate and establish facts in criminal or civil courts of law.”

Essentially, forensics is the use of science to process evidence so you can establish the facts of a case. The individual case being examined could be criminal or civil, but the process is the same. The evidence has to be examined and processed in a consistent, scientific manner. This is to ensure that the evidence is not accidentally altered and that appropriate conclusions are derived from that evidence.

You have probably seen some crime drama wherein forensic techniques were a part of the investigative process. In such dramas, a bullet is found and forensics is used to determine which gun fired the bullet. Or perhaps a drop of blood is found and forensics is used to match the DNA to a suspect. These are all valid aspects of forensics. However, our modern world is full of electronic devices with the capacity to store data. The extraction of that data in a consistent, scientific manner is the subject of **computer forensics**. In fact, with the proliferation of smartphones, smartwatches, and other devices, some now refer to this field as **digital forensics**, emphasizing the wide range of different devices that can be included.

The U.S. Computer Emergency Response Team (US-CERT) defines computer forensics in this manner:

Forensics is the process of using scientific knowledge for collecting, analyzing, and presenting evidence to the courts.... Forensics deals primarily with the recovery and analysis of latent evidence. Latent evidence can take many forms, from finger-prints left on a window to DNA evidence recovered from bloodstains to the files on a hard drive.

According to the website Computer Forensics World:

Generally, computer forensics is considered to be the use of analytical and investigative techniques to identify, collect, examine and preserve evidence/information which is magnetically stored or encoded.

The objective in computer forensics (or digital forensics, if you prefer) is to recover, analyze, and present computer-based material in such a way that it can be used as evidence in a court of law. In computer forensics, as in any other branch of forensic science, the emphasis must be on the integrity and security of evidence. A forensic specialist must adhere to stringent guidelines and avoid taking shortcuts.

Any device that can store data is potentially the subject of computer forensics. Obviously, that includes devices such as network servers, personal computers, and laptops. However, computer forensics also encompasses devices such as smartphones, routers, tablets, printers, and global positioning system (GPS) devices. Remember that

any device that can store data is a potential subject of computer forensics.

Although the subject of computer forensics, as well as the tools and techniques used, is significantly different from traditional forensics—like DNA analysis and bullet examination—the goal is the same: to obtain evidence that can be used in some legal proceeding. Computer forensics applies to all the domains of a typical IT infrastructure, from the User Domain and Remote Access Domain to the Wide Area Network (WAN) Domain and Internet Domain (see **FIGURE 1-1**).

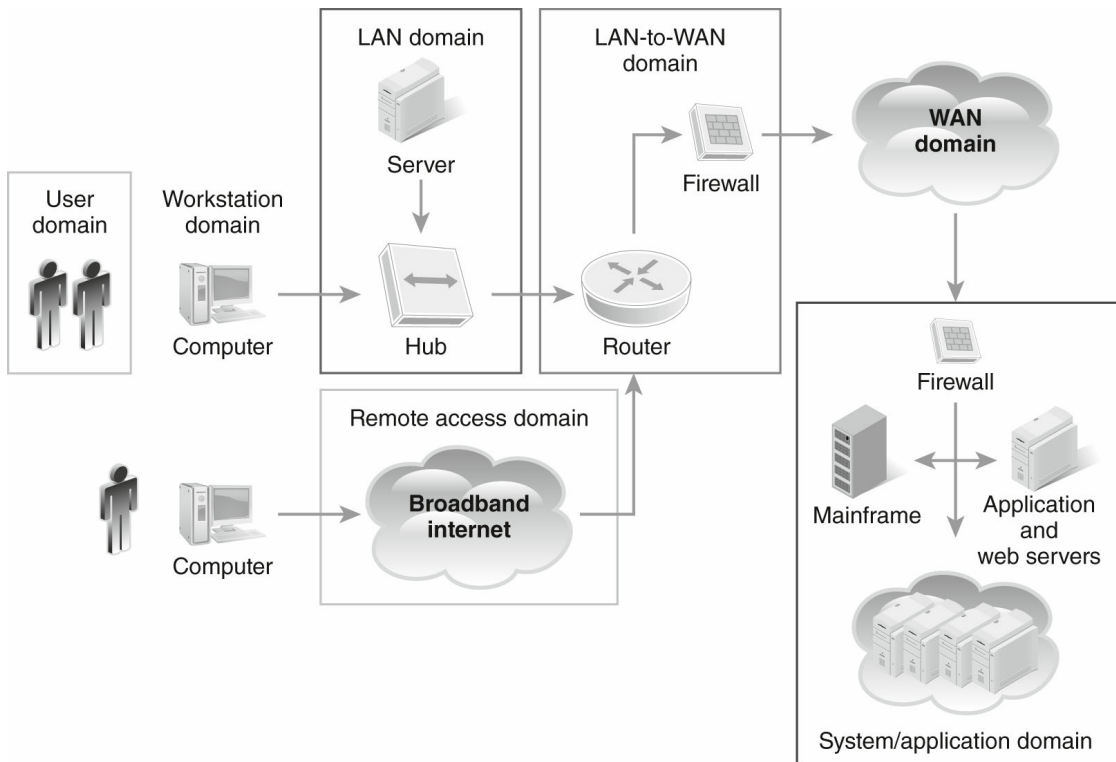


FIGURE 1-1 The seven domains of a typical IT infrastructure.

Consider some elements of the preceding definitions. In particular, let's look at this sentence: "Forensics is the process of using scientific knowledge for collecting, analyzing, and presenting evidence to the courts." Each portion of this is critical, and the following sections of this chapter examine each one individually.

Using Scientific Knowledge

First and foremost, computer forensics is a science. This is not a process based on your "gut feelings" or personal whim. It is important to understand and apply scientific methods and processes. It is also important that you have knowledge of the relevant scientific disciplines. That also means you must have scientific knowledge of the field. Computer forensics begins with a thorough understanding of computer hardware. Then you need to

understand the operating system running on that device; even smartphones and routers have operating systems. You must also understand at least the basics of computer networks. Indeed, one could argue that one issue with the current practice of forensics is that too many individuals want to enter the field without adequate computer backgrounds. Consider DNA forensics; you would not consider attempting such an endeavor if you did not have a solid working knowledge of biochemistry, genetics, and related subjects. The same is true with digital forensics. In this text, in addition to providing you with very specific forensic techniques and procedures, it will also be my goal to introduce you to enough working knowledge of computers for you to be effective as a forensic examiner.

If you attempt to master forensics without this basic knowledge, you are not likely to be successful. But if you find yourself starting in on a course and are not sure if you have the requisite knowledge, don't panic. First, you simply need a basic knowledge of computers and computer networks. If you have taken a couple of basic computer courses at a college or perhaps the CompTIA A+ certification, you have the baseline knowledge. Also, you will get a review of some basic concepts in this chapter. And, as previously stated, as we go through the book, you will be given technical details as needed. Material will be presented with the assumption that you have zero knowledge of computers. That is not likely to be true for all readers. If you already have substantial computer knowledge, then you can consider the technical material presented to be a review.

However, the more you know about computers and networks, the better you will be at computer forensics. There is no such thing as "knowing too much." Even though some technical details change quickly, such as the capacity and materials of hard disks, other details change very slowly, if at all, such as the various file systems, the role of volatile and non-volatile memory, and the fact that criminals take advantage of the advancements in computer and digital technology to improve their lives as much as the businessperson, student, or homeowner. A great deal of information is stored in computers. Keep learning what is there, where it is stored, and how that information may be used by computer user and computer criminal alike.

Collecting

Before you can do any forensic analysis or examination, you have to collect the evidence. There are very specific procedures for properly collecting evidence. You will be introduced to some general guidelines later in this chapter. The important thing to realize for now is that how you collect the evidence determines if that evidence is admissible in a court.

Analyzing

Data analysis is one of the most time-consuming parts of a forensic investigation, and it can be the most challenging. Once you have collected the data, what does it mean? The real difference between a mediocre investigator and a star investigator is the analysis. The data is there, but do you know what it means? This is also related to your level of scientific knowledge. If you don't know enough, you may not see the significance of the data you have.

You also have to be able to solve puzzles. That is, in essence, what any forensic

investigation is. It is solving a complex puzzle—putting together the data you have and finding out what sort of picture is revealed. You might try to approach a forensic investigation like Sherlock Holmes. Look at every detail. What does it mean? Before you jump to a conclusion, how much evidence do you have to support that conclusion? Are there alternative and, in fact, better explanations for the data?

Presenting

Once you have finished your investigation, done your analysis, and obeyed all the rules and guidelines, you still have one more step. You will have to present that evidence in one form or another. The two most basic forms are the *expert report* and *expert testimony*. In either case, it will be your job to interpret the arcane and seemingly impenetrable technical information using plain English that paints an accurate picture for the court. You must not use jargon and technobabble. Your clear use of language, and potentially graphics and demonstrations if needed, may be the difference between a big win and a lost case. So you should take a quick look at each of these.

The Expert Report

An **expert report** is a formal document that lists what tests you conducted, what you found, and your conclusions. It also includes your **curriculum vitae (CV)**, which is like a résumé, only much more thorough and specific to your work experience as a forensic investigator. Specific rules will vary from court to court, but as a general rule, if you don't put a specific subject in your report, you cannot testify about it at trial. So you need to make very certain that your report is thorough. Put in every single test you used, every single thing you found, and your conclusions. Expert reports tend to be rather long.



WARNING

Court procedures vary from jurisdiction to jurisdiction, but in most cases, an expert cannot directly testify about anything not in his or her expert report. That is why it is critical to be thorough and to put into the report anything you feel might be pertinent to the case. In your work as an expert witness, you will often find additional items in an investigation—items that are peripheral to the main case. If you put those in your report, however, you will be able to testify about them at trial.

It is also important to back up your conclusions. As a general rule, it's good to have at least two to three references for every conclusion. In other words, in addition to your own opinion, you want to have a few reputable references that either agree with that conclusion or provide support for how you came to that conclusion. This way, your conclusion is not just based on your expert opinion, but also supported by other reputable sources. Make sure you use reputable sources. For example, US-CERT, the Federal Bureau of Investigation (FBI), the U.S. Secret Service, and the Cornell University Law School are all very reputable sources.

The reason for this is that in every legal case, there are two sides. The opposing side will have an attorney and perhaps its own expert. The opposing attorney will want to pick apart every opinion and conclusion you have. If there is an opposing expert, he or she will be looking for alternative interpretations of the data or flaws in your method. You have to make sure you have fully supported your conclusions.

It should be noted that the length and level of detail found in reports varies. In many cases, criminal courts won't require a formal expert report, but rather a statement from the attorney as to who you are and what topics you intend to testify about. You will need to produce a report of your forensic examination. In civil court, particularly in intellectual property cases, the expert report is far more lengthy and far more detailed. In my own experience, reports of 100, 200, or more pages are common. The largest I have seen yet was over 1500 pages long.

While not all cases will involve a full, detailed expert report, many will—particularly intellectual property cases. There are few legal guidelines on expert report writing, but a few issues have become clear in my experience. Let's cover what I have learned from years of working on court cases.

Expert reports generally start with the expert's qualifications. This should be a complete CV detailing education, work history, and publications. Particular attention should be paid to elements of the expert's history that are directly related to the case at hand. If the case involves Windows Server 2019, what is your experience and training related to that? If you use a particular forensics tool or technique, you should describe your experience and training that are related to that tool or technique. Then the report moves on to the actual topic at hand. An expert report is a very thorough document. It must first detail exactly what analysis was used: How did the expert conduct their examination and analysis? In the case of computer forensics, the expert report should detail what tools the expert used, what the results were, and the conditions of the tests conducted. You may wonder how much detail is required. The answer is simple: enough detail so that any competent forensics analyst could replicate your tests. Also, any claim an expert makes in a report should be supported by extrinsic reputable sources. This is sometimes overlooked by experts because they themselves are sources that are used, or because the claim being made seems obvious to them. For example, if an expert report needs to detail how domain name service (DNS) works to describe a DNS poisoning attack, then there should be references to recognized, authoritative works regarding the details of domain name service. The reason this matters is that at trial, a creative attorney can often extract nontraditional meanings from even commonly understood terms.

The next issue with an expert report is its completeness. The report must cover every item the expert wishes to opine on, and in detail. Nothing can be assumed. In some jurisdictions, if an item is not in the expert report, then the expert is not allowed to express an opinion about it during testimony. Whether that is the case in your jurisdiction or not, it is imperative that the expert report that is submitted must be very thorough and complete—and, of course, it must be error free. Even the smallest error can give opposing counsel an opportunity to impugn the accuracy of the entire report—as well as the expert's entire testimony. This is a document that should be carefully proofread by the expert and by the attorney retaining the expert.

Expert Testimony

As a forensic specialist, you will testify as an expert witness—that is, on the basis of

scientific or technical knowledge you have that is relevant to a case, rather than on the basis of direct personal experience. Your testimony will be referred to as **expert testimony**, and there are two scenarios in which you give it. The first is a deposition, and the second is a trial. A *deposition*—testimony taken from a witness or party to a case before a trial—is less formal and is typically held in an attorney's office. The other side's lawyer gets to ask you questions. In fact, the lawyer can even ask some questions that would probably be disallowed by a trial judge. But do remember, this is still sworn testimony, and lying under oath is perjury, which is a felony.

Allow me to elaborate a bit on perjury. Telling an overt lie is not only a felony, but even if criminal charges are not brought, it will destroy your reputation. A forensics expert can survive a technical mistake or even being outright wrong. But your career cannot survive a lie. Some people try to shade the truth a bit—not overtly lying, but being evasive or trying to alter their answer to point in a particular direction. This is a significant mistake for a forensic analyst. First, you should remember that your goal is not to win or lose a case. Your goal is to present scientifically valid evidence in a manner that is acceptable to a court. If in your investigation you find evidence that would tend to undermine the case of whomever hired you, then your responsibility is to inform them of this as early as possible. It is not your responsibility to try and color your testimony in such a way as to obfuscate that evidence. Many people find testifying very stressful. I must confess that I, too, found it immensely stressful the first few times. However, I learned a secret that I will impart to you: If you do a really thorough and complete job, then all you have to do is to tell the truth. And that is not stressful at all.

U.S. Federal Rule 702 defines what an expert is and what expert testimony is:

“A witness who is qualified as an expert by knowledge, skill, experience, training, or education may testify in the form of an opinion or otherwise if:

- a. the expert's scientific, technical, or other specialized knowledge will help the trier of fact to understand the evidence or to determine a fact in issue;
- b. the testimony is based on sufficient facts or data;
- c. the testimony is the product of reliable principles and methods; and
- d. the expert has reliably applied the principles and methods to the facts of the case.”¹

This definition is very helpful. Yes, you do require training and experience in order to be an expert witness. However, regardless of your credentials, did you base your conclusions on sufficient facts and data? Did you apply reliable scientific principles and methods in forming your conclusions? These questions should guide your forensic work.

During a deposition, the opposing counsel has a few goals. The first goal is to find out as much as possible about your position, methods, conclusions, and even your side's legal strategy. It is important to answer honestly but as briefly as possible. Don't volunteer information unasked. That simply allows the other side to be better prepared for trial. The second thing a lawyer is looking for during a deposition is to get you to commit to a position you may not be able to defend later. So follow a few rules:

- If you don't fully understand the question, say so. Ask for clarification before you

answer. The opposing counsel will likely ask questions in such a way as to lead to a particular conclusion. Listen very carefully to the specific words he or she uses.

- If you really don't know, say so. Do not ever guess. Now, opposing counsel may try to make you feel awkward about not knowing something—try to badger you into giving some answer. But the fact is, no one knows everything. It is better to say you don't know than to take a guess.
- If you are not 100 percent certain of an answer, say so. Say, “to the best of my current recollection,” or something to that effect.
- Whenever possible, review any document being referred to. Re-read your report and read any exhibit. If you have a document there, refer to it; do not testify from memory.

The other way you may testify is at trial. The first thing you absolutely must understand is that the first time you testify, you will be nervous. You'll begin to wonder if you are properly prepared. Are your conclusions correct? Did you miss anything? Don't worry; each time you do this, it gets easier. Next, remember that the opposing counsel, by definition, disagrees with you, and wants to trip you up. It might be helpful to remind yourself, “The opposing counsel's default position is that I am both incompetent and a liar.” Now that is a bit harsh, and probably an overstatement. But if you start from that premise, you will be prepared for the opposing counsel's questions. Don't be too upset if he or she is trying to make you look bad. It's not personal.

The secret to deposition and trial testimony is simple: Be prepared. Not only should you make certain your forensic process is done correctly and well documented, including liberal use of charts, diagrams, and other graphics, but you should also prepare before you testify. Go over your report and your notes again. Often, your attorney will prep you, particularly if you have never testified before. Try to look objectively at your own report to see if there is anything the opposing counsel might use against you. Are there alternative ways to interpret the evidence? If so, why did you reject them?

The most important things on the stand are to keep calm and tell the truth. Obviously, any lie, even a very minor one that is not directly related to your investigation, would be devastating. But becoming agitated or angry on the stand can also undermine your credibility. When asked a question, answer it directly. Don't try to be evasive.

In addition to U.S. Federal Rule 702, there are several other U.S. Federal Rules related to expert witness testimony at trial. They are listed and very briefly described here.

- **Rule 703: Bases of an expert²:** An expert may base an opinion on facts or data that the expert has been made aware of or personally observed. If experts in the particular field would reasonably rely on those kinds of facts or data in forming an opinion on the subject, they need not be admissible for the opinion to be admitted. But if the facts or data would otherwise be inadmissible, the proponent of the opinion may disclose them to the jury only if their **probative value**—that is, the weight they carry in helping reach a valid judgment—in helping the jury evaluate the opinion

substantially outweighs their prejudicial effect.

- **Rule 704: Opinion on ultimate issue³:** An opinion is not objectionable just because it embraces an ultimate issue. In other words an expert witness can, in many cases, offer an opinion as to the ultimate issue in a case.
- **Rule 705: Disclosing the facts or data underlying an expert⁴:** Unless the court orders otherwise, an expert may state an opinion—and give the reasons for it—without first testifying to the underlying facts or data. But the expert may be required to disclose those facts or data on cross-examination. Essentially, the expert can state his or her opinion without first giving the underlying facts, but he or she should expect to be questioned on those facts at some point.
- **Rule 706: Court-appointed expert witness⁵:** This rule covers the appointment of neutral experts used to advise the court. Such experts are working for neither the plaintiff nor the defendant; they work for the court.
- **Rule 401: Test for relevant evidence⁶:** Evidence is relevant if (a) it has any tendency to make a fact more or less probable than it would be without the evidence and (b) the fact is of consequence in determining the action.

Understanding the Field of Digital Forensics

The digital forensics field is changing very rapidly. First and foremost, standards are emerging. This means there are clearly defined ways of properly doing forensics. When computer forensics first began, most investigations were conducted according to the whims of the investigator rather than through a standardized methodology. But as the field has matured, it has also become standardized. Today, there are clear, codified methods for conducting a forensic examination.

Another change is in who is doing forensics. At one time, all forensics, including computer forensics, was the exclusive domain of law enforcement. That is no longer the case. Today, the following entities are also involved in and actively using computer forensics:

- **The military** uses digital forensics to gather intelligence information from computers captured during military actions.
- **Government agencies** use digital forensics to investigate crimes involving computers. These agencies include the Federal Bureau of Investigation (FBI), the U.S. Postal Inspection Service, the Federal Trade Commission (FTC), the U.S. Food and Drug Administration (FDA), and the U.S. Secret Service. They also include the U.S. Department of Justice's National Institute of Justice (NIJ), the National Institute of Standards and Technology (NIST) Office of Law Enforcement Standards (OLEs), the Department of Homeland Security, and foreign government agencies, among others.
- **Law firms** need experienced system forensics professionals to conduct investigations and testify as expert witnesses. For example, civil cases can use records found on computer systems that bear on cases involving fraud, divorce, discrimination, and harassment.
- **Criminal prosecutors** use digital evidence when working with incriminating documents. They try to link these documents to crimes such as drug trafficking, embezzlement, financial fraud, homicide, and child pornography.
- **Academia** is involved with forensic research and education. For example, many universities offer degrees in digital forensics and online criminal justice.
- **Data recovery firms** use digital forensics techniques to recover data after hardware or software failures and when data has been lost.
- **Corporations** use digital forensics to assist in employee termination and prosecution. For example, corporations sometimes need to gather information

concerning theft of intellectual property or trade secrets, fraud, embezzlement, sexual harassment, and network and computer intrusions. They also need to find evidence of unauthorized use of equipment, such as computers, fax machines, answering machines, and mobile phones.

- **Insurance companies** use digital evidence of possible fraud in accident, arson, and workers' compensation cases.
- **Individuals** sometimes hire forensic specialists in support of possible claims. These cases may include, for example, wrongful termination, sexual harassment, or age discrimination.

What Is Digital Evidence?

Information includes raw numbers, pictures, and a vast array of other data that may or may not have relevance to a particular event or incident under investigation. **Digital evidence** is information that has been processed and assembled so that it is relevant to an investigation and supports a specific finding or determination. Put another way, all the raw information is not, in and of itself, evidence. Data has to be first and foremost relevant to a case, in order to be evidence.

Investigators must carefully show an unbroken chain of custody to demonstrate that evidence has been protected from tampering. The **chain of custody** is the continuity of control of evidence that makes it possible to account for all that has happened to evidence between its original collection and its appearance in court, preferably unaltered. If forensic specialists can't demonstrate that they have maintained the chain of custody, then the court may consider all their conclusions invalid.

Courts deal with four types of evidence:

- **Real** evidence is a physical object that someone can touch, hold, or directly observe. Examples of real evidence are a laptop with a suspect's fingerprints on the keyboard, a hard drive, a universal serial bus (USB) drive, and a handwritten note.
- **Documentary** evidence is data stored as written matter, on paper, or in electronic files. Documentary evidence includes memory-resident data and computer files. Examples are email messages, logs, databases, photographs, and telephone call-detail records. Investigators must **authenticate** documentary evidence—that is, demonstrate that it's genuine and was not created after the fact.
- **Testimonial** evidence is information that forensic specialists use to support or interpret real or documentary evidence. For example, they may employ testimonial evidence to demonstrate that the fingerprints found on a keyboard are those of a specific individual. Or system access controls might show that a particular user

stored specific photographs on a desktop.

- **Demonstrative** evidence is information that helps explain other evidence—*any* other evidence. That could be testimonial evidence, documentary evidence, or real evidence. An example is a chart that explains a technical concept to the judge and jury. Forensic specialists must often provide testimony to support the conclusions of their analyses. For example, a member of an incident response team might be required to testify that he or she identified the computer program that deleted customer records at a specified date and time. In such a case, the testimony must show how the investigator reached his or her conclusion. The testimony must also show that the specialist protected against tampering with the information used in making the determination. That is, the testimony must show that the forensic investigator maintained the chain of custody. It must also show that the testifier based his or her conclusion on a reasonable, although not necessarily absolute, interpretation of the information. Further, the forensic specialist must present his or her testimony in a manner that avoids use of technical jargon and complex technical discussions and should use pictures, charts, and other graphics when helpful. Judges, juries, and lawyers aren't all technical experts. Therefore, a forensic specialist should translate technology into understandable descriptions. Pictures often communicate better than just numbers and words, so a forensic specialist may want to create charts and graphs.

Scope-Related Challenges to System Forensics

The scope of a forensic effort often presents not just an analytical challenge but a psychological challenge as well. Information systems collect and retain large volumes of data. They store this data in a dizzying array of applications, formats, and hardware components. In completing an analysis, forensic specialists face variations in the following:

- The volume of data to be analyzed
- The complexity of the computer system
- The size and character of the crime scene, which might involve a network that crosses U.S. and foreign jurisdictions
- The size of the caseload and resource limitations

Forensic specialists must be prepared to quickly complete an analysis regardless of these factors. The following sections discuss these factors in more detail.

Large Volumes of Data

Digital forensics is useful in identifying and documenting evidence. It is a disciplined approach that looks at the entire physical media, such as a hard disk drive, for all information representations. A system forensics specialist has access to all the information contained on a device—not just what the end user sees. A forensic analyst also examines *metadata*, which is data about information, such as disk partition structures and file tables. Metadata also includes file creation and modification times. Who authored a file and when it was revised or updated are also important pieces of metadata for a forensic analyst to document. An analyst also examines the often-critical unused areas of the media where information might be hidden. Examining all areas of potential data storage and examining all potential data representations generates extremely large volumes of information. A forensic specialist must analyze, store, and control all this information for the full duration of the investigation and analysis.

The total amount of information that is potentially relevant to a case offers a challenge to forensic analysts. Hard drives well in excess of 1 terabyte are quite common today. In fact, one can purchase a 4- or 5-terabyte drive for under \$120 at any electronics store. While writing this chapter for the fourth edition of the book, I bought a 10-terabyte external drive for only \$180. Sizes keep increasing and prices dropping. When working with such large volumes, a forensic specialist must do the following:

- Ensure that his or her equipment is capable of manipulating large volumes of information quickly.
- Provide for duplicate storage so that the original media and its resident information are preserved and protected against tampering and other corruption.
- Create backups early and often to avoid losing actual information and its associated metadata.
- Document everything that is done in an investigation and maintain the chain of custody.

In addition to all these tasks, a forensic specialist must work within the forensic budget. Manipulating and controlling large volumes of information is expensive. An investigator should show how budget cost items contribute to the analysis and to maintaining the chain of custody. Resource limitations increase the potential for analysis error and may compromise the analysis. For example, a forensic analyst may need to explain how the addition of data custodians or additional hard drives can multiply costs.

System Complexity

Modern computer systems can be extremely complex. This is not just a matter of the aforementioned size of storage, but rather the wide array of data and formats. Digital devices use multiple file formats, including Adobe Portable Document Format (PDF) files, Microsoft Word (DOC and DOCX) documents, Microsoft Excel spreadsheets (XLS), video files (MP4, AVI, MOV, etc.), and image files (JPEG, GIF, BMP, PNG, etc.), to name just a few. This does not even take into account formats of information “in motion” such as Voice over IP (VoIP), instant messaging protocols, or real-time video broadcast or two-

way conferences. These systems connect to and share data with other systems that may be located anywhere in the world. In addition, the law may protect specific items and not others. No single forensic software application can deal with all the complexity.

Forensic specialists must use a set of software and hardware tools and supporting manual procedures. Further, a forensic specialist must build a case to support his or her interpretation of the “story” told by the information being analyzed. The specialist, therefore, must have an understanding of all digital information and its associated technology. The specialist should also be able to show corroboration that meets the traditional legal evidence tests. Specific tests of legal evidence can vary from venue to venue and from jurisdiction to jurisdiction—or both. There are a few basic tests that apply everywhere, but the chain of custody and the Daubert standard, both of which are discussed in this chapter, are nearly universal.

Individual pieces of information may have more than one possible interpretation. To reach a conclusion and turn raw information into supportable, actionable evidence, a forensic specialist must identify and analyze corroborating information. In other words, it is often the case that a single piece of information is not conclusive. It often takes the examination and correlation of multiple individual pieces of information to reach a conclusion. It is also a common practice for a forensic investigator to use more than one tool to conduct a test. For example, if you utilize one particular tool to recover deleted files, it can be a good idea to use yet another tool to conduct the same test. If two different tools yield the same result, this is compelling evidence that the information gathered is accurate and reliable. However, if the results differ, the forensic analyst has another situation to deal with.

Distributed Crime Scenes

Because networks are geographically dispersed, crime scenes may also be geographically dispersed. This creates practical as well as jurisdictional problems. Think about how difficult it is for a U.S. investigator to get evidence out of computers in China, for instance. Criminals take advantage of jurisdictional differences. A criminal may sell fake merchandise via the internet from a foreign country to Americans in several states. The criminal may then route his or her internet access, and the associated electronic payments, through several other countries before they reach their final destination.

Digital crime scenes can, and increasingly do, span the globe. Depending on the type of system connectivity and the controls in place, a forensic specialist may have to deal with information stored throughout the world and often in languages other than English. This could involve thousands of devices and network logs. Networks and centralized storage also present challenges because items of interest may not be stored on the target computer.

Gathering evidence from such a geographically far-flung digital crime scene requires the cooperation of local, state, and tribal governments, sometimes multiple national governments, and international agencies in tracking down the criminals and bringing them to justice. If all the governments and agencies do not cooperate with one another, the investigation may fail.

Growing Caseload and Limited Resources

The number of forensic specialists today is too small to analyze every cybercrime. Regardless of the state of the economy, digital forensics specialists can be assured of two

things: Their caseload will grow, and their resources will, relative to caseload, become more limited. It is a simple fact that anyone in law enforcement who works in digital crimes has a case backlog, and that backlog is increasing.

The digital forensics analysis workload is growing and will continue to grow as computers and related digital devices are used more and in different ways in the commission of crimes. Driving this growth is the increasing use of technology in all aspects of modern life, not just in support of business objectives. Criminals utilize technology not only to conduct crimes but also, in some cases, to hide the evidence. Forensic tools can also be used by criminals to eradicate evidence as easily as they can be used by investigators to locate, analyze, and catalog evidence.

Types of Digital System Forensics Analysis

Today, digital system forensics includes a number of specialties. The following are some examples:

- **Disk forensics** is the process of acquiring and analyzing information stored on physical storage media, such as computer hard drives, smartphones, GPS systems, and removable media. Disk forensics includes both the recovery of hidden and deleted information and the process of identifying who created a file or message.
- **Email forensics** is the study of the source and content of email as evidence. Email forensics includes the process of identifying the sender, recipient, date, time, and origination location of an email message. You can use email forensics to identify harassment, discrimination, or unauthorized activities. There is also a body of laws that deal with retention and storage of emails that are specific to certain fields, such as financial and medical.
- **Network forensics** is the process of examining network traffic, including transaction logs and real-time monitoring using sniffers and tracing.
- **Internet forensics** is the process of piecing together where and when a user has been on the internet. For example, you can use internet forensics to determine whether inappropriate internet content access and downloading were accidental.
- **Software forensics**, also known as *malware forensics*, is the process of examining malicious computer code.
- **Live system forensics** is the process of searching memory in real time, typically for working with compromised hosts or to identify system abuse. Each of these types of forensic analysis requires specialized skills and training.
- **Cell-phone forensics** is the process of searching the contents of cell phones. A few years ago, this was just not a big issue, but with the ubiquitous nature of cell phones

today, cell-phone forensics is a very important topic. A cell phone can be a treasure trove of evidence. Modern cell phones are essentially computers with processors, memory, even hard drives and operating systems, and they operate on networks. Phone forensics also includes VoIP and traditional phones and may overlap the Foreign Intelligence Surveillance Act of 1978 (FISA), the USA PATRIOT Act, and the Communications Assistance for Law Enforcement Act (CALEA) in the United States.

General Guidelines

Later in this chapter, you will read about specific federal guidelines, but you should keep a few general principles in mind when doing any forensic work, as discussed in the following sections.

Chain of Custody

This is the most important principle in any forensic effort, digital or nondigital. The chain of physical custody must be maintained. From the time the evidence is first seized by a law enforcement officer or civilian investigator until the moment it is shown in court, the whereabouts and custody of the evidence, and how it was handled and stored and by whom, must be able to be shown at all times. Failure to maintain the proper chain of custody can lead to evidence being excluded from trial.

Don't Touch the Suspect Drive

One very important principle is to touch the system as little as possible. It is possible to make changes to the system in the process of examining it, which is very undesirable. Obviously, you have to interact with the system to investigate it. The answer is to make a forensic copy and work with that copy. You can make a forensic copy with most major forensic tools such as AccessData's Forensic Toolkit, Guidance Software's EnCase, or PassMark's OSForensics. There are also open source software products that allow copying of original source information. To be specific, make a copy and analyze the copy.

There are times when you will need to interact directly with live evidence. For example, when a computer is first discovered, you will want to do an initial analysis to determine running processes and connections before you make an image. You may also need to perform live forensics in certain situations such as some cloud computing environments. We will discuss these as we encounter them in this book.

Document Trail

The next issue is documentation. The rule is that you document everything. Who was present when the device was seized? What was connected to the device or showing on the screen when you seized it? What specific tools and techniques did you use? Who had access to the evidence from the time of seizure until the time of trial? All of this must be documented. And when in doubt, err on the side of over-documentation. It really is not possible to document too much information about an investigation.

Secure the Evidence

It is absolutely critical to the integrity of your investigation as well as to maintaining the chain of custody that you secure the evidence. It is common to have the forensic lab be a locked room with access given only to those who must enter. Then, evidence is usually secured in a safe, with access given out only on a need-to-know basis. You have to take every reasonable precaution to ensure that no one can tamper with the evidence.

Knowledge Needed for Computer Forensics Analysis

To conduct computer forensics, a certain background body of knowledge is required, just as with traditional forensics. For example, you cannot examine DNA without some basic education in blood and genetics. This applies to computer forensics as well. You must have an understanding of the systems you are examining in order to successfully examine them.

This chapter assumes that you have a basic understanding of computer hardware, software, and operating systems. This section briefly discusses the highlights of these areas that you need to know, however. If you find you are lacking in one or more areas, you should take some time to brush up on these topics before continuing. For many readers, these items will be a review; for others, some information may be new. If this is new information for you, bear in mind that this is the absolute minimum of knowledge. The more you know about the underlying technology, the more effective you will be.

Hardware

In general, the good digital forensics examiners begin with a working knowledge of the hardware for the devices they want to examine. For PCs and laptops, this includes knowledge equivalent to the CompTIA A+ certification or a basic PC hardware course. If you are doing phone or router forensics, you need a similar level of knowledge of the hardware on those devices.

For PCs, this means a strong understanding of hard drives, memory, motherboards, and expansion cards. What exactly is a “strong understanding”? Think about random access memory (RAM). You are probably aware that RAM is **volatile memory** and it stores the programs and data you currently have open, but only for as long as the computer has power supplied to it. However, that level of knowledge is inadequate for forensics. A forensic examiner needs to go much deeper and understand the various types of RAM, how they work, the type of information that is contained in each, and how the computer uses them.

Random Access Memory

RAM can be examined in multiple ways. One way is to look at the method whereby information is written to and read from the RAM. These are presented in sequential order from older to newer technologies:

- **Extended data out dynamic random access memory (EDO DRAM)**—Single-cycle EDO has the ability to carry out a complete memory transaction in one clock cycle. Otherwise, each sequential RAM access within the same page takes two clock cycles instead of three, once the page has been selected.

- **Burst EDO (BEDO) DRAM**—An evolution of the EDO, burst EDO DRAM can process four memory addresses in one burst.
- **Asynchronous dynamic random access memory (ADRAM)**—ADRAM is not synchronized to the CPU clock.
- **Synchronous dynamic random access memory (SDRAM)**—SDRAM is a replacement for EDO.
- **Double data rate (DDR) SDRAM**—DDR SDRAM was a later development of SDRAM. DDR2, DDR3, and DDR4 are now available. DDR 5 is still under development at the time of this writing, but should be available soon, in fall of 2021.

SDRAM and, more specifically, DDR3 and DDR4, are the most common forms of RAM found in PCs and laptops.

Another way to look at RAM, and one that is particularly important from a forensic point of view, is to consider the volatility of the data stored. Volatility refers to how easily the data can be changed, either intentionally or unintentionally:

- **Random access memory (RAM)**—RAM is what most people think of when they say *memory*. It is easy to write to and read from. RAM is very volatile; as soon as power is discontinued, the data is gone.
- **Read-only memory (ROM)**—As the name suggests, ROM is not at all volatile; it cannot be changed. This is usually used for instructions embedded in chips and controls how the computer, option cards, peripherals, and other devices operate.
- **Programmable read-only memory (PROM)**—PROM can be programmed only once. Data is not lost when power is removed.
- **Erasable programmable read-only memory (EPROM)**—Data is not lost when power is removed. Again, EPROM is a technique for storing instructions on chips.
- **Electrically erasable programmable read-only memory (EEPROM)**—This form is how the instructions in your computer's basic input/output system (BIOS) are stored.

Hard Drives

A forensic specialist must also understand the following storage devices. The descriptions given here are for various types of connectors. The drives themselves are the same, but the method of attaching the drive, as well as the speed and efficiency of getting data to and from the drive, differ.

- **Small Computer System Interface (SCSI)**—SCSI has been around for many years, and it is particularly popular in high-end servers. This standard is actually fairly old,

as it was established in 1986. SCSI devices must have a terminator at the end of the chain of devices to work and are limited to 16 chained devices.

- **Integrated Drive Electronics (IDE)**—IDE is an older standard, but it is one that was commonly used on PCs for many years. It is obvious you are dealing with an IDE or EIDE drive if you encounter a 40-pin connector on the drive.
- **Enhanced Integrated Drive Electronics (EIDE)**—This is an extension/enhancement of IDE.
- **Parallel Advanced Technology Attachment (PATA)**—PATA is an enhancement of IDE. It uses either a 40-pin (like IDE) or 80-pin connector.
- **Serial Advanced Technology Attachment (SATA)**—SATA is what you are most likely to find today. These devices are commonly found in workstations and many servers. The internals of the hard drive are very similar to IDE and EIDE, but the connectivity to the computer's motherboard is different. Also, unlike IDE or EIDE drives, this type of drive has no jumpers to set the drive.
- **Serial SCSI**—This is an enhancement of SCSI. It supports up to 65,537 devices and does not require termination.
- **Solid-state drives**—Solid-state drives (SSDs) are becoming more common, so it's worthwhile to discuss them in a bit more detail. Unlike the previously discussed drive types, these are not the same basic hard drive. These drives have an entirely different construction and method of storing data. SSDs use microchips that retain data in non-volatile memory chips and contain no moving parts. Since 2010, most SSDs have used NAND-based flash memory (NAND stands for "negated AND gate"), which retains memory even without power. Solid-state drives do not benefit from defragmentation. Any defragmentation process adds additional writes on the NAND flash, which already has a limited cycle life. High-performance flash-based SSDs generally require one-half to one-third the power of hard disk drives (HDDs); high-performance DRAM SSDs generally require as much power as HDDs and consume power when the rest of the system is shut down.

All of these, except for SSDs, refer to how the hard drive connects to the motherboard and transfers data, and do not define how information is stored on the disk. For all but SSDs, the following hard drive facts apply.

HDDs record data by magnetizing ferromagnetic material directionally to represent either a 0 or a 1 binary digit. The magnetic data is stored on platters; the platters are organized on a spindle with a read/write head reading and writing data to and from the platters. The data is organized as follows:

- A *sector* is the basic unit of data storage on a hard disk, which is usually 512 bytes. However, newer systems often use a 4096-byte sector size.
- A cluster is a logical grouping of sectors. Clusters can be 1 to 128 sectors in size. That means 512 bytes up to 64 kilobytes. The minimum size a file can use is one cluster. If the file is less than the size of a cluster, the remaining space is simply unused.
- Sectors are in turn organized by tracks.
- **Drive geometry** refers to the functional dimensions of a drive in terms of the number of heads, cylinders, and sectors per track.

That is a basic description of most hard drives (with the exception of solid-state drives). Forensic examiners should know the following terms, which are used with all hard drives, including solid-state drives (note these terms are the same, even though the structures of solid-state drives and traditional hard drives are different):

- **Slack space** is the space between the end of a file and the end of the cluster, assuming the file does not occupy the entire cluster. This is space that can be used to hide data. Discussing slack space brings us to an issue regarding SSDs. With SSDs, a technique called *wear leveling* is used to extend the life of the drive. The issue is that SSDs use flash memory (and related technology) with individual segments (as opposed to sectors). Each segment has a finite number of erase cycles before the segment is unreliable. Thus wear leveling spreads out the use of the SSD to avoid this problem. That means slack space is not particularly useful on SSDs.
- **Low-level format** creates a structure of sectors, tracks, and clusters.
- **High-level format** is the process of setting up an empty file system on the disk and installing a boot sector. This is sometimes referred to as a quick format.

It should be noted that SSDs have become the most common. At first, they were used largely for external drives and laptops. However, the use of that SSDs is continuing to grow. So you should expect to see these more often.

Software

Once you have a basic understanding of hardware, the next step is to learn about the software, and this begins with the operating system. It is imperative that you have a strong working knowledge of the operating system running on the device you want to examine.

Windows

There's a lot to know about Windows, but for now, here's a basic overview of how it works. The heart of Windows is the Windows Registry. The Windows Registry is essentially a repository of all settings, software, and parameters for Windows. If new software is installed, the Registry is updated to indicate the new software. If the background color of the desktop is changed, the Registry is updated to indicate the new color. From this Registry, you can get all kinds of information, including the password for wireless networks and the serial numbers for all USB devices that have been connected to that computer. This is really the most important part of Windows from both a technical support and a forensic point of view.

Windows also has other interesting places to look for forensic evidence. There are certain folders and files—the index.dat file, for instance—that are great places to find evidence. Even browser cookies and history can be useful. Given that Windows is such a common operating system, it is advisable to be very familiar with Windows.

Linux

Linux is particularly interesting from a forensic point of view. Even though it is not as widely used as Windows, it is a favorite in the security and forensics community. You will find that a lot of free forensic tools come with Linux. In fact, one specific Linux distribution called Kali Linux (formerly BackTrack in 2013) has an extensive collection of forensic, security, and hacking tools.

Linux is a UNIX clone, developed originally by Linus Torvalds. There are now well over 100 different distributions, or variations, of Linux. However, all have some commonalities. In the Linux world, work done from the command line, called the shell in Linux, is far more important than it is in Windows.

Mac OS

For many years, Apple Macintosh (currently branded as macOS) was a complete operating system. However, beginning with OS X, the Mac OS system has been based on FreeBSD, a UNIX clone very similar to Linux. The graphical user interface is just that: an interface. The underlying operating system is a UNIX-like system.

This means that many forensic techniques you can use on Linux can also be used on Mac OS, from the shell prompt.

Files and File Systems

Computers store discrete sets of related information in files. Any document, spreadsheet, picture, video, or even program is a file. It is a very easy thing to change the extension of a file so that it looks like some other type of file. However, that will not change the file structure itself. There are tools that allow viewing of the actual file structure and the file header. This is very important from a forensic perspective. The file header gives you an accurate understanding of the file, regardless of whether the extension has been changed. A few basic facts about files are as follows:

- File headers start at the first byte of a file. This is particularly important when we look at file carving later in this book.
- In graphics file formats, the header might give information about an image's size,

resolution, number of colors, and the like.

- The Executable and Linkable Format (ELF, formerly called Extensible Linking Format) is a common standard file format for executables, object code, and shared libraries for UNIX-based systems.
- Portable Executable (PE) is used in Windows for executables and dynamic-link libraries (DLLs). PE files are derived from the earlier Common Object File Format (COFF) found on VAX/VMS, a common operating system for mainframe computers.
- Area density is the data per area of disk.
- Windows Office files have a globally unique identifier (GUID) to identify them.

Files are organized on the computer based on the file system. There are many file systems, but they can be divided into two categories. Journaling is basically the process whereby the file system keeps a record of what file transactions take place so that in the event of a hard drive crash, the files can be recovered. Journaling file systems are fault tolerant because the file system logs all changes to files, directories, or file structures. The log in which changes are recorded is referred to as the file systems journal—thus the term *journaling* file systems.

There are actually two types of journaling: physical and logical. With physical journaling, the system logs a copy of every block that is about to be written to the storage device before it is written. The log also includes a checksum of those blocks, to make sure there is no error in writing the block. With logical journaling, only changes to file metadata are stored in the journal.

Here are some specific file systems:

- **File Allocation Table (FAT)** is an older system that was popular with Microsoft operating systems for many years. FAT was first implemented in Microsoft Standalone Disk BASIC. FAT stores file locations by sector in a file called the file allocation table. This table contains information about which clusters are being used by which particular files and which clusters are free to be used. The various extensions of FAT, such as FAT16 and FAT32, differ in the number of bits available for filenames.
- **New Technology File System (NTFS)** was introduced by Microsoft in 1993 as a new file system to replace FAT. This is the file system used by Windows NT 4, 2000, XP, Vista, 7, Server 2003, and Server 2008. One major improvement of NTFS over FAT was the increased volume sizes NTFS could support. The maximum NTFS volume size is $2^{64} - 1$ clusters. We will be discussing NTFS in more detail when we discuss Windows forensics later in this book.
- **ReFS or Resilient File System** is a new file system from Microsoft. It is available on

Windows Server 2019, but not on Windows 10. As the name suggests, it is, in essence, a more resilient file system. This is accomplished with a variety of techniques, including checksums for both metadata and file data as well as proactive error correction. You can learn more at Microsoft's online documentation (<https://docs.microsoft.com/en-us/windows-server/storage/refs/refs-overview>).

- **Apple File System (APFS)** is the default file system for Apple computers using Mac OS 10.13. APFS supports encryption, snapshots, and other features. It is optimized for use with solid-state drives, but can also be used with traditional hard drives.
- **Extended file system** was the first file system created specifically for Linux. There have been many versions of EXT; the current version is 4. The EXT4 file system can support volumes with sizes up to 1 exabyte (10^{18} bytes, or 1 billion gigabytes) and files with sizes up to 16 terabytes. This is a huge file and volume size, and no current hard drives come even close to that volume size. For an administrator, one of the most exciting features of EXT4 is that it is backward compatible with EXT2 and EXT3, making it possible to mount drives that use those earlier versions of EXT.
- **ReiserFS** is a popular journaling file system, used primarily with Linux. ReiserFS was the first file system to be included with the standard Linux kernel, and first appeared in kernel version 2.4.1. Unlike some file systems, ReiserFS supported journaling from its inception, whereas EXT did not support journaling until version 3. ReiserFS is open source and was invented by Hans Reiser.
- **The Berkeley Fast File System** is also known as the UNIX file system. As its name suggests, it was developed at the University of California, Berkeley specifically for UNIX. Like many file systems, Berkeley uses a bitmap to track free clusters, indicating which clusters are available and which are not. Like EXT, Berkeley includes the FSCK utility. This is only one of many similarities between Berkeley and EXT. In fact, some sources consider EXT to just be a variant of the Berkeley Fast File System.

Networks

Digital forensics, like all branches of cybersecurity, breaks information into two types. There is information at rest and information in motion. Information at rest includes anything that is stored inside the computer, including in the file system or memory. Information in motion is information being transmitted between endpoints and includes the protocols and other information needed for transmission. The transmission of information across networks and the network components used make up a vast, quickly changing field. The modern forensic investigator, however, should be very familiar with the

components and how they work, as well as the protocols and their operation, if information in motion is to be considered as a part of the investigator’s skill set. The modern forensic analyst who will consider information in motion must also be very familiar with the concepts and operation of both the seven-layer Open Systems Interconnection (OSI) Reference Model and the five-layer Internet Engineering Task Force (IETF) model. If you lack this knowledge, you must acquire it before proceeding any further.

Addresses

The digital forensics analyst must be aware of the way that computer information is addressed and the proper vocabulary for discussing the different types of addresses and units of information transfer. It is also important for the digital forensics analyst to understand that not all addresses are a part of every communication. If they are present, the addresses are part of a hierarchy and are placed, one within the other, like envelopes.

Physical Ports

Physical ports are physical. You can touch them. Even a wireless physical port can be touched, although you must open the computer or other device to find the antenna first. The physical ports operate at OSI Layer 1, the Physical Layer. The units of information transfer are 1 and 0 bits grouped into fixed-length units called Layer 1 frames.

Media Access Control (MAC) Addresses

A MAC address is a 6-byte (or 48-bit) address used to identify a network interface card. The first three bytes identify the vendor, the second three identify the specific card. This can also be referred to as a computer’s physical address.

A MAC address is supposed to be unique, is supposed to be tied to one—and only one—physical port, and is not supposed to be duplicated or reused for any reason. In practice, this is not always the case. Duplication of MAC addresses can occur due to bad quality control or can be done intentionally for a variety of malicious reasons. The keen forensic investigator will never be fooled by duplicate MAC addresses.

IP Addresses

IP addresses, sometimes called logical addresses, are assigned to a computer and can be easily changed. While IP version 6 has been available for quite some time, a majority of computers are still using IP version 4, which provides a 32-bit address. We will discuss IP version 4 and version 6 in more detail later in this book when we discuss network forensics.

Logical Port Numbers

Communication over a network depends on an IP address and a port number. You can think of the port as a channel. TABLE 1-1 lists some common ports and their uses.

TABLE 1.1 Common ports and their uses.	
20, 21 – FTP (File Transfer Protocol)	Used for transferring files between computers. Port 20 is for data, and port 21 for control.

22 – SSH and secure FTP	Secure communications and file transfer
23 – Telnet	Used to remotely log onto a system. You can then use a command prompt or shell to execute commands on that system. Popular with network administrators.
25 – SMTP (Simple Mail Transfer Protocol)	Used for sending email
43 – WhoIS	A command that queries a target IP address for information
53 – DNS (Domain Name Service)	Translates URLs into web addresses
69 – TFTP	UDP-based file transfer
80 – HTTP (Hyper Text Transfer Protocol)	Displays web pages
88 – Kerberos Authentication	Authentication in environments using Kerberos authentication
109 – POP 2	Old email protocol
110 – POP3 (Post Office Protocol Version 3)	Used to retrieve email
137, 138, 139 – NetBIOS	Used in Windows networks
161 – SNMP (and 162)	Simple network management protocol
179 – BGP	Border gateway protocol. Used by gateway routers exchanging routing data.
194 – IRC (Internet Relay Chat)	Used in chat rooms
220 – IMAP	Email protocol
389 – LDAP	Lightweight directory access protocol
443 – HTTPS	Encrypted HTTP
445 – Active Directory, SMB	Used in Windows networks
464 – Kerberos	Used to change passwords
465 – SMTP over SSL	Encrypted email
636 – LDAPS (LDAP over SSL/TLS)	Encrypted LDAP

Uniform Resource Locators

As the internet grew and the number of servers and their IP addresses grew, the Domain Name System (DNS) was created to allow internet users to type a name instead of an IP address. This level of simplification is great, but it introduces a number of potential forensic issues. Issues range from changing the mapping of website name to IP address permanently or temporarily and many different forms of this that can be used to redirect browsers incorrectly and befuddle forensic efforts.

Addressing Review

In a complete, end-to-end internet communication, it is most common that user information, such as email text, would be formatted as specified by the email protocol. A URL would then be used to find the actual IP address of the recipient. The message would be formatted per the TCP protocol and sent with the proper TCP port number set to the IP addresses. The IP packet containing all of this would be put into a special envelope built per the protocol rules of Ethernet, which would make its way onto the actual wire, or go across the wireless or optical connection, on its way through the cloud to its destination. At the destination, the process would be done in reverse and the email, or at least a part of it, would have gotten through to its destination.

Basic Network Utilities

You can execute some basic network utilities from a command prompt (Windows) or from a shell (UNIX/Linux). This text's discussion executes the commands and discusses them from the Windows command-prompt perspective; however, it must be stressed that these utilities are available in all operating systems. This section covers the `ipconfig`, `ping`, and `tracert` utilities.

Working with ipconfig

The first thing you need to do is to get information about your own system. To accomplish this fact-finding mission, you need to get to a command prompt. In Windows 10, you do this by going to the search box at the bottom left-hand side of the screen and typing `cmd`. For other versions of Windows, the process is identical, except the first option is called simply Programs rather than All Programs. Now you can type in `ipconfig`. You could input the same command in UNIX or Linux by typing in `ifconfig` from the shell. After typing in `ipconfig`—`ifconfig` in Linux—you should see something similar to what is shown in **FIGURE 1-2**.


```
Administrator: C:\Windows\system32\cmd.exe

C:\Users\chuck>ipconfig

Windows IP Configuration

Wireless LAN adapter Wireless Network Connection 2:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . : 
Wireless LAN adapter Wireless Network Connection:

    Connection-specific DNS Suffix  . : gateway.2wire.net
    Link-local IPv6 Address . . . . . : fe80::2dff:c9b4:92ca:9b43%11
    IPv4 Address. . . . . : 192.168.1.101
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.1.254

Ethernet adapter Local Area Connection:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . : 
Ethernet adapter VirtualBox Host-Only Network:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::851e:deca:6578:af54%49
    IPv4 Address. . . . . : 192.168.56.1
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 

Tunnel adapter isatap.gateway.2wire.net:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . : 
Tunnel adapter Reusable ISATAP Interface {15831C80-8547-4DBC-A5E7-160479674F9B}:

    Media State . . . . . : Media disconnected
```

FIGURE 1-2 ipconfig.

This command gives you some information about your connection to a network or to the internet. Most important, you find out your own IP address. The command also has the IP address for your default gateway, which is your connection to the outside world. Running the `ipconfig` command is a first step in determining your system's network configuration.

You can see that this option gives you much more information. For example, `ipconfig/all` gives the name of your computer, when your computer obtained its IP address, and more.

Using ping

Another commonly used command is `ping`, which is used to send a test packet, or echo packet, to a machine to find out if the machine is reachable and how long the packet takes to reach the machine. This useful diagnostic tool can be employed in elementary hacking techniques. The command is shown in [FIGURE 1-3](#).

```
Administrator: Command Prompt

C:\>ping www.chuckeasttom.com

Pinging sbsfe-p10.geo.mf0.yahoodns.net [67.195.61.46] with 32 bytes of data:
Reply from 67.195.61.46: bytes=32 time=65ms TTL=46
Reply from 67.195.61.46: bytes=32 time=64ms TTL=46
Reply from 67.195.61.46: bytes=32 time=64ms TTL=46
Reply from 67.195.61.46: bytes=32 time=65ms TTL=46

Ping statistics for 67.195.61.46:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 64ms, Maximum = 65ms, Average = 64ms

C:\>
```

FIGURE 1-3 ping.

You can see in **FIGURE 1-3** that a 32-byte echo packet was sent to the destination and returned. The TTL item means *time to live*. That time unit is how many intermediary steps, or hops, the packet should take to the destination before giving up. Remember that the internet is a vast conglomerate of interconnected networks. Your packet probably won't go straight to its destination. It will have to take several hops to get there. As with ipconfig, you can type in ping -? to find out various ways you can refine your ping.

Working with tracert

The final command this section examines is the tracert command. While tracert can be useful for some live network troubleshooting, the information reported by tracert is not useful or trustworthy for forensic examination. This same command can be executed in Linux or UNIX, but there it is called “traceroute” rather than “tracert.” You can see this command in **FIGURE 1-4**.

```
Administrator: Command Prompt

C:\>tracert www.chuckeasttom.com

Tracing route to sbsfe-p10.geo.mf0.yahoodns.net [67.195.61.46]
over a maximum of 30 hops:

  0  <1 ms    <1 ms    <1 ms    Tardis [192.168.1.11]
  1  <1 ms    <1 ms    <1 ms    192.168.0.1
  2  8 ms     8 ms     7 ms     142.254.141.53
  3  26 ms    20 ms    28 ms    tge0-0-4.plaotxso01h.texas.rr.com [24.28.90.2]
  4  12 ms    9 ms     10 ms    agg21.plantxmp01r.texas.rr.com [24.175.49.2]
  5  13 ms    13 ms    14 ms    agg27.crtntxjt01r.texas.rr.com [24.175.36.1]
  6  46 ms    13 ms    13 ms    agg21.dillatx1301r.texas.rr.com [24.175.49.0]
  7  11 ms    15 ms    14 ms    66.109.1.216
  8  10 ms    9 ms     10 ms    107.14.17.133
  9  10 ms    12 ms    11 ms    UNKNOWN-216-115-102-X.yahoo.com [216.115.102.1]
 10  54 ms    64 ms    54 ms    ae-3.pat2.bfz.yahoo.com [216.115.97.209]
 11  64 ms    64 ms    64 ms    ae-6.pat2.gq1.yahoo.com [216.115.96.62]
 12  66 ms    64 ms    64 ms    et-18-1-0.msr2.gq1.yahoo.com [66.196.67.115]
 13  64 ms    64 ms    65 ms    et-1-0-0.clr2-a-gdc.gq1.yahoo.com [67.195.3.3]
 14  64 ms    64 ms    64 ms    te-8-1.bas2-1-flk.gq1.yahoo.com [67.195.1.1]
 15  64 ms    65 ms    64 ms    p10pn-i.geo.vip.gq1.yahoo.com [67.195.61.46]
 16  64 ms    65 ms    64 ms

Trace complete.

C:\>_
```

This section is just a brief overview of the hardware, software, and networking knowledge you should have in order to study forensics. If you find you are lacking in one or more areas, do some review in those areas before you proceed.

Obscured Information and Anti-Forensics

Two more challenges in obtaining digital evidence are obscured information and anti-forensics.

Obscured Information

Information can be obscured in a number of ways. *Obscured information* may be scrambled by encryption, hidden using steganographic software, compressed, or in a proprietary format. Sometimes, cybercriminals obscure information to deter forensic examination. More often, companies use certain manipulation and storage techniques to protect business-sensitive information. Regardless of the reason for obscured data, collecting and analyzing it is difficult.

Data that has been obscured through encryption, steganography, compression, or proprietary formats can sometimes be converted with some serious detective work and the right tools. Forensic specialists often must do quite a bit of work to decrypt encrypted information. In many cases, the investigator cannot decrypt information unless the data owner provides the encryption key and algorithm. When digital evidence has been encrypted and is in use on a live system, an investigator might have to collect evidence through a live extraction process.

Anti-Forensics

Every investigation is unique. Investigations are not necessarily friendly activities. Forensic specialists may have to conduct the investigation with or without the cooperation of the information owner. And the information owner may or may not be the target of the investigation. Investigations are difficult with uncooperative information owners.

Attackers may use techniques to intentionally conceal their identities, locations, and behavior. For example, perpetrators may conceal their identities by using networked connections at a library, an internet café, or another public computer kiosk. Or they may use encryption or anonymous services to protect themselves. The actions that perpetrators take to conceal their locations, activities, or identities are generally termed **anti-forensics**.

Cybercriminals are becoming better at covering their tracks as their awareness of digital forensics capabilities increases. The following are examples of anti-forensics techniques:

- **Data destruction**—Methods for disposing of data vary. They can be as simple as wiping the memory buffers used by a program, or they can be as complex as repeatedly overwriting a cluster of data with patterns of 1s and 0s. Digital evidence

can be destroyed easily. For example, starting a computer updates timestamps and modifies files. Attaching a hard disk or USB stick modifies file-system timestamps. Powering off a machine destroys volatile memory. Suspects may delete files and folders and defragment their hard drives in an attempt to overwrite evidence.

- **Data hiding**—Suspects often store data where an investigator is unlikely to find it. They may hide data, for example, in reserved disk sectors or as logical partitions within a defined, public partition. Or they may simply change filenames and extensions.
- **Data transformation**—Suspects may process information in a way that disguises its meaning. For example, they may use encryption to scramble a message based on an algorithm. Or they may use steganography to hide a message inside a larger message.
- **File system alteration**—Suspects often corrupt data structures and files that organize data, such as a Windows NT File System (NTFS) volume.

The Daubert Standard

One legal principle that is key to forensics and is all too often overlooked in forensics books is the Daubert standard. The Cornell University Law School defines the **Daubert standard** as follows:

Standard used by a trial judge to make a preliminary assessment of whether an expert's scientific testimony is based on reasoning or methodology that is scientifically valid and can properly be applied to the facts at issue. Under this standard, the factors that may be considered in determining whether the methodology is valid are: (1) whether the theory or technique in question can be and has been tested; (2) whether it has been subjected to peer review and publication; (3) its known or potential error rate; (4) the existence and maintenance of standards controlling its operation; and (5) whether it has attracted widespread acceptance within a relevant scientific community.

What this means, in layman's terms, is that any scientific evidence presented in a trial has to have been reviewed and tested by the relevant scientific community. For a computer forensics investigator, that means that any tools, techniques, or processes you utilize in your investigation should be ones that are widely accepted in the computer forensics community. You cannot simply make up new tests or procedures.

This, naturally, brings up a question: How do new techniques become widely accepted? Let's suppose you have developed a new tool that extracts forensic information from the Windows Registry. A first step might be to provide a copy of that tool to a few professors of forensics, allowing them to experiment with it. You might also publish an article describing it. After it has been tested by the forensic community and articles about it have been read (and possibly rebutted), then your tool would be usable in real forensic investigations.

It is important to remember the Daubert standard because it will affect your forensic approach. It also reminds us of an even more basic concept: The evidence you collect is important only if it is admissible in court. So you have to pay attention to the techniques and tools you use and maintain the chain of custody.

If you fail to use widely accepted techniques, to fully document your methodology, and to use only those tools and techniques you are qualified to use, the opposing attorney might issue what is commonly called a "Daubert challenge." This is a motion to exclude all or part of your testimony due to it failing to meet the Daubert standard. Daubert challenges are quite common in civil cases, but are not common in criminal court. There has been a movement in the legal community in recent years to increase Daubert challenges in criminal court. The rationale behind this is that some people believe that "junk science" is making its way into criminal proceedings, and well-articulated Daubert challenges could reduce that.

U.S. Laws Affecting Digital Forensics

There are many laws that affect digital forensics investigation. For example, some jurisdictions have passed laws that require the investigator to be either a law enforcement officer or a licensed private investigator to extract the evidence. Of course, that does not prevent a forensic investigator from working with information someone else extracted or extracting evidence if the information owner gave his or her permission. It is important to be aware of the legal requirements in the jurisdiction in which you work.

The Federal Privacy Act of 1974

The Privacy Act of 1974 establishes a code of information-handling practices that governs the collection, maintenance, use, and dissemination of information about individuals that is maintained in systems of records by U.S. federal agencies. A system of records is a group of records under the control of an agency from which information is retrieved by the name of the individual or by some identifier assigned to the individual.

The Privacy Protection Act of 1980

The Privacy Protection Act (PPA) of 1980 protects journalists from being required to turn over to law enforcement any work product and documentary materials, including sources, before it is disseminated to the public. Journalists who most need the protection of the PPA are those who are working on stories that are highly controversial or that describe criminal acts, because the information gathered may also be useful to law enforcement.

The Communications Assistance to Law Enforcement Act of 1994

The Communications Assistance to Law Enforcement Act of 1994 is a federal wiretap law for traditional wired telephony. It was expanded in 2004 to include wireless, voice over packets, and other forms of electronic communications, including signaling traffic and metadata.

Unlawful Access to Stored Communications: 18 U.S.C. § 2701

This act covers access to a facility through which electronic communication is provided or exceeding the access that was authorized. It is broadly written to apply to a range of offenses. Punishment can be up to 5 years in prison and fines for the first offense.

The actual wording of the statute is as follows:

1. Offense. —Except as provided in subsection (c) of this section whoever—
intentionally accesses without authorization a facility through which an electronic communication service is provided; or
2. intentionally exceeds an authorization to access that facility; and thereby obtains, alters, or prevents authorized access to a wire or electronic communication while it is in electronic storage in such system shall be punished as provided in subsection (b) of this section.

This law is used less frequently than the Computer Fraud and Abuse Act. However, it is written broadly enough to cover a number of acts. Primarily, the focus is on any facility, server, or device used to store electronic communications. It is sometimes the case that when employees leave a company, they seek to take information that they can use in competition with the company. This can include emails or other stored communications.

The Electronic Communications Privacy Act of 1986

The Electronic Communications Privacy Act of 1986 governs the privacy and disclosure, access, and interception of content and traffic data related to electronic communications.

The Computer Security Act of 1987

The Computer Security Act of 1987 was passed to improve the security and privacy of sensitive information in federal computer systems. The law requires the establishment of minimum acceptable security practices, creation of computer security plans, and training of system users or owners of facilities that house sensitive information.

The Foreign Intelligence Surveillance Act of 1978

The Foreign Intelligence Surveillance Act of 1978 (FISA) is a law that allows for collection of “foreign intelligence information” between foreign powers and agents of foreign powers using physical and electronic surveillance. A warrant is issued by the FISA court for actions under FISA.

The Child Protection and Sexual Predator Punishment Act of 1998

The Child Protection and Sexual Predator Punishment Act of 1998 requires service providers that become aware of the storage or transmission of child pornography to report it to law enforcement.

The Children's Online Privacy Protection Act of 1998

The Children's Online Privacy Protection Act of 1998 (COPPA) protects children 13 years of age and under from the collection and use of their personal information by websites. It is noteworthy that COPPA replaces the Child Online Protection Act of 1988 (COPA), which was determined to be unconstitutional.

The Communications Decency Act of 1996

The Communications Decency Act of 1996 was designed to protect persons 18 years of age and under from downloading or viewing material considered indecent. This act has been subject to court cases that subsequently changed some definitions and penalties.

The Telecommunications Act of 1996

The Telecommunications Act of 1996 includes many provisions relative to the privacy and disclosure of information in motion through and across telephony and computer networks.

The Wireless Communications and Public Safety Act of 1999

The Wireless Communications and Public Safety Act of 1999 allows for collection and use of "empty" communications, which means nonverbal and nontext communications, such as GPS information.

The USA PATRIOT Act

The USA PATRIOT Act is the primary law under which a wide variety of internet and communications information content and metadata is currently collected. Provisions exist within the PATRIOT Act to protect the identity and privacy of U.S. citizens.

The Sarbanes-Oxley Act of 2002

The Sarbanes-Oxley Act of 2002 contains many provisions about recordkeeping and destruction of electronic records relating to the management and operation of publicly held companies.

18 USC 1030 Fraud and Related Activity in Connection with Computers

This is one of the most widely used laws in hacking cases. It covers a wide range of crimes involving illicit access of any computer.

18 USC 1020 Fraud and Related Activity in Connection with Access Devices

This is closely related to 1030 but covers access devices (such as routers).

The Digital Millennium Copyright Act (DMCA)

This controversial law was enacted in 1998. It makes it a crime to publish methods or techniques to circumvent copyright protection. It is controversial because it has been used against legitimate researchers publishing research papers.

18 USC § 1028A Identity Theft and Aggravated Identity Theft

As the name suggests, this law targets any crime related to identity theft. It is often applied in stolen credit card cases.

18 USC § 2251 Sexual Exploitation of Children

This law covers a range of child exploitation crimes and is often seen in child pornography cases. Related to this rather broad law are several others, such as:

- 18 U.S.C. § 2260: Production of sexually explicit depictions of a minor for importation into the United States
- 18 U.S.C. § 2252: Certain activities relating to material involving the sexual exploitation of minors (possession, distribution, and receipt of child pornography)
- 18 U.S.C. § 2252A: Certain activities relating to material constituting or containing child pornography

Warrants

According to the Supreme Court, a “seizure of property occurs when there is some meaningful interference with an individual’s possessory interests in that property” (*United States v. Jacobsen*, 466 U.S. 109, 113 [1984]). The Court also characterized the interception of intangible communications as a seizure, in the case of *Berger v. New York* (388 U.S. 41, 59–60 [1967]). That means that law enforcement need not take property in order for it to be considered seizure; merely interfering with an individual’s access to his or her own property constitutes seizure. *Berger v. New York* extends that to communications. If law enforcement’s conduct does not violate a person’s “reasonable expectation of privacy,” then formally it does not constitute a Fourth Amendment “search” and no warrant is required. There have been many cases where the issue of reasonable expectation of privacy has been argued. To use an example that is quite clear, if you save

a message in an electronic diary, you clearly have a reasonable expectation of privacy; however, if you post such a message on a public bulletin board, you can have no expectation of privacy. In less clear cases, a general rule is that courts have held that law enforcement officers are prohibited from accessing and viewing information stored in a computer if it would be prohibited from opening a closed container and examining its contents in the same situation.

Warrants are not needed when evidence is in plain sight. For example, if a detective is talking to someone about a string of burglaries in the neighborhood and can clearly see child pornography on that person's computer screen, no warrant is needed. Another exception to the need for a warrant is consent. If someone who is authorized to provide consent (for example, the owner of a phone or computer) gives law enforcement that consent to a search, then no warrant is needed.

In computer crime cases, two consent issues arise particularly often. First, when does a search exceed the scope of consent? For example, when a person agrees to the search of a location, such as his or her apartment, does that consent authorize the retrieval of information stored in computers at the location? Second, who is the proper party to consent to a search? Can roommates, friends, and parents legally grant consent to a search of another person's computer files? These are all critical questions that must be considered when searching a computer. In general, courts have held that only the actual owner of a property can grant consent, or someone who has legal guardianship of the owner. For example, a parent of a minor child can grant consent to search the child's living quarters and computers. However, a roommate who shares rent can grant consent to search only shared living quarters and computers co-owned by both parties. A roommate cannot grant consent to search the private property of the other person.

There are other cases where investigators don't need a warrant. One such circumstance is border crossing. Anyone going through customs in any country may have their belongings searched. This can include a complete forensic examination of laptops, cell phones, and other devices. Another such instance where a warrant is not needed is if there is imminent danger that evidence will be destroyed. In the case of the *United States v. David*, the court held that "When destruction of evidence is imminent a warrantless seizure of that evidence is justified if there is probable cause to believe that the item seized constitutes evidence of criminal activity."

It is also important not to exceed the scope of a warrant. In *United States v. Schlingloff*, 2012 U.S. Dist. LEXIS 157272 (C.D. Ill. Oct. 24, 2012), Judge Shadid held that use of Forensic Toolkit's (FTK) Known File Filter (KFF) to alert on child pornography files was outside the scope of a warrant issued to look for evidence of identity theft. In this case, the owner of the device was suspected of identity theft, and a warrant was issued so that police could search for evidence of that crime. However, the investigator used the Known File Filter to search for child pornography, and indeed found illegal images on the computer in question.

Federal Guidelines

If you are setting up a forensic lab, or if you are new to forensics, a good place to start is the federal guidelines. Two agencies in particular—the FBI and the Secret Service—are particularly important.

The FBI

If an incident occurs, the FBI recommends that the first responder should preserve the state of the computer at the time of the incident by making a backup copy of any logs, any damaged or altered files, and any other files modified, viewed, or left by the intruder. This last part is critical. Hackers frequently use various tools and may leave traces of their presence. Furthermore, the FBI advises that if the incident is in progress, you should activate any auditing or recording software you might have available. Collect as much data about the incident as you can. In other words, this might be a case where you do not take the machine offline, but rather analyze the attack in progress.

The FBI computer forensics guidelines stress the importance of securing any evidence. They further stress that computer evidence can come in many forms. Here are a few common forms:

- Hard drives
- System logs
- Portable storage, such as USB drives and external drives
- Router logs
- Emails
- Chat room logs
- Cell phones
- SIM cards for cell phones
- Logs from security devices, such as firewalls and intrusion-detection systems
- Databases and database logs

What you secure will be dependent upon the nature of the cybercrime. For example, in the case of child predators, online stalkers, or online fraud, email may be very important, but router logs may be irrelevant. The FBI also stresses that you should work with a copy of the hard drive, not the original.

The FBI has a cybercrimes web page, which is a very useful resource for learning more about trends in cybercrime and in computer forensics.

The Secret Service

The U.S. Secret Service is the premier federal agency tasked with combating cybercrime. It has a website devoted to computer forensics that includes forensics courses. These courses are usually for law enforcement personnel.

FYI

Since 9/11, the U.S. Secret Service has been tasked with taking the lead in U.S. cybercrime efforts. There are electronic crime task force centers set up in several major cities, including Atlanta, Baltimore, Birmingham, Boston, Buffalo, Chicago, Dallas, Houston, and San Francisco. These electronic crime task force centers cooperate with other law enforcement agencies, including local police departments, in computer crime investigations.

The Secret Service also has released a guide for first responders to computer crime. The agency has listed its “golden rules” to begin the investigation. They are as follows:

- Officer safety: Secure the scene and make it safe.
- If you reasonably believe that the computer is involved in the crime you are investigating, take immediate steps to preserve the evidence.
- Determine whether you have a legal basis to seize the computer, such as plain view, search warrant, or consent.
- Do not access any computer files. If the computer is off, leave it off.
- If it is on, do not start searching through the computer. Instead, properly shut down the computer and prepare it for transport as evidence.
- If you reasonably believe that the computer is destroying evidence, immediately shut down the computer by pulling the power cord from the back of the computer.
- If a camera is available and the computer is on, take pictures of the computer screen. If the computer is off, take pictures of the computer, the location of the computer, and any electronic media attached.
- Determine whether special legal or privacy considerations apply, such as those for doctors, attorneys, clergy, psychiatrists, newspapers, or publishers.

These are all important first steps to both preserving the chain of custody and ensuring the integrity of the investigation from the very beginning.

The Regional Computer Forensics Laboratory Program

The Regional Computer Forensics Laboratory (RCFL) Program is a national network of

forensic laboratories and training centers. The FBI provides startup and operational funding, training, staff, and equipment to the program. State, local, and other federal law enforcement agencies assign personnel to staff RCFL facilities.

Each of the 16 RCFLs examines digital evidence in support of criminal and national security investigations. The RCFL Program provides law enforcement at all levels with digital forensics expertise. It works with a wide variety of investigations, including terrorism, child pornography, fraud, and homicide.

The RCFL Program conducts digital forensics training. In 2008, for example, the program trained nearly 5000 law enforcement personnel in system forensics tools and techniques. For more information, see <http://www.rcfl.gov>.

CHAPTER SUMMARY

This chapter explored the basics of computer forensics. You have learned general principles, such as working only with a copy of the drive you're investigating and maintaining the chain of custody. The chapter also examined the types of digital forensics done as well as the laws regarding digital forensics. You should be familiar with the Daubert standard, warrants, federal forensic guidelines, and the general forensic procedure.

KEY CONCEPTS AND TERMS

Anti-forensics
Cell-phone forensics
Chain of custody
Computer forensics
Curriculum vitae (CV)
Daubert standard
Demonstrative evidence
Digital evidence
Disk forensics
Documentary evidence
Email forensics
Expert report
Expert testimony
Internet forensics
Live system forensics
Network forensics
Real evidence
Software forensics
Testimonial evidence
Volatile memory

CHAPTER 1 ASSESSMENT

1. In a computer forensics investigation, this describes the route that evidence takes from the time you find it until the case is closed or goes to court.
 - A. Rules of evidence
 - B. Law of probability
 - C. Chain of custody
 - D. Policy of separation
2. If the computer is turned on when you arrive, what does the Secret Service recommend you do?
 - A. Begin your investigation immediately.
 - B. Shut the computer down according to the recommended Secret Service procedure.
 - C. Transport the computer with power on.
 - D. Unplug the machine immediately.
3. Why should you note all cable connections for a computer you want to seize as evidence?
 - A. To know what outside connections existed
 - B. In case other devices were connected
 - C. To know what peripheral devices existed
 - D. To know what hardware existed
4. What is the essence of the Daubert standard?
 - A. That only experts can testify at trial
 - B. That an expert must affirm that a tool or technique is valid
 - C. That only tools or techniques that have been accepted by the scientific community are admissible at trial
 - D. That the chain of custody must be preserved
5. When cataloging digital evidence, the primary goal is to do what?
 - A. Make bitstream images of all hard drives.
 - B. Preserve evidence integrity.

- C. Keep evidence from being removed from the scene.
 - D. Keep the computer from being turned off.
6. Which of the following is important to the investigator regarding logging?
- A. The logging methods
 - B. Log retention
 - C. Location of stored logs
 - D. All of the above
7. Your roommate can give consent to search your computer.
- A. True
 - B. False
8. Evidence need not be locked if it is at a police station.
- A. True
 - B. False

References

1. Cornell Law School Legal Information Institute. (n.d.) Rule 702. Testimony by Expert Witness. Retrieved from https://www.law.cornell.edu/rules/fre/rule_702 on January 27, 2021.
2. Cornell Law School Legal Information Institute. (n.d.) Rule 703. Bases of an Expert. Retrieved from https://www.law.cornell.edu/rules/fre/rule_703 on January 27, 2021.
3. Cornell Law School Legal Information Institute. (n.d.) Rule 704. Opinion on an Ultimate Issue. Retrieved from https://www.law.cornell.edu/rules/fre/rule_704 on January 27, 2021.
4. Cornell Law School Legal Information Institute. (n.d.) Rule 705. Disclosing the Facts or Data Underlying an Expert. Retrieved from https://www.law.cornell.edu/rules/fre/rule_705 on January 27, 2021.
5. Cornell Law School Legal Information Institute. (n.d.) Rule 705. Court-Appointed Expert Witness. Retrieved from https://www.law.cornell.edu/rules/fre/rule_706 on January 27, 2021.
6. Cornell Law School Legal Information Institute. (n.d.) Rule 401. Test for Relevant Evidence. Retrieved from https://www.law.cornell.edu/rules/fre/rule_401 on January 27, 2021.



CHAPTER 2

Overview of Computer Crime

© phyZick/Shutterstock

BEFORE DELVING INTO COMPUTER FORENSICS, it is important for you to understand the types of computer crimes that are likely to lead to forensic investigations. This chapter is not meant to be an exhaustive catalog of every computer crime that can be perpetrated, but rather a discussion of the most common computer crimes.

Chapter 2 Topics

This chapter covers the following topics and concepts:

- How computer crime affects forensics
- What the details of identity theft are
- Hacking
- Cyberstalking and harassment
- Fraud on the internet
- Non-access computer crimes
- Cyberterrorism: the new frontier

Chapter 2 Goals

When you complete this chapter, you will be able to:

- Describe common computer crimes
- Understand varying forensic approaches to different crimes
- Apply the appropriate forensic strategy based on the specific crime

How Computer Crime Affects Forensics

Many crimes today involve the use of computers and networks. A computer or another device can play one of three roles in a computer crime:

- It can be the target of the crime.
- It can be the instrument of the crime.
- It can be an evidence repository that stores valuable information about the crime.

In some cases, a computer can have multiple roles. It can be the instrument of a crime and also serve as a file cabinet that stores critical evidence. For example, an attacker may use a computer as a tool to break into another computer and steal files. The attacker may then store the stolen files on the computer used to perpetrate the theft. When investigating a case, it is important that the investigator know what roles a computer played in the crime and then tailor the investigative process to those roles.

Applying information about how a computer was used in a crime also helps when searching a system for evidence. If a computer was used to hack into a network password file, the investigator should look for password-cracking software and password files. If a computer was the target of a crime, such as an intrusion, the investigator should check audit logs and look for unfamiliar programs. Knowing how a computer was used in a crime helps narrow down the evidence collection process. Hard drives and other mass storage devices today are generally very large, reaching several terabytes. Therefore, checking and analyzing every piece of data a computer and associated media contain would take an impossibly long time if searched manually. Even when automated, more comprehensive searches can take a frustratingly long time. Often, law enforcement officials need information quickly. Having a general idea of what to look for on a suspect computer speeds the evidence collection process.

Computers can be involved in a variety of types of crimes, including white-collar crimes, violent crimes such as murder and terrorism, counterintelligence, economic espionage, counterfeiting, child pornography, and drug dealing, among others.

The internet has made targets much more accessible, and the risks involved for criminals are much lower than with traditional crimes. From the comfort of home or some other remote site, a cybercriminal can hack into a bank and transfer millions of dollars to a fictitious account. In essence, the criminal can rob the bank without the threat of being physically harmed while trying to escape.

Cybercrime can also involve modification of a traditional crime by using the internet in some way. It can be as simple as the illegal online sale of prescription drugs or as sophisticated as cyberstalking. Pedophiles use the internet to exchange child pornography and pose as children to lure victims into real-life kidnappings. Laws governing fraud apply with equal force, regardless of whether the activity is online or offline.

In the arena of computer forensics, the nature of the crime can have a significant effect on the forensic process. Certain crimes are more likely than others to yield certain

types of forensic evidence. For example, identity theft is likely to leave email evidence via phishing emails, but hacking into a system and stealing data probably does not leave any email evidence. On the other hand, hacking into the system probably does leave evidence in the firewall and intrusion detection system logs, whereas phishing emails may not.

In order to select the appropriate forensic tests, the investigator must understand the types of computer crimes and how the crime affects the forensic process.

Most computer security books categorize computer attacks based on the nature of the attack. For example, such books look at denial-of-service attacks, malware, hacking into web pages, and so forth. However, for our purposes, this chapter categorizes computer attacks based on the type of crime being done, regardless of how it was performed. As you proceed through this chapter, you will see that this makes more sense for forensic examinations. This chapter examines the following categories:

- Identity theft
- Hacking systems for data
- Cyberstalking/harassment
- Internet fraud
- Non-access computer crimes
- Cyberterrorism

These are rather broad categories that encompass a great many activities. But the categories work well for investigating criminal behavior. It should also be noted that digital devices can be of interest in non-computer crimes. Certainly, examining drug traffickers' smartphones could yield information as to their colleagues, travel habits, and other information, even though the crime in question is not actually a computer crime.

Identity Theft

Identity theft is a growing problem. It is any use of another person's identity. Now that might seem like a pretty broad definition, but it is accurate. Most often, criminals commit identity theft in order to perpetrate some financial fraud. For example, a criminal might use the victim's information to obtain credit card information. If they use the card to make purchases, the victim is left with the bill.

The U.S. Department of Justice defines identity theft and identity fraud as:

... terms used to refer to all types of crime in which someone wrongfully obtains and uses another person's personal data in some way that involves fraud or deception, typically for economic gain.

The simple act of wrongfully obtaining another person's personal data is the crime, with or without stealing any money. Notice that the Justice Department's definition states that it is *typically* for economic gain. However, a criminal might steal someone's identity for other reasons as well. Therefore, even non-financial identity theft is still a crime. For example, here is a real-world case. Some details have been changed to preserve confidentiality, but the essentials of the story are all true.

This crime occurred in a state that used Social Security numbers for driver's license numbers. No state does this anymore, for good reason. In this case, an individual worked at a local office of the Department of Motor Vehicles. When someone came in to renew a license, he or she surrendered the old license. The criminal in this case took some old licenses that he thought resembled him. He then put his picture on them and used one of them if he was pulled over for a traffic ticket. This caused the ticket to be issued to the individual who owned the license, along with a ticket for having an expired license. Eventually, however, an investigation tied the tickets to his car and license plate number.

This story illustrates one way in which criminals can accomplish identity theft—by getting official documents with someone else's information on them. It also shows an alternative reason for identity theft, one that does not involve bank accounts or credit. This is certainly not the most common example of identity theft, but it is one possible example. Criminals also use the following common methods to perpetrate identity theft:

- Phishing
- Spyware
- Discarded information

The following sections briefly examine each of these.

Phishing

Phishing is an attempt to trick a victim into giving up personal information. It is usually

done by emailing the victim and claiming to be from some organization a victim would trust, such as his or her bank or credit card company. In one of its simplest forms, a perpetrator sends out an email to a large number of people. It claims to be from some bank—for the purposes of this example, consider a fictitious bank called Trustworthy Bank. The email claims that there is some issue with the recipient's account and states the recipient needs to click a link in the email to address the problem. However, the link actually takes the recipient to a fake website that simply looks like the real website. When the victim types in his or her username and password, this fake system displays some message like "login temporarily unavailable" or "error, please try later." What the perpetrator has done is tricked the victim into giving the criminal the victim's username and password for his or her bank account.

Clearly, in any mass email scenario, many recipients aren't customers of the financial institution being faked. And those recipients will likely just delete the email. Even many of those who are customers of the spoofed financial institution won't fall for the scam. They will delete the email, too. But, in this case, it is a numbers game for the criminal. If he or she sends out enough of these emails, it is certain that someone will fall for it. So the trick is to send out as many emails as possible, and know that only a small percentage will respond.

Phishing is generally a process of reaching out to as many people as possible, hoping enough people respond. In general, about as many people fall for scam emails as respond to other, legitimate, unsolicited bulk email, or spam. A good fictitious email gets a 1–3% response rate, according to the Federal Bureau of Investigation (FBI). An identity thief—if he or she uses the target organization's format, spells everything correctly, and uses logos and artwork that look legitimate—can count on a response of 10,000 to 30,000 clickthroughs per million emails sent.

Every year in the United States, shortly after federal taxes are due on April 15, tax-related fraud via phishing scams will begin. These phishing emails purport to be from the U.S. Internal Revenue Service (IRS), and they claim that there was an error with the person's online tax submission. The recipient is then directed to click on a link to fix the problem. What really occurs, if the victim clicks on the link, is that the perpetrator gets all their personal information, thus making identity theft quite easy.

Recent years have seen the growth of more targeted attacks. The first such targeted attack is called *spear phishing*. With spear phishing, the criminal targets a specific group. For example, the criminal may want to get information about the network of a specific bank, so he or she targets emails to the IT staff at that bank. The emails are a bit more specific, and thus more likely to look legitimate to the recipients.

Similar to spear phishing is *whaling*. This is phishing with a specific, high-value target in mind. For example, the attacker may target the CIO of a bank. First, the attacker performs a web search on that CIO and learns as much about him or her as possible. LinkedIn, Facebook, and other social media can be very helpful in this regard. Then, the attacker sends an email targeted to that specific individual. This makes it much more likely the email will appear legitimate and the victim will respond.

One scenario is to research the target, the CIO in this case, and find out his or her hobbies. For example, if the CIO is an avid fisherman, the attacker might send him or her an email offering a free subscription to a fishing magazine if he or she fills out a survey. The survey is generic, but requires the target to select a password. This is important because most people reuse passwords. Whatever password the CIO selects, it is likely he

or she used that same password elsewhere as well. Even if it is not used as his or her network login password, it could be a password to a Hotmail, Gmail, LinkedIn, or Facebook account. This gives the attacker an inroad into that person's electronic life. From there, it is a matter of time before the attacker is able to secure the victim's network credentials. Information learned in phishing can also be used in social engineering or other highly targeted attacks such as advanced persistent threat attacks, which are ongoing attacks that make repeated and concerted attempts at phishing. It is usually for a specific, high-value target that several related phishing emails are sent.

Spyware

Spyware is any software that can monitor your activity on a computer. It may involve taking screenshots or perhaps logging keystrokes. It can even be as simple as a cookie—a tiny text file that simply records a few brief facts about your visit to a website. Normal web traffic is “stateless,” meaning no information is passed from page to page without help. This is accomplished via cookies. For example, when you visit Amazon.com, the site remembers what you were last searching for. This is accomplished via cookies. Now, like most reputable sites, Amazon does not write your personal data to a cookie. Rather, there is an identifier that Amazon can utilize to match with your data it keeps on its back-end servers. Some people might object to website cookies being labeled as spyware, and it should be pointed out that cookies have many legitimate uses. However, it is up to whoever programmed the website to decide what information is stored in a website cookie and how it will be used. This means that, at least technically speaking, cookies could be considered spyware.

It has been claimed that 80% of all computers connected to the internet have spyware. Whether the number is really that high is hard to determine. However, it is a fact that spyware is quite prevalent. One reason (which may surprise you) is that such software itself is perfectly legal, if used correctly. There are two situations that allow a person to legally monitor another person's computer usage. The first is parents monitoring minor children. If a child is under the age of 18, it is perfectly legal for the parents to monitor their child's computer activity. In fact, some experts would go so far as to say it is neglectful *not* to monitor a young child on the internet. Another legal application of computer monitoring is in the workplace. Numerous court cases have upheld an employer's right to monitor computer and internet usage on company-owned equipment.

Because there are legal applications of “spying” on a person's computer usage, a number of spyware products are easily and cheaply available. Just a few are listed here:

- **Teen Safe**—This product can be found at <http://www.teenSAFE.net>.
- **Web Watcher**—This product can be found at <https://www.webwatcher.com>.
- **ICU**—This product can be found at <http://www.softpedia.com/get/Security/Security-Related/ICU-Child-Monitoring-Software.shtml>.
- **WorkTime**—This product can be found at http://www.nestersoft.com/worktime/corporate/employee_monitoring.shtml.

The only issue for a criminal who wants to misuse this software is how to get it onto the target system. In some cases, it is done via a Trojan horse. The victims are tricked into downloading the spyware onto their machines. In other cases, the spyware can be distributed like a virus, infecting various machines. It is also possible to manually put spyware on a machine. This is usually done when the spyware is being placed due to a warrant for a law enforcement agency to monitor a target system, or when a private citizen is legally placing spyware on a system.

Of course, spyware can also be placed on the target's machine by tricking the user into opening an attachment. You may get several emails every week that try to lure you into opening some attachment. These have either a virus, spyware, or Trojan horse. You can see one example of such an email in **FIGURE 2-1**.

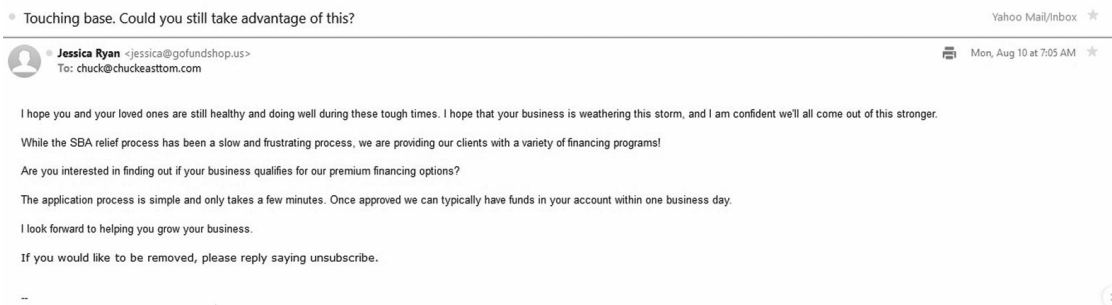


FIGURE 2-1 Email attachment.

The email entices the user into clicking on the attachment and downloading it. At that point, some sort of malware is installed on the user's machine. However, after the software is installed on the victim's computer, it then begins to gather information about that person's internet and computer activities. For criminals, the most interesting information is usually financial data, bank login passwords, and so forth.

Discarded Information

Another method that allows a hacker to gather information about a person's identity is discarded information. Any documents that are thrown out without first being shredded could potentially aid an identity thief. This usually doesn't leave much forensic evidence, but it does indicate that the perpetrator is local—they must be in order to access the victim's trash, a practice commonly known as dumpster diving.

How Does This Crime Affect Forensics?

If the crime being investigated is identity theft, then the first thing the investigator should be looking for is spyware on the victim's machine. While there are certainly other ways to get one's identity, this is an easy one to check. It is certainly possible that somewhere on the victim's machine is some type of spyware. If spyware exists, the investigator must start searching for where the spyware is sending its data. Yes, spyware collects data on

the user's computer and internet activities, but ultimately that data must be communicated to the criminal. It could be something as simple as a periodic email with an attachment, or it could be a stream of packets to a server the criminal has access to. And since a firewall is more strict on blocking inbound communication rather than stopping outbound messages, sending data out to the criminal is easily done. Whatever the specific communication mechanism, there absolutely must be some way to get the information from the victim's computer to the attacker—and that will leave some forensic trace.



WARNING

It is important to remember the limits of monitoring employees and minor children. You can monitor employee activities, but only on company systems. Furthermore, the day a child turns 18, he or she is legally an adult and cannot be monitored. It is illegal for you to monitor other adults—even relatives living in your home.



TIP

Dumpster diving is why paper must always be shredded or burned. A criminal could use any documents found in the trash to derive information that helps him or her perpetrate a crime, such as identity theft. Another issue the investigator should explore is that of phishing emails. It is important to check the email history for the victim's computer as well as the web history. If a phishing website was involved, it is important to gather information about that site.

Hacking

Hacking is a generic term that has different meanings to different people. In the hacking community, it means to experiment with a system, learning its rules or processes, in order to better understand the system or to fix the flaws. In most other contexts, it means circumventing a system's security. This section uses the latter definition. It is certainly possible to break into a system remotely. Attackers can use a number of techniques to do this. The following sections discuss a few of these techniques.

Structured Query Language Injection

Structured Query Language (SQL) injection may be the most common web application attack. It is based on inserting SQL commands into text boxes, such as the username and password text fields on the login screen. If the login fields expect only text and do not protect against SQL commands, the web attack is possible. According to the most recent Verizon Terremark Data Breach Investigations Report, SQL injection was once one of the most common types of web attack, but it has fallen off in recent years thanks to better website coding practices. Still, it is remarkable how many sites remain susceptible.

To understand how SQL injection works, you have to first understand the basics of how data entry boxes should be guarding against unexpected text. A login screen requires the user to enter a username and password, and these then have to be validated. Most often, they are validated by checking a database that has a table of users to see if the password matches that user. All modern databases “speak” SQL, so if the programmer who created the login screen and validation process is not careful, the web page may be susceptible to SQL injection. Here is how that attack works. SQL looks a lot like English. For example, to check a username and password, you might want to query the database and see if there is any entry in the users table that matches the username and password that were entered. If there is, then you have a match. The SQL statements in the programming code for the website have to use quotation marks to separate the SQL code from the programming code. A typical SQL statement might look something like this:

```
SELECT * FROM tblUsers WHERE USERNAME = '"' + txtUsername.Text
+' AND PASSWORD = '"' + txtPassword.Text +'''
```

If you enter username 'thisuser' and the password 'letmein', this code produces the SQL command:

```
SELECT * FROM tblUsers WHERE USERNAME = 'thisuser' AND PASSWORD
= 'letmein'
```

This is fairly easy to understand even for nonprogrammers. Plus, it is effective. If there is a match in the database, that means the username and password match. If no records are returned from the database, that means there was no match, and this is not a valid

login.

SQL injection is basically about subverting this process. The idea is to create a statement that will always be true and would cause the application to process a query. Before a true statement is considered, the entered text needs to “escape” the application reading it as text and instead process it as an instruction. For example, you enter in a single quote, such as ', then a statement that is always true, such as `1 = 1`, into the username and password boxes. This causes the program to execute whatever query that follows:

```
SELECT * FROM tblUsers WHERE USERNAME = '' or 1=1 AND PASSWORD =  
' ' or 1=1.
```

Here you are telling the database and application to return all records where the username and password are blank or if `1 = 1`. The fact is that 1 always equals 1, so this works. Now if the programmer wrote the application properly—so that it does not allow any extra characters to escape out of being normal text—this does not work. But in all too many cases, it does work. And then the intruder has logged on to your web application and can do whatever any authorized user can do.

Technical TIP

SQL injection can be a lot more sophisticated than this section demonstrates. This chapter looks at the simplest implementation of SQL injection. Many other methods are available, including related attacks such as cross-site scripting, in which script—often JavaScript—is put into input boxes so it will be executed on the target website.

The example just described is the simplest version of SQL injection. There are more advanced SQL injection techniques. In fact, SQL injection is limited only by your own knowledge of SQL. Obviously, SQL injection attacks can be very sophisticated, involving a complex array of SQL statements, or they can be as simple as the example just discussed.

There are even tools that make the process of executing this attack—or testing your website to see if it is vulnerable to this attack—even easier. A few are listed here:

- Several tools at Database Security at <http://www.databasesecurity.com/sqlinjection-tools.htm>
- Sqlmap at <http://sqlmap.org/>
- SQL Ninja at <http://sqlninja.sourceforge.net/>

How Does This Crime Affect Forensics?

Regardless of the sophistication of the SQL injection attack, or the lack thereof, such attacks leave specific forensic evidence. The first place you should look is in the firewall logs. There should be some indication of where the connection came from. Second, search your database logs; some relational database engines log transactions, when they

occurred, and what they were. This can be invaluable in your investigation.

Cross-Site Scripting

Cross-site scripting is another very common attack. In this attack, a legitimate website allows malicious script to act, and deliver content, as if it comes from the legitimate website. All that is needed for the perpetrator is to seek out some place on the target website that allows malicious script to wait for end users to fall victim from it. One example is to post text that other users will see. Product reviews are a great place for this. But instead of posting a review, or other text, the attacker will post JavaScript. If the website does not filter the user input before displaying it, then when other users navigate to this review, the website will instead execute that script. The attacker is only limited by his or her knowledge of JavaScript. One popular thing to do is to redirect the user to a phishing site. Phishing involves tricking an end user, generally by email, into giving up their account information. This practice of using technical means to redirect people to a very similar, but fake, phishing site is called *pharming*.

To better understand this attack, let us walk through a scenario. Before we do, I would point out to you that to the best of my knowledge, none of the major e-commerce or auction sites is vulnerable to this kind of attack. In this scenario, the attacker sets up a website that looks very much like the target site. He gives that site a name similar to the target site, off by only one letter. That makes it likely an end user will not notice the minor difference. Then the attacker infects the target site with cross-site scripting, a script that will redirect the user to the phishing site. Once at the phishing site, the malicious site simply displays a notice stating "your session has expired, please log in again." When the user logs in, the malicious site captures the login information, then sends the user back to the real site. Now the attacker has that user's login information. To the end user, it would appear as if they have always been on the same website.

How Does This Crime Affect Forensics?

Cross-site scripting can be a complex crime to investigate. The first item to look for is any scripts in the website. Certainly, websites have many scripts that are there intentionally for beneficial purposes, but this is the first place to search for any malicious scripts. In a large website, that search can be a very tedious task, and it is possible the attacker has removed the malicious script. A more efficient method is to search the web server's logs for any redirect messages (these are HTTP messages in the 300 range), then determine if any of these redirects cannot be accounted for via legitimate web coding.

Ophcrack

Probably one of the most basic tools for physically accessing a Windows machine is Ophcrack. Ophcrack can be downloaded from <http://ophcrack.sourceforge.net/>. It is a tool to crack the local passwords on Windows systems. It is usually pretty effective. In fact, if an attacker can sit at a Windows machine on your network with an Ophcrack compact disc (CD) or USB flash drive for 10 minutes or less, chances are good that the attacker is going to get the local passwords. This is a significant problem on corporate networks that

meet the following criteria:

- If physical security is lax, an outsider can get in the building, often by posing as a cleaning or maintenance person or a temporary employee.
- It is usually possible to find an unoccupied desk in the building.
- The network's focus is on domain accounts, not local accounts. There is a good chance that the local accounts for one Windows machine are the same throughout. The systems are usually just imaged from a base system.

It should be noted that Ophcrack is only one such tool. There are myriad similar tools available on the internet—some that work much better than Ophcrack.

How does Ophcrack work? First, let's discuss how Windows passwords work. When you choose your local Windows passwords, the password you choose is hashed and stored in the SAM file, which is found in the Windows\System32\ directory. The hash of the password is not the password itself, but is created from the password using a hashing algorithm that makes two identical hashes for different passwords very unlikely.

To make this work, all you have to do is put the Ophcrack CD into the system and reboot. During the boot-up process, press the key needed to enter the system's BIOS, often F2 or the DEL key, to change the boot order. Additionally, the F10 or F12 key might bring up a boot menu; then choose Boot from CD. Note that in [FIGURE 2-2](#), the passwords that Ophcrack found are blocked out. There's a lot to know about hashes and cryptography, but for now, you just need to know that a hash is one-way; you don't "unhash" something. When you log on to Windows, the system hashes whatever you type in and compares it with whatever hash is in the SAM file. If there is an exact match, then you are given access.

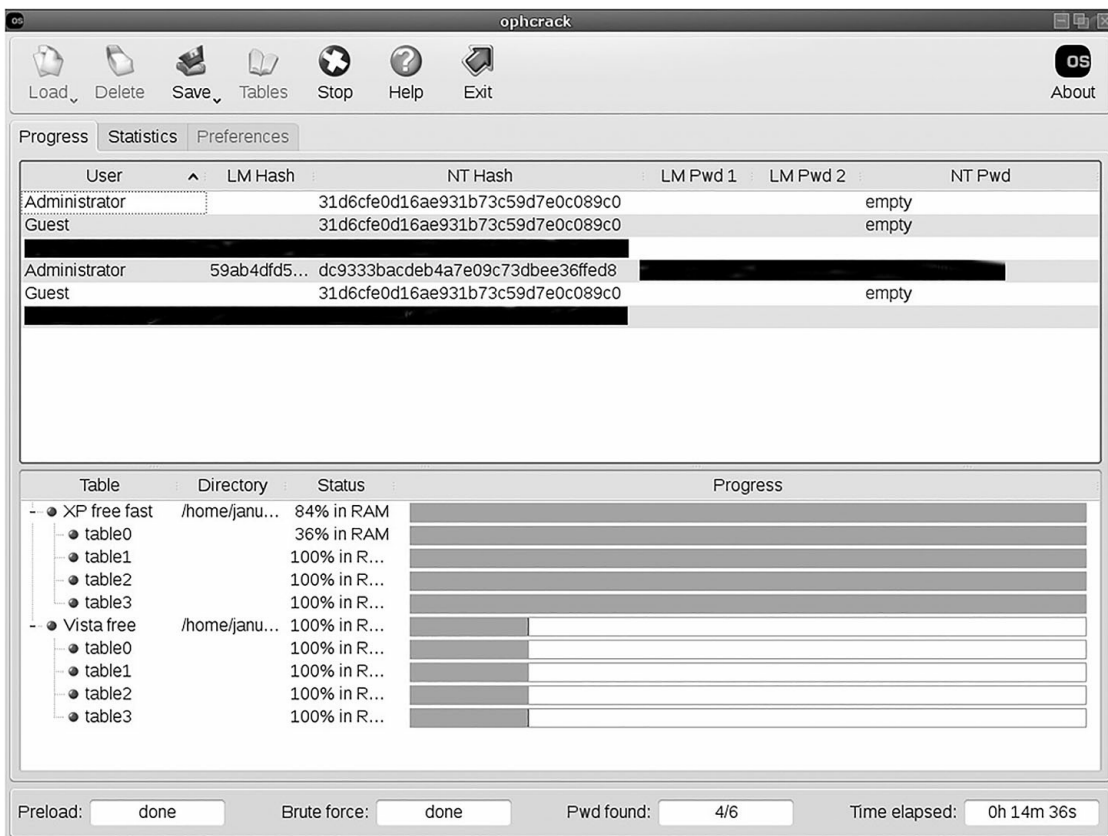


FIGURE 2-2 Ophcrack. Note: This screenshot was taken from a live machine, so all nonstandard user accounts and all passwords were redacted.

The most basic way to extract passwords from hashes is a **rainbow table**, and that is what Ophcrack uses. To understand rainbow tables, consider a scenario where one wishes to extract Windows local passwords. Windows uses the NTLMv2 hashing algorithm to store passwords. Imagine you make a table of all common eight-character passwords in one column, and the NTLMv2 hash of them in the second column. Then you repeat this for all common nine-character passwords, then for all 10-character passwords. You can take this as far as you like, and as far as your computing resources will support. Then if you can extract a hash from the target machine, you search the tables for a match. If you find a match in the second column, whatever is in the first column must be that person's password. These tables get huge very fast, so most are no more than 8–10 characters in length, which works for most passwords. A sample of a rainbow table with both good and bad passwords is shown in **FIGURE 2-3**.

Password	NTLM Hash
password	8846F7EAAE8FB117AD06BDD830B7586C
letmein	7156684CFA75A3D5678B3C144F64E14A
baspassword	24A4001F435CABC9914E34B8CAA9D01C
pa\$\$w0rd0!	03EDECCBCCA5A08A6581804ED776067D

FIGURE 2-3 Rainbow table.

The problem is getting the SAM file to start with. When Windows boots up, long before you even get the login screen, the system locks the SAM file—preventing you from copying or editing it. Well, that is where Ophcrack comes in. It boots to a Linux Live CD and then scans its rainbow table searching for matches. It displays all the passwords it finds in an easy-to-use graphical user interface.

Once the attacker has a valid login account, particularly an administrator account, he or she can log on to that computer, even from a remote location. This doesn't let the attacker join the domain, but he or she now has a foothold in your network. You can see this in [FIGURE 2-2](#).

How Does This Crime Affect Forensics?

There may or may not be much in the logs for this crime. If the target system is a Windows Server 2003, 2008, or 2012 machine, then the rebooting of the machine will show in the log. If you see a reboot followed by a successful login with an account like Administrator, it is an indication that a tool like Ophcrack might have been used. Another issue to examine is physical security. If a physical intrusion is suspected, then traditional forensic methods, such as examining security cameras and even fingerprints, become important. Of course, having an account logged on at a time when the actual user who is assigned that account is not present is also a clear sign that a breach of some kind has occurred.

Tricking Tech Support

The following is a simple trick, and one that is a follow-up to using Ophcrack to break local accounts. After the attacker has gained access to a local account, he or she will really want to get domain admin privileges. The command `net user` can help do this. First, the attacker writes the following two-line script:

```
net user /domain /add localaccountname password
net group /domain "Domain Admins" /add localaccount
```

The attacker then saves that script in the All Users startup folder. The next step is to get a domain admin to log onto this machine. If that happens, the script runs—in the background and not visible—and your local account is now a domain admin. But how do you get a domain administrator to log on? Well, it just so happens that in many

organizations, the tech support personnel are in the domain admin group. So the attacker merely needs to do something to render the machine not fully operational. When a tech support person logs on to fix that problem, the script is run.

How Does This Crime Affect Forensics?

Searching the system for any unrecognized scripts, particularly in any startup folders, is a good first step if you suspect a physical breach. Of course, the usage of the compromised account also yields clues. If the network admin account shows that it was used at a time when the network administrator was away, this suggests the account has been compromised. And, as with Ophcrack, physical security is an issue in this crime; therefore, investigating physical breaches of the premises is important.

Hacking in General

Entire books have been written on hacking techniques, and entire certification courses focus on such skills. The purpose here is to introduce you to some techniques that an attacker might use. To go into all the common hacking techniques attackers use is beyond the scope of this text. However, this section illustrates an important point: Computer crime investigators should have a strong working knowledge of hacking techniques. Your forensic investigations will be drastically improved if you have an understanding of the techniques that attackers use.

Cyberstalking and Harassment

Cyberstalking, cyberbullying, and online harassment are getting increasing attention in the media. As society becomes ever more wired, conduct online becomes more important. With many people using social media to interact with others, dating sites to find that special someone, and online discussion boards to talk, inappropriate behavior online becomes more noticeable. Some would say that bad behavior is becoming more common online. People feel more comfortable ranting at a faceless name on a screen than at a real person. But where does rudeness cross the line into stalking or harassment? Surely not every rude word on the internet constitutes a crime.

Cyberstalking or harassment is using electronic communications to harass or threaten another person. The U.S. Department of Justice puts it this way:

Although there is no universally accepted definition of cyber stalking, the term is used in this report to refer to the use of the internet, e-mail, or other electronic communications devices to stalk another person. Stalking generally involves harassing or threatening behavior that an individual engages in repeatedly, such as following a person, appearing at a person's home or place of business, making harassing phone calls, leaving written messages or objects, or vandalizing a person's property. Most stalking laws require that the perpetrator make a credible threat of violence against the victim; others include threats against the victim's immediate family; and still others require only that the alleged stalker's course of conduct constitute an implied threat. While some conduct involving annoying or menacing behavior might fall short of illegal stalking, such behavior may be a prelude to stalking and violence and should be treated seriously.

Now, even after reading this description, you may still not know where the line between bad behavior and criminal behavior lies. Here are three criteria for law enforcement officers to bear in mind when considering cyberstalking and harassment cases. All three aren't necessarily essential to create a case of cyberstalking or harassment, but all three must be considered:

- **Is it possible?** If a person makes a threat, is that threat credible? To illustrate this question, consider two extremes. In the first scenario, you are playing a game online and another player, who lives in a different country, tells you he is so mad at you he is going to punch you in the nose. Given that you are probably not even using your real name, and this person is thousands of miles away, this is not a credible threat. At the other extreme, consider a scenario in which you receive an email threatening to kill you, but attached to the email is a recent photo of you leaving the front door of your home. That is clearly alarming and indicates the sender has the means and intent to commit harm.

- **How frequent?** Notice that the U.S. Department of Justice uses the term “repeatedly.” People get angry and say things they later regret. Someone saying something rude and even violent, one time, is not necessarily stalking. Reasonable people calm down and regret the harsh words they said, and then they don’t repeat them. But repeated behavior is a pattern, not a mistake.
- **How serious?** Again, reasonable people can lose their temper and say things they don’t mean. Many people have at some point uttered the words, “I could kill ...”—but they don’t act on them. Reasonable people do make vague statements in anger that they later regret and are embarrassed about. Specific and serious threats are more disconcerting. Someone saying, “I could just kill him,” may be cause for concern, or may just be blowing off steam. Someone who makes such a statement and then goes on to detail just how he would go about killing the person, indicating that he has put thought into this, should be taken seriously as a threat.

Again, not all of these elements need to be present in order to constitute cyberstalking or harassment. However, all three need to be considered. Clearly, some people do make false reports to the police. Other people overreact to benign comments. On the other hand, cyberstalking can lead to real-world violent crimes.

Real Cyberstalking Cases

The following nine cases should give you a good overview of cyberstalking. Examining the facts in these cases might help you to get an idea of what legally constitutes cyberstalking. Some of these cases are quite recent. Others are older and are included because they were historically significant cases.

1. In 2019, North Carolina State Representative Cody Henson pled guilty to cyberstalking charges involving his ex-wife. The case involved threats to kill his ex-wife and her entire family. This case illustrates that cyberstalking can involve people from any segment of society.
2. In 2010, 70-year-old Joseph Medico met a 16-year-old girl at church. The girl was at the church volunteering, helping to prepare donations for homeless shelters. Mr. Medico followed the girl to her car and tried to talk her into going to dinner with him, and then back to his home. When she spurned his advances, he began calling and texting her several times a day. When she realized he was not going to stop, she called the police. Mr. Medico was arrested and charged with stalking. This case illustrates how easy it is for an unstable person to become obsessed with the victim. It also demonstrates the proper way to handle this sort of situation. This is definitely a

case to report to the police. An adult who is making overtures like this to a minor is a matter of grave concern.

3. In the first successful prosecution under California's cyberstalking law, prosecutors in the Los Angeles District Attorney's Office prosecuted a 50-year-old former security guard who used the internet to solicit the rape of a woman who rejected his advances. The defendant terrorized his 28-year-old victim by impersonating her in various internet chat rooms and on online bulletin boards, where he posted, along with her telephone number and address, messages that she fantasized about being raped. On at least six occasions, sometimes in the middle of the night, men knocked on the woman's door saying they wanted to rape her. The former security guard pled guilty in April 1999 to one count of stalking and three counts of solicitation of sexual assault.
4. A local prosecutor's office in Massachusetts charged a man who, using anonymous remailers, allegedly engaged in a systematic pattern of harassment of a coworker, which culminated in an attempt to extort sexual favors from the victim under threat of disclosing past sexual activities to the victim's new husband. (A remailer is an anonymous server that resends emails so they cannot be traced back to the original sender.)
5. In 2020, Samuel Trelawney Hughes was indicted by a federal grand jury on charges that he used cyberstalking to threaten to injure, rape, or kill at least 10 different people. He was also charged with seven counts of witness tampering. Hughes allegedly sent victims messages in which he expressed hope they would die or made specific threats to hurt them. In one example from October 2019, Hughes allegedly sent an email to a person who had reported prior threats, saying, "someone I can guarantee will come out and first bash you head in, rape you slash your throat and burn your car and house."
6. An honors graduate from the University of San Diego terrorized five female university students over the internet for more than a year. The victims received hundreds of violent and threatening emails, sometimes receiving four or five messages a day. The graduate student, who entered a guilty plea and faced up to six years in prison, told police he committed the crimes because he thought the women were laughing at him and causing others to ridicule him. In fact, the victims had never met him.
7. In England, Jason Smith continually harassed college student Alexandra Scarlett. He sent her as many as 30 messages a day threatening to slash her face, sexually assault her mother, or shoot her father. He was convicted and given a 12-month

suspended sentence and a restraining order. However, within a week of this conviction, he used social networking sites to track down Ms. Scarlett and continue the campaign of harassment. Media in Britain have dubbed Mr. Smith "England's Most Obsessive Stalker." This case is also an example of stalking in response to unrequited romantic feelings. Mr. Smith had met Ms. Scarlett at a nightclub. She had given him her phone number. He then became convinced that they were in love and that they must be together. This led him to extreme jealousy, and eventually to the obsessive stalking.

8. Robert James Murphy was the first person charged under U.S. federal law for cyberstalking. He was accused of violating Title 47 of U.S. Code 223, which prohibits the use of telecommunications to annoy, abuse, threaten, or harass anyone. Murphy was accused of sending sexually explicit messages and photographs to his ex-girlfriend. This activity continued for a period of years. Mr. Murphy was charged and eventually pled guilty to two counts of cyberstalking.
9. In 2020, Kristian James O'Hara pled guilty to cyberstalking a woman he met while attending Fordham University. He is alleged to have initially started using the victim's phone number to have unsolicited late-night food orders delivered to her and make prank phone calls. He also left voicemails to the victim's family home in Delaware, in which he lied and accused her of giving him a sexually transmitted disease. The harassment escalated in both severity and frequency and lasted for 18 months. Mr. O'Hara has also admitting to cyberstalking at least eight other victims.

How Does This Crime Affect Forensics?

Cyberstalking and harassment is an interesting computer crime in that the computer is simply incidental. The intent of the crime is to target the human victim; the computer is just a vehicle. Fortunately, stalkers are often not the most technically savvy computer criminals. In stalking cases, you should begin with tracing emails and text messages. In many cases, they come directly from the perpetrator with little or no attempt to obfuscate their origin. Of course, if a suspect is arrested, any electronic devices in his or her possession should be examined for evidence. Stalking, by definition, indicates repeated, obsessive behavior. This means there is likely to be some evidence retained by the criminal.

Fraud

Fraud is a broad category of crime that can encompass many different activities. Essentially, any attempt to gain financial reward through deception is fraud. Two major subclasses of fraud are as follows:

- Investment offers
- Data piracy

The following sections briefly examine these classes of computer fraud.

Investment Offers

Investment offers are neither new nor necessarily illegal. In fact, cold-calling is a legitimate sales technique when selling stocks. However, the process can be used to artificially and fraudulently inflate the value of a target stock. The most common version of this is called the “pump and dump.” In this scheme, the perpetrators buy significant amounts of stock in a company that is relatively cheap, often penny stocks. Then, they fuel false rumors that the company is on the verge of some large contract or other business deal that would increase its value significantly. This artificially drives up the price of the stock. Once the rumors have raised the stock as high as the criminals think it will go, they dump their stock at an inflated price, thus making substantial profits. Eventually, once it is clear the rumors were not true, the stock’s value will drop again. The people who purchased the stock at an inflated price, but were not in on the scam and did not know to sell their stock before its value plummeted, lose significant amounts of money.

The growth of the internet did not create these scams—they existed long before the internet. But the widespread popularity and speed of the internet simply made scams easier to perpetrate. For example, with the pump and dump, the internet allows the perpetrator to create fake blogs, bulletin board postings, and emails, all claiming the target stock is likely to rise in value. The key to internet-based fraud of this kind is that, instead of cold-calling via the phone, the perpetrators send an enticing email to as many recipients as possible. Of course, they realize that most people will not respond to the email, but if the perpetrator sends out a million emails and even a tiny percentage of recipients respond, he or she can still pull in a significant amount of money.

One of the more common internet schemes involves sending out an email that suggests that you can make a large sum of money with a very minimal investment. It may be a processing fee you must submit in order to receive some lottery winnings, or perhaps legal fees in order to receive some inheritance. Perhaps the most famous of these schemes has been the “Nigerian prince” fraud. In this scenario, an email is sent to a large number of random email addresses. Each email contains a message purporting to be from a relative of some deceased Nigerian doctor or government official, always of significant social standing. (It’s more likely to convince victims that the arrangement is legitimate if it seems to involve people of good social standing.) The offer goes like this: A

person has a sum of money he or she wants to transfer out of the country, and he or she cannot use normal channels. He or she wants to use your bank account to “park” the funds temporarily. If you allow the person access to your account, you will receive a hefty fee. If you do agree to this arrangement, you will receive, via normal mail, a variety of very official-looking documents—enough to convince most casual observers that the arrangement is legitimate. You will then be asked to advance some money to cover items such as taxes and wire fees. Should you actually send any money, however, you will lose it, and you will never hear from these individuals again. The FBI has issued a bulletin detailing this particular fraud scheme. Further FBI internet crime information is available at <https://www.fbi.gov/scams-and-safety/common-scams-and-crimes>.

How Does This Crime Affect Forensics?

The key in this sort of crime is to begin by tracing the communications. If it is a fake blog that is endorsing some investment, then someone had to register the domain for that blog. If there are emails involved, they had to come from somewhere. Of course, the more sophisticated the attacker, the less evidence there will be. Another way to seek evidence outside computer forensics is to follow the money. Someone is reaping financial rewards from the scheme.

Data Piracy

Intellectual property is a very real commodity. Large companies spend millions of dollars on filing patents and defending their patents and copyrights. The internet makes distribution of illegally copied materials, or data piracy, very easy. You are probably quite familiar with illegal music downloads; however, that is only one aspect of intellectual property theft.

Illegal copies of software can be found on the internet. There are websites that have such copies or the activation codes for software. These sites are colloquially referred to as warez (pronounced like wares) sites. As a consumer, the best advice to follow is, “If it seems too good to be true, it is probably not true.” In other words, if a website boasts of a \$400 software package for \$89, it is probably illegally copied software.

How Does This Crime Affect Forensics?

The investigation of this sort of crime involves trying to trace the owners of the website that is distributing the intellectual property. This involves finding out who registered the domain and performing a WHOIS search on that domain. If the perpetrator is clever, he or she will hide behind several identities. However, the starting point is to track the website distributing the intellectual property.



NOTE

Data piracy is frequently addressed via civil court rather than criminal. It is often a better option for the victim to sue the perpetrator rather than press criminal charges. This is one reason forensics is no longer just a law enforcement activity. There are

myriad civilian reasons to utilize forensics.

Non-Access Computer Crimes

Non-access computer crimes are crimes that do not involve an attempt to actually access the target. For example, a virus or logic bomb does not require the attacker to attempt to hack into the target network. And denial-of-service attacks are designed to render the target unreachable by legitimate users, not to provide the attacker with access to the site.

Denial of Service

A **denial-of-service (DoS) attack** is an attempt to prevent legitimate users from being able to access a given computer resource. The most common target is a website. Although there are a number of methods for executing this type of attack, they all come down to the simple fact that every technology can handle only a finite load. If you overload the capacity of a given technology, it ceases to function properly. If you flood a website with fake connections, it becomes overloaded and unable to respond to legitimate connection attempts. This is a classic example of a DoS attack. Although these attacks may not directly compromise data or seek to steal personal information, they can certainly cause serious economic damages. Imagine the cost incurred if a DoS attack were to take eBay offline for a period of time!

Denial-of-service attacks are the cyber equivalent of vandalism. Rather than seek to break into the target system, the perpetrator simply wants to render the target system unusable. These attacks require minimal skill. For example, consider one of the most basic DoS attacks, called a SYN flood. This simple attack takes advantage of how connections to websites are established. So, first, let's take a look at how that works.

The client machine sends a Transmission Control Protocol (TCP) packet to the server with a synchronize flag turned on—it is a single bit that is turned to a 1. Because this is synchronizing, or starting the connection, it is called a SYN flag.

The server sets aside enough resources to handle the connection and sends back a TCP packet with two flags turned on: the acknowledgment flag (ACK) and the synchronize (SYN) flag. Essentially, this is acknowledging the request to synchronize. The client is supposed to respond with a single ACK flag to establish the connection and allow communications to begin. This is called the **three-way handshake**.

In the SYN flood attack, the attacker keeps sending SYN packets but never responds to the SYN/ACK packets it receives from the server. Eventually, the server has responded to millions of connection requests for a client that never fully connects. After several millions of connection requests in seconds, the server exhausts its resources and can no longer respond to legitimate users.

In addition to various DoS attack types, there are tools that can be used to create a DoS attack. One of the easiest to use is the Low Orbit Ion Cannon, shown in **FIGURE 2-4**.

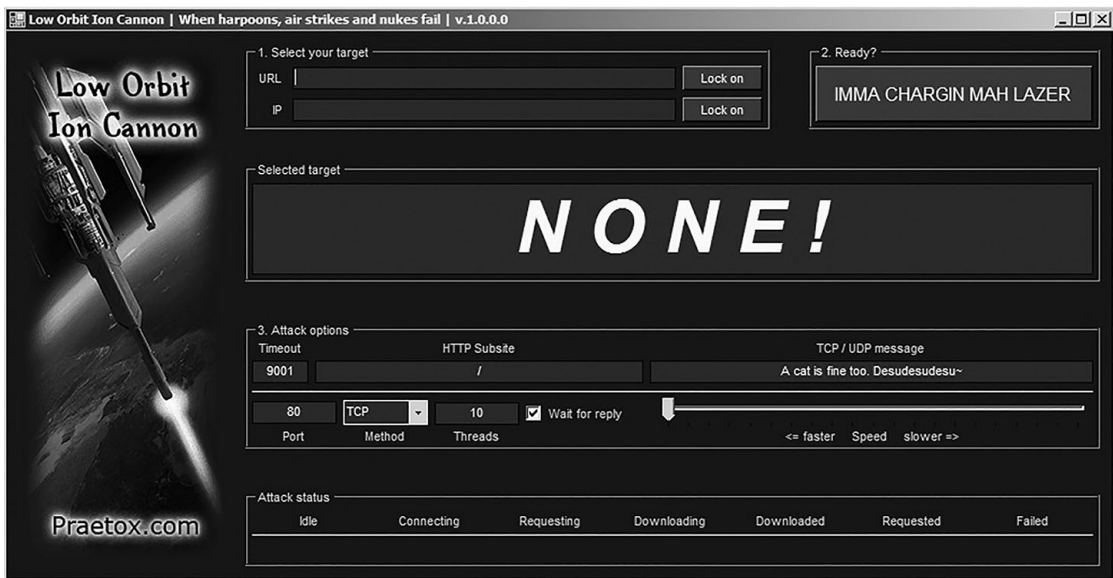


FIGURE 2-4 Low Orbit Ion Cannon.

This tool is freely available on the internet and terribly easy to use. The prevalence of such easy-to-use tools is one reason why DoS attacks are so common.

The Tribal Flood Network (TFN) is probably the most widely used DoS tool. There is a newer version of it called TFN2K. The new version sends decoy information to make tracing more difficult. Both the original and the new version work by configuring the software to attack a particular target, and then getting the target on a specific machine. Usually, the attacker seeks to infect several machines with the TFN program in order to form a TFN. Instead of connection requests originating from one machine, the barrage is distributed across many. This attack variation is called a **distributed denial-of-service (DDoS) attack**.

You can get more details about TFN and TFN2K at these websites:

- Washington University at <http://staff.washington.edu/dittrich/misc/tfn.analysis.txt>
- Packetstorm Security at http://packetstormsecurity.com/distributed/TFN2k_Analysis-1.3.txt
- The Computer Emergency Response Team (CERT) at <http://www.cert.org/advisories/CA-1999-17.html>

Trin00 is another popular DoS tool. It was originally available only for UNIX but is now available for Windows as well. It is an alternative to TFN. One common technique attackers use is to send the Trin00 client to machines via a Trojan horse—a type of code that looks to the casual user like it is legitimate, but is really malware. Then, the infected machines can all be used to launch a coordinated attack on the target system.

A Smurf attack is a DoS attack that uses a combination of IP spoofing and ICMP to saturate a target network with traffic. Smurf consists of three elements: a source site, a

bounce site, and a target site. The attacker (the source site) sends a modified ping to the broadcast address of a large network (the bounce site). The modified packet contains the source address of the target site—and everyone at the bounce site replies to the target site. A Fraggle attack is a variation of a Smurf attack where an attacker sends a large amount of UDP traffic to ports 7 (echo) and 19 (chargen) to a broadcast address, spoofing the intended victim's source IP address.

Dynamic Host Configuration Protocol (DHCP) starvation is another type of DoS attack. DHCP is used to dynamically assign network addresses to computers. This is widely used in most organizations. If enough requests flood onto the network, the attacker can completely exhaust the address space allocated by the DHCP servers for an indefinite period of time. There are tools such as Gobbler that will do this for the attacker.

An HTTP post DoS attack targets web servers. Such an attack sends a legitimate HTTP post message. Part of the post message is the 'content-length'. This indicates the size of the message to follow. In this attack, the attacker then sends the actual message body at an extremely slow rate. The web server is then "hung" waiting for that message to complete. For more robust servers, the attacker will need to use multiple HTTP post attacks simultaneously.

There are other DoS attacks targeting web servers and websites. The attacker could create a program that submits the registration forms repeatedly, adding a large number of spurious users to the application. The attacker may also choose to overload the login process by continually sending login requests that require the presentation tier to access the authentication mechanism, rendering it unavailable or unreasonably slow to respond.

A **permanent denial of service (PDoS)** is an attack that damages the system so badly that the victim machine needs an operating system reinstall or even new hardware. This is sometimes called *phlashing*. This will usually involve a DoS attack on the device's firmware.

Another type of DoS attack that has become more prevalent in recent years is the telephony denial-of-service (TDoS) attack. A TDoS attack is possible, and certainly has been documented, with traditional telephone systems by using an automatic dialer to tie up target phone lines. TDoS is flourishing, however, with the wide availability of Voice over Internet Protocol (VoIP) tools that make automated TDoS attacks against traditional and IP-based VoIP very easy to carry out. The way that a TDoS attack works is that a call center or business receives so many inbound calls that the equipment and staff are overwhelmed and unable to do business. A call to a supervisor or manager demands a certain amount of money be sent or a certain eradication service be purchased to stop the attacks.

How Does This Crime Affect Forensics?

When investigating DoS attacks launched from a single machine, the obvious task is to trace the packets coming from that machine. It is common for attackers to spoof some other IP address, but not as common for them to spoof a MAC address, which is related to the underlying hardware. If the attacker is not savvy enough to spoof the MAC address, then each packet contains evidence of the actual machine that it was launched from.

In DDoS attacks, the packets come from a multitude of machines. Usually, the owners of these machines are unaware that their machines are being used in this way. However, that does not mean the investigation is at a dead end. You can still trace back the packets and get a group of infected machines. You can then seek out commonalities

on those machines. Did they all download the same free game from the internet or frequent the same website? Anything that all infected machines have in common is a candidate for where the machines got the software that launched the DDoS attack.

Viruses

Viruses are a major problem in modern computer systems. A **virus** is any software that self-replicates, like a human or animal virus. It is common for viruses to also wreak havoc on infected machines, but the self-replication is the defining characteristic of a virus. It should be noted that in modern times, most malware combines facets of different types of attacks (i.e., a virus and a Trojan horse). Some people now use the term *virus* to mean any malware. That is not technically accurate, but you should be prepared to see that in practice. Before discussing the forensics of viruses, it is a good idea to consider some recent viruses:

- **FakeAV.86**—This is a fake antivirus. It purports to be a free antivirus scanner, but is really itself a Trojan. This virus first appeared in July 2012. It affected Windows systems ranging from Windows 95 to Windows 7 and Windows Server 2003. This is not the only fake antivirus to have been found, but it is a widespread one.
- **Flame**—No modern discussion of viruses would be complete without a discussion of Flame, a virus that targeted Windows operating systems. The first item that makes this virus notable is that it was specifically designed for espionage. It was first discovered in May 2012 at several locations, including Iranian government sites. Flame is spyware that can monitor network traffic and take screenshots of the infected system. This malware stores data in a local database that is heavily encrypted. Flame is also able to change its behavior based on the specific antivirus software running on the target machine. This indicates that this malware is highly sophisticated. Also of note is that Flame is signed with a fraudulent Microsoft certificate. This means that Windows systems would trust the software.

These two pieces of malware give you some idea of the impact a virus can have on an organization's network. Viruses range from terribly annoying, like FakeAV, to sophisticated mechanisms for espionage, like Flame. A few other more recent viruses are discussed briefly here:

- **GameOver Zeus** is a virus that creates a peer-to-peer botnet. This virus first began to spread in 2015. The virus creates encrypted communication between infected computers and the command and control computer, allowing the attacker to control the various infected computers.
- **Wannacry** hit the world in March 2017 with a storm of activity. However, this virus

will be studied for many years to come. There are several reasons for this, but the main reason this virus is noteworthy is that there was a patch for the vulnerability it exploited, and that patch had been available for weeks. This illustrates why patch management is such an important part of cybersecurity.

- **Emotnet** came out in 2019; it was malware that pretended to be a scanned copy of Edward Snowden's memoir. Once the target clicks on the attachment, a Microsoft Word window opens with the message "Word hasn't been activated," prompting users to click on the "Enable Content" button. After the user clicks on the button, a PowerShell command is launched that attempts to download the botnet malware from one of the three URLs embedded in the application.
- **Ryuk** malware appeared throughout 2019 and affected millions of people all over the world. The ransomware targeted several state, local, and territorial government entities and demanded ransom in Bitcoin to decrypt files.
- The **Rombertik** virus began to be seen in 2015. This virus uses the browser to read user credentials to websites. It is most often sent as an attachment to an email. The virus can also either overwrite the master boot record on the hard drive, making the machine unbootable, or begin encrypting files in the user's home directory.
- The **Lucky** virus began to show up in 2016. It is a ransomware virus that encrypts sensitive files on the victim computer and then demands ransom for the encryption key. Unlike previous ransomware viruses, this one can encrypt data on unmapped network shares.

Viruses can be divided into distinct categories. A list of major virus categories is provided here:

- **Macro:** Macro viruses infect the macros in office documents. Many office products, including Microsoft Office, allow users to write mini-programs called macros. These macros can also be written as a virus. This type of virus is very common due to the ease of writing such a virus.
- **Memory-resident:** A memory-resident virus installs itself and then remains in RAM from the time the computer is booted up to when it is shut down.
- **Multi-partite:** Multi-partite viruses attack the computer in multiple ways—for example, infecting the boot sector of the hard disk and one or more files.
- **Armored:** An armored virus uses techniques that make it hard to analyze. This is done by either compressing the code or encrypting it with a weak encryption method.

- **Sparse infector:** A sparse infector virus attempts to elude detection by performing its malicious activities only sporadically. With a sparse infector virus, the user will see symptoms for a short period, then no symptoms for a time. In some cases, the sparse infector targets a specific program but the virus only executes every 10th time or 20th time that target program runs.
- **Polymorphic:** A polymorphic virus literally changes its form from time to time to avoid detection by antivirus software. A more advanced form of this is called the Metamorphic virus; it can completely rewrite itself.

How Does This Crime Affect Forensics?

Viruses are remarkably easy to locate, but difficult to trace back to the creator. The first step is to document the particulars of the virus—for example, its behavior, the file characteristics, and so on. Then, you must see if there is some commonality among infected computers. For example, if all infected computers visited the same website, then it is likely that the website itself is infected. In addition, numerous sources of information about known viruses are available on the internet from software publishers and virus researchers, which is very useful in doing forensic research.

It is a slow and tedious process, but it is possible to track down the creator of a virus.

Logic Bombs

A **logic bomb** is malware that is designed to do harm to the system when some logical condition is reached. Often it is triggered based on a specific date and time. It is certainly possible to distribute a logic bomb via a Trojan horse, but this sort of attack is often perpetrated by employees. The following two cases illustrate this fact:

- In 2019, David Tinley, a contract programmer for Siemens, was charged with infecting his employer with a logic bomb. According to the U.S. Attorney's Office of the Western District of Pennsylvania's press release, Tinley pleaded guilty in federal court to a charge of intentional damage to a **protected computer**. He allegedly planted logic bombs in the spreadsheet. The logic bombs were timed to go off periodically, creating glitches that would require the company to call Tinley to fix the problem.
- Logic bombs are not new. In June 2006, Roger Duronio, a system administrator for the Swiss bank UBS, was charged with using a logic bomb to damage the company's computer network. His plan was to drive the company stock down due to damage from the logic bomb; thus, he was charged with securities fraud. Duronio was later convicted and sentenced to 8 years and 1 month in prison, as well as \$3.1 million in restitution to UBS.

How Does This Crime Affect Forensics?

Logic bombs that are created by disgruntled employees are actually reasonably straightforward to investigate. First, the nature of the logic bomb gives some indication of the creator. It has to be someone with access to the system and with a programming background. Then, traditional issues such as motive are also helpful in investigating a logic bomb. If the logic bomb is distributed randomly via a Trojan horse, then investigating it follows the same parameters as investigating a virus.

Cyberterrorism

You cannot discuss cybercrime without having some discussion of cyberterrorism. Just a few years ago, the idea of cyberterrorism seemed completely hypothetical, perhaps even a bit sensationalist. Now, however, cyberterrorism is seen by many to surpass terrorism as a threat. There are definite reasons to take it seriously:

- In 2008 and 2009, there were several reports of attacks that were traced back to North Korea or China. Given that both nations are totalitarian regimes with very strict control on their populace, it is difficult to believe that the governments of those countries were not at least aware of those attacks.
- In December 2009, hackers broke into computer systems and stole secret defense plans of the United States and South Korea. The information stolen included a summary of plans for military operations by South Korean and U.S. troops in case of war with North Korea, though the attacks were traced back to a Chinese IP address.
- In December 2010, a group calling itself the Pakistan Cyber Army hacked the website of India's top investigating agency, the Central Bureau of Investigation (CBI).
- In March 2013, a cadre of the United States' top intelligence officials told Congress that cyberattacks led the numerous national security threats the United States faces. It is the first time since the September 11, 2001, terrorist attacks that anything other than an extremist physical threat has been the top concern in the Intelligence Community Worldwide Threat Assessment, which is presented annually to the Senate Select Committee on Intelligence. James Clapper, director of national intelligence at the time, told the panel that cyber and financial threats were being added "to the list of weapons being used against us." They help define a new "soft" kind of war.
- In 2015, 19-year-old hacker Ardit Ferizi was convicted of supplying the Islamic State insurgency (ISIS) with the data of 1300 U.S. military personnel and government personnel so they could be targeted for attacks.

In 2020, many sources began expressing concern over cyberattacks on their nations' power grids. According to the North American Electric Reliability Corporation (NERC), another type of cyberattack on power grids involves exploiting vulnerabilities in firewall firmware. Such an attack happened in 2019 and caused communication outages between the control center and generation sites. These cases clearly illustrate that cyberterrorism and cyberespionage are real threats that need to be examined and dealt with.

A critical topic in cyberterrorism is the subject of the China Eagle Union. This group consists of several thousand Chinese hackers whose stated goal is to infiltrate Western computer systems. There are a number of web resources regarding this group:

- <http://www.thedarkvisitor.com/2007/10/china-eagle-union/>
- <https://news.hitb.org/node/6164>
- <http://archives.cnn.com/2001/WORLD/asiapcf/east/04/27/china.hackers/index.html>

Members and leaders of the group insist that not only does the Chinese government have no involvement in their activities, but that they are breaking Chinese law and are in constant danger of arrest and imprisonment. However, most analysts believe this group is working with the full knowledge and support of the Chinese government. Throughout the first quarter of 2013, accusations of cyberattacks were leveled by both the U.S. and Chinese governments.



NOTE

Even at the time of this writing, the news was filled with more stories of the United States and China accusing each other of cyberespionage and warfare. It is clear that there is now a significant cyber component to any international conflict. This makes computer security an issue of national security.

How Does This Crime Affect Forensics?

Because cyberterrorism and cyberespionage use the same techniques as any other cybercrime, the actual technical portions of the investigation are the same. If it is a virus or DoS attack, you investigate it as you would any virus or DoS attack. However, the difference lies in the jurisdiction for the crime itself. Issues of cyberterrorism and cyberespionage are referred to the FBI.

CHAPTER SUMMARY

This chapter examined various ways in which the nature of a computer crime can affect the process of forensically investigating the crime. It is imperative that you be aware of the different crimes and how to investigate them. For example, seeking email evidence would be useful for investigating cyberstalking, but would not be useful for most DoS attacks. It is important that forensic investigators have a working knowledge of how these attacks are committed in order to properly investigate them.

KEY CONCEPTS AND TERMS

Cyberstalking

Denial-of-service (DoS) attack

Distributed denial-of-service (DDoS) attack

Fraud

Identity theft

Logic bomb

Rainbow table

Three-way handshake

Virus

CHAPTER 2 ASSESSMENT

1. When investigating a virus, what is the first step?
 - A. Check firewall logs.
 - B. Check IDS logs.
 - C. Document the virus.
 - D. Trace the origin of the virus.
2. Which of the following crimes is most likely to leave email evidence?
 - A. Cyberstalking
 - B. DoS
 - C. Logic bomb
 - D. Fraud
3. Where would you seek evidence that Ophcrack had been used on a Windows Server 2008 machine?
 - A. In the logs of the server; look for the reboot of the system
 - B. In the logs of the server; look for the loading of a CD
 - C. In the firewall logs
 - D. In the IDS logs
4. Logic bombs are often perpetrated by _____.
 - A. identity thieves
 - B. disgruntled employees
 - C. terrorists
 - D. hackers
5. Spyware is legal.
 - A. True
 - B. False
6. It is legal for employers to monitor work computers.
 - A. True
 - B. False

7. What is the primary reason to take cyberstalking seriously?
 - A. It can damage your system.
 - B. It can be annoying and distracting.
 - C. It can be a prelude to real-world violence.
 - D. It can be part of identity theft.
8. What is the starting point for investigating denial-of-service attacks?
 - A. Firewall logs
 - B. Email headers
 - C. System logs
 - D. Tracing the packets



CHAPTER 3

Forensic Methods and Labs

© phyZick/Shutterstock

IN THIS CHAPTER, YOU WILL LEARN SOME SPECIFIC APPROACHES to forensic investigation. These methodologies provide a framework for your investigations. You will also learn the requirements for setting up a computer forensics lab. Finally, you will get a brief introduction to major computer forensics software.

Chapter 3 Topics

This chapter covers the following topics and concepts:

- The methodologies used in forensic investigations
- Formal forensic approaches
- Proper documentation of methodologies and findings
- Evidence-handling tasks
- How to set up a forensics lab
- Common forensics software programs
- Common forensics certifications

Chapter 3 Goals

When you complete this chapter, you will be able to:

- Understand major forensic methodologies
- Set up a computer forensics lab
- Demonstrate an understanding of major forensics software

Forensic Methodologies

You will learn very specific techniques for computer forensics; however, it is important that you have a general framework for approaching forensics. This section examines general principles and specific methodologies you can apply to your own forensic investigations. First, here are some basic principles to consider.

Handle Original Data as Little as Possible

A forensics specialist should touch the original data as little as possible. Instead, information should be copied prior to examination. This means that the first step in any investigation is to make a copy of the suspected storage device. In the case of computer hard drives, you make a complete copy. That means a bit-level copy. Tools like EnCase, Forensic Toolkit, and OSForensics will do this for you; it is also possible to do this with basic Linux commands. In addition, it is a common practice to make two copies of the drive. This gives you one to work with and a backup in the event you need it.

The idea of handling original information as little as possible is a critical philosophy that should permeate your approach to forensics. But the real question is, why? Why is it so important that you not touch the actual original evidence any more than you have to? The first answer to that question is that each time you touch digital information, there is some chance of altering it. Even such a simple thing as changing the time/date stamp on a file is altering it. And if you alter the file, you cannot be certain that the evidence you find is valid.

Another reason is that there may be a need for another investigator to do his or her own examination. If you have worked with the original information, you may have altered it so that another person cannot now do a fresh analysis. There are many situations in which another examiner will need to review the original information. The most obvious situation is when the opposing counsel hires his or her own expert who wants to do his or her own examination.

This stems from a principle known in forensics as **Locard's principle of transference**. Edmond Locard was a pioneer in forensics. While he dealt with physical forensics (hair, blood, and so on) and lived long before the advent of the computer age, his concepts are still applicable. Essentially, he stated that you cannot interact in an environment without leaving some trace. This is true in computers. For example, the moment you log into a Windows system, you have changed a few Windows Registry keys, added to the log, and changed a few temp files.

There are times when live forensics may be needed. However, that is always a secondary choice. The preference is to work with an image of a drive, rather than the actual drive. If you must work with a live system, your report should explain why. One common place for live forensics is when you must extract evidence from cloud storage. It simply is not practical to image an entire cloud.

Comply with the Rules of Evidence

During an investigation, a forensics specialist should keep in mind the relevant rules of evidence. The chain of custody and the Daubert standard, for instance, are just two of these that you must follow.

Rules of evidence govern whether, when, how, and why proof of a legal case can be placed before a judge or jury. A forensics specialist should have a good understanding of the rules of evidence in the given type of court and jurisdiction.

As one example, the Federal Rules of Evidence (FRE) is a code of evidence law. The FRE governs the admission of facts by which parties in the U.S. federal court system may prove their cases. The FRE provides guidelines for the authentication and identification of evidence for admissibility under Rules 901 and 902. The following is an excerpt from Rule 901 of the FRE from Cornell University Law School (2011) with the portions relevant to computer forensics shown:

(a) In General. To satisfy the requirement of authenticating or identifying an item of evidence, the proponent must produce evidence sufficient to support a finding that the item is what the proponent claims it is....

(1) Testimony of a Witness with Knowledge. Testimony that an item is what it is claimed to be....

(3) Comparison by an Expert Witness or the Trier of Fact. A comparison with an authenticated specimen by an expert witness or the trier of fact....

(9) Evidence About a Process or System. Evidence describing a process or system and showing that it produces an accurate result.¹

Item 1 refers to expert testimony. You as a forensic examiner may be called upon to authenticate evidence. Item 3 refers to a comparison between a given specimen and another item. This can be used to authenticate evidence. Item 9 is critical for computer forensics. Even if you use automated tools such as EnCase from Guidance Software or Forensic Toolkit from AccessData, you should understand how the tools work in detail so you can authenticate the process if necessary.

In Chapter 1, you were introduced to Federal Rule 702, which defines what constitutes an expert witness. There are other, related rules of which you should be aware.

Rule 703 discusses the bases of an expert opinion. Rule 703 states that an expert

may base an opinion on facts or data in the case that the expert has been made aware of or personally observed. If experts in the particular field would reasonably rely on those kinds of facts or data in forming an opinion on the subject, they need not be admissible for the opinion to be admitted. But if the facts or data would otherwise be inadmissible, the proponent of the opinion may disclose them to the jury only if their probative value in helping the jury evaluate the opinion substantially outweighs their prejudicial effect.²

Rule 705 states that, “unless the court orders otherwise, an expert may state an opinion—and give the reasons for it—without first testifying to the underlying facts or data. But the expert may be required to disclose those facts or data on cross-examination.”³ Now, this does not mean the expert does not have to have a reason for the opinion. In fact, you can rest assured that opposing counsel will probe this reasoning in some detail. The rule simply states you can give your opinion without *first* providing the reasons for it.

Individual jurisdictions may have some additional rules particular to that jurisdiction. It is critical that you be aware of the rules in your jurisdiction as well as general rules of evidence.

Avoid Exceeding Your Knowledge

A forensics specialist should not undertake an examination that is beyond his or her current level of knowledge and skill. This might seem obvious, but it is a problem that you can observe not just in forensics, but in the IT industry in general. Most other professions are more than happy to refer a client to a specialist. For example, if you see your family doctor and she discovers an anomaly regarding your heart, she will refer you to a cardiologist. Certainly she studied cardiology in medical school, but she will still send you to someone who specializes in cardiology. However, IT professionals all too often believe that if they have a little knowledge, that is enough to proceed.

FYI

In the field of forensics, your reputation is the most important thing you have. If you overextend beyond your actual skills, it is likely to come out at trial. The opposing side might have experts advising them—and when the other side’s attorney cross-examines you, and your lack of knowledge becomes apparent, your reputation will be damaged. Consider adopting this standard: *Never testify or write an expert report unless you are very sure of your expertise in the relevant technologies and very comfortable with the conclusions you are presenting.* Even one occasion of being found to have been exaggerating, fabricating, or overextending yourself during testimony can ruin your reputation and your career.

This can be very problematic in forensics. Suppose you are a very skilled forensic examiner, and you have extensive experience with Microsoft Windows and Linux. But a computer is brought to you that runs Mac OS. Now, it is very likely that your skills would allow you to extract data. And it is true that Mac OS is based on a Linux-like system (FreeBSD). But is that enough? Very likely, it is not. It is also very likely that if you insist on doing the investigation yourself, you may miss key evidence—or at the very least, the opposition’s attorney can claim in court that you have.

These basic principles should guide your forensic investigation. These are not specific procedures, but rather general philosophical approaches to investigation. It may seem that this point is being overstated, but there are numerous instances of expert witnesses going well beyond their actual skills. Here is one such story from the Expert Witness Institute:

My worst experience with an expert witness concerned a misdiagnosis of precancerous cells in the uterus. All went well on direct examination. However, during cross-examination my expert had testified that one of the things he did to prepare for his testimony was to “google” the condition that was the subject of the entire lawsuit. Let’s just say the defense attorney had a ball with him after that and my expert lost all credibility with the jury. That is one of the worst things an expert witness can say on the stand because the judge reminds the jurors not look up the medical conditions at issue in the case on Google or on the internet—one of the reasons being that there is a lot of wrong information on the web. I had prepared that expert witness for days leading up to the trial, but did not take it upon myself to advise him not to discuss “google” or the internet. Ever since that experience, I specifically advise my experts to never mention Google or the internet when discussing how the expert prepared for his or her testimony. You would think this is obvious, but my experience proved otherwise. Experts, no matter how experienced, need to be properly prepared with respect to every single aspect of their testimony, even the most obvious aspects.⁴

If the witness had true expertise in this area, he would not have needed to “google” information on it. That is what a layperson does when curious about a topic.

Create an Analysis Plan

Before you begin any forensic examination, you should have an analysis plan. This plan is a guide for your work. How will you gather evidence? Are there concerns about evidence being changed or destroyed? What tools are most appropriate for this specific investigation? Is this a federal or state case? Will this affect admissibility rules? You should address all of these issues in your data analysis plan. It is advisable to have a standard data analysis plan that you simply customize for specific situations.

Creating an Order of Volatility

Much of the evidence on a system does not last very long. Some evidence resides in storage that requires a consistent power supply. *Volatility* refers to how easy it is for data to change. Registers are very volatile, whereas a CD-ROM is not. Other evidence might sit in media locations that are continuously changing. You must start with collecting the most volatile evidence and proceed to the least volatile. To determine what evidence to collect first, draw up an order of volatility—a list of evidence sources ordered by their relative volatility. The following is an example of an order of volatility:

1. Registers and cache
2. Routing tables
3. ARP cache

4. Process table
5. Kernel statistics and modules
6. Main memory
7. Temporary file systems
8. Secondary memory
9. Router configuration
10. Network topology

The standards document, RFC 3227, presents guidelines for evidence collection and archiving.⁵ These are not regulatory requirements, but rather suggested guidelines. This exact order may not be applicable to every investigation.

- volatile data
- file slack
- file system
- registry
- memory dumps
- system state backup
- internet traces

Technical Information Collection Considerations

System forensics specialists must keep in mind three main technical data collection considerations. These are understanding the life span of information, collecting information quickly, and collecting bit-level information.

Considering the Life Span of Information

In planning collection efforts, a forensics specialist must be aware that information has a life span. **Life span** refers to how long information is valid. The term is related to volatility. More volatile information tends to have a shorter life span. The nature of the information as well as organizational policies and practices determine the information's life span. For example, data regarding network traffic and the messages themselves may exist only for the time the transmission is passing through a router. This may be only milliseconds. Information stored in computer memory, such as the complete packet, may have a life span of 1 millisecond. Or, in the case of a cached IP address, the life span may last 20 minutes. In either case, memory is volatile because it lasts only for as long as the device is powered, so the forensics specialist must act accordingly.

As information life spans increase, the life span determinant is typically related to organizational practice. For example, an organization may establish an "email retention" policy that an email message may be stored within the email system for only 30 days. After 30 days, any message that is not moved to alternate storage is deleted. Log files may be retained for months or years, in accordance with an organization's audit policy.

Finance and accounting information may have a multiple-year life span that corresponds with requirements established by state or federal governments.

In planning a collection effort, forensics specialists must be aware of the life span of the information with which they are working. They must use collection techniques appropriate to the information's life span.

Collecting Information Quickly

Once the collection effort is announced or in process, it is important to collect the evidence as quickly as possible. It is frequently not possible or practical to determine who made a change or when. In addition, the target of an investigation may try to conceal information, which further obscures changes. Networking systems also increase the potential for unauthorized changes. The person making a change on a network does not have to be local to the device on which the information is stored.

Collecting Bit-Level Information

To be useful, 1 and 0 bits must be converted through hardware and software into text, pictures, screen displays, videos, audio, or other usable formats. Investigators also look for whether unrelated bits were inserted, such as trade secrets buried within other files. Forensics specialists must therefore have tools that allow manipulation and evaluation of bit-level information. Use of bit-level tools also enables an investigator to reconstruct file fragments if files have been deleted or overwritten.

Basically, **bit-level information** is information at the level of actual 1s and 0s stored in memory or on the storage device, as opposed to going through the file system's interpretation. Whatever operating system is being used simply shows its representation of the data. Going to a bit-level view gives the most accurate view of how the information is actually stored on the hardware. If you use the file system to copy a suspect drive, you probably won't get slack space or hidden partitions. But you will get those items with a bit-level copy.

Formal Forensic Approaches

Several organizations have established formal guidelines for approaching a forensic investigation. You should become familiar with these guidelines. Depending on your work environment, you might implement one of these or use one of these as a base and adjust it to your own plan.

DoD Forensic Standards

The U.S. Department of Defense (DoD) coordinates and supervises agencies and functions of the government related to national security and the U.S. armed forces. The DoD uses system forensics to evaluate and examine data related to cyberattacks. The DoD estimates the potential impact of malicious activity. It also assesses the intent and identity of perpetrators. The DoD Cyber Crime Center (DC3) sets standards for digital evidence processing, analysis, and diagnostics. DC3 is involved with DoD investigations that require computer forensics support to detect, enhance, or recover digital media. DC3 is also involved in criminal law enforcement forensics and counterintelligence. It assists in criminal, counterintelligence, counterterrorism, and fraud investigations. In addition, it supports safety investigations, commander-directed inquiries, and inspector-general investigations.

DC3 provides computer investigation training. It trains forensics examiners, investigators, system administrators, and others. It also ensures that defense information systems are secure from unauthorized use, criminal and fraudulent activities, and foreign intelligence service exploitation. DC3 partners with government, academic, and private industry computer security officials. For more information on DC3, see <http://www.dc3.mil>.

The DFRWS Framework

The Digital Forensic Research Workshop (DFRWS) is a nonprofit volunteer organization. Its goal is to enhance the sharing of knowledge and ideas about digital forensics research. DFRWS sponsors annual conferences, technical working groups, and challenges to help drive the direction of research and development. In 2001, the DFRWS developed a framework for digital investigation that is still applicable and followed. The DFRWS framework is a matrix with six classes:

- Identification
- Preservation
- Collection
- Examination
- Analysis

- Presentation

The SWGDE Framework

The Scientific Working Group on Digital Evidence (SWGDE) promotes a framework process that includes four stages. The stages are:

- Collect
- Preserve
- Examine
- Transfer

That final step means any sort of transfer—even moving evidence from the lab to a court or returning evidence when no longer needed.

FYI

Although all forensic methodologies and texts recommend you make a copy of the suspect drive to work with, you may want to consider actually making two copies—each with a different imaging tool. Then, if time permits, use different tools on each copy. If both copies, made with different tools and examined with different tools, yield the same evidentiary results, that is a very powerful indication that the evidence is accurate. It would be exceedingly difficult for opposing counsel to find an issue with your examination.

An Event-Based Digital Forensics Investigation Framework

In 2004, Brian Carrier and Eugene Spafford, researchers at the Center for Education and Research in Information Assurance and Security (CERIAS) at Purdue University, proposed a model that is more intuitive and flexible than the DFRWS framework.

This model has five primary phases, each of which may contain additional subphases. The primary phases are the Readiness phase, the Deployment phase, the Physical Crime Scene Investigation phase, the Digital Crime Scene Investigation phase, and the Presentation phase. The Readiness phase contains the Operations Readiness subphase, which involves training people and testing investigation tools, and the Infrastructure Readiness subphase, which involves configuring the equipment. The Deployment phase includes the Detection and Notification subphase, in which someone detects an incident and alerts investigators, and the Confirmation and Authorization subphase, in which investigators receive authorization to conduct the investigation.

Documentation of Methodologies and Findings

Documentation of forensic processing methodologies and findings is critical. Without proper documentation, a forensics specialist has difficulty presenting findings. When security or audit findings become the object of a lawsuit or a criminal investigation, the legal system requires proper documentation. Without documentation, courts are unlikely to accept investigative results. Thus, a system forensics specialist must know the ins and outs of computer evidence processing methodology. This methodology includes strong evidence-processing documentation and good chain-of-custody procedures.

Disk Structure

A system forensics specialist should have a good understanding of how computer hard disks, flash drives, and compact discs (CDs) are structured. A specialist should also know how to find data hidden in obscure places on CDs and hard disk drives. In fact, as technology progresses, it will be important for the digital forensics examiner to be familiar with any sort of media in common use. This is also an area wherein one might have to use multiple tools to get at the data.

File Slack Searching

A system forensics specialist should understand techniques and automated tools used to capture and evaluate file slack. A hard disk or CD is segmented into clusters of a particular size. Each cluster can hold only a single file or part of a single file. If you write a 1-kilobyte (KB) file to a disk that has a cluster size of 4 KB, the last 3 KB of the cluster are wasted. This unused space between the logical end of file and the physical end of file is known as **file slack** or **slack space**.

Most computer users have no idea that they're creating slack space as they use a computer. In addition, pieces of a file may remain even after you delete it. This residual information in file slack is not necessarily overwritten when you create a new file. File slack is therefore a source of potential security leaks involving passwords, network logins, email, database entries, images, and word processing documents. A forensics specialist should know how to search file slack, identify what information is or is not useful, and document any findings.

Evidence-Handling Tasks

A system forensics specialist has three basic tasks related to handling evidence:

- **Find evidence**—Gathering computer evidence goes beyond normal data recovery. Finding and isolating evidence to prove or disprove allegations can be difficult. Investigators may need to investigate thousands of active files and fragments of deleted files to find just one that makes a case. System forensics has therefore been described as looking for one needle in a mountain of needles. Examiners often work in secure laboratories where they check for viruses in suspect machines and isolate data to avoid contamination.
- **Preserve evidence**—Preserving computer evidence is important because data can be destroyed easily. The 1s and 0s that make up data can be hidden and vanish instantly with the push of a button. As a result, forensic examiners should assume that every computer has been rigged to destroy evidence. They must proceed with care in handling computers and storage media.
- **Prepare evidence**—Evidence must be able to withstand judicial scrutiny. Therefore, preparing evidence requires patience and thorough documentation. Failing to document where evidence comes from and failing to ensure that it has not been changed can ruin a case. Judges have dismissed cases because of such failures.

Evidence-Gathering Measures

Here are principles to use when you gather evidence:

- **Avoid changing the evidence**—Photograph equipment in place as you find it before you remove it. Label wires and sockets so that you can put everything back as it was once you get computers and other equipment into your lab. Transport items carefully and avoid touching hard disks or CDs. Make exact, bit-by-bit copies and store them on a medium such as a write-once CD.
- **Determine when evidence was created**—You should create timelines of computer usage and file accesses. This can be difficult, because there are so many ways to falsify data. But timelines can make or break a case.
- **Trust only physical evidence**—The 1s and 0s of data are recorded at the physical

level of magnetic materials. This is what counts in system forensics. Other items may be corrupt.

- **Search throughout a device**—You need to search at this level of 1s and 0s across a wide range of areas inside a computer.
- **Present the evidence well**—Forensic examiners must present computer evidence in a logical, compelling, and persuasive manner. A jury must be able to understand the evidence. In addition, the evidence should be solid enough that a defense counsel cannot rebut it.

Expert Reports

An expert report is a formal document that details the expert's findings. Often this document is filed in a case prior to trial. If there are depositions, then the expert report will probably be used as the basis for some of the questions you are asked during deposition. When writing an expert report, you should consider several issues. An expert report will always be needed in civil cases, but may or may not be required in criminal cases. When you do need to write an expert report, it is critical that you do so properly.

The first issue is the format of the report. You usually list all items, documents, and evidence you considered. You also detail tests you performed, analysis done, and your conclusion. You should list your entire curriculum vitae (CV)—an extensive document detailing your experience and qualifications for a position—in an appendix. Keep in mind that a CV is much more thorough than a résumé. You should list every publication, award, or credential you have earned. A CV should also include more detail on work history and educational history.

Another issue for your report is thoroughness. In most jurisdictions, if it is not in your report, you are not allowed to testify about it at trial. So be very thorough. Anything you leave out may become a problem at trial. It is critical that you be detailed in what you write and that you document all the analysis done. For example, if you performed three tests and all three support a specific conclusion, make sure you list all three tests. If you list just one, then that is the only test you can testify about at trial.

Finally, back up everything you say. Clearly, you are an expert in forensics or else you would not be asked to testify. But remember that there is an opposing counsel whose job it is to disagree with you. The opposing counsel may have his or her own expert who will testify to different conclusions. It's good to have well-respected references to support any important claims you make. This way, it is not just your opinion, but rather your opinion along with the support of multiple credible sources. I recommend your report be replete with citations from reputable sources—but ensure that you actually *read* those sources. The opposing counsel will. By citing them, you are making a statement that you agree with them, so be careful in selecting your sources.

How to Set Up a Forensics Lab

The detailed specifics of any given lab are based on the needs of the lab, the budget, and the types of cases that lab is likely to handle. A state law enforcement agency with a high volume of cases has different needs from a small forensics lab that deals only with civil matters. However, some general principles apply to all labs.

Equipment

First and foremost, you must have adequate equipment for the job. Among other things, this means adequate storage for the data. Remember, you might analyze a system, but it could be months before the case goes to trial. A server with the most storage you can afford is in order. Also, that server must have redundancy. It should have a bare minimum of one redundant array of independent disks or RAID 1 (disk mirroring), but RAID 5 is recommended. And it should be backed up at least once per day. It is likely you will need multiple servers to accommodate your storage needs.

You also need a variety of computers capable of attaching various types of drives—for example, external universal serial bus (USB), internal Small Computer System Interface (SCSI), Enhanced Integrated Drive Electronics (EIDE), and Serial Advanced Technology Attachment (SATA) drives. The exact number depends on the workload expected for the lab. You should also have power connectors for all types of smartphones, laptops, routers, and other devices.

Security

Security is paramount for forensics. Above all, the machines being examined should not be connected to the internet. You can have a lab network that is not attached to the internet and is separate from your working network where you check email and use the internet. It is also important to have the lab in a room that is shielded from any electromagnetic interference. This means that cellular and wireless signals cannot penetrate the room housing the lab.

After you have established network and electronic security, physical security is the next concern. It is imperative to limit access to the lab. Allow only people with a legitimate need to enter the lab. It is recommended that the lab entrance have some sort of electronic method of recording who enters and when they enter. Swipe-card access is ideal for this. Furthermore, the room itself should be difficult to forcibly access. That means the windows and doors are very secure and would be extremely difficult to force open.

The lab also requires the means to secure evidence when it is not being used. An evidence safe is the best way to do this. The safe should be highly fire resistant as well, so that in case of fire, the evidence is preserved.

In addition to the general guidelines already listed, you should consider various

international standards that are published and updated by the International Organization for Standards (ISO). A few are briefly described here:

- ISO/IEC 27037:2012—Information technology—Security techniques—Guidelines for identification, collection, acquisition and preservation of digital evidence. This is one common standard for digital forensics. This standard regards forensic practices and processes, particularly for capturing forensic evidence.
- ISO/IEC 27041:2015—Information technology—Security techniques—Guidance on assuring suitability and adequacy of incident investigative method. This standard is about forensics methods and tools.
- ISO/IEC 27042:2015—Information technology—Security techniques—Guidelines for the analysis and interpretation of digital evidence. This standard provides guidance on processing and analyzing digital evidence.

The National Institute of Standards and Technology (NIST) has a Computer Forensics Tool Testing Program that is used to test forensic tools. It would be a very good idea to see if your favorite tool has been tested and found adequate.

American Society of Crime Laboratory Directors

The American Society of Crime Laboratory Directors (ASCLD) provides guidelines for managing a forensics lab. It also provides guidelines for acquiring crime lab and forensics lab certifications. The ASCLD offers voluntary accreditation to public and private crime laboratories in the United States and around the world. It certifies computer forensics labs that analyze digital evidence and other criminal evidence, such as fingerprints and DNA samples. The ASCLD/LAB certification regulates how to organize and manage crime labs. Achieving ASCLD accreditation is a rigorous process. A lab must meet about 400 criteria to achieve accreditation. Typically, an unaccredited lab needs two to three years to prepare for accreditation. It spends this time developing policies, procedures, document controls, analysis validations, and so on. Then, the lab needs another year to go through the process. The lab manager submits an application. The lead assessor and a team spend one to two months reviewing the application and the policies and procedures to make sure the lab is ready. The assessment takes about a week. The assessment team generates findings that require corrective action. The lab typically requires several months to make corrections to the satisfaction of the lead assessor. Once the facility has made all corrections, the lead assessor recommends the lab to the board of directors for accreditation. Finally, the ASCLD/LAB board of directors votes on whether to accredit the lab.

The ASCLD/LAB program includes audits to ensure that forensics specialists are performing lab procedures correctly and consistently for all casework. The society performs these audits in computer forensics labs to maintain quality and integrity. One recommendation for labs is to follow the DoD guidelines on electromagnetic radiation (EMR). The DoD shields computers to prevent would-be infiltrators from detecting them

via their EMR emission under its TEMPEST program. You can find out more about TEMPEST at <http://www.gao.gov/products/NSIAD-86-132>. Shielding all computers would be impossible because of the high cost involved. To protect high-risk investigations, however, a lab might also consider implementing TEMPEST protection.

TEMPEST certifies equipment that is built with shielding that prevents EMR release. In some cases, TEMPEST can be applied to an entire lab. Shielding a lab is an extremely high-cost approach that includes the following measures:

- Lining the walls, ceiling, floor, and doors with specially grounded, conductive metal sheets
- Installing filters that prevent power cables from transmitting computer emanations
- Installing special baffles in heating and ventilation ducts to trap emanations
- Installing line filters on telephone lines
- Installing special features at entrances and exits that prevent the facility from being open to the outside at all times

Creating and maintaining a TEMPEST-certified lab is expensive. Such a lab must be inspected and tested regularly. Only large, regional computer forensics labs that demand absolute security from eavesdropping should consider complete TEMPEST protection. For smaller facilities, use of TEMPEST-certified equipment is often a more effective approach. You can find out more about TEMPEST at <http://www.gao.gov/products/NSIAD-86-132>.

Common Forensic Software Programs

After setting up the lab and the equipment, the next thing to address is the software. Several software tools are available that you might want to use in your forensics lab. This section takes a brief look at several commonly used tools. However, this section gives extra attention to Guidance Software's EnCase and AccessData's Forensic Toolkit because these two programs are very commonly used by law enforcement.

EnCase

EnCase from Guidance Software is a very widely used forensic toolkit. This tool allows the examiner to connect an Ethernet cable or null modem cable to a suspect machine and to view the data on that machine. EnCase prevents the examiner from making any accidental changes to the suspect machine. This is important: Remember the basic principle of touching the suspect machine as little as possible. EnCase organizes information into "cases." This matches the way examiners normally examine computers. **FIGURE 3-1** shows a sample EnCase case file.

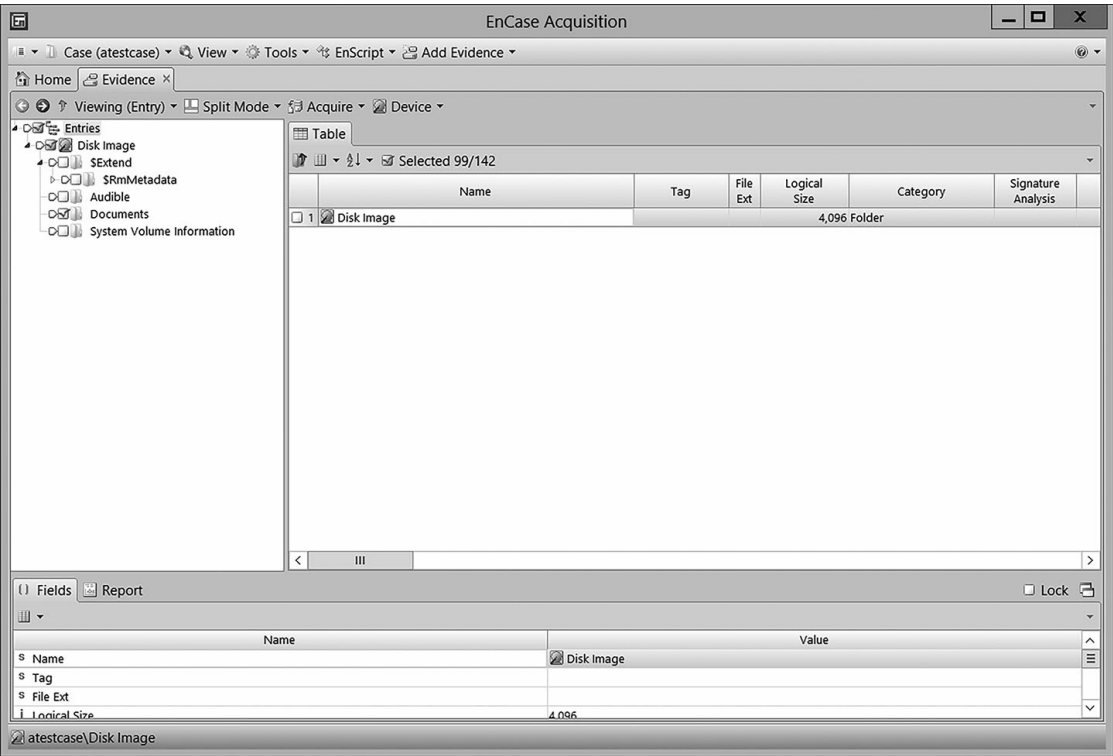


FIGURE 3-1 EnCase case file.

The EnCase concept is based on the evidence file. This file contains the header, the checksum, and the data blocks. The data blocks are the actual data copied from the suspect machine, and the checksum is done to ensure there is no error in the copying of that data and that the information is not subsequently modified. Any subsequent modification causes the new checksum to not match the original checksum. As soon as the evidence file is added to the case, EnCase begins to verify the integrity of the entire disk image. The evidence file is an exact copy of the hard drive. EnCase calculates an MD5 hash when the drive is acquired. This hash is used to check for changes, alterations, or errors. When the investigator adds the evidence file to the case, it recalculates the hash; this shows that nothing has changed since the drive was acquired.

You can use multiple methods to acquire the data from the suspect computer:

- **EnCase boot disk** is a method that boots the system to EnCase using DOS mode rather than a GUI mode. You can then copy the suspect drive to a new drive to examine it.
- **EnCase network boot disk** is very similar to the EnCase boot disk, but it allows you to perform the process over a crossover cable between the investigator's computer and the computer being investigated.
- **LinEn boot disk** is specifically for acquiring the contents of a Linux machine. It operates much like the boot disk method, but it is for target machines that are running Linux.

After you have acquired a suspect drive, you can then examine it using EnCase.

The EnCase Tree pane is like Windows Explorer. It lists all the folders and can expand any particular element in the tree (folders or subfolders). The Table pane lists the subfolders and files contained within the folder that was selected in the Tree pane. When you select an item, it is displayed in the View pane, as shown in [FIGURE 3-2](#).

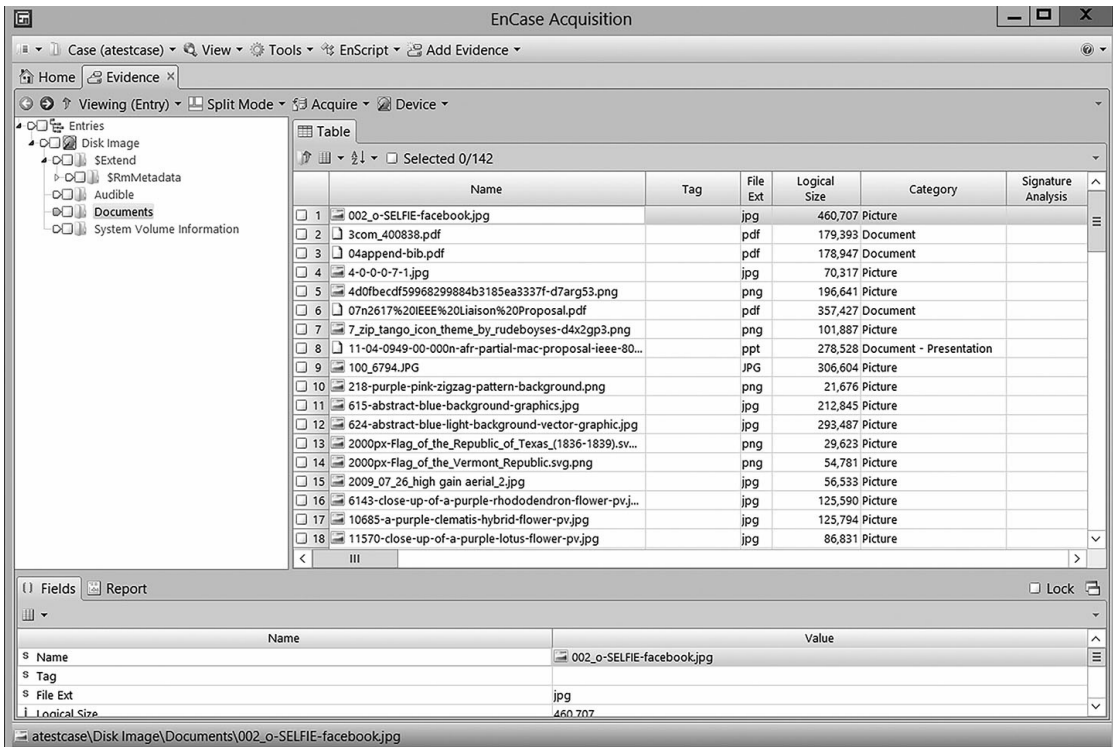


FIGURE 3-2 EnCase View pane.

EnCase allows you to filter what you view, narrowing your focus to specific items of interest. You can also search data using the EnCase Search feature, shown in [FIGURE 3-3](#).

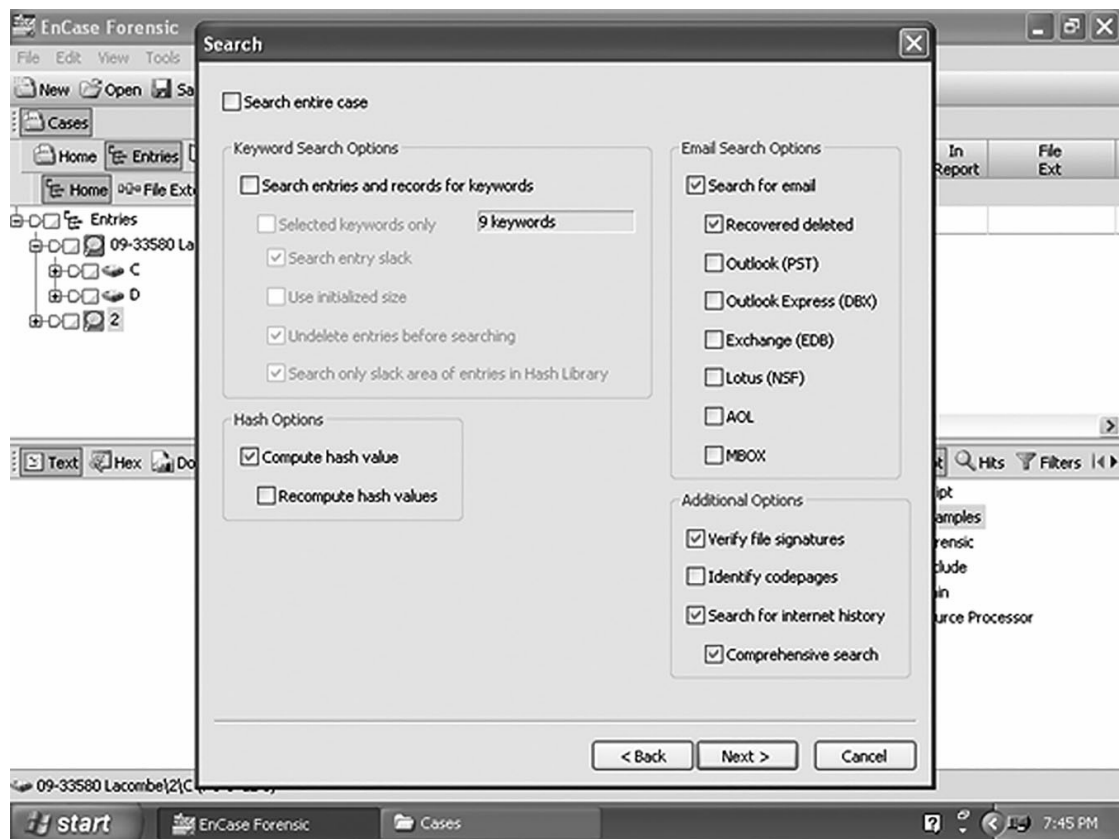


FIGURE 3-3 EnCase Search.

The Filter pane is a useful tool that can affect the data you view in the Table pane.

This is just a very brief introduction to EnCase. It is a very popular tool with law enforcement, and the vendor, Guidance Software, offers training for its product. You can visit the vendor website for more details at <http://www.guidancesoftware.com/>.

Forensic Toolkit

The Forensic Toolkit (FTK) from AccessData is another widely used forensic analysis tool that is also very popular with law enforcement. You can get additional details at the company's website, <http://accessdata.com/product-download/digital-forensics>, but this section reviews some basics of the tool.

With FTK, you can select which hash to use to verify the drive when you copy it, which features you want to use on the suspect drive, and how to search, as shown in **FIGURE 3-4**.

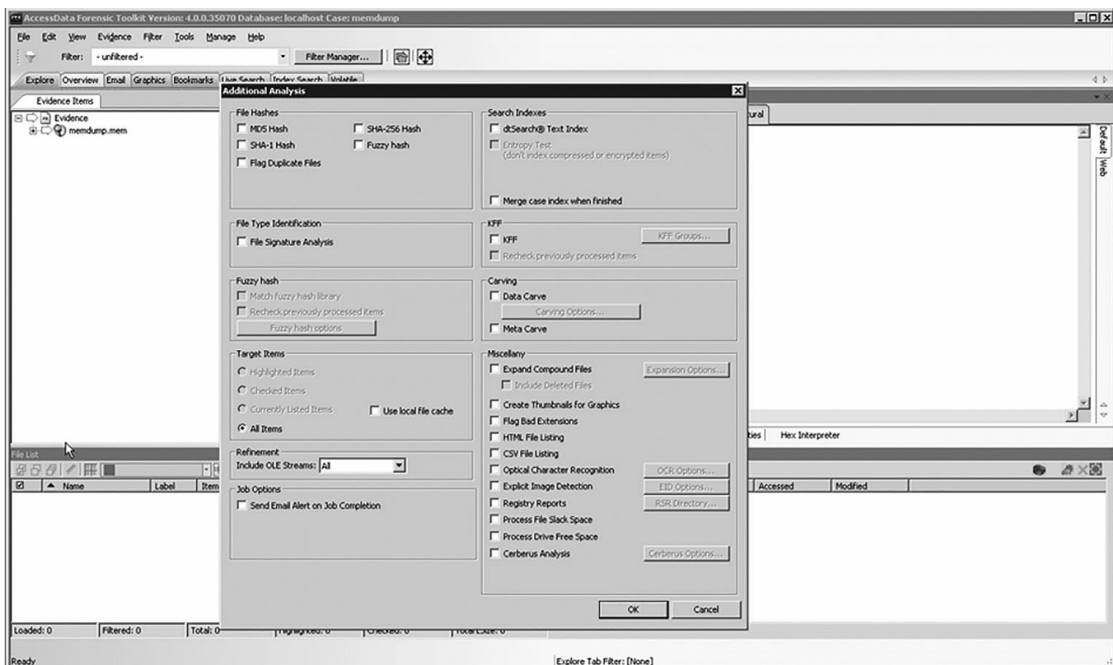


FIGURE 3-4 FTK features.

Forensic Toolkit is particularly useful at cracking passwords. For example, password-protected Portable Document Format (PDF) files, Excel spreadsheets, and other documents often contain important information. FTK also provides tools to search and analyze the Windows Registry. The Windows Registry is where Windows stores all information regarding any programs installed. This includes viruses, worms, Trojan horses, rootkits, hidden programs, and spyware. The ability to effectively and efficiently scan the Registry for evidence is critical.

FTK gives you a robust set of tools for examining email. The email can be arranged in a timeline, giving the investigator a complete view of the entire email conversation and the ability to focus on any specific item of interest, as shown in **FIGURE 3-5**.

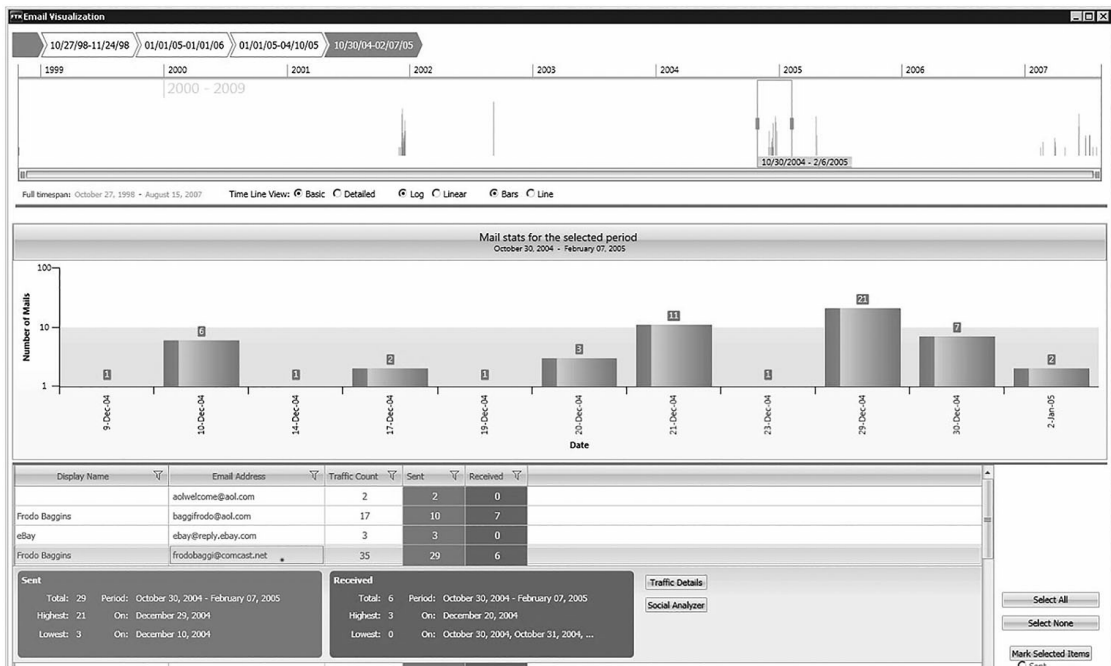


FIGURE 3-5 Email analysis.

Another feature of this toolkit is its distributed processing. Scanning an entire hard drive, searching the Registry, and doing a complete forensic analysis of a computer can be a very time-intensive task. With AccessData's Forensic Toolkit, processing and analysis can be distributed across up to three computers. This lets all three computers perform the three parts of the analysis in parallel, thus significantly speeding up the forensic process. In addition, FTK has an Explicit Image Detection add-on that automatically detects pornographic images. This is very useful in cases involving allegations of pornography and is a particularly useful tool for law enforcement. FTK is available for Windows or Mac OS.

OSForensics

The OSForensics tool from the company PassMark Software in Australia has been widely used since about 2010. One of the first attractive aspects of this tool is its cost. The full product is US\$899, which is a fraction of the cost of many other tools. There is also a fully functional 30-day trial version. Furthermore, it is very easy to use. It will do most of what EnCase and FTK will do, but lacks a few of those products' specialized features. For example, OSForensics does not have a Known File Filter, as does FTK. You will see some labs using OSForensics in this book.

Helix

Helix is a customized Linux Live CD used for computer forensics. The suspect system is booted into Linux using the Helix CDs and then the tools provided with Helix are used to perform the analysis. This product is robust and full of features, but simply has not become as popular as AccessData's FTK and Guidance Software's EnCase. For more information, check out its website at <http://www.e-fense.com/products.php>.

Kali Linux

Kali Linux (formerly called BackTrack) is a Linux Live CD that you use to boot a system and then use the tools. Kali is a free Linux distribution, making it extremely attractive to schools teaching forensics or to laboratories on a strict budget. It is not used just for forensics, however, as it offers a wide range of general security and hacking tools. In fact, it is probably the most widely used collection of security tools available.

AnaDisk Disk Analysis Tool

AnaDisk from New Technologies Incorporated (NTI) turns a PC into a sophisticated disk analysis tool. The software was originally created to meet the needs of the U.S. Treasury Department in 1991. AnaDisk scans for anomalies that identify odd formats, extra tracks, and extra sectors. It can be used to uncover sophisticated data-hiding techniques.

AnaDisk supports all DOS formats and many non-DOS formats, such as Apple Mac OS and UNIX TAR. If a disk will fit in a PC CD drive, it is likely that AnaDisk can be used to analyze it. For information on AnaDisk, see <http://www.retrocomputing.org/cgi-bin/sitewise.pl?act=det&p=776&id=retroorg>.

CopyQM Plus Disk Duplication Software

CopyQM Plus from NTI essentially turns a PC into a disk duplicator. In a single pass, it formats, copies, and verifies a disk. This capability is useful for system forensics specialists who need to preconfigure CDs for specific uses and duplicate them. In addition, CopyQM Plus can create self-extracting executable programs that can be used to duplicate specific disks. CopyQM is an ideal tool for use in security reviews because once a CopyQM disk creation program has been created, anyone can use it to make preconfigured security risk-assessment disks. When the resulting program is run, the disk image of the original disk is restored on multiple disks automatically. The disk images can also be password-protected when they are converted to self-extracting programs. This is helpful when security is a concern, such as when disks are shared over the internet. CopyQM Plus is particularly helpful in creating computer incident response toolkit disks.

CopyQM Plus supports all DOS formats and many non-DOS formats, such as Apple Mac OS and UNIX TAR. It copies files, file slack, and unallocated storage space. However, it does not copy all areas of copy-protected disks—extra sectors added to one or more tracks on a CD. AnaDisk software should be used for this purpose. For information on CopyQM Plus, see <http://vetusware.com/download/CopyQM%203.24/?id=6457>.

The Sleuth Kit

The Sleuth Kit is a collection of command-line tools that are available as a free download. You can get them from this site: <http://www.sleuthkit.org/sleuthkit/>. This toolset is neither as rich nor as easy to use as EnCase, FTK, or OSForensics but can be a good option for a budget-conscious agency. The most obvious of the utilities included is `ffind.exe`.

There are options to search for a given file or to search for only deleted versions of a file. This particular utility is best used when you know the specific file you are searching for. It is not a good option for a general search. A number of utilities are available in Sleuth Kit; however, many people find using command-line utilities to be cumbersome. Fortunately, a graphical user interface (GUI) has been created for Sleuth Kit. That GUI is named Autopsy and is available at <http://www.sleuthkit.org/autopsy/download.php>. You can see Autopsy in **FIGURE 3-6**.

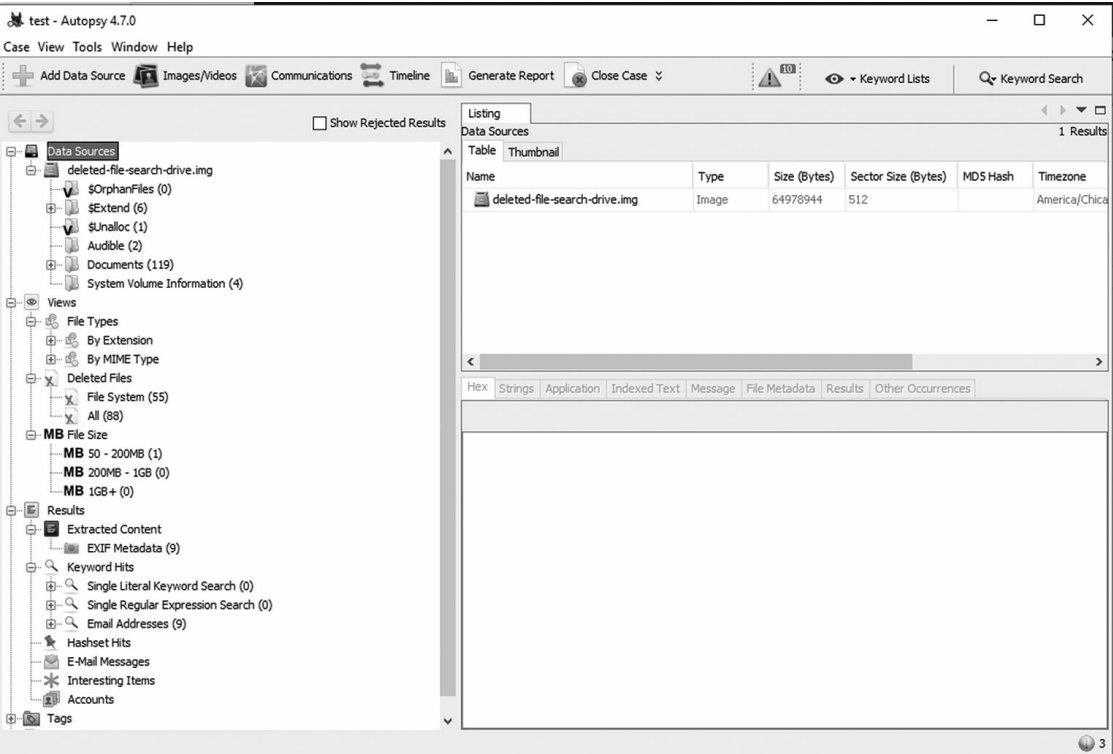


FIGURE 3-6 Autopsy.

You will see Autopsy used frequently in this book. Since this tool is a free download, it is cost effective for the reader to use. It is also worthwhile to learn Autopsy even if you have a commercial forensics toolkit. Autopsy can be a second tool used to validate the results you derive from your primary tool.

Disk Investigator

This is a free utility that comes as a GUI for use with Windows operating systems. You can download it from <http://www.theabsolute.net/sware/dskinv.html>. It is not a full-featured product like EnCase, but it is remarkably easy to use. When you first launch the utility, it presents you with a cluster-by-cluster view of your hard drive in hexadecimal form.

From the View menu, you can view directories or the root. The Tools menu allows you to search for a specific file or to recover deleted files.

Entire books could be written about the various forensic utilities available on the internet. It is a good idea for any investigator to spend some time searching the internet and experimenting with various utilities. Depending on your own skill set, technical background, and preferences, you might find one utility more suitable than another. It is also recommended that after you select a tool to use, you scan the internet for articles about that tool. Make certain that it has widespread acceptance and that there are no known issues with its use. It can also be useful to use more than one tool to search a hard drive. If multiple tools yield the same result, this can preempt any objections the opposing attorney or his or her expert may attempt to present at trial. And remember—as always—to document every single step of your investigation process.

Forensic Certifications

You have a lab, you have software, but what about personnel? When considering potential candidates, looking for candidates who have taken a forensics class is a very good first step, but you should also look for candidates who have earned industry certifications. Before looking at specific certifications, let's discuss computer certifications in general.

Certifications have always been a controversial topic. Some people swear by them and won't even interview a candidate who does not have a few. Other people are convinced they are worthless. The issue stems from a misunderstanding of what a certification means. It is not meant to certify the person as an expert or master in a specific field. But a certification would imply a person has a working knowledge comparable to that certification. It is meant to demonstrate a baseline of competence.

Think about a medical degree. Simply having an MD does not guarantee the person is a brilliant physician. It just shows that the person achieved a certain minimum skill level. There is certainly a wide variation in skills among physicians. The same thing occurs with IT certifications. There are people with the Certified Information Systems Security Professional (CISSP®) credential from the International Information Systems Security Certification Consortium (ISC)²® who are brilliant security professionals with a very deep understanding of security and a wide set of skills. There are others with that credential who are only moderately competent.

Another issue with certifications is the boot camp. These programs are usually four or five days of intense study where the materials needed to pass a certification test are crammed into the students. On the final day, when it is all still fresh in their minds, they take the relevant certification test. This does lead to many boot camp attendees forgetting everything a few months later; however, this can be seen not as a failure of the training, but rather of the student. If you attend a boot camp, it is incumbent upon you to keep your skills up after the training is over.

Regardless of your personal feelings on certifications, it is a fact that they can only help your résumé as a forensic analyst. That doesn't mean, however, that you should ever hire any IT professional based solely on certifications—they are but one part of the total résumé. A combination of the right certifications along with formal education and experience make an ideal candidate.

So what are the right certifications? Forensics is a very broad topic and requires analysts to have both a broad and deep knowledge. Some of this knowledge is obtained in a formal degree program, whereas some is obtained on the job. But anywhere you have a gap in your knowledge, or simply want to enhance your résumé, is a good place to add a certification. You need to know the following areas:

- **PC hardware**—This can be obtained in a basic hardware course at a college or via the CompTIA A+ certification.
- **Basic networking**—Most computer science–related degrees include a course in basic networking. This satisfies your needs as a forensics expert. However, you

might consider the CompTIA Network+ or the Cisco Certified Network Associate certifications.

- **Security**—You must have a general knowledge of security. This can be best demonstrated with the (ISC)² CISSP certification or the CompTIA Security+ certification.
- **Hacking**—Yes, you do need to know what the hackers know. A few certifications for this area of study exist. One is Offensive Security's test. That test requires hands-on hacking. Additionally, there are the Certified Ethical Hacker from EC Council and the Global Information Assurance Certification (GIAC) Penetration Tester (GPEN) from SANS. There are also Offensive Security certifications that are all hands-on hacking tests.

Now that you have learned about certifications in general, it's time to consider specific forensics certifications. The following sections examine two vendor certifications. Clearly, if your lab uses a specific tool, it is a good idea to have analysts who are certified in that tool. Subsequent sections explore a couple of general forensic certifications. These tests are about forensic methodologies rather than a specific tool.

EnCase Certified Examiner Certification

Guidance Software, the creator of EnCase, sponsors the EnCase Certified Examiner (EnCE) certification program. EnCE certification is open to the public and private sectors. This certification focuses on the use and mastery of system forensics analysis using EnCase. For more information on EnCE certification requirements, visit <http://www.guidancesoftware.com>.

AccessData Certified Examiner

AccessData is the creator of Forensic Toolkit (FTK). AccessData sponsors the AccessData Certified Examiner (ACE) certification program. ACE certification is open to the public and private sectors. This certification is specific to the use and mastery of FTK. Requirements for taking the ACE exam include completing the AccessData boot camp and Windows forensics courses. For more information on ACE certification, visit <http://www.accessdata.com/>.

OSForensics

OSForensics also has a certification test. This test covers a few basics of forensic methodology, but focuses on the use of the OSForensics tool. This certification does not have specific educational requirements. You can take an online course, self-study, or take

an in-person course. For more information, visit <http://www.osforensics.com/>.

EC Council Certified Hacking Forensic Investigator

The EC Council Certified Hacking Forensic Investigator (CHFI) certification is a good general forensics certification. EC Council is more widely known for its Certified Ethical Hacker test, but its forensics test is a solid choice. It covers the general principles and techniques of forensics rather than specific tools like EnCase or FTK. This is a good starting point for learning forensics. You can learn more at its website at <http://www.eccouncil.org/Computer-Hacking-Forensic-Investigator/index.html>.

GIAC Certifications

The Global Information Assurance Certification (GIAC) certifications are well respected in the IT industry. They include security, hacking, and forensic certifications. GIAC provides several levels of certification, beginning with the GIAC Certified Forensic Analyst (GCFA) and culminating with the GIAC Certified Forensic Examiner (GCFE). You can learn more about its certifications at the GIAC website at <http://www.giac.org/certified-forensic-analyst-gcfa>.

CHAPTER SUMMARY

This chapter provided an overview of the forensic process. You examined general concepts as well as specific forensics frameworks. It is important that you fully understand these concepts before you move forward.

The chapter also looked at some widely used forensic tools. Even if you already have a tool that you prefer to use or that is mandated at your lab, it is worthwhile for you to at least have a basic familiarity with other forensic tools that are available. Kali Linux, in particular, is a tool you should become familiar with because it is free to use.

KEY CONCEPTS AND TERMS

Bit-level information

File slack

Life span

Locard's principle of transference

Rules of evidence

Slack space

CHAPTER 3 ASSESSMENT

1. To preserve digital evidence, an investigator should _____.
 - A. make two copies of each evidence item using a single imaging tool
 - B. make a single copy of each evidence item using an approved imaging tool
 - C. make two copies of each evidence item using different imaging tools
 - D. store only the original evidence item
2. Bob was asked to make a copy of all the evidence from the compromised system. Melanie did a DOS copy of all the files on the system. What would be the primary reason for you to recommend for or against using a disk-imaging tool?
 - A. A disk-imaging tool would check for internal self-checking and validation and have an MD5 checksum.
 - B. The evidence file format will contain case data entered by the examiner and encrypted at the beginning of the evidence file.
 - C. A simple DOS copy will not include deleted files, file slack, and other information.
 - D. There is no case for an imaging tool because it will use a closed, proprietary format that if compared with the original will not match up sector for sector.
3. It takes _____ occurrence(s) of overextending yourself during testimony to ruin your reputation.
 - A. only one (if it is a major case)
 - B. several
 - C. only one
 - D. at least two
4. The MD5 message-digest algorithm is used to _____.
 - A. wipe magnetic media before recycling it
 - B. make directories on an evidence disk
 - C. view graphics files on an evidence drive
 - D. hash a disk to verify that a disk is not altered when you examine it
5. You should make at least two bitstream copies of a suspect drive.
 - A. True

B. False

6. What is the purpose of hashing a copy of a suspect drive?

A. To make it secure

B. To remove viruses

C. To check for changes

D. To render it read-only

7. What is the most important reason that you not touch the actual original evidence any more than you have to?

A. Each time you touch digital data, there is some chance of altering it.

B. You might be accused of planting evidence.

C. You might accidentally decrypt files.

D. It can lead to data degradation.

References

1. Cornell Law School Legal Information Institute. (n.d.). Rule 901. Testimony by Expert Witness. Retrieved from https://www.law.cornell.edu/rules/fre/rule_901 on January 27, 2021.
2. Cornell Law School Legal Information Institute. (n.d.). Rule 703. Bases of an Expert. Retrieved from https://www.law.cornell.edu/rules/fre/rule_703 on January 27, 2021.
3. Cornell Law School Legal Information Institute. (n.d.). Rule 705. Disclosing the Facts or Data Underlying an Expert. Retrieved from https://www.law.cornell.edu/rules/fre/rule_705 on January 27, 2021.
4. Rahman, M. (2020). 15 attorneys share their expert witness horror stories. Expert Institute: Working with Experts [blog]. Retrieved from <https://www.expertinstitute.com/resources/insights/15-attorneys-share-their-expert-witness-horror-stories/> on January 29, 2021.
5. Internet Society Network Working Group. (2002). Guidelines for evidence collection and archiving. Retrieved from <https://tools.ietf.org/html/rfc3227> on January 29, 2021.



PART II

Forensics Tools, Techniques, and Methods

© phyZick/Shutterstock

CHAPTER 4 Collecting, Seizing, and Protecting Evidence

CHAPTER 5 Understanding Techniques for Hiding and Scrambling Information

CHAPTER 6 Recovering Data

CHAPTER 7 Incident Response



CHAPTER 4

Collecting, Seizing, and Protecting Evidence

© phyZick/Shutterstock

In this chapter, you see specific and practical steps that must be taken when seizing evidence, imaging drives, and preparing suspect drives for analysis. You are also introduced to some concepts such as forensic file formats.

Chapter 4 Topics

This chapter covers the following topics and concepts:

- Using proper forensic procedure
- Handling evidence appropriately
- Different storage formats
- The process of forensically imaging a drive
- Acquiring RAID

Chapter 4 Goals

When you complete this chapter, you will be able to:

- Properly seize a suspect computer
- Prepare that computer for forensic examination
- Understand the various storage formats
- Image a drive
- Acquire RAID drives

Proper Procedure

It is important to follow proper procedure when examining a suspect machine. This chapter covers specific details on the proper procedure to follow when collecting, seizing, and protecting evidence.

Shutting Down the Computer

At one time, it was recommended that the investigator shut down the computer as a first step. However, it soon became apparent that one could lose valuable evidence found in running processes or memory. It also may be the case that the computer is using hard drive encryption. If you simply shut the system down, you may not be able to get back into the system. Before you shut the system down, at a minimum, you need to see what is currently running on the computer. Remember, you want to touch it as little as possible, so it is important to be careful. But you do need to find out if someone is currently accessing the computer—or if there is malware running on the computer—before you shut it down. Although the specifics may vary depending on the installed operating system, this section focuses on Windows because it is the most common desktop operating system.

The first thing to do is to check for running processes. In Windows (all versions), you press the Ctrl+Alt+Delete keys simultaneously, then select Task Manager. The Task Manager window opens; select the Processes tab. The Windows 10 version of this is shown in **FIGURE 4-1**. You should note that this looks much the same in Windows Server.

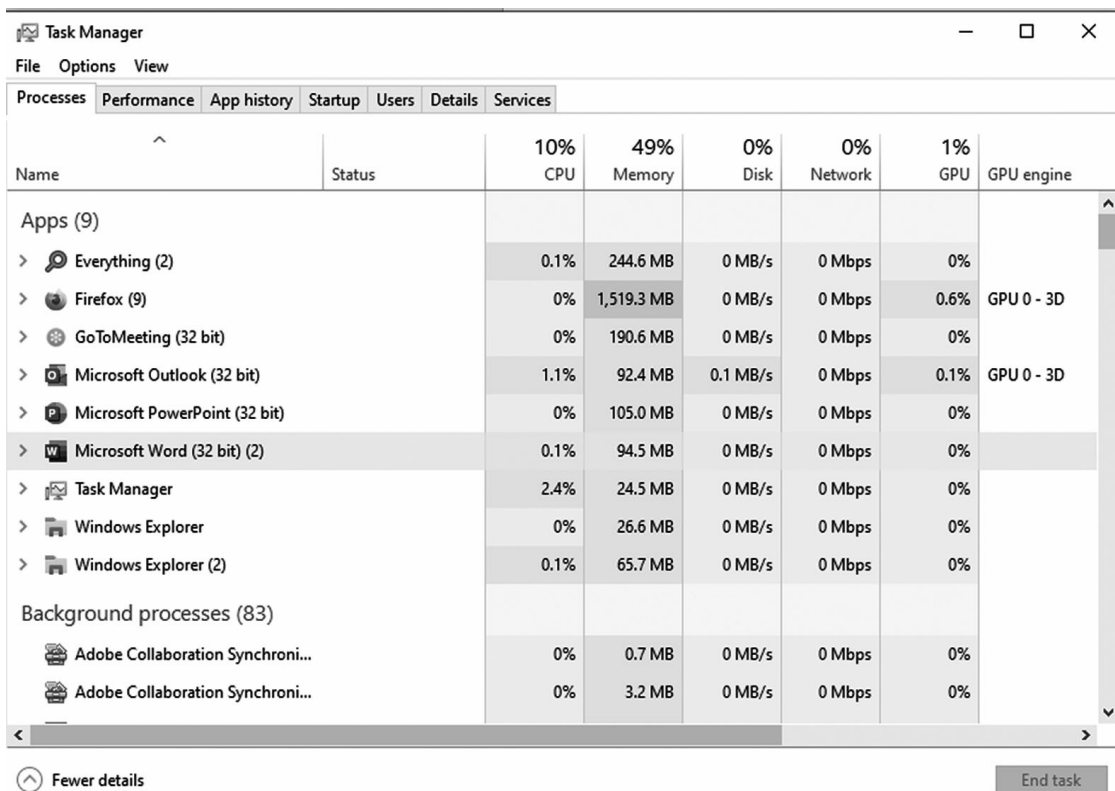
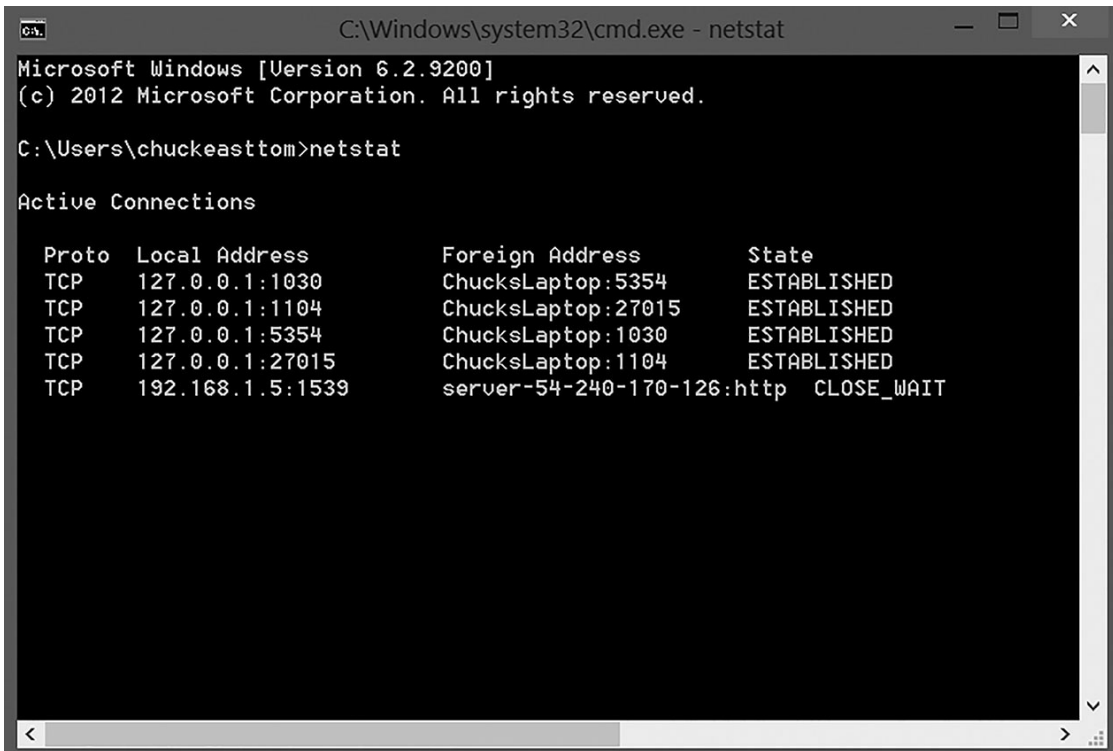


Figure 4-1 Windows 10 running processes.

Now take a picture of the screen so you have a record of the running processes. In this case, “take a picture” means taking an actual photo with a camera, not taking a screenshot. In many cases, your photos are also subject to the rules of the chain of custody for evidence. You should assume that they are. Next, it is important to see if there are live connections to this system. Fortunately, there are built-in commands (most work in Linux as well as Windows) that will help you with that. The following sections cover a few of those commands.

Using netstat

The netstat command shows network statistics and any current connections. Normally, there are connections. For example, a Windows 7 computer that is part of a homegroup will have communications with other members of that group. What you are looking for are external connections, particularly ones from outside the local network. You can see an example of netstat in [FIGURE 4-2](#).



```
C:\Windows\system32\cmd.exe - netstat
Microsoft Windows [Version 6.2.9200]
(c) 2012 Microsoft Corporation. All rights reserved.

C:\Users\chuckeasttom>netstat

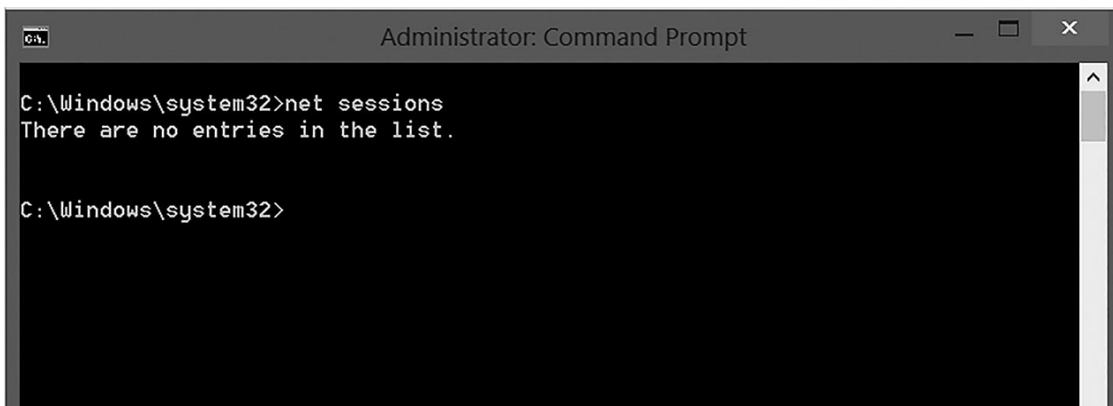
Active Connections

Proto Local Address          Foreign Address         State
TCP   127.0.0.1:1030          ChucksLaptop:5354      ESTABLISHED
TCP   127.0.0.1:1104          ChucksLaptop:27015     ESTABLISHED
TCP   127.0.0.1:5354          ChucksLaptop:1030      ESTABLISHED
TCP   127.0.0.1:27015         ChucksLaptop:1104      ESTABLISHED
TCP   192.168.1.5:1539        server-54-240-170-126:http CLOSE_WAIT
```

Figure 4-2 Using netstat.

Using net sessions

The net sessions command is actually more helpful than netstat. The netstat command shows even meaningless connections, such as your computer opening a web browser. But net sessions shows only established network communication sessions, such as someone logging on to that system. You can see an example of net sessions in **FIGURE 4-3**.



```
Administrator: Command Prompt

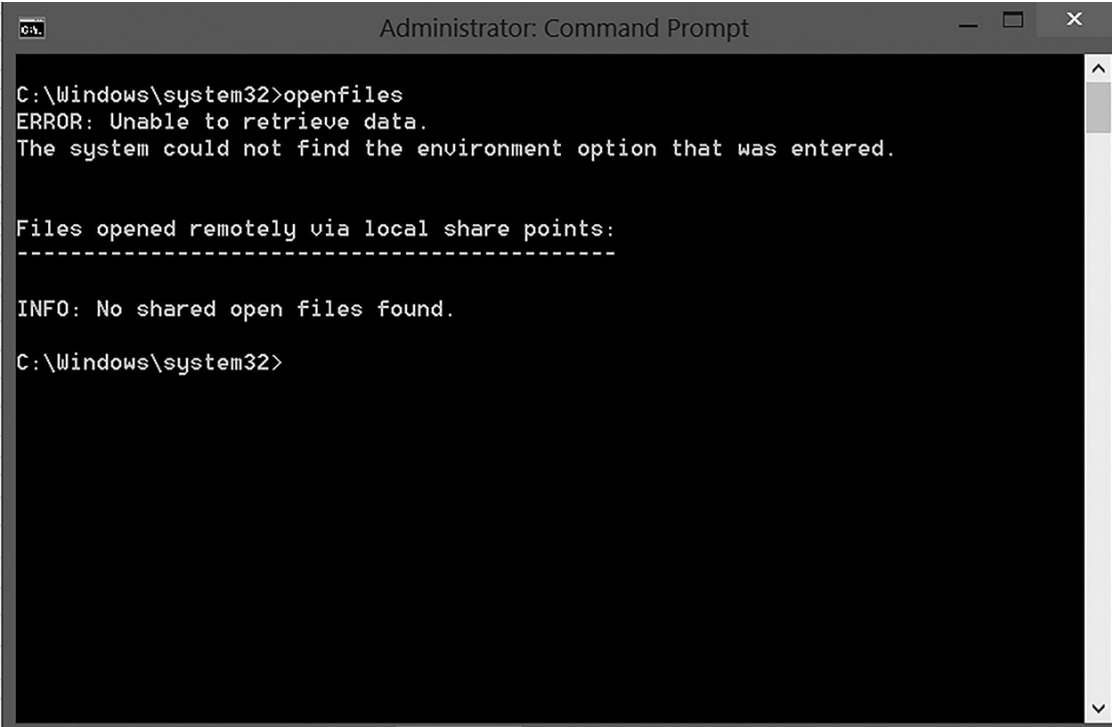
C:\Windows\system32>net sessions
There are no entries in the list.

C:\Windows\system32>
```

Figure 4-3 Using net sessions.

The openfiles Command

The openfiles command is very useful. It tells you if any shared files or folders are open and who has them open. Before shutting down the suspect machine, this is a critical command to run. You can see an example of openfiles in [FIGURE 4-4](#).

A screenshot of a Windows Command Prompt window titled "Administrator: Command Prompt". The window has a black background with white text. The command prompt shows the following text:

```
C:\Windows\system32>openfiles
ERROR: Unable to retrieve data.
The system could not find the environment option that was entered.

Files opened remotely via local share points:
-----

INFO: No shared open files found.
C:\Windows\system32>
```

Figure 4-4 Using openfiles.

You should run each of these commands and photograph the results before shutting down the machine. Also document that you ran them, the time you started them, and the results. Then power down the machine. Most sources recommend you simply pull the plug. This may be contrary to how you usually power down a machine, but the idea is to interrupt normal operations. It is possible, though not likely, that there is some malware on the machine that would delete files, clear the swap, or otherwise destroy evidence during a normal power-down or the subsequent power-up of a machine.

Capturing Memory

If you believe that you may wish to analyze the system's memory at a later time, then it is imperative that you capture the memory now. Many tools exist that will capture memory. Remembering Locard's principle of transference—that interacting with an environment changes it—you will want to run these tools from a USB device, not actually on the suspect system. OSForensics can be installed to USB and can capture the system's memory. You can see this in [FIGURE 4-5](#).

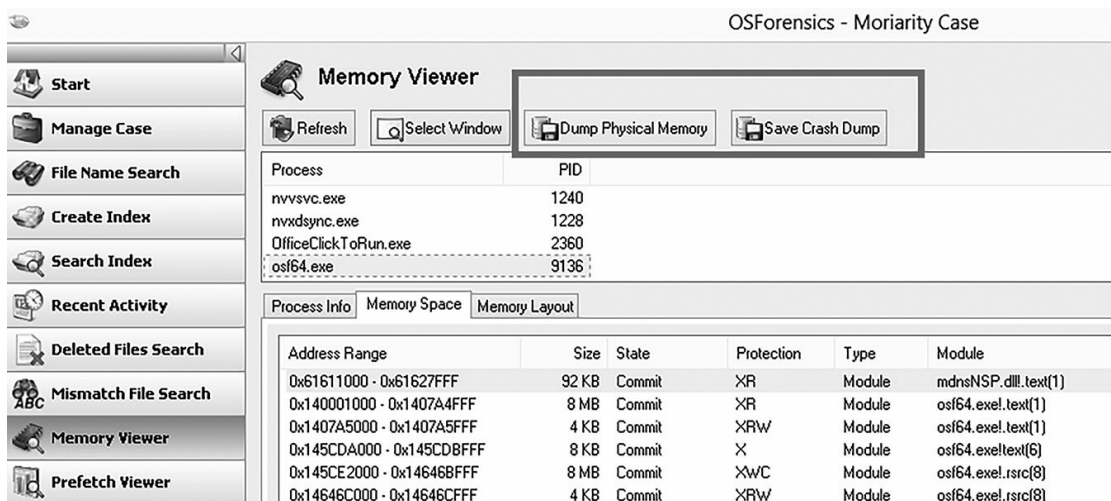


Figure 4-5 Capturing memory with OSForensics.

Magnet RAM Capture and DumpIt are two free tools that will capture memory. Both can be easily found on the internet using your favorite search engine. AccessData's FTK (which we will see later used to capture a drive image) can also be used to capture memory.

You will also want to document the surroundings of the device. Was there a printer attached, or any external device? Document any cables that are attached, as these may indicate there were external devices or drives were previously attached. Just remember that more information and detail are always better.

Transporting the Computer System to a Secure Location

Seized computers are often stored in less-than-secure locations. Both law enforcement agencies and corporations sometimes fail to transport and store suspect systems properly. It is imperative that you treat a subject computer as evidence and store it out of reach of curious computer users. Sometimes, individuals operate seized computers without knowing that they are destroying potential evidence and the chain of custody. A seized computer left unattended can easily be compromised. Someone could plant evidence or destroy crucial evidence. Lack of a proper chain of custody can make a savvy defense attorney's day. Without a proper chain of custody, you can't ensure that evidence was not planted on the computer after the seizure.

During the transport, you must be aware that this seized computer is evidence. It should be locked in a vehicle and the vehicle should be driven directly to the lab. This is not a time to stop for lunch! Any period of time in which you cannot account for the evidence is a break in the chain of custody. And it is certainly possible for someone to break into the vehicle while you are stopped at your favorite lunch spot.

Preparing the System

If the device you have seized is a computer, you need to remove the drive(s) from the suspect machine even if the drive(s) is not currently attached to any cabling. Create a chain of custody form. You can see a sample evidence form in [FIGURE 4-6A](#).

Single Evidence Form																										
Case No.					Evidence No.																					
PLEASE COMPLETE FORM IN UPPERCASE																										
Section B: Evidence Collection																										
Date/Time Collected	D	D	/	M	M	/	Y	Y	H H : M M	Collected by																
Site Address																										
Section C: Evidence Details																										
Date/Time Stored	D	D	/	M	M	/	Y	Y	H H : M M																	
Storage Location																										
Device Type					Capacity																					
Manufacturer					Model																					
Serial No.																										
MD5 Sum																										
SHA-1 Sum																										
Additional Information ...																										
Note any damage, marks and scratches													Digital Image Taken ☐ Yes ☐ No													
Section D: Image Details																										
Date/Time Imaged	D	D	/	M	M	/	Y	Y	H H : M M	Imaged by																
Storage Location																										
Image Filename													Image Size (inc. unit)													
Additional Information ...																										

Figure 4-6A Evidence form.

Some forensic examiners have a separate chain of custody form. **FIGURE 4-6B** shows one from an actual police department. Tools such as OSForensics include a chain of custody form, which is shown in **FIGURE 4-6C**. The chain of custody is integrated into the case file, making case management much easier.

OWNER: _____
ADDRESS: _____

CHAIN OF CUSTODY

Date	Time	Officer	Locker # or Location

Received from the McKinney Police Department the item(s) shown on the reverse side of this card. I hereby certify that I am authorized to take possession and that I release the McKinney Police Department from any and all responsibility.

Witness: _____ Signature: _____
Date: _____ Address: _____

Figure 4-6B Sample police department chain of custody form.

Help

Case Categories Offense & Custody Data Description of Evidence Chain of Custody Custom Fields Case Narrative < >

Evidence #	Date & Time	Released by	Received by
1002	1/8/2021, 15:06:28, GMT -6:00	Det Smith	Det Johns
1003	1/8/2021, 15:06:54, GMT -6:00	Shelock Homes	Watson

Note: Editing the chain of custody data is done through the Description of Evidence tab.

OK Cancel

Figure 4-6C OSForensics chain of custody form.

Now, the specifics of your chain of custody form will vary depending on your jurisdiction and your organizational policies. You typically need to use a separate chain of custody form for each drive you have removed. Depending on your level of comfort in reliably describing and re-creating the technology present in the suspect system, you may want to take photographs of all of the drive connections, cable connections to the case, and general work area for future use. Photos are not required for admittance into court, but you should take photographs whenever possible. Any time you can use photographs to enhance your investigation or your reporting, you should do so. You can also leave the drives in the system and acquire their data with some forensically safe boot disks, CD-ROMs, or thumb drives.

In the case of phones, it is sometimes necessary to remove the SIM card (though this is not always required). It is certainly possible to examine a phone without removing the SIM card, and most modern phone forensic software allows you to simply dock the phone into the device.

Documenting the Hardware Configuration of the System

Before dismantling the computer, it is important to take pictures of the computer from all angles to document the system hardware components and how they are connected. Labeling each wire is also important, so that you can easily reconnect each one when the system configuration is restored to its original condition. You should also record basic input/output system (BIOS) information. Note that modern systems use Unified Extensible Firmware Interface (UEFI) rather than BIOS, but you can get the same information from UEFI that you would otherwise retrieve from BIOS.

At this point, the drives are removed and you have identified and removed the media from the system. You can now safely boot up the system to check the BIOS information. In the chain of custody form, enter information about the BIOS of the system; you can typically access this information by pressing Esc, Delete, F2, F9, F10, or F11 during the initial boot screen (the specific key depends on the system, but F2 seems to be the most common). This varies depending on the system manufacturer, so always try to search the system manufacturer's website ahead of time to determine how to access this information. Once you've accessed the BIOS information, you need to record the system time and date in the chain of custody form. The BIOS time is important because it can significantly differ from the actual time and time zone set for the geographic area in which you are located. The importance of the BIOS time varies by the file system (the New Technology File System [NTFS] used in Windows stores Greenwich Mean Time, for example) and operating system, and some update the time using network time servers. If the BIOS time is different, you need to note this and then adjust the times of any files you recover from the image to determine the actual time and date they were created, accessed, or modified. After the power has been restored to the system, eject all media contained in drives that cannot be operated without power (such as some CD-ROMs and DVD-ROMs) and remove them. Then fill out a separate chain of custody form for each of the items removed. If you forget to eject the CD-ROM before powering it down, do not worry, because most CD-ROM drives can be opened by sticking the end of a paper clip in

the tiny hole near the eject button.

Mathematically Authenticating Data on All Storage Devices

You must be able to prove that you didn't alter any of the evidence after taking possession of a suspect computer. Such proof helps rebut allegations that the investigator changed or altered the original evidence. After imaging any drive, you must always create a **hash** of the original and the copy (see the FYI "What is a hash?" for more on hashes). Compare the hashes. If they do not match exactly, then something was altered. You must also document what hashing algorithm you used (SHA1 is the most common, but SHA2 is being increasingly used) and what the results were. Linux has built-in tools for hashing, but many forensic tools such as EnCase and Forensic Toolkit (FTK) hash the suspect drive after it is imaged to check for copy errors. OSForensics will also create a hash of the suspect drive when imaging is complete.

In Linux, the following command hashes a partition:

```
md5sum /dev/hda1
```

FYI

What is a hash?

Although you might already have some knowledge of hashing algorithms, it is important to make certain you are completely clear on what a hash is. A hash is not encryption. There are three criteria for an algorithm to be considered a hash:

1. It must be nonreversible. Things are so scrambled they cannot be "unhashed." You don't "decrypt" or "dehash" a hash. You can compare it with another hash to see if it matches.
2. Variable-length input produces fixed-length output. No matter how much you put in, the hash is always the same size, and the size of the resulting hash value depends on the specific hashing algorithm.
3. There are few or no collisions. It should be extremely rare that you can put in two different values and get the same hash. Ideally, this should never occur.

MD5 has been a popular hash for many years. SHA1 and SHA2 are currently the most widely used hashing algorithms.

This assumes the partition is hda1. If your partition is different, then substitute your partition name. If you want to send that hash to a target machine (such as your forensic server), use this command:

```
md5sum /dev/hda1 | nc 192.168.0.2 8888 -w 3
```

This says to create the hash of the partition, then use netcat to send it to IP 192.168.0.2 port 8888. Obviously, your IP address and port could be different.

Handling Evidence

Once you have appropriately transported the device and prepared it for forensic examination, you have to handle the evidence. There are specific steps to use.

Preserving computer evidence requires planning and training in incident discovery procedures. The following sections describe tasks related to handling evidence and measures to take when gathering evidence. To review, a system forensics specialist has three basic tasks related to handling evidence:

- Find evidence
- Preserve evidence
- Prepare evidence

Collecting Data

There are three primary types of data that a forensic investigator must collect: volatile data, temporary data, and persistent data. As an investigator, you must attempt to avoid permanently losing data. Therefore, you must carefully secure the physical evidence first; then you can collect volatile and temporary data. Such data is lost whenever a system is used, so you should collect it first to minimize corruption or loss. The following are examples of volatile data:

- **Swap file**—The swap file is used to optimize the use of random access memory (RAM). Data is frequently found in the swap file. The details of how to extract data from the swap file vary depending on the installed operating system. While we still call this the swap file, in modern Windows systems it is actually `pagefile.sys`.
- **State of network connections**—This data is captured before the system is shut down.
- **State of running processes**—This data is captured before the system is shut down.

After collecting volatile data, you collect **temporary data**—data that an operating system creates and overwrites without the computer user taking a direct action to save this data. The likelihood of corrupting temporary data is less than that of volatile data. But temporary data is just that—temporary—and you must collect it before it is lost. Only after collecting volatile and temporary data should you begin to collect persistent data.

Documenting Filenames, Dates, and Times

From an evidence standpoint, filenames, creation dates, and last-modified dates and

times can be relevant. Therefore, it is important to catalog all allocated and “erased” files. Sort the files based on the filename, file size, file content, creation date, and last-modified date and time. Such sorted information can provide a timeline of computer usage. The output should be in the form of a word processing-compatible file to help document computer evidence issues tied to specific files.

Identifying File, Program, and Storage Anomalies

Encrypted, compressed, and graphics files store data in binary format. As a result, text search programs can't identify text data stored in these file formats. These files require manual evaluation, which may involve a lot of work, especially with encrypted files. Depending on the type of file, view and evaluate the content as potential evidence. Reviewing the partitioning on seized hard disk drives is also important. Evaluate hidden partitions for evidence and document their existence. With Windows operating systems, you should also evaluate the files contained in the Recycle Bin. The Recycle Bin is the repository of files selected for deletion by the computer user. The fact that they have been selected for deletion may have some relevance from an evidentiary standpoint. If you find relevant files, thoroughly document the issues involved. Those issues can include the following:

- How did you find the files?
- What condition were they in (i.e., did you recover the entire file or just part of the file)?
- When was the file originally saved?

Remember that the more information you document about evidence, the better.

Evidence-Gathering Measures

Forensic specialists should take the following measures when gathering evidence:

- **Avoid changing the evidence**—Before removing any equipment, forensics specialists should photograph equipment in place and label wires and sockets so that computers and peripherals can be reassembled in a laboratory exactly as they were in the original location. When transporting computers, peripherals, and media, forensics specialists must be careful to avoid heat damage, jostling, or touching original computer hard disks and compact discs (CDs). Forensics specialists should also make exact bit-by-bit copies, storing the copies on an unalterable medium, such as a DVD-ROM.
- **Determine when evidence was created**—Timelines of computer usage and file

accesses can be valuable sources of computer evidence. The times and dates when files were created, last accessed, or modified can make or break a case. However, forensics specialists should not trust a computer's internal clock or activity logs. It is possible that the internal clock is wrong, that a suspect tampered with logs, or that simply turning on the computer changes a log irrevocably. Before logs disappear, an investigator should capture the time a document was created, the last time it was opened, and the last time it was changed. The investigator can then calibrate or recalibrate evidence, based on a time standard, and work around log tampering.

- **Search throughout a device**—Forensic specialists must search at the bit level (the level of 1s and 0s) across a wide range of areas inside a computer. This includes email, temporary files, swap files, logical file structures, and slack and free space on the hard drive. They must also search software settings, script files, web browser data caches, bookmarks and history, and session logs. Forensic specialists can then correlate evidence to activities and sources. Don't be overly concerned about how difficult this process will be. Modern forensics tools will automate a great deal of the search process for you. You will see that first hand in [Chapter 8](#).
- **Determine information about encrypted and steganized files**—Investigators should usually not attempt to decode encrypted files. Rather, investigators should look for evidence in a computer that tells them what is in the encrypted file. Frequently, this evidence has been erased, but unencrypted traces remain and can be used to make a case. For steganized information—that is, information concealed within other files or buried inside the 1s and 0s of a picture, for example—an investigator can tell that the data is there, even though it is inaccessible. The investigator can compare nearly identical files to identify minute differences. We will be exploring this in some detail in [Chapter 5](#).
- **Present the evidence well**—Forensic examiners must present computer evidence in a logical, compelling, and persuasive manner. The jury must be able to understand the evidence, and the evidence must be solid enough that a defense counsel cannot rebut it. The forensic examiner must be able to create a step-by-step reconstruction of actions, with documented dates and times. In addition, the forensic examiner must prepare charts, graphs, and exhibits that explain what was done, describe how it was done, and withstand scrutiny. The forensic examiner's testimony must explain simply and clearly what a suspect did or did not do. The forensic examiner should remember that the jury and judge are rarely savvy computer technologists, and the ability of a forensic examiner to explain technical points clearly in plain English can make or

break a case.

What to Examine

This chapter has so far discussed general preparations involved in the initial seizing, duplication, and finding of digital evidence. There's much more to learn, especially about examining data to find *incriminating evidence*—evidence that shows, or tends to show, a person's involvement in an act, or evidence that can establish guilt. One of the three techniques of forensic analysis is *live analysis*, which is the recording of any ongoing network processes. The remaining two techniques are **physical analysis** and **logical analysis**, which both deal with hard drive structures and file formats.

Physical imaging is making a physical copy of the disk. This is a bit-by-bit copy. Forensics tools will do this for you, and it is always the way to image a computer drive. In some cases, you cannot perform a physical imaging of phones. **Logical imaging** uses the target system's file system to copy data to an image for analysis. This can miss deleted files, files no longer in the file system but on the drive, and similar data.

Two of the easiest things to extract and analyze are a list of all website uniform resource locators (URLs) and a list of all email addresses on the computer. The user may have attempted to delete these, but you can reconstruct them from various places on the hard drive. Next, you should index the different kinds of file formats.



NOTE

Of most interest forensically is the fact that swap files are not erased when the system shuts down. They work on a queue system. Data stays in the swap file and is not overwritten until that space is needed. That means it is possible to find data in the swap file that was live in memory and not stored on the suspect drive.

The file format you start with depends on the type of case. For example, you might want to start with graphics file formats or document formats in a pornography or forgery case. There are lots of other file formats: multimedia, archive, binary, database, font, game, and internet-related. Computers generally save things in file formats beyond the user's control. For example, all graphics files have header information. Collectors of pornography usually don't go to the trouble of removing this header information, so it's an easy matter of finding, for example, one graphics header at the beginning of a JPEG (Joint Photographic Experts Group) file and doing a string search for all other graphics of that type.

The following sections describe some of the places that an investigator must physically analyze.

The Swap File

You read briefly about the swap file earlier in this chapter. A swap file is the most important type of ambient data. Windows uses a swap file on each system as a “scratch

pad” to write data when additional RAM is needed. A swap file is a virtual memory extension of RAM. Most computer users are unaware of the existence of swap files. The size of these files is usually about 1.5 times the size of the physical RAM in the machine. Swap files contain remnants of word processing documents, emails, internet browsing activity, database entries, and almost any other work that has occurred during past Windows sessions. Swap files can be temporary or permanent, depending on the version of Windows installed and the settings selected by the computer user. Permanent swap files are of the greatest forensic value because they hold larger amounts of information for longer periods of time. However, temporary, or dynamic, swap files are more common. These files shrink and expand as necessary. When a dynamic swap file reduces its size close to zero, it sometimes releases the file’s content to unallocated space, which you can also forensically examine. Modern Windows systems call this file pagefile.sys, but it has the same function.

Unallocated (Free) Space

Unallocated space, or free space, is the area of a hard drive that has not been allocated for file storage. It’s the leftover area that the computer regards as unallocated after file deletion. When a file is deleted, only the header or reference point is deleted, while the file data remains. Space taken by that file data is now considered unallocated space, made available again for new data. If no data gets rewritten, then that space often contains fragments of the previously deleted files. The only way to clean unallocated space is with cleansing devices known as **sweepers** or **scrubbers**. While “scrubber” implies they clean, they are actually writing over the unallocated old fragments to remove that evidence. However, a few commercial products scrub free space to Department of Defense (DoD) standards. The fragments of old files in free space can be anywhere on the disk, even on a different partition, but they tend to fall next to partition headers, file allocation tables (FAT), and the last sectors of a cluster.

You may indeed find data in obvious places. There are cases where child pornography was found in the pictures folder of a Windows computer. However, you should not expect it to be that easy. Criminals do not wish to be caught, at least not usually. They use various tactics to hide what they’ve been doing. For example, perpetrators often use unusual file paths. In addition, many try to thwart investigators by using encryption to scramble information or steganography to hide information, or both together. Or they may use **metadata** to combine different file formats into one format. You can also expect to find lots of deleted, professionally scrubbed data.

FYI

What is metadata?

Metadata is essentially data about the data. In the case of files, it can include creation time/date, size, last modified date, and even file header information. This information can be as useful as the data itself.

A JPEG file might, for example, show evidence of a crime, but the date and time it was taken can be useful information as well. Image files, for example, have Exif data. Exif is shorthand for “exchangeable image file format” and applies to a range of images. To

illustrate, I begin with a picture of one of my dogs.

There is a great deal of Exif data one can gather from the image shown in FIGURE 4-7A. Information such as the device the picture was taken from, the date and time of the image, and even GPS latitude and longitude can be found in the Exif data FIGURE 4-7B.



Figure 4-7A Exif sample image.

General		Security		Details		Previous Versions	
Property		Value				^	
Date taken		7/15/2020 5:30 PM					
Program name		13.5.1					
Date acquired							
Copyright							
Image							
Image ID							
Dimensions		480 x 640					
Width		480 pixels					
Height		640 pixels					
Horizontal resolution		72 dpi					
Vertical resolution		72 dpi					
Bit depth		24					
Compression							
Resolution unit		2					
Color representation		sRGB					
Compressed bits/pixel							
Camera							
Camera maker		Apple					
Camera model		iPhone 8					
F-stop		f/1.8				v	

Figure 4-7B Exif data.

Creating a Timeline

To reconstruct the events that led to corruption of a system, create a timeline. This can be particularly difficult when it comes to computers. Clock drift, delayed reporting, and different time zones can create confusion. Never change the clock on a suspect system. Instead, record any clock drift and the time zone in use. It is also common to use the timeline format or TLN pipe-delimited format (a “pipe” is a vertical line character like this: |) with five values: Time | Source | System | User | Description. So the record might look something like this:

10-04-2020 | 15:45:23 | Chrome Browser | Windows 10 Computer | Jsmith | Visited a site that allows one to download source code for viruses.

10-6-2020 | 05:03:54 | FileZilla FTP Client | Windows 10 Computer | Jsmith | Uploads a virus to the server of the victim company.

10-7-2020 | 10:14:20 | Call App | Samsung S9 Phone | Jsmith | Calls victim company.

Now this is a very brief excerpt, but you can see that putting things in order gives one a very clear view of the activities and an understanding of the crime, even if evidence came from different devices. In this case, the perpetrator appears to have downloaded virus code, then two days later uploaded it to the target. Then he called the target the next day. That call is likely to have been made to look like a random sales call advertising PC repair services. This is actually a not uncommon scam: The perpetrator causes the problem that they then purport to repair.

Storage Formats

Working with forensics, you need to be familiar with a variety of storage formats. Specifically, you should be familiar with the various hard drive types, file systems, and journaling. This section reviews a variety of storage and file formats and explores additional issues with storage formats.

Magnetic Media

Although mobile devices like smartphones and tablets are a growing part of forensics work, computers are still the biggest target of forensic investigations. Most computers utilize magnetic media. Hard drives and floppy drives are types of magnetic media. Essentially, the data is organized by sectors and clusters, which are in turn organized in tracks around the platter. A typical sector is 512 bytes, although newer drives use 4096-byte sectors, and a cluster can be from 1 to 128 sectors.

Because the data is stored magnetically, the drives are susceptible to magnetic interference. This can include being demagnetized. If a drive has been demagnetized, there is no way to recover the data. You should transport drives in special transit bags that reduce electrostatic interference. This reduces the chance of inadvertent loss of data.

There are five types of drive connections, whether the drive is magnetic or solid state (which will be discussed a bit later in this chapter):

- Integrated Drive Electronics (IDE)
- Extended Integrated Drive Electronics (EIDE)
- Parallel Advanced Technology Attachment (PATA)
- Serial Advanced Technology Attachment (SATA)
- Serial SCSI

These drive types refer to the connection between the drive and the motherboard as well as the total capacity of the drive. SATA drives have become the norm, and what you will find most often. Serial SCSI can be found in some servers. However, IDE, EIDE, or PATA would only be found in very old systems.

It is important to remember that because magnetic drives have moving parts in them, they are also susceptible to physical damage. If you drop a drive, you may render the data inaccessible. This is one reason you must take care when handling magnetic drives.

Solid-State Drives

Solid-state drives (SSDs) use microchips, which retain data in non-volatile memory chips and contain no moving parts. Most SSDs use Negated AND (NAND) gate-based flash

memory, which retains memory even without power. Because there are no moving parts, these drives are usually less susceptible to physical damage than magnetic drives are. They have become the standard for many internal drives and for all external drives.

One reason these drives are so popular is because they generally require one-half to one-third the power of hard disk drives. The startup time for SSDs is usually much faster than for magnetic storage drives. They are often used in tablets and in some laptops. This means that you are likely to encounter them at some point in your forensics career.

If these drives are internal, they can use the same interfaces magnetic drives use, including SCSI and SATA. However, if connected externally, it is most common for them to have a universal serial bus (USB) connection.

Both magnetic and solid-state drives include a few features that are important for forensics:

- **Host protected area (HPA)**—This was designed as an area where computer vendors could store data that is protected from user activities and operating system utilities, such as delete and format. To hide data in the HPA, a person would need to write a program to access the HPA and write the data.
- **Master boot record (MBR)**—This requires only a single sector, leaving 62 empty sectors of MBR space for hiding data.
- **Volume slack**—This is the space that remains on a hard drive if the partitions do not use all the available space. For example, suppose that two partitions are filled with data. When you delete one of them, its data is not actually deleted. Instead, it is hidden.
- **Unallocated space**—An operating system can't access any unallocated space in a partition. That space may contain hidden data.
- **Good blocks marked as bad**—Suppose that someone manipulates the file system metadata to mark unused blocks as bad. The operating system will no longer access these blocks. These blocks can then be used to hide data.
- **File slack**—File slack is the unused space that is created between the end of file and the end of the last data cluster assigned to a file.

Digital Audio Tape Drives

Although many organizations are moving from electronic backups to optical media or even direct network backups to an off-site location, digital audio tape (DAT) drives are still sometimes used. DAT drives are among the most common types of tape drives. DAT uses 4-mm magnetic tape enclosed in a protective plastic shell. Even though this looks very similar to audio tapes, the recording is digital rather than analog.

From a forensic point of view, it is important to remember that these tapes do wear

out, just like audio tapes. If you are old enough to remember cassette or 8-track tapes, you'll recall that these tapes would, from time to time, become stretched and worn and no longer usable. The same thing happens with the DAT tapes. In fact, network administrators are admonished to replace them periodically.

When working with DAT drives, most likely they will contain archived/backup data that you need to analyze. Make certain you first forensically wipe the target drive so you can be sure that there is no residual data on that drive. You then need to restore it to the target hard drive (magnetic or solid state) in order to analyze it.

Digital Linear Tape and Super DLT

Digital Linear Tape (DLT) is another type of tape storage, more specifically a magnetic tape. The DLT technology relies on a linear recording method. The tape itself has either 128 or 208 total tracks. This technology was first invented by Digital Electronics Corporation (DEC). This tape, like DAT, is used primarily to store archived data. So, as with DAT, you need to make sure you have a forensically wiped hard drive to restore the data to and then restore the data to that hard drive in order to analyze it. These tapes have become relatively uncommon, but you may still find them.

Optical Media

Like hard disks, optical media such as CD-ROMs, DVD, and Blu-ray discs use high and low polarization to set the bits of data; however, CDs have reflective pits that represent the low bit. If the pit is nonexistent, the data is a 1; if the pit exists, it's a 0. The laser mechanism actually detects the distance the light beam has traveled in order to detect the presence or absence of a pit. This is why scratches can be problematic for optical media.

Since the advent of the original compact disc, there have been enhancements. These enhancements still utilize the same optical process, but have larger capacity. The DVD (or digital video disc) can hold 4.7 gigabytes (GB) for a one-sided DVD and 9.4 GB for a double-sided DVD. This technology uses a 650-nm wavelength laser diode light as opposed to 780 nm for CDs. The smaller wavelength allows DVDs to use smaller pits, thus increasing storage capacity.

Blu-ray discs are the successor to the DVD and store up to 25 GB per layer, with dual-layer discs storing up to 50 GB. There are also triple- and quadruple-layer discs such as the Blu-ray Disc XL that allow up to 150 GB of storage. Although Blu-ray discs are primarily associated with movies, you can certainly store data on them. And for smaller organizations, the Blu-ray disc can be an attractive backup medium.

Just like all other storage devices, a Blu-ray device should be forensically copied to a clean, forensically wiped drive for analysis. No matter what the medium, you never work with the original suspect storage if it is at all possible to avoid it.

Using USB Drives

USB, or universal serial bus, is actually a connectivity technology, not a storage

technology. USB can be used to connect to external drives that can be either magnetic or solid state. Small USB flash drives, also known as thumb drives, are quite common. These drives can be easily erased or overwritten. It is important to copy the data from the USB drive to a target forensic drive for analysis. You must, of course, document the copying process and ensure nothing was missed or altered.

USB thumb drives have no moving parts. USB thumb drives or external drives utilize solid-state drive technology. Because there are no moving parts, these drives are resilient to shock damage (i.e., dropping them probably won't hurt them). From a forensics point of view, you should remember that many of these drives come with a small switch to put them in read-only mode. Use this whenever you are extracting data for investigation. If the drive is in read-only mode, it is unlikely you will accidentally alter the data.

The current most widely used USB standard is USB 3.2. However, you will still find a great many USB 2.0 devices. The USB 4.0 specification was released in August 2019. The differences in USB specifications primarily affect the speed of data transfer and will have little, if any, direct impact on your investigations.

File Formats

In addition to physical means of storing data, there are a variety of file formats for storing forensic data on a given storage device. It is important that you have a working knowledge of these formats for forensic analysis.

The Advanced Forensic Format

The advanced forensic file format (abbreviated AFF) was invented by Basis Technology. It is an open file standard with three variations: AFF, AFM, and AFD. The AFF variation stores all data and metadata in a single file. The AFM variation stores the data and the metadata in separate files, while the AFD variation stores the data and metadata in multiple small files. The AFF file format is part of the AFF Library and Toolkit, which is a set of open-source computer forensics programs. Sleuth Kit and Autopsy both support this file format.

EnCase

The EnCase format is a proprietary format that is defined by Guidance Software for use in its EnCase tool to store hard drive images and individual files. It includes a hash of the file to ensure nothing was changed when it was copied from the source.

The Generic Forensic Zip

Gfzip is another open-source file format used to store evidence from a forensic examination.

Forensic Imaging

Once you have acquired a physical storage medium of some type, you need to image the suspect data. You always work with an image whenever possible. Even if the medium is an optical storage device like a Blu-ray disc, you should make a forensic image of the drive and work with the image. It is possible to create a forensic image utilizing open-source tools, specifically Linux commands. This section explains all the details behind each step.

First, you must forensically wipe the target drive (which is the drive to which you will copy the suspect drive contents) to ensure there is no residual data left from a previous case. Forensically wiping is not simply deleting files; it involves actually overwriting *every single bit* with some pattern. That pattern can be random, or all zeros. I personally first format the drive, then perform a forensic wipe. Many forensic tools and software have the option to do a forensic wipe for you. You can also do this with the Linux `dd` command:

```
dd if=/dev/zero of=/dev/hdb1 bs=2048
```

This command is literally using `/dev/zero` as an input file and writing its contents out to the partition `hdb1` as the output file. If you are not familiar with Linux, `/dev/zero` is a special file on UNIX-like systems that reads out as many nulls as are required. So this command is overwriting everything on the target drive with null values.

If your partition is different, you can use `fdisk -l` to list the partitions on your system.



NOTE

Many Linux distributions have `dd` and `netcat`, so you do not have to utilize Kali Linux. However, Kali Linux is designed for computer security. This Linux distribution has a host of security, hacking, and forensic tools on it. It is a very good idea to start getting comfortable with Kali Linux early in your forensic training.

The primary purpose of `dd`, a common UNIX program, is the low-level copying and conversion of raw data. Low-level copying means at the bit level. If you do your copy through the file system/operating system, then you can see only the data that the operating system sees. You won't get deleted files or slack space. That is why a basic file system copy is inadequate for forensic analysis. You must get a bit-level copy, and the `dd` utility is perfect for that. While most forensic tools will do imaging for you, this process can be done with a Linux live cd and the `dd` and `netcat` commands.

You also need to use `netcat` to set up the forensic server to listen, so you have a Linux live CD boot up the suspect drive to copy it to the forensic server. At this point, both the suspect drive and the target forensic server have been booted into Linux using any Linux live distribution.

The `netcat` command reads and writes bits over a network connection. The command to run on the forensic server is as follows:

```
# nc -l -p 8888 > evidence.dd
```

This sets up the listen process on the forensic server prior to sending the data from the subject's computer. The process listens (the `-l` flag) on port 8888 (the `-p 8888` command) and takes all input and writes to a file called `evidence.dd`. You can always use another port or another filename if necessary. You must ensure the target drive is at least as big as the suspect drive.



NOTE

Even if you use automated forensic systems, it is critical that you know how to perform all forensic processes manually. If you don't know how the process works, then during cross-examination, you will appear to have too little knowledge of the forensic process to be able to validate that the evidence is correct and has not been tampered with.

On the suspect computer, use the `dd` command to read the first partition:

```
# dd if=/dev/hda1 | nc 192.168.0.2 8888 -w 3
```

You then pipe the output of the `dd` command to `netcat`, which sends the bits over the network to the specified network address and port on the listening forensic computer. The argument `-w 3` indicates that `netcat` should wait 3 seconds before closing the connection upon finding no more data. This assumes that the suspect partition is `hda1`, but it might be a different partition.

This process can be accomplished with most major forensic tools, including EnCase from Guidance Software, OSForensics from PassMark Software, and Forensic Toolkit from AccessData.

Imaging with EnCase

EnCase is a forensic tool that is widely used by law enforcement. Once you have the suspect's hard drive disconnected from the suspect machine, you can connect that drive to the forensic computer. In some cases, you first connect to a device that prevents writing to the suspect device. FastBlock and Tableau are two such devices that are widely used in forensics.

At the top of the EnCase window, click **New** on the toolbar to start the new case you will be working. The Case Options dialog box opens, as shown in **FIGURE 4-8**.

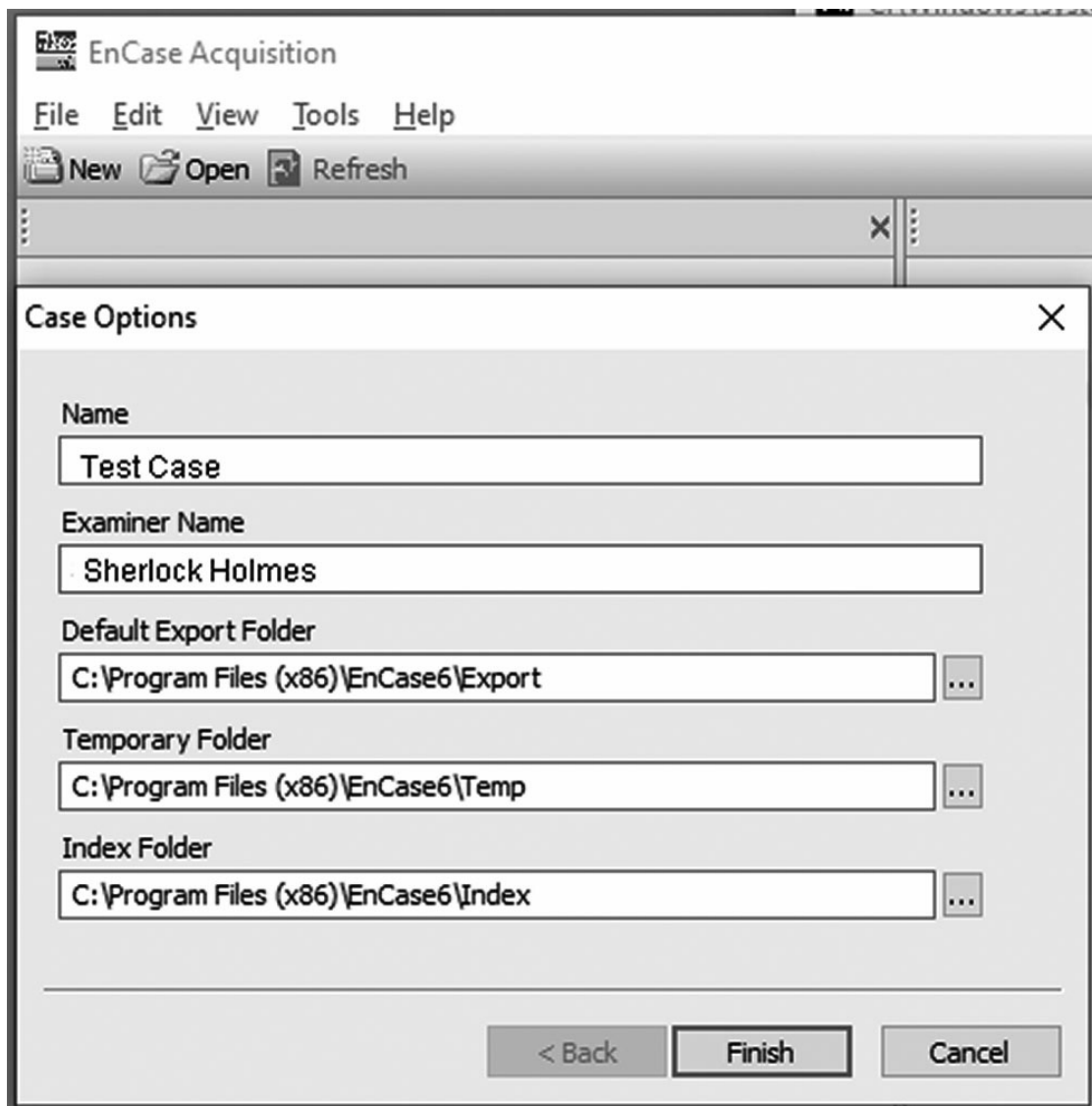


Figure 4-8 EnCase Case Options dialog box.

This dialog box allows you to type in the case name and the examiner's name. Tracking evidence by case and examiner is one convenient feature of EnCase that helps make it popular with law enforcement agencies. The text boxes are filled in automatically, but you have to click on the button on the right side next to each of the lower text boxes to select the paths. After selecting the paths, click the Finish button.

Now that you have created the case, you need to save it by clicking the Save icon on the EnCase toolbar. Select a path for the save location when prompted. Now, you are ready to acquire evidence. On the EnCase toolbar, click the Add Device button. The Add Device window appears in EnCase, asking which device to add, as shown in [FIGURE 4-9](#).

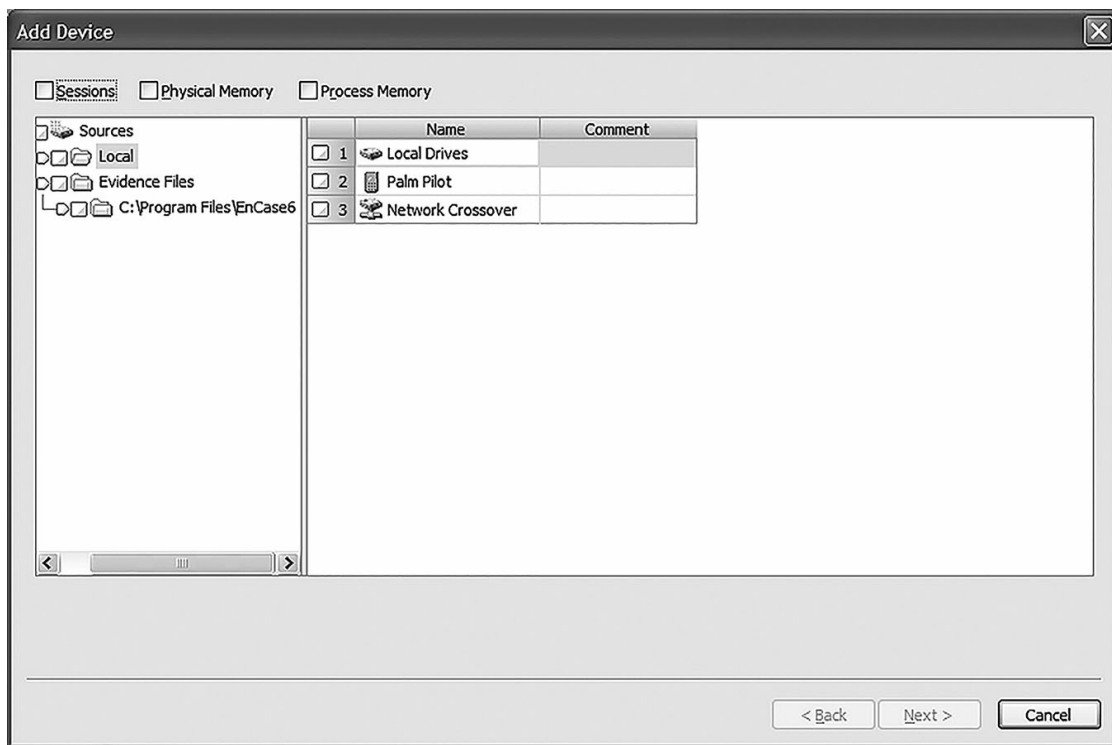


Figure 4-9 EnCase Add Device window.

The left pane lists devices with subfolders, Local and Evidence Files. The right pane lists Local Drives, Palm Pilot, Parallel Port, and Network Crossover (note these options may differ on different systems). In this procedure, you check the Local Drives in the right pane. After EnCase reads the local drives, another window appears. Once you have added the device, it shows in the case, as shown in **FIGURE 4-10**.

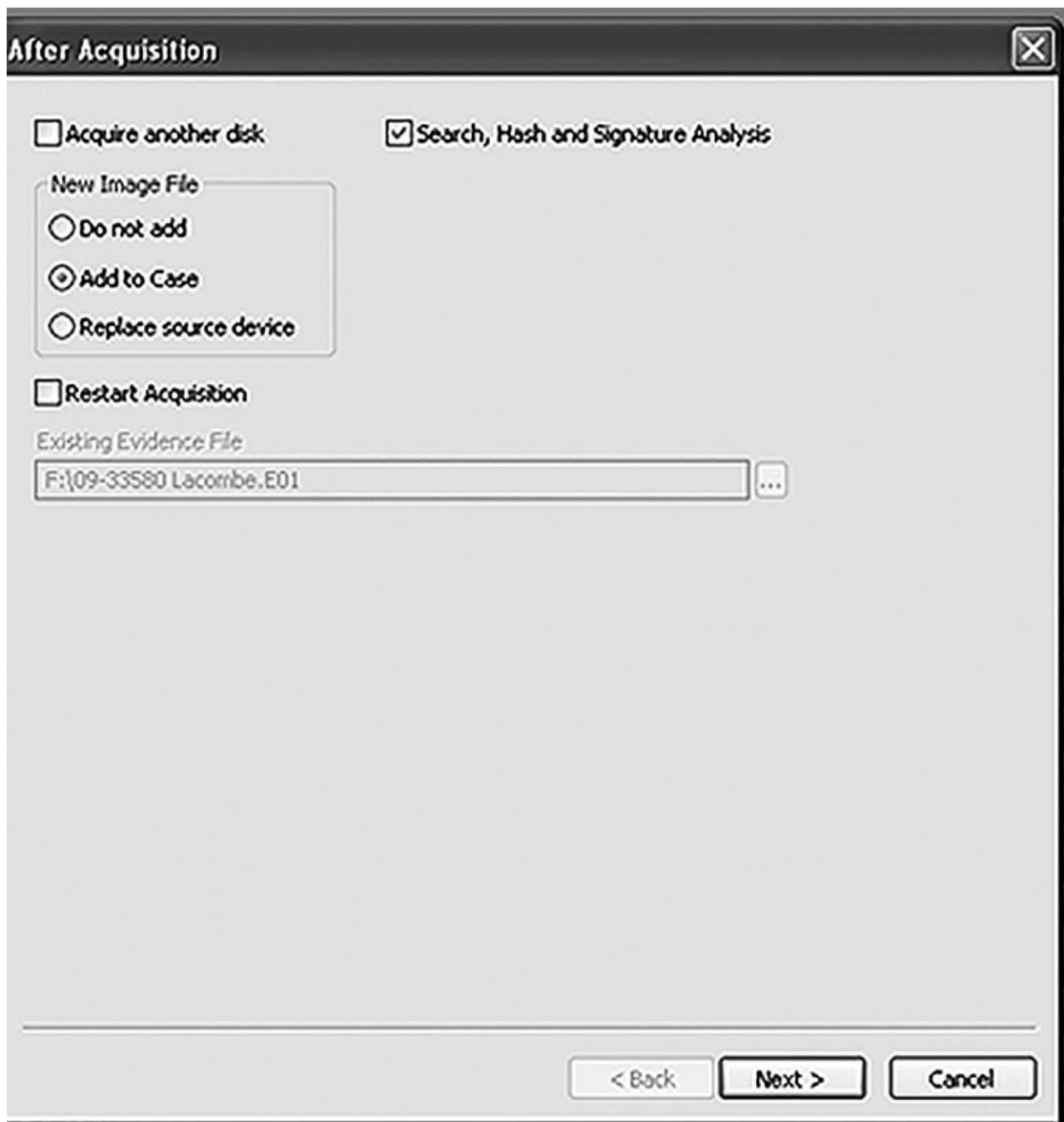


Figure 4-10 EnCase After Acquisition dialog box.

One of the first things you should note is that you can add multiple devices to a single case. This makes sense because many cases will have more than one seized device that requires examination.

Imaging with the Forensic Toolkit

The Forensic Toolkit (FTK) from AccessData is another popular forensic tool that is widely

used by law enforcement. You can purchase FTK or you can request a free download of the FTK Imager from this website: <https://marketing.accessdata.com/imager4.3.1.1>. The current version of FTK Imager, as of February 2021, is 4.5. The main screen of FTK Imager is shown in **FIGURE 4-11**.

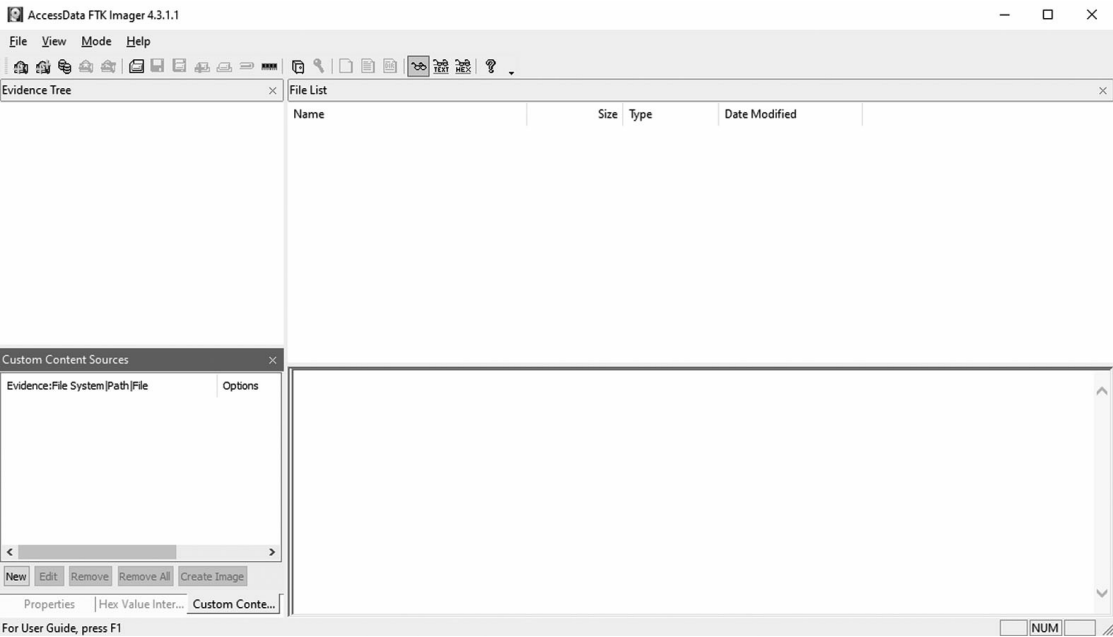


Figure 4-11 FTK Imager.

You now have to select specifically what you want to image. The first step is to select the create image option from the dropdown box (**FIGURE 4-12**).

AccessData FTK Imager 4.3.1.1

File View Mode Help

-  Add Evidence Item...
-  Add All Attached Devices
-  Image Mounting...
-  Remove Evidence Item
-  Remove All Evidence Items

-  Create Disk Image...
-  Export Disk Image...
-  Export Logical Image (AD1)...
-  Add to Custom Content Image (AD1)
-  Create Custom Content Image (AD1)...
- Decrypt AD1 image...
-  Verify Drive/Image...
-  Capture Memory...
-  Obtain Protected Files...
-  Detect EFS Encryption
-  Export Files...
-  Export File Hash List...
-  Export Directory Listing...

Exit

Figure 4-12 FTK Imager create image option.

This will launch a wizard that will walk you through the process. The first step is to select what it is you wish to image. This is shown in **FIGURE 4-13**.

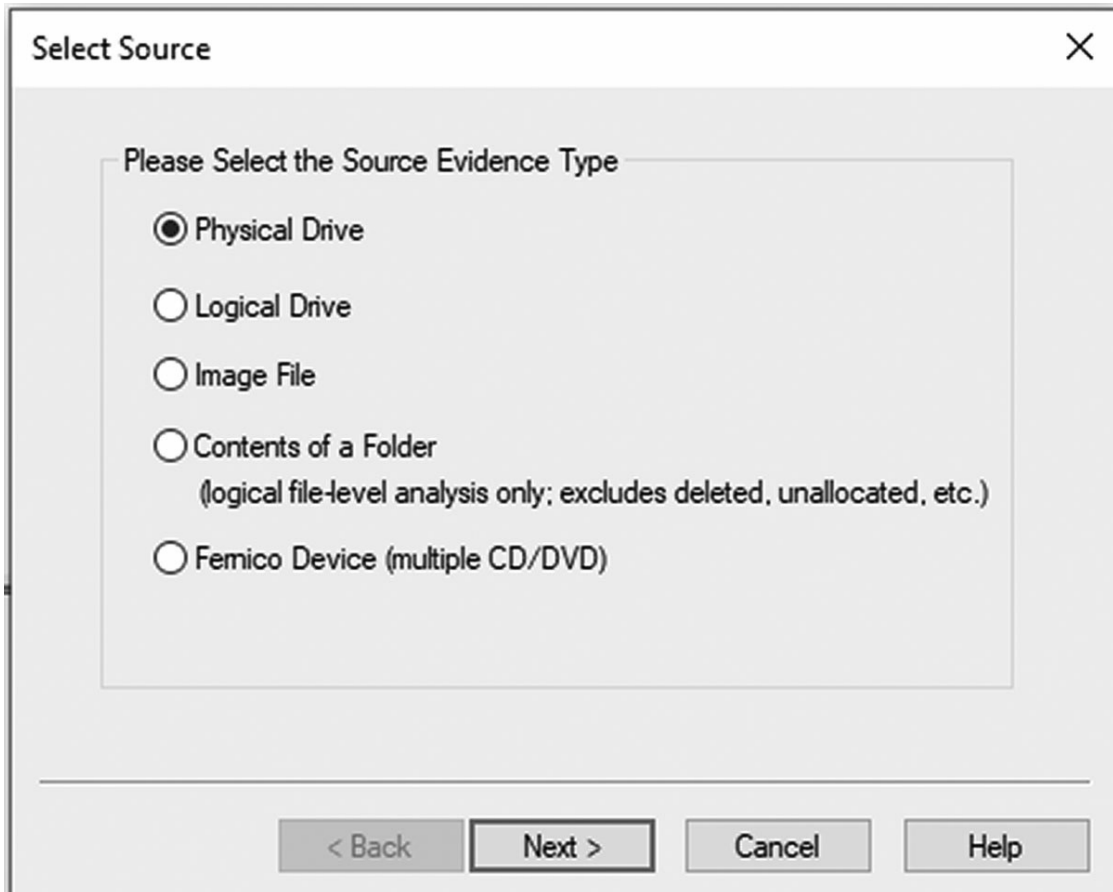


Figure 4-13 FTK Imager selecting image source.

The most common scenario is to select to image a physical drive. If you select that, the next step will be to select which physical drive. This is shown in **FIGURE 4-14**.

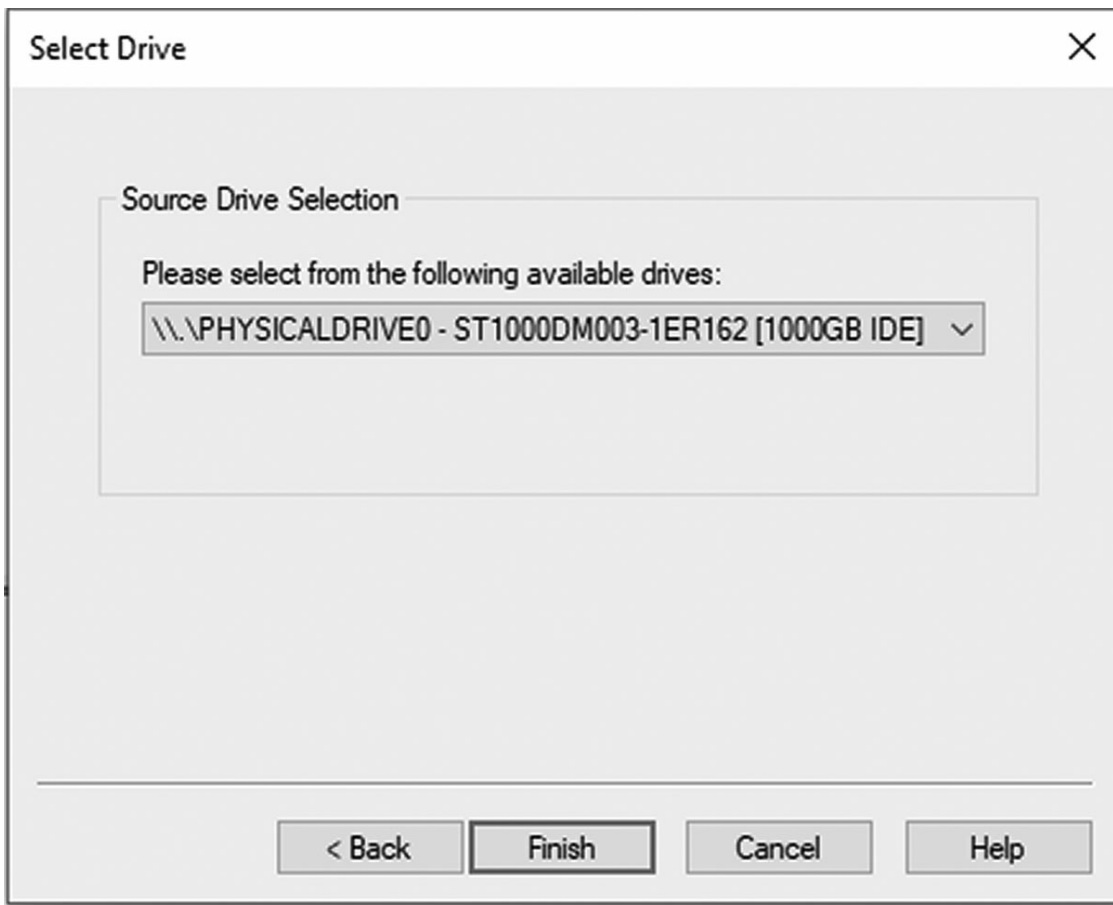


Figure 4-14 FTK Imager selecting a drive.

The next screen is quite important. Notice that the Verify Image option is checked by default. This will cause FTK Imager to create a cryptographic hash of the source drive and the image and compare them. This screen is also where you will select the drive destination, which is presumably another drive you have forensically wiped. This screen is shown in **FIGURE 4-15**.

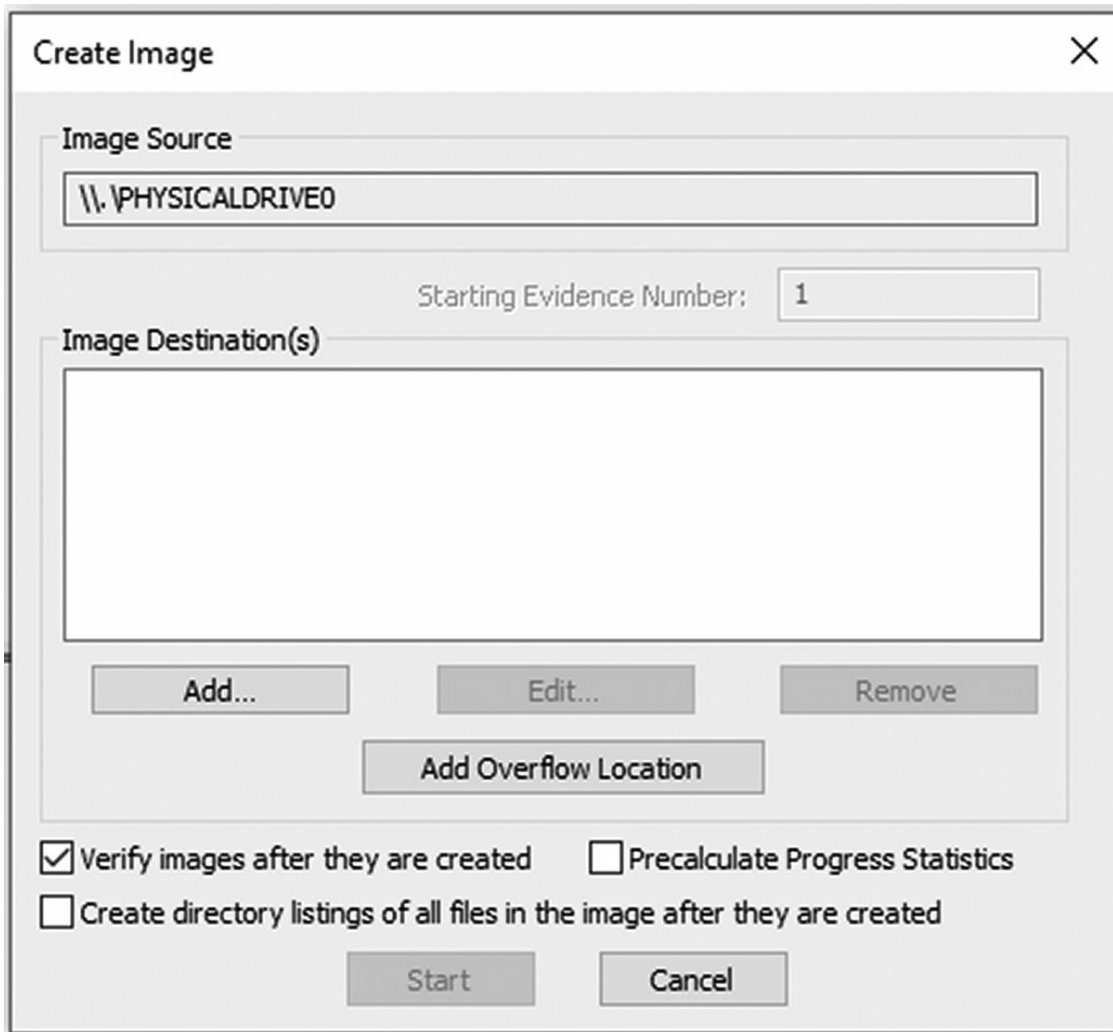


Figure 4-15 FTK Imager Verify Image option.

After that, it is just a matter of waiting for the imaging process to complete. The larger the drive, the longer this process will take. It is often the case that it takes several hours to image an entire drive. That is true regardless of the specific imaging tool you use.

Imaging with OSForensics

OSForensics allows you to mount images created with other tools, but also allows you to create an image. The first step is to select Drive Imaging from the menu on the left, shown in [FIGURE 4-16](#).

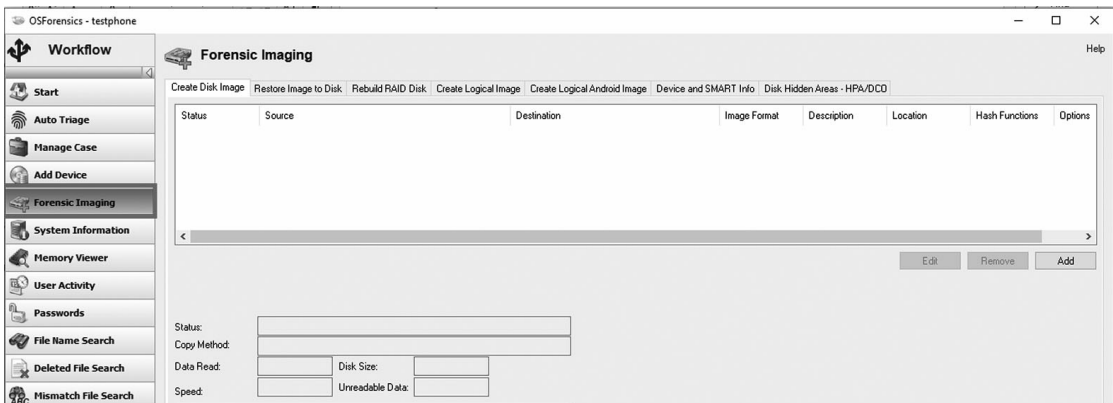


Figure 4-16 OSForensics Drive Imaging Step 1.

Then you will select the source drive you wish to image, and the target where the image will be put. Notice that “verify image” is checked by default (**FIGURE 4-17**). You should not uncheck this.

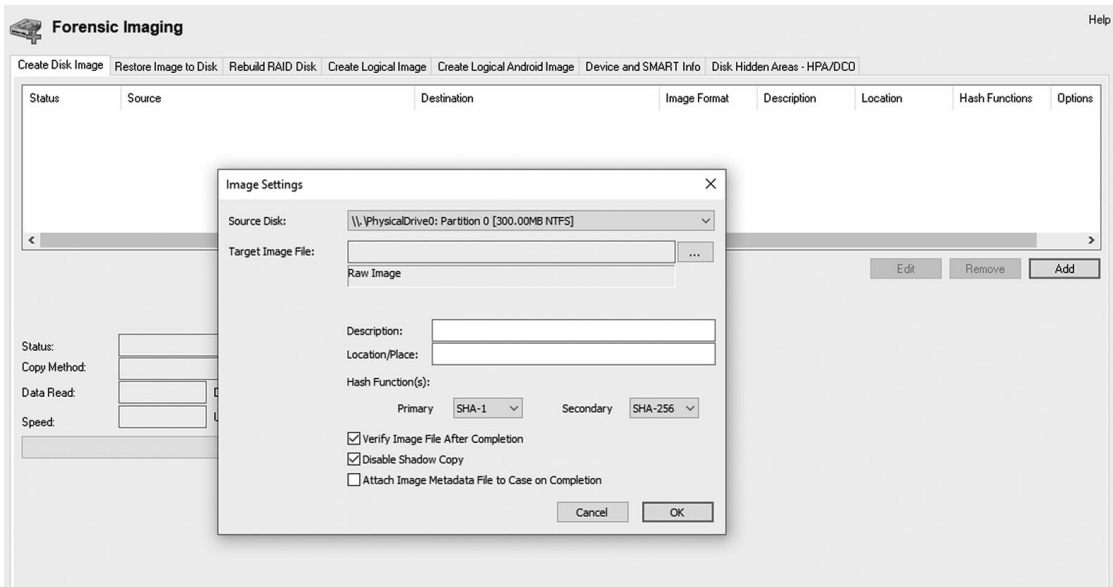


Figure 4-17 OSForensics Drive Imaging Step 2.

You now just start the process, and an image of the source drive will be created and verified for you.

RAID Acquisitions

RAID stands for “redundant array of independent disks.” You may already be comfortable with the concept of RAID; however, if you are not, this section provides a brief overview. The most common RAID levels are as follows:

- RAID 0 (**disk striping**) distributes data across multiple disks in a way that gives improved speed for data retrieval.
- RAID 1 mirrors the contents of the disks. The disk is completely mirrored so there is an identical copy of the drive running on the machine.
- RAID 3 or 4 (striped disks with dedicated parity) combines three or more disks in a way that protects data against loss of any one disk. Fault tolerance is achieved by adding an extra disk to the array and dedicating it to storing parity information. The storage capacity of the array is reduced by one disk.
- RAID 5 (striped disks with distributed parity) combines three or more disks in a way that protects data against the loss of any one disk. It is similar to RAID 3, but the parity is not stored on one dedicated drive; instead, parity information is interspersed across the drive array. The storage capacity of the array is a function of the number of drives minus the space needed to store parity.
- RAID 6 (striped disks with dual parity) combines four or more disks in a way that protects data against loss of any two disks.
- RAID 1+0 (or 10) is a mirrored data set (RAID 1), which is then striped (RAID 0)—hence the “1+0” name. A RAID 1+0 array requires a minimum of four drives: two mirrored drives to hold half of the striped data, plus another two mirrored drives for the other half of the data.

No matter what version of RAID you are using (except for RAID 1), what you have is an array of disks with data distributed across them. With RAID 1, the two disks are mirror copies of each other.

Some people have some difficulty understanding RAID 3, 4, 5, and 6 and specifically how the parity bit works to store data. It is all predicated on the basic mathematical operation of exclusive OR (XOR).

For example, suppose two drives in a three-drive RAID 5 array contained the following data:

Drive A: 01101111

Drive B: 11010100

To calculate parity data for the two drives, an exclusive OR is performed on their data:

01101111

XOR 11010100

10111011

The resulting parity data, 10111011, is then stored on Drive C.

Now if either Drive A or B fails, the data can be recreated. Let us assume that Drive B fails. We just exclusively OR the data stored on Drive C, with the data still on Drive A.

Drive A: 01101111

Drive c: 10111011

And you get back 11010100, which is the data originally on Drive B. This is how parity bits work in RAID.

Acquiring a RAID array has some challenges that are not encountered when acquiring a single drive. Some people recommend acquiring each disk separately. This is fine for RAID 1. Each disk is a separate entity. However with RAID 0, 3, 4, 5, and 6, there is data striping. The data is striped across multiple disks. In these situations, acquiring the disks separately is not recommended. Instead, make a forensic image of the entire RAID array—which requires you to copy it to a rather large target drive.



NOTE

FTK, OSForensics, and EnCase provide built-in tools for acquiring RAID arrays.

CHAPTER SUMMARY

In this chapter, you were introduced to some very specific procedures. These procedures govern how you will seize evidence, transport it, and prepare it for analysis. When you perform forensic analysis on drives, you gather very specific information and/or evidence. However, if the procedures outlined in this chapter are not followed carefully, any evidence subsequently gathered may be suspect. Failure to properly seize, transport, and handle evidence may even render the evidence inadmissible in a court of law.

KEY CONCEPTS AND TERMS

Disk striping

Hash

Metadata

Logical analysis

Physical analysis

Scrubber

Swap file

Sweeper

Temporary data

Unallocated space

Volatile data

CHAPTER 4 ASSESSMENT

1. What is the most commonly used hashing algorithm?
 - A. MD5
 - B. Whirlpool
 - C. SHA1
 - D. CRC
2. What Linux command can be used to create a hash?
 - A. SHA
 - B. MD5
 - C. MD5sum
 - D. Sha3sum
3. What Linux command can be used to wipe a target drive?
 - A. Del
 - B. Delete
 - C. nc
 - D. dd
4. RAID 4 should be acquired as individual disks.
 - A. True
 - B. False
5. Which of the following drives would be least susceptible to damage when dropped?
 - A. SCSI
 - B. SSD
 - C. IDE
 - D. SATA
6. It is acceptable, when you have evidence in a vehicle, to stop for a meal, if the vehicle is locked.
 - A. True
 - B. False

7. Which of the following might contain data that was live in memory and not stored on the hard drive?
- A. Swap file
 - B. Registry Hive
 - C. Backup File
 - D. Log file

CHAPTER LAB

1. Download a trial version of OSForensics from www.OSForensics.com.
2. Make an image of a machine using the steps outlined in this chapter. Note: you will need someplace to copy the image to, such as an external portable drive.



CHAPTER 5

Understanding Techniques for Hiding and Scrambling Information

© phyZick/Shutterstock

TECHNICALLY SAVVY CRIMINALS will try to hide evidence on their computers. There are any number of techniques one can use to either hide or protect information. That way, even if the computer is seized and searched, investigators are less likely to find the evidence. This chapter introduces the two ways of hiding and scrambling information: steganography and cryptography. These techniques predate modern computers. In fact, they are so old that they can trace their origins to ancient Greece. Steganography comes from the Greek *steganos*, meaning covered or protected. Cryptography comes from the Greek *kryptos*, to hide. Encrypted information is clearly scrambled, and not hidden, per se.

Chapter 5 Topics

This chapter covers the following topics and concepts:

- Understanding the use and detection of steganography
- Encryption

Chapter 5 Goals

When you complete this chapter, you will be able to:

- Understand steganography
- Use steganography
- Detect steganography
- Understand basic cryptography
- Utilize basic cryptography
- Understand general cryptanalysis techniques

Steganography

Steganography is the art and science of writing hidden messages. The goal is to hide information so that even if it is intercepted, it is not clear that information is hidden there. The most common method today is to hide messages in pictures. One of the most common methods of performing this technique is the **least significant bit (LSB)** method (when the last bit or least significant bit is used to store data). To be clear, this is not the only technical method for performing steganography, just the most common. The LSB method depends on the fact that computers store things in bits and bytes. Now consider for a moment an 8-bit byte. For example, consider 11111111. If you convert this to a decimal number, it equals 255. Now if you change the first 1 to a 0, you get 01111111. This equals 127 in decimal numbers, which is a pretty major change.

However, what if—instead of changing the first 0—you change the last 0? That would give you 11111110, which is equal to 254 in decimal numbers. This is a trivial change. That is why this last bit is called the least significant bit. Changing the least significant bit from a 0 to a 1 or from a 1 to a 0 makes the smallest change in the original information. Also, consider that if the steganographic software overwrites the least significant bit with a 0 and it was already a 0, or overwrites the least significant bit with a 1 and it was already a 1, then there is no change to the original information.

Colored pixels in a computer are stored in bits. In Windows, for example, 24 bit is the normal color resolution. If you examine the Windows color palette, you'll find that you define a color by selecting three values between 0 and 255 in the Red, Green, and Blue text boxes shown in **FIGURE 5-1**.

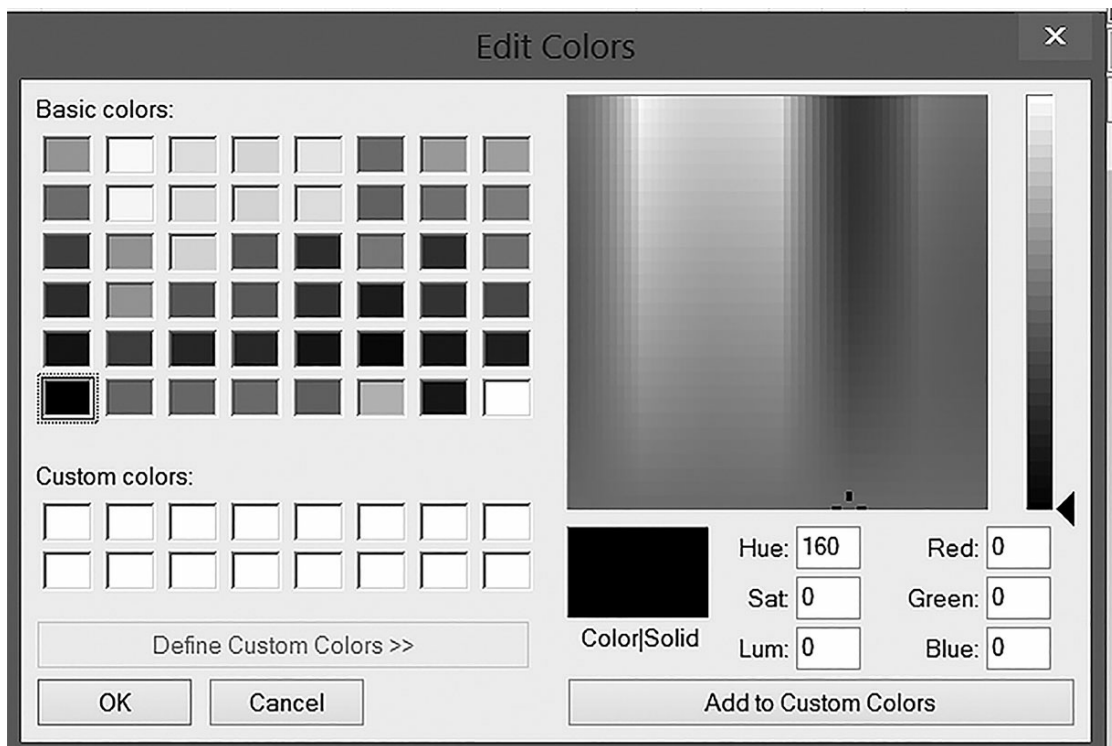


FIGURE 5-1 The Windows color palette in the Edit Colors dialog box.

Now consider what happens if you change just one bit. In [FIGURE 5-2](#), you see a color that is defined by three numbers: 252, 101, and 100.

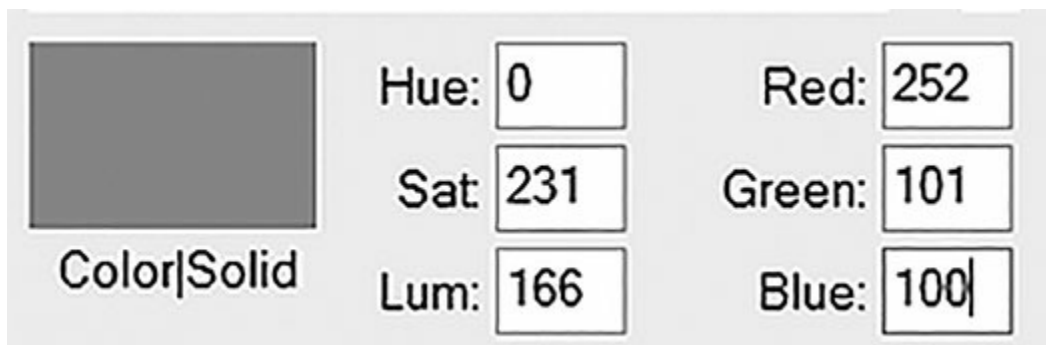


FIGURE 5-2 Windows color.

You can change the 101 by just one bit and make it 100, as you see in [FIGURE 5-3](#).

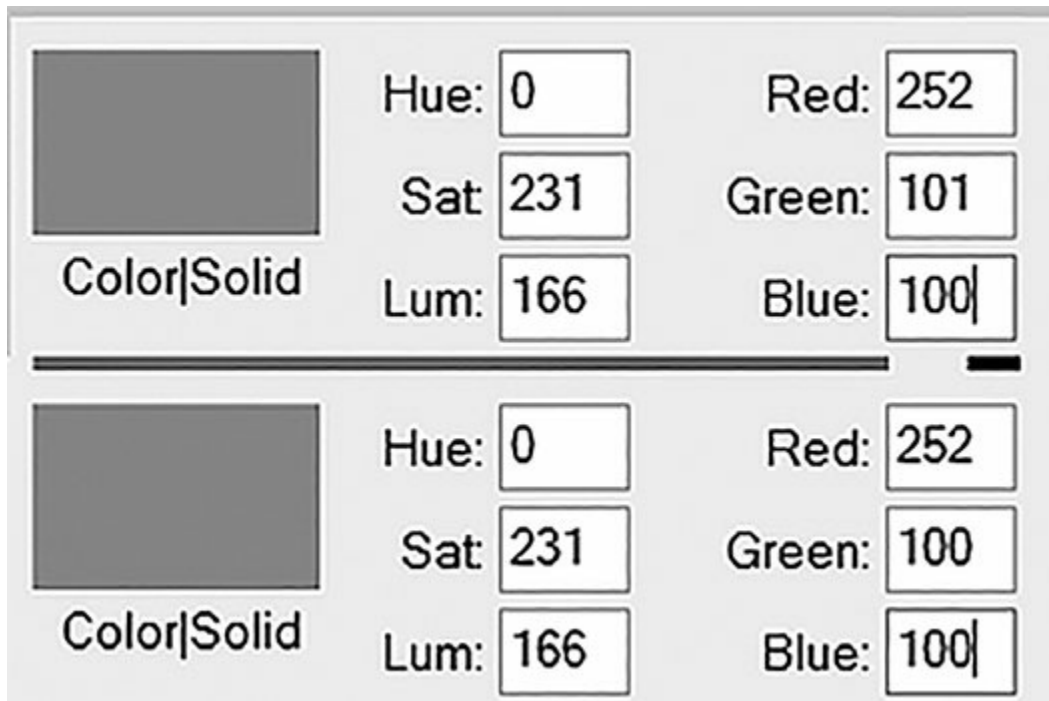


FIGURE 5-3 Windows color changed by one bit.

Your eye cannot really tell the difference; even if this book were in color, the difference would be impossible to detect. This is the basis for modern image steganography. If you change the least significant bit in a pixel, the image still looks the same. But a picture is made up of thousands—sometimes millions—of pixels. So by changing the least significant bit of many pixels, you can hide data in an image. If someone finds the image, even by using a tool such as Photoshop or GIMP (GNU Image Manipulation Program) to magnify the image, that person will not be able to see that data is hidden in it. Only by comparing the original image, bit by bit, to the steganized image can it be determined that information *may* be hidden within.

FYI

The following are some basic steganography terms you should know:

- **Payload** is the information to be covertly communicated. In other words, it is the message you want to hide.
- The **carrier** (or carrier file) is the signal, stream, or file in which the payload is hidden.
- The **channel** is the type of medium used. This may be a passive channel, such as photos, video, or sound files, or even an active channel, such as a Voice over IP (VoIP) voice call or streaming video connection.

It used to be the case that steganography required someone to be able to write specific computer program code to manipulate the bits in an image. This took training and skill; therefore, steganography was used only by computer professionals. However, a number of tools are now available on the web that will hide information within an image for you:

- **QuickStego** is very easy to use, but very limited.
- **Invisible Secrets** is much more robust, with both a free and a commercial version.
- **MP3Stego** hides a payload in MP3 files.
- **Stealth Files 4** works with sound files, video files, and image files.
- **StegVideo** hides data in a video sequence.
- **Deep Sound** hides data in sound files.

Historical Steganography

Obviously, using digital images and files to hide messages did not exist prior to the advent of modern computers. However, hiding messages is not new. It has been done since ancient times. The following methods were once used to hide messages:

- The ancient Chinese wrapped notes in wax and swallowed them for transport. This was a crude but effective method of hiding messages.
- In ancient Greece, a messenger's head might be shaved, a message written on his head, then his hair was allowed to grow back. Obviously, this method required some time to work effectively.
- The German scholar Johannes Trithemius (1462–1516) wrote a book on cryptography and described a technique where a message was hidden by having each letter taken as a word from a specific column.
- During World War II, the French Resistance sent messages written on the backs of couriers using invisible ink.



NOTE

It is a common practice for pornographers, cybercriminals, terrorists, and others to cache steganized files on the servers or file stores of unsuspecting third parties and to use such locations as “dead drops”—a place where the criminal can deliver the data to its intended recipient without actually physically meeting the recipient—without the knowledge of the third party.

Steganophony

Steganophony is a term for hiding messages in sound files. This can be done with the LSB method; however, another method that can be used for steganophony is the echo method. This method adds extra sound to an echo inside an audio file. It is that extra sound that contains information. Steganophony can be used with static files, such as MP3 files, but can also be used dynamically with VoIP and similar multimedia technologies, also utilizing the LSB method and imperceptibly changing the sound being transmitted.

Video Steganography

Information can also be hidden in video files, a practice called *video steganography*. There are various ways to do this, including the LSB method. Whatever method is used, it is important to realize that video files are obviously larger than other file types. This provides a great deal of opportunity for hiding information.

More Advanced Steganography

While simply using least significant bits, particularly with an image, is rather common and widely used steganography, it is not the only option. One other option is Bit-Plane Complexity Segmentation Steganography (BPCS).

Since the carrier is often an image that stores colors in 24 bits, this fact can be used to increase the storage area for payload. The complex areas on the bit planes are replaced with the payload. A bit plane of any discrete digital file is the set of bits that correspond to a given bit position. For example, in 24-bit files, there are 24 bit planes. This can be applied to signals as well as files.

Steganalysis

Steganalysis is the process of analyzing a file or files for hidden content. It is a difficult task. At best, it can show a likelihood that a given file has additional information hidden in it. A common method for detecting LSB steganography is to examine close-color pairs. Close-color pairs consist of two colors that have binary values that differ only in the LSB. If this is seen too frequently in a given file, it can indicate that steganographically hidden messages may be present.

Before we dive into technical methods for detecting steganography, there are some easy-to-use indicators of steganography that are important. The first is examining metadata about a given image or sound file. Two pieces of data are of greatest interest: the created date and the last-modified date. The created date is not when the file was originally created, but rather when it was created *on that device*. If you download an mp4 file, then the date/time you download it to your computer will be the created date. The last-modified date indicates when it was last changed. Most people do not modify music files; they usually just download music, perhaps from Google Play or Apple Music. Either the last-modified date and created date will be the same, or the last-modified date will be

older. If the last-modified date is newer, this indicates the file has been modified since it was downloaded. If that person has music editing software and is known to mix music, then that explains the date discrepancy. However, if that is not the case, then steganography should be considered.

Many steganography tools don't do a really good job of steganography and actually bloat the target file's size. This means seeing a file with an incongruous size could indicate possible steganography. If a suspect has a collection of 100 vacation pictures, all of which are roughly 2 megabytes in size, but one is 4 megabytes in size, it may be worthwhile to analyze that image.

Aside from these indicators, there are several technical methods for analyzing an image to detect hidden messages. The raw quick pair method is one. It is based on statistics of the numbers of unique colors and close-color pairs in a 24-bit image. Basically, it performs a quick analysis to determine if there are more close-color pairs than would be expected.

Another option uses the chi-square method from statistics. Chi-square analysis calculates the average LSB and builds a table of frequencies and a second table with pairs of values. Then it performs a chi-square test on these two tables. Essentially, it measures the theoretical versus the calculated population difference. When analyzing audio files, you can use steganalysis, which involves examining noise distortion in the carrier file. Noise distortion could indicate the presence of a hidden signal.

Many modern forensic tools also check for the presence of steganographically hidden messages. Forensic Toolkit (FTK) and EnCase both check for steganography, and FTK has an entire image detection engine devoted to this task. Details about this feature of FTK can be found at <https://accessdata.com/blog/image-detection-or-image-recognition-quin-c-does-both>.

There are several free or inexpensive tools for detecting steganography:

- McAfee has an online steganography detection tool: <https://www.mcafee.com/enterprise/en-us/downloads/free-tools/steganography.html>
- Steg Secret is another tool: <http://stegsecret.sourceforge.net/>
- StegSpy has fewer limitations than StegDetect: <http://www.spy-hunter.com/stegspydown-load.htm>

Be aware that none of these methods is perfect. A great deal depends on the size of the payload compared with the size of the carrier file. This determines what percentage of the bits need to be changed. For example, if you have a 10-kilobyte text message in a 2-megabyte image file, it will be hard to detect. However, if you hide a 1-megabyte image in a 4-megabyte image, it will be easier to find.

It is also the case that the specific steganographic tool you use will determine how reliable steganalysis tests are. Some stego tools are more efficient than others. Depending upon how well information has been hidden, and if it is encrypted, it may be impossible to detect.

Invisible Secrets

A forensic examiner must be very familiar with steganography. This means you should be able to do steganography. Many tools are available on the web. In this section, you will learn about a tool called Invisible Secrets. This tool is very inexpensive and a free trial version is available. It is also easy to use.

You can download Invisible Secrets from <https://www.east-tec.com/invisiblesecrets/download/>. First, you must choose whether you want to hide a file or extract a hidden file. For this example, suppose you want to hide a file. You select your chosen option in the Invisible Secrets Select Action dialog box, shown in **FIGURE 5-4**, and then click the Next button.

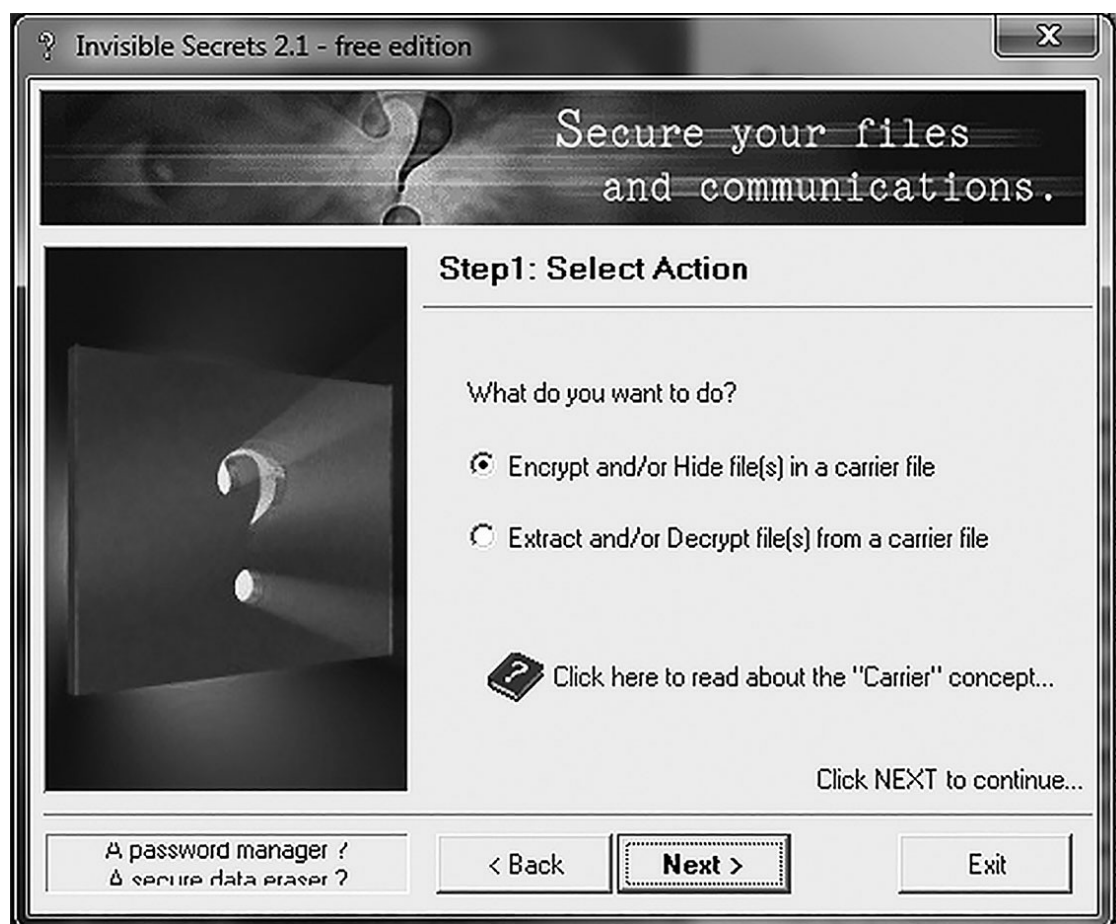


FIGURE 5-4 Choose to hide a file or extract a hidden file in the Invisible Secrets Select Action dialog box.

Now select an image you want to use as the carrier file. You can see this in **FIGURE 5-5**. Select the file you want to hide. It can be a text file or another image file. You can also choose to encrypt as well as hide. This is shown in **FIGURE 5-6**.



FIGURE 5-5 Select an image to use as the carrier file in the Invisible Secrets Select Carrier File dialog box.

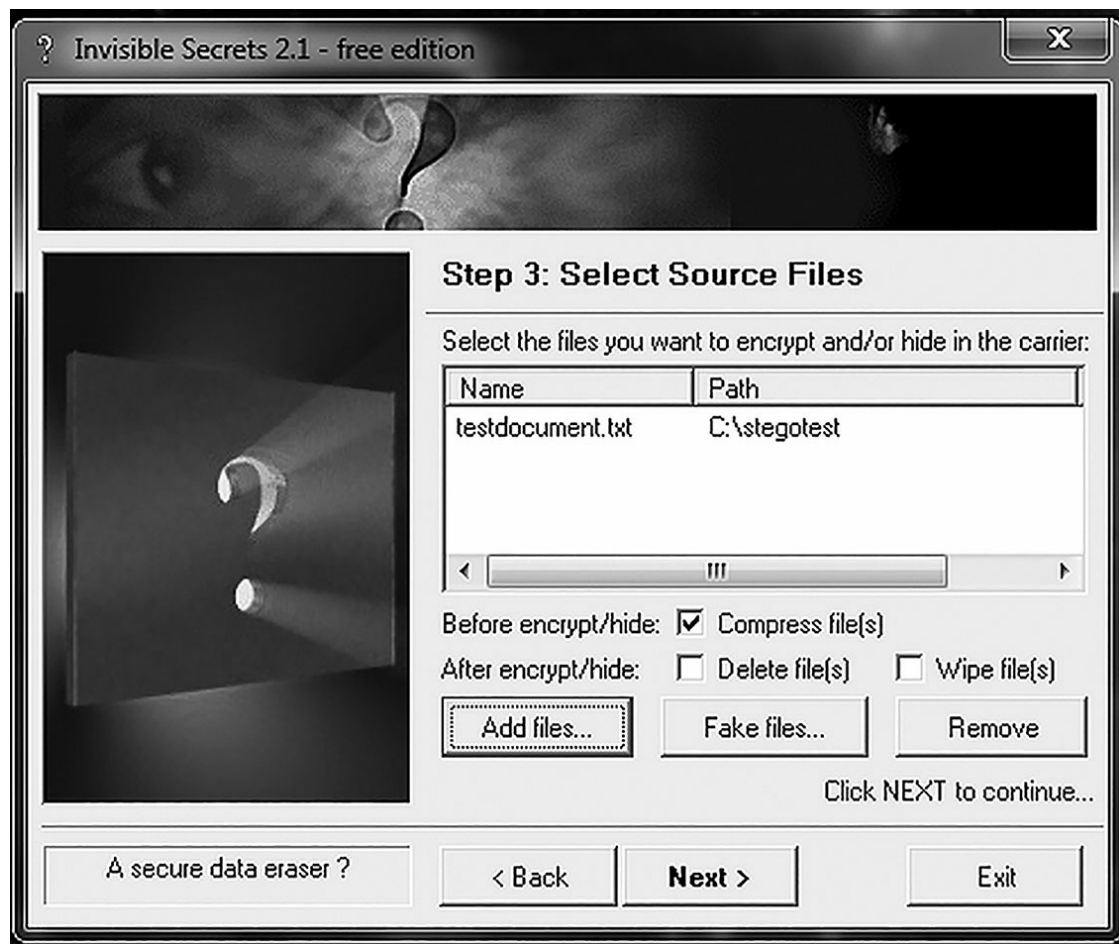


FIGURE 5-6 Select the file to hide in the Invisible Secrets Select Source Files dialog box.

Now, select a password for your hidden file, as shown in [FIGURE 5-7](#).



FIGURE 5-7 Select a password in the Invisible Secrets Encryption Settings dialog box.

Next, pick a name for the resulting file that contains your hidden file, as shown in **FIGURE 5-8**.

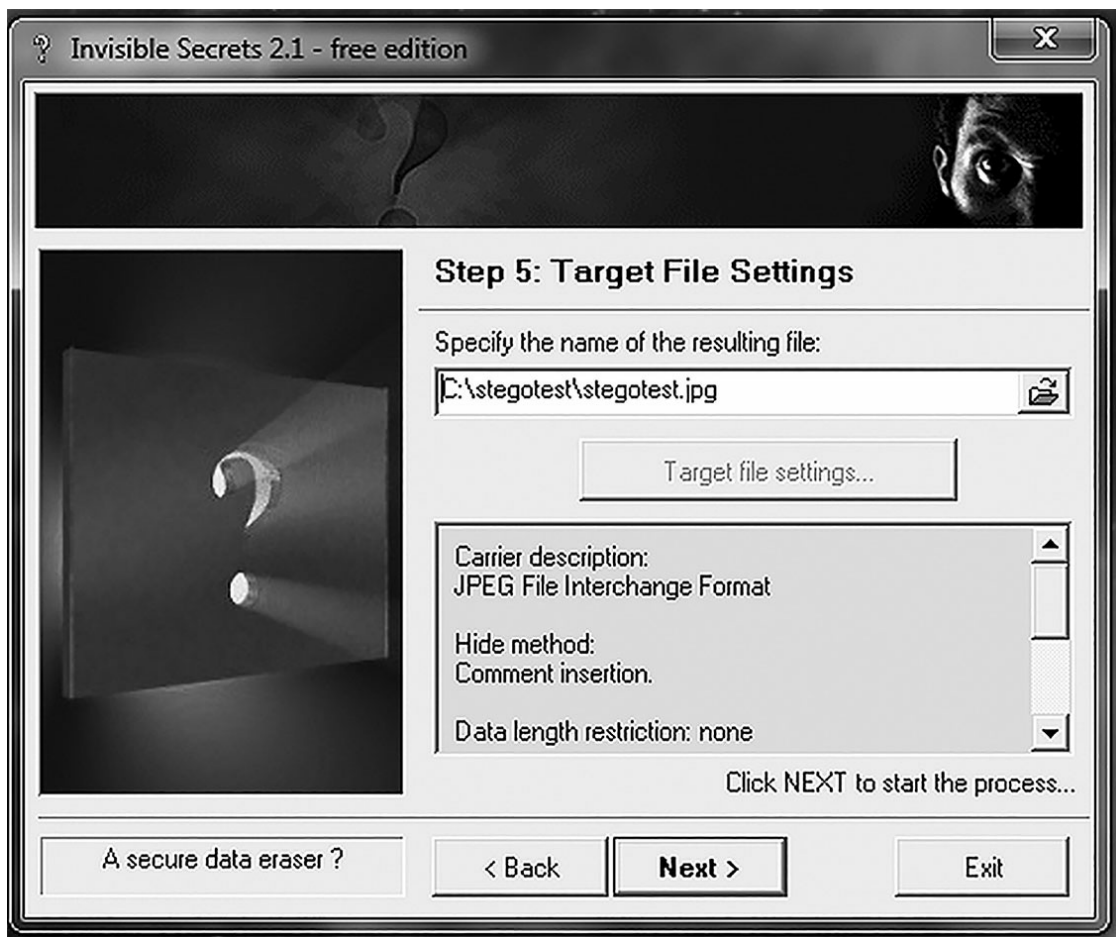


FIGURE 5-8 Name the new file in the Invisible Secrets Target File Settings dialog box.

That's it. You have just done steganography. Now consider this for just a moment. If it is that easy and tools are available on the internet, then this is something many criminals probably use. Fortunately, not all criminals are tech savvy, so you will still find many computers with evidence that is not hidden with steganography. However, during your career as a forensic examiner, you will come across steganography from time to time, and more often in complex cases involving organized crime, spying, and terrorism.

FYI

During the raid on Osama Bin Laden's compound, which resulted in his death, a number of computer hard drives were found. On those hard drives, a number of pornographic videos were discovered. It was later determined, using computer forensics, that these videos contained steganographically hidden messages. It is clear that Bin Laden was communicating with terrorist cells via steganography.

MP3Stego

You can download the program MP3Stego from <http://www.petitcolas.net/steganography/mp3stego/>. This program is used to hide data in MP3 files. It takes the information (usually text) and combines it with a sound file to create a new sound file that contains the hidden information. The MP3Stego readme file provides these instructions:

- `encode -E data.txt -P pass sound.wav sound.mp3`—Compresses sound.wav and hides data.txt, using the password “pass.” This produces the output called sound.mp3. The text in data.txt is encrypted using pass.
- `decode -X -P pass sound.mp3`—Uncompresses sound.mp3 into sound.mp3. pcm and attempts to extract hidden information. The -P flag denotes the following password “pass.” The hidden message is decrypted, uncompressed, and saved into sound.mp3.

This is a very simple program to use and it is freely available on the internet.

Deep Sound

This tool is a free download from <http://jpinsoft.net/deepsound>. It allows one to hide files in mp3, wav, cda, and other file formats. It is very easy to use. A screenshot of the main screen of Deep Sound is shown in **FIGURE 5-9**.



FIGURE 5-9 Deep Sound main screen.

Like many steganography tools, this one is very easy to use. It is self-explanatory. The ease of use, along with the product being free, makes finding steganographically hidden evidence more likely than it was in the past.

Additional Resources

The information provided here is enough steganography for you to work as a forensic examiner, but if you want to learn more, you might find the following resources of value (a full citation and URL for each reference can be found in the references list at the end of the chapter):

- The online publication Towards Data Science published an article on steganography with Python in May 2020.¹
- InfoSec Institute published an article on steganography tools in July 2020.²
- A 2019 technical paper by two Egyptian researchers published in an open access forum describes a steganography technique.³

- An undated article from a digital security company describes detecting steganography in images.⁴

Encryption

Cryptography is not so much about hiding a message, as with steganography, but rather about obfuscating the message so that it cannot be read. In other words, with steganography, the examiner may not even be aware a message is present. With cryptography, it is obvious there is a message present, but the examiner cannot easily decipher the message. The word cryptography is derived from word *kryptós*, which means *hidden*, and the verb *gráfo*, which means *I write*. Therefore, cryptography is the study of writing secret messages.

FYI

Cryptography is an area in which many security professionals, including forensic examiners, are weak. Even the major security certifications give only a cursory coverage of cryptography. It is particularly important for forensic examiners to be more knowledgeable about cryptography. This section provides a thorough introduction to the field.



NOTE

Technically speaking, cryptography is the study of encryption and decryption methods; cryptanalysis is the study of breaking ciphers; and cryptology is the combination of cryptography and cryptanalysis. But, like many books, we will use cryptography and cryptology synonymously.

The History of Encryption

Encrypting communications is almost as old as writing. Throughout history, people have wanted to keep their communications private. Although for much of human history this has been a requirement primarily for governments, militaries, and businesses, in modern times private individuals also have had a need for cryptography.

The concept of cryptography is actually pretty simple. Messages must be changed in such a way that they cannot be read easily by any party that intercepts them but can be decoded easily by the intended recipient. Modern methods usually depend on some combination of mathematics and information theory. First, it is a good idea to start by examining a few historical methods of encryption. Keep in mind that these historical methods are no longer considered secure. They can be cracked in seconds by modern computers. But they are very useful for the novice to begin learning the encryption process.

The Caesar Cipher

The **Caesar cipher** is purported to have been used by the ancient Roman Caesars, such as Julius Caesar—hence the name. This method is also referred to as a substitution cipher. Almost every introductory cryptography book in existence mentions the Caesar cipher. It is even mentioned in the course material for several prominent network security certifications. It is actually quite simple to do. You choose some number by which to shift each letter of a text and substitute the new alphabetic letter for the letter you are encrypting. For example, if the text is

A CAT

and you choose to shift by two letters, then *C* replaces *A*, *E* replaces *C*, *C* replaces *A*, and *V* replaces *T*. The encrypted message is

C ECV

Or, if you choose to shift by three letters, the encrypted message becomes

D FDW

You can choose to shift by any number of letters, either left or right. If you choose to shift 2 to the right, that would be a +2; if you choose to shift 4 to the left, that would be a -4. If you get to the end of the alphabet, just keep going back to the beginning. So if you are shifting to the right and need to go past Z, just start over at A. Julius Caesar was reputed to have used a shift of 3 to the right.

Because this is a very simple method to understand, it is a good place to start your study of encryption. It is, however, extremely easy to crack using the two major forms of attacking text for decryption. The first is a **brute-force attack**. If a Caesar cipher is suspected, modern computers can simply try all possible combinations and see if recognizable text emerges. Frankly, you could do this with pen and paper. With any cipher there is the concept of key space, which is the total number of possible keys. With a Caesar cipher applied to the English language, there are only 26 possible keys. You could easily try all of those in just a few minutes.

The second approach is based on the attacker's knowledge of the underlying language. The Caesar cipher is easy to crack using an academic approach because of letter and word frequency. Any language has a certain letter and word frequency, meaning that some letters or words are used more frequently than others. In the English language, the most common single-letter word is *a*. The most common three-letter word is *the*. Those two rules alone could help you decrypt a Caesar cipher. For example, if you saw a string of seemingly nonsense letters and noticed that a three-letter word was frequently repeated in the message, you might easily surmise that this word was *the* and the odds are highly in favor of this being correct. Furthermore, if you frequently noticed a single-letter word in the text, it is most likely the letter *a*. You now have found the substitution scheme for *a*, *t*, *h*, and *e*. You can now either translate all of those letters in the message and attempt to guess the rest, or simply analyze the substitute letters used for *a*, *t*, *h*, and *e* and derive the substitution cipher that was used for this message.

Decrypting a message of this type does not even require a computer. Someone with

no background in cryptography could do it in less than 10 minutes using pen and paper. A popularized example is in the movie *A Christmas Story*, where schoolboy Ralphie decrypts the message “Be sure to drink your Ovaltine.” There are other rules that help make cracking this code even easier. For example, in the English language, the two most common two-letter combinations are *ee* and *oo*. That gives you even more to work with.

The substitution scheme you choose (e.g., +2, +1) is referred to as a substitution alphabet (i.e., *b* substitutes for *a*, *u* substitutes for *t*, and so on). Thus, the Caesar cipher is also referred to as a monoalphabet or single-alphabet substitution method, meaning that it uses a single substitution for the encryption. That just means that all letters in the plaintext are shifted by the same number.

In any cryptographic algorithm, be it a simple one like the Caesar cipher or a more modern one, the number that is used by the algorithm to encrypt or decrypt a message is called the *key*, because it unlocks the scrambled information. In the case of the Caesar cipher, it is a single digit (like +2), and in the case of modern algorithms like Advanced Encryption Standard (AES), it is a 128-bit number. Even though the Caesar cipher may have a much simpler algorithm (shift the letters by whatever number and direction is in the key) and a smaller key (a single digit, or at most two digits, as in +12 or -11), it is still an example of the basic concepts you see in more sophisticated modern cryptographic algorithms.

The Caesar cipher also introduces two more basic concepts of cryptography. The text you want to encrypt is referred to as the *plaintext*. After it has been subjected to the algorithm and key, the resultant text is called the *ciphertext*. So, although simple, the Caesar cipher introduces cryptography algorithms, keys, plaintext, and ciphertext.

This example gives you a primitive introduction to cryptography and encryption. It must be stressed that the Caesar cipher is no longer a secure method of encrypting messages, but it is an interesting exercise to begin introducing the basic concepts of encryption.

The Atbash Cipher

Hebrew scribes copying the book of Jeremiah used the Atbash cipher. This cipher is very simple—just reverse the alphabet. This is also, by modern standards, a very primitive and easy-to-break cipher. But it will help you get a feel for how cryptography works.

The Atbash cipher is a Hebrew code that substitutes the first letter of the alphabet for the last letter and the second letter for the second-to-last letter, and so forth. It simply reverses the alphabet. This, like the Caesar cipher, is a single-alphabet substitution cipher. A becomes Z, B becomes Y, C becomes X, and so on.

The ROT13 Cipher

The ROT13 cipher is another single-alphabet substitution cipher. It is, in fact, the simplest of all of them. It is really just a permutation of the Caesar cipher. All characters are rotated 13 characters through the alphabet. The phrase

A CAT

becomes

N PNG

It is essentially the Caesar cipher, but always using a rotation or shift of 13 characters. This is very simple and not sophisticated enough for any real security. But, again, it can be done with pen and paper, or with a simple computer program.

The Scytale Cipher

The *scytale*, which rhymes with Italy, was a cylinder or baton used by the Greeks, and is often specifically attributed to the Spartans. This physical cylinder was used to encrypt messages. Turning the cylinder produced different ciphertexts. Although it is not clear exactly how old this cipher is, it was first mentioned in the 7th century BC by the Greek poet Archilochus. The recipient used a rod of the same diameter as the one used to create the message. He then wrapped the parchment to read the message. To encrypt, he simply wrote across a leather strip attached to a rod. To decrypt, the recipient would just wrap the leather strip around the rod and read across. This was a simple process; it just required both parties have the same size rod and the leather “key.”

The Playfair Cipher

The Playfair cipher was invented in 1854 by Charles Wheatstone; however, it was popularized by Lord Playfair, so it bears his name. While it was first rejected by the British government as being too complex, it was actually used by the British military in World War I and to some extent in World War II. This cipher works by encrypting pairs of letters, also called digraphs, at a time.

The Playfair cipher uses a 5×5 table that contains a keyword or key phrase. To use the Playfair cipher, one need only memorize that keyword and four rules. First break the plaintext message into digraphs. Thus, “Attack at Dawn” becomes “At ta ck at da wn.” If the final digraph is just a single letter, you can pad it with a letter z.

Any square of 5×5 letters can be used. You first fill in the keyword, then start, in order, adding in letters that did not appear in the keyword. I/J are combined. You can see this in the table on the next page. In this example the keyword is “falcon,”

F	A	L	C	O
N	B	D	E	G
H	I/J	K	M	P
Q	R	S	T	U
V	W	X	Y	Z

Since the 5×5 matrix is created by starting with a keyword, then filling in letters that did not appear in the keyword, the matrix will be different when different keywords are used. The next step is take the plaintext, in this case “attack at dawn,” and divide it into digraphs. If there are any duplicate letters, replace the second letter with an X. For example, “dollar” would be “dolxar.” Playfair does not account for numbers or punctuation marks, so you will need to remove any punctuation from the plaintext and spell out any numbers. Next, you take the plaintext—in our case

At ta ck at da wn

and find the pairs of letters in the table. Look to the rectangle formed by those letters. In our example, the first letters are AT, thus forming the rectangle shown below, with A in the upper left-hand corner and T in the lower right-hand corner.

A	L	C
B	D	E
I/J	K	M
R	S	T

Then you will take the opposite ends of the rectangle to create the ciphertext. A is in the upper left-hand corner, so you replace it with whatever appears in the upper right-hand corner, which in this case is the letter C. T is in the lower right-hand corner, so you replace it with whatever letter is in the lower left-hand corner, which in this case is the letter R. So AT gets enciphered as CR. Continuing on, the next pair of letters is TA and will form the same rectangle. However, since T is the first letter of the plaintext, R will be

the first letter of the ciphertext, yielding RC. Next we have CK. Those letters form the rectangle shown here.

A	L	C
B	D	E
I/J	K	M

C becomes A, and K becomes M, so we have AM. If you continue this process through to the end of the plaintext, you will have “Attack at dawn” encrypted to yield

CRRCLMCRBLVB

If you really wish to learn the Playfair cipher you should work with this by hand, with pencil and paper. But you can check your work with online Playfair calculators:

<https://planetcalc.com/7751/>

<https://www.geocachingtoolbox.com/index.php?lang=en&page=playfairCipher>

Multialphabet Substitution

Eventually, a slight improvement on the Caesar cipher was developed, called multialphabet substitution. In this scheme, you select multiple numbers by which letters in the plaintext will be shifted; in other words, multiple substitution alphabets are created. For example, if you select three substitution alphabets (+2, -2, +3), then A CAT becomes C ADV. Notice that the fourth letter starts over with another +2, and you can see that the first A was transformed to C and the second A was transformed to D. This makes it more difficult to decipher the underlying text. Although this is harder to decrypt than a Caesar cipher, it is not overly difficult. It can be done with simple pen and paper and a bit of effort. It can be cracked very quickly by a computer. In fact, no one would use such a method today to send any truly secure message, because this type of encryption is considered very weak.

The Vigenère Cipher

One of the most widely known multialphabet ciphers was the **Vigenère cipher**. This cipher was invented in 1553 by Giovan Battista Bellaso. It is a method of encrypting alphabetic text by using a series of different monoalphabet ciphers selected based on the letters of a keyword. This algorithm was later misattributed to Blaise de Vigenère, and so it is now known as the Vigenère cipher, even though Vigenère did not really invent it.

You use the table (shown in **FIGURE 5-10**) along with a keyword you have selected. Match the letter of your keyword on the top with the letter of your plaintext on the left to find the ciphertext. Using the table shown in **FIGURE 5-10**, if you are encrypting the word *cat* and your keyword is *horse*, then the ciphertext is *jok*.

	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
A	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
B	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A
C	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B
D	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C
E	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D
F	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E
G	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F
H	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G
I	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H
J	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I
K	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J
L	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K
M	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L
N	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M
O	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N
P	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O
Q	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P
R	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q
S	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R
T	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S
U	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T
V	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U
W	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V
X	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W
Y	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X
Z	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y

FIGURE 5-10 Vigenère table.

Multialphabet ciphers are more secure than single-alphabet substitution ciphers. However, they are still not acceptable for modern cryptographic usage. Computer-based cryptanalysis systems can crack historical cryptographic methods (both single-alphabet and multialphabet) very easily. This chapter presents the single-alphabet substitution and multialphabet substitution ciphers just to show you the history of cryptography and to help you get an understanding of how cryptography works.

The Enigma Machine

In World War II, the Germans made use of an electromechanical rotor-based cipher system known as the Enigma machine. The Enigma machine is pivotal in the history of cryptography. It is a multialphabet substitution cipher using machinery to accomplish the encryption. There are multiple variations on this machine.

The machine was designed so that when the operator pressed a key, the encrypted ciphertext for that plaintext was altered each time. So, if the operator pressed the *A* key, he or she might generate an *F* in the ciphertext, and the next time it might

be a *D*. Essentially, this was a multialphabet cipher, consisting of 26 possible alphabets.

Allied cipher machines used in World War II included the British TypeX and the American SIGABA. Both of these were quite similar to the Enigma machine, but with improvements that made them more secure. The Enigma machine and its variations were essentially mechanical implementations of multialphabet substitution.

Modern Cryptography

The History of Encryption section was designed to give you a feel for cryptography. Some forms, like the Caesar cipher, can even be done with pen and paper. Modern cryptography methods, as well as computers, make decryption a rather advanced science. Therefore, encryption must be equally sophisticated to have a chance of success. It is also important to realize that cryptographic methods have evolved quite a bit since the days of these ancient ciphers.

Modern cryptography is separated into two distinct groups: symmetric cryptography and asymmetric cryptography. Symmetric cryptography uses the same key to encrypt and decrypt the plaintext, while asymmetric cryptography uses different keys to encrypt and decrypt the plaintext. In this section, you will learn about both methods.

FIY

Beware of Algorithms Too Good to Be True

As you are discovering in this chapter, the basic concepts of encryption are very simple. Anyone with even rudimentary programming skills can write a program that implements one of the simple encryption methods examined here. However, these methods are not secure and are only included to illustrate fundamental encryption concepts.

From time to time, someone new to encryption discovers these basic methods and, in their enthusiasm, attempts to create their own encryption method by making some minor modifications. Although this can be a very stimulating intellectual exercise, it is only that. Users without training in advanced math or cryptography are extremely unlikely to stumble across a new encryption method that is effective for secure communications.

Amateurs frequently post claims that they have discovered the latest, unbreakable encryption algorithm on the Usenet newsgroup sci.crypt (if you are not familiar with Usenet, those groups are now accessible via the Groups link on <http://www.google.com>). Their algorithms are usually quickly broken. Unfortunately, some people implement such methods into software products and market them as secure.

Some distributors of insecure encryption methods and software do so out of simple greed and are intentionally defrauding an unsuspecting public. Others do so out of simple ignorance, honestly believing that their method is superior. Methods for evaluating encryption claims are discussed later in this chapter.

Kerckhoffs' Principle

Kerckhoffs' principle states that the security of a cryptographic algorithm depends

only on the secrecy of the key, not the algorithm itself. For practical purposes, this means that the details of a cryptographic algorithm can be made public. In fact, all the major algorithms discussed here are published. You can get all the details online or in books. This does not undermine the security of the algorithm. In fact, it enhances it. Publishing the algorithm allows cryptographic researchers to analyze the algorithm and to search for flaws in it. The opposite of Kerckhoffs' principle is an application of the principle of "security by obscurity" to the underlying cryptographic algorithm—that is, the algorithm is kept secret. Although this is a fairly common practice, it does not contribute to the secrecy of encrypted information—in fact, quite the opposite.

Symmetric Cryptography

Symmetric cryptography refers to those methods where the same key is used to encrypt and decrypt the plaintext. One step that has been used widely is to use two different encryption keys, one from sender to receiver and one from receiver to sender. This is still symmetric cryptography because the same key is used for encryption as is used for decryption—having different keys in both directions just provides additional security if the keys are learned or disclosed. This is historically the type of encryption that has been used exclusively until recently.

Substitution and Transposition.

Substitution is changing some part of the plaintext for some matching part of the ciphertext. The Caesar and Atbash ciphers are simple substitution ciphers. The Vigenère cipher is a bit more complex, but is still a substitution cipher. They are substitution ciphers because each single character of plaintext is converted into a single character of ciphertext.

Transposition is the swapping of blocks of ciphertext. For example, if you have the text "I like ice cream," you could transpose or swap every three-letter sequence (or block) with the next and get:

ikel l creiceam

Of course, modern transposition is at the level of bits, or rather blocks, or contiguous groups, of bits. However, this illustrates the concept. All modern block-cipher algorithms use both substitution and transposition. The combination of substitution and transposition increases the security of the resultant ciphertext. Modern symmetric ciphers perform a complex series of substitutions and transpositions.

Block Ciphers and Stream Ciphers

There are two types of symmetric algorithms: block ciphers and stream ciphers. A **block cipher** literally encrypts the data in blocks; 64-bit blocks are quite common, although some algorithms (like AES) use larger blocks. For example, AES uses a 128-bit block. **Stream ciphers** encrypt the data as a stream, one bit at a time.

There are a few basic facts that are generally applicable to all block ciphers. Assuming the actual algorithm is mathematically sound, then the following is true:

- Larger block sizes increase security.

- Larger key sizes increase security against brute-force attack methods.
- If the round function is secure, then more rounds increase security to a point.

Now, the real caveat here is the “assuming the algorithm is mathematically sound” part. If the algorithm is mathematically sound, these facts hold true. If the algorithm is not sound, a larger block size or larger key size may have little impact on security. This takes us back to Kerckhoffs’ principle, mentioned previously. It is important that any cryptographic algorithm be rigorously examined by mathematicians and cryptographers to ensure that it is sound.

The Feistel Function

This function is named after its inventor, the German-born physicist and cryptographer Horst Feistel. At the heart of many block ciphers is a **Feistel function**. So this makes it a good place to start your study of symmetric algorithms. This function forms the basis for many, if not most, block ciphers. This makes it one of the most influential developments in symmetric block ciphers. It is also known as a Feistel network or a Feistel cipher. Any block cipher that is based on Feistel will essentially work in the same manner; the differences will be found in what is done in the round function.

The Feistel function starts by splitting the block of plaintext data (often 64 bits) into two parts (traditionally termed L_0 and R_0). Usually the split is equal—both sides are the same size. However, there are variations where this is not the case.

The round function F is applied to one of the halves. The term *round function* simply means a function performed with each iteration, or round, of the Feistel cipher. The details of the round function F can vary with different implementations. Usually, these are relatively simple functions, to allow for increased speed of the algorithm.

The output of each round function F and the remaining half of the data are then run through the exclusive OR (XOR) function. This means, for example, that you take L_0 , pass it through the round function F , then take the result and XOR it with R_0 .

Then, the halves are transposed, or their positions switched. This means L_0 gets moved to the right and R_0 gets moved to the left. This process is repeated a given number of times. The main difference between different cryptographic algorithms that are Feistel ciphers is the exact nature of the round function F and the number of iterations. A simple diagram of this process is shown in **FIGURE 5-11**.

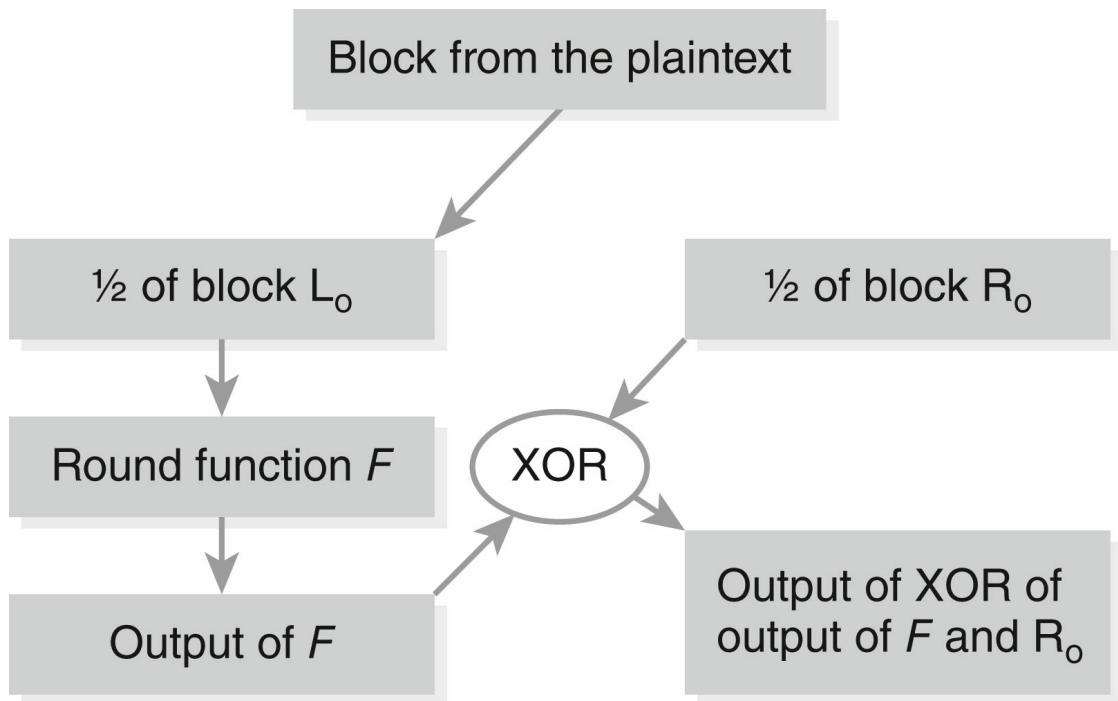


FIGURE 5-11 Feistel function.

A Brief Review of Binary Operations

When working with binary numbers, there are three logical operations not found in normal math: AND, OR, and XOR operations. Each is illustrated below.

AND

To perform the AND operation, you take two binary numbers and compare them one place at a time. If both numbers have a 1 in both places, then the resultant number is a 1. If not, then the resultant number is a 0, as you see here:

```

1101
1001
-----
1001
  
```

OR

The OR operation checks to see whether there is a 1 in either or both numbers in a given place. If so, then the resultant number is 1. If not, the resultant number is 0, as you see here:

```
1101
1001
-----
1101
```

XOR

The exclusive OR (XOR) operation affects your study of encryption the most. It checks to see whether there is a 1 in a number in a given place, but not in both numbers at that place. If it is in one number but not the other, then the resultant number is 1. If not, the resultant number is 0, as you see here:

```
1101
1001
-----
0100
```

The XOR function has a very interesting property in that it is reversible. If you XOR the resultant number with the second number, you get back the first number. And if you XOR the resultant number with the first number, you get the second number.

```
0100
1001
-----
1101
```

Data Encryption Standard

One of the oldest of the modern symmetric ciphers is the Data Encryption Standard (DES). DES was developed by IBM in the early 1970s. DES is a block cipher. It was a U.S. government standard until the 1990s. IBM had originally developed a cipher called Lucifer, which was designed by Horst Feistel. When the U.S. government began seeking a standardized encryption algorithm, IBM worked with the National Security Agency (NSA) to alter Lucifer to fit the government's needs; thus DES was created. As you might guess, DES is a Feistel cipher.

The basic concept of DES is as follows:

1. Data is divided into 64-bit blocks.
2. That data is then manipulated by 16 separate steps of encryption involving

substitutions, bit-shifting, and logical operations using a 56-bit key.

3. Data is then further scrambled using a swapping algorithm.
4. Data is finally transposed one last time.

Those four steps provide a simplified, high-level view of DES. As you can see, it works on splitting the block into two sections, as with all Feistel ciphers. The idea is to continually scramble the underlying message to make it appear as random as possible.

To generate the keys for each round, the 56-bit key is split into two 28-bit halves, and those halves are circularly shifted after each round by 1 or 2 bits. In other words, the halves are first subjected to a round function, then the keys are shifted by 1 to 2 bits each time so they can be used in the next round as a different key. Then 48 bits from those two halves are selected and permuted to form the round key. This means there is a different round key for each round—but it is related to the previous round key. In fact, it is derived from the previous round key.

DES uses eight S-boxes. The term *S-boxes* means substitution boxes. They are simply lookup tables. Each S-box basically has a table that determines, based on the bits passed into it, what to substitute for those bits. Each item passed into the box is substituted with the item that matches it in the lookup table. This is a very common tactic in symmetric key algorithms. Each one of the DES S-boxes takes in 6 bits and produces 4 bits. The middle 4 bits of the 6-bit input are used to look up the 4-bit replacement.



NOTE

The Vulnerabilities of DES

DES is no longer considered secure because of its small key size. The algorithm is sound, but the key size is not. DES uses short keys compared with later algorithms and is therefore considered vulnerable to brute-force attacks. A brute-force attack is one in which the attacker tries to decrypt a message by simply applying every possible key in the key space.

The round *F* function works as follows:

1. Expand the 32-bit half that was input to 48 bits; this is done by replicating some bits.
2. XOR the resultant 48 bits with the 48-bit round key.
3. Split the result into eight 6-bit sections.
4. Pass each of these 6-bit portions through a different S-box. Each S-box produces a 4-bit output, giving a total of 32 output bits. Note in Step 1 the expansion of the 32 bits into 48; it's now taken back to just 32 bits, which demonstrates yet another way

to scramble the resultant ciphertext.

5. Transpose the output bits.

This is done for each round of DES. DES has 16 rounds. So this is an effective way to scramble the plaintext.

The only reason DES is no longer considered secure is the short key. The 56-bit key is simply not long enough to prevent brute-force attacks. Brute force is trying every possible key. DES has a total number of possible keys (also called a **key space**) of 2^{56} . A modern computer system can break this in a reasonable amount of time.

Triple DES

Eventually, it became obvious that DES would no longer be secure. The U.S. federal government began a contest seeking a replacement cryptography algorithm. However, in the meantime, Triple DES (3DES) was created as an interim solution. Essentially, it does DES three times, with three different keys. 3DES uses a “key bundle,” which comprises three DES keys: K_1 , K_2 , and K_3 . Each key is a standard 56-bit DES key. It then applies the following process:

DES encrypt with K_1 , DES *decrypt* with K_2 , then DES encrypt with K_3 .

FYI

You might ask, “If DES was the first DES, and 3DES is currently popular, what happened to 2DES—and is there a 4DES?” Whereas 3DES basically does DES three times, there was an interim step, which was to do DES twice. This was called 2DES; however, it was not much more secure than DES and it took more time and computer resources to implement, so it was not widely used. On the other hand, 4DES was never implemented because early simulations indicated that 4DES was too scrambled—so scrambled, in fact, that blocks of the original plaintext appeared in the final ciphertext. This was one of the driving factors behind searching for a new algorithm not in the DES line.

There are three options for the keys. In the first option, all three keys are independent and different. In the second option, K_1 and K_3 are identical. In the third option, all three keys are the same, so you are literally applying the exact same DES algorithm three times, with the same key. Option 1 is the most secure, and Option 3 is the least secure.

Advanced Encryption Standard

The Advanced Encryption Standard (AES), also known as the Rijndael block cipher, was officially designated as a replacement for DES in 2001 after a five-year process involving 15 competing algorithms. AES is designated as Federal Information Processing Standard 197 (FIPS 197).

AES can have three different key sizes: 128, 192, or 256 bits. The three different implementations of AES are referred to as AES 128, AES 192, and AES 256. All three operate on a block size of 128 bits.

The AES algorithm was developed by two Belgian cryptographers, Joan Daemen and

Vincent Rijmen. Unlike both DES and 3DES, AES is not based on a Feistel network. AES uses a substitution-permutation matrix instead. AES operates on a 4×4 column matrix of bytes, termed the *state* (versions of AES with a larger block size have additional columns in the state). The general steps of AES are as follows:

1. **Key expansion**—Round keys are derived from the cipher key using Rijndael's key schedule. The specifics of that key schedule are not important for this book, but essentially it generates a different key in each round, based on the original key. This is much like DES.
2. **Initial round**
 - a. **AddRoundKey**—Each byte of the state is combined with the round key using bitwise XOR. In other words, the plaintext is arrayed bit by bit in a matrix that is XOR'd with the key.
3. **Rounds**
 - a. **SubBytes**—A nonlinear substitution step where each byte is replaced with another according to a lookup table. Basically, each byte in the matrix is then fed into a substitution box. However, with AES, this box also transposes the bits as well as substituting them, so it is called a permutation box.
 - b. **ShiftRows**—A transposition step where each row of the state is shifted cyclically a certain number of steps.
 - c. **MixColumns**—A mixing operation that operates on the columns of the state, combining the 4 bytes in each column.
 - d. **AddRoundKey**—A step where the key is XOR'd with the matrix again.
4. **Final round (no MixColumns)**
 - a. **SubBytes**—Same as above
 - b. **ShiftRows**—Same as above
 - c. **AddRoundKey**—Same as above

Some details about these steps are as follows:

- In the SubBytes step, each byte in the matrix is substituted for another byte using an 8-bit substitution box, called the Rijndael S-box.
- The ShiftRows step works by shifting the bytes in each row by a certain amount. The first row is left unchanged. The second row is shifted one to the left, the third row is shifted by two, and so on.

- In the MixColumns step, the columns are mixed, similar to the shifting rows. However, rather than just shifting them, they are actually mixed together.
- In the AddRoundKey step, the subkey is XOR'd with the state. For each round, a subkey is derived from the main key using Rijndael's key schedule; each subkey is the same size as the state.

This algorithm is a bit more complex than DES or 3DES.

AES can use three different key sizes: a 128-bit, a 192-bit, or a 256-bit key. The longer the key, the more resistant the resultant ciphertext will be to brute-force attacks. The National Security Agency has approved 256-bit AES for use with Top Secret data; therefore, it is secure enough for commercial applications.

Other Symmetric Algorithms

There are many other symmetric algorithms. A few examples include the following:

- Blowfish
- Serpent
- Skipjack

However, AES is the most commonly used symmetric algorithm today, and DES is one of the most widely known and an excellent example of a Feistel cipher. If you study these two, you will be reasonably well informed on symmetric ciphers.

Cryptographic Hashes

Cryptographic hashes were discussed earlier in this book, but not in any detail. In this section, we will explore hashes in more detail. A *hash* is a type of cryptographic algorithm that has some specific characteristics. First and foremost, it is one-way, not reversible. That means you cannot “unhash” something. The second characteristic is that you get a fixed-length output no matter what input is given. The third is that the algorithm must be collision resistant. A *collision* occurs when two different inputs to the same hashing algorithm produce the same output (called a hash or digest). Now ideally, we would like to have no collisions. But the reality is that with a fixed-length output, a collision is possible. So the goal is to make it so unlikely as to be something we need not think about.

Cryptographic hashes are how many systems, including Microsoft Windows, store passwords. For example, if your password is “password”, then Windows will first hash it, producing something like this:

OBD181063899C9239016320B50D3E896693A96DF

Windows will then store that hash in the SAM (Security Accounts Manager) file in the Windows System directory. When you log on, Windows cannot unhash your password. Instead, what Windows does is take whatever password you type in, hash it, and then compare the result with what is in the SAM file. If they match (exactly), then you can log in.

There are various hashing algorithms. The two most common are MD5 and SHA (the latter was SHA-1, but since then, later versions like SHA-256 have become more common.).

Asymmetric Cryptography

Asymmetric cryptography is cryptography wherein two keys are used: one to encrypt the message and another to decrypt it.

RSA

The RSA algorithm was publicly described in 1977 by Ron Rivest, Adi Shamir, and Leonard Adleman at MIT. The letters RSA are the initials of their surnames. RSA is perhaps the most widely used public key cryptography algorithm in existence today.

It is based on some interesting relationships of prime numbers. The security of RSA derives from the fact that it is difficult to factor a large integer composed of two or more large prime factors.

To create the key, two large random prime numbers, p and q , of approximately equal size are generated. Next, two numbers are chosen so that when multiplied together the product will be the desired size—for example, 1,024 bits, 2,048 bits, and so on.

Now p and q are multiplied to get n .

The next step is to multiply **Euler's Totient** for each of these primes. Euler's Totient is the total number of coprime numbers. Two numbers are considered coprime if they have no common factors. For example, if the original number is 7, then 5 and 7 would be coprime. It just so happens that for prime numbers, this is always the number minus 1. For example, 7 has six numbers that are coprime to it. Therefore,

$$m = (p - 1)(q - 1)$$



NOTE

Modulo refers to dividing two numbers and returning the remainder. For example, 8 modulo 3 would be 8/3 with a remainder of 2. The modulo would, therefore, be 2. This is a rather simplified explanation of the modulus concept, but sufficient for the purposes of a forensic analyst understanding RSA.

Now another number is selected. This number is called e and e is coprime to m .

At this point, the key is almost generated. Now a number d is calculated that when multiplied by e and modulo m would yield a 1.

Find d , such that $[d \times e] \bmod(m) = 1$.

Now you have the public keys, e and n , and the private, or secret, keys, d and n . To encrypt, you simply take your message raised to the e power and modulo n .

$$= M^e \bmod(n)$$

To decrypt, you take the ciphertext, raise it to the d power modulo n , or

$$P = C^d \bmod(n)$$

You can get a better understanding of RSA by walking through the algorithm utilizing small integers. Normally, RSA would be done with very large integers.

RSA is based on large prime numbers. Now you might think, couldn't someone take the public key and use factoring to derive the private key? Hypothetically, yes. However, factoring really large numbers into their prime factors is difficult. There is no efficient algorithm for doing it. RSA can use 1,024-, 2,048-, 4,096-bit and larger keys. Those make for some huge numbers. Of course, should anyone ever invent an efficient algorithm that will factor a large number into its prime factors, RSA would be obsolete.

Diffie-Hellman

The Diffie-Hellman algorithm is a cryptographic protocol that allows two parties to establish a shared key over an insecure channel. In other words, Diffie-Hellman is often used to allow parties to exchange a symmetric key through some insecure medium, such as the internet. It was developed by Whitfield Diffie and Martin Hellman in 1976. An interesting twist is that the method had actually already been developed by Malcolm J. Williamson of the British Intelligence Service, but it was classified, and therefore could not be publicly disclosed at the time of its creation. Diffie-Hellman enabled all secure communications between parties that did not have a preestablished relationship, such as e-commerce, and facilitated communications even between parties with a preestablished relationship, such as e-banking.

Other Asymmetric Algorithms

RSA is the most widely used asymmetric algorithm, so it is the only one this chapter covers in detail. However, you can study other asymmetric algorithms if you desire:

- MQV
- Elliptic Curve
- DSA

Each of these is based on some aspect of number theory.

Breaking Encryption

Cryptanalysis is using techniques other than brute force to attempt to uncover a key. This is also referred to as academic or knowledge-based code breaking. In some cases, cryptographic techniques are used to test the efficacy of a cryptographic algorithm. Such techniques are frequently used to test hash algorithms for collisions. Any attempt to crack a nontrivial cryptographic algorithm is simply an attempt. There is no guarantee of any method working. And whether it works or not, it will probably be a long and tedious process. If cracking encryption were a trivial process, then encryption would be useless.

Frequency Analysis

This is the basic tool for breaking most classical ciphers. In natural languages, certain letters of the alphabet appear more frequently than others. By examining those frequencies, you can derive some information about the key that was used. This method is very effective against classic ciphers like Caesar, Vigenère, and so on. It is not effective against modern methods of cryptography. Remember, in English, the words *the* and *and* are the two most common three-letter words. The most common single-letter words are *a* and *I*. If you see two of the same letters together in a word, it is most likely *ee* or *oo*.

Kasiski Examination

Kasiski examination was developed by Friedrich Kasiski in 1863. It is a method of attacking polyalphabetic substitution ciphers, such as the Vigenère cipher. This method can be used to deduce the length of the keyword used in a polyalphabetic substitution cipher. Once the length of the keyword is discovered, the ciphertext is lined up in n columns, where n is the length of the keyword. Then, each column can be treated as a monoalphabetic substitution cipher and each column can be cracked with simple frequency analysis. The method simply involves looking for repeated strings in the ciphertext. The longer the ciphertext, the more effective this method will be. This is sometimes also called Kasiski's test or Kasiski's method.

Modern Methods

Cracking modern cryptographic methods is a nontrivial task. In fact, the most likely outcome is failure. However, with enough time and resources (i.e., computational power, sample cipher/plaintexts, etc.), it is possible. Following are some techniques that can be employed in this process:

- **Known plaintext attack**—This method is based on having a sample of known plaintexts and their resulting ciphertexts, and then using this information to try to ascertain something about the key used. It is easier to obtain known plaintext samples than you might think. Consider email. Many people use a standard signature block. If you intercept encrypted emails, you can compare a known signature block with the end of the encrypted email. You would then have a known plaintext and the matching ciphertext to work with.
- **Chosen plaintext attack**—In this attack, the attacker obtains the ciphertexts corresponding to a set of plaintexts of his own choosing. This can allow the attacker to attempt to derive the key used and thus decrypt other messages encrypted with that key. This can be difficult, but it is not impossible.
- **Ciphertext-only**—The attacker only has access to a collection of ciphertexts. This is much more likely than known plaintext, but also the most difficult. The attack is completely successful if the corresponding plaintexts can be deduced, or even better, the key. But obtaining any information at all about the underlying plaintext in this situation is still considered a success.

- **Related-key attack**—This attack is like a chosen plaintext attack, except the attacker can obtain ciphertexts encrypted under two different keys. This is actually a very useful attack if you can obtain the plaintext and matching ciphertext.

There are other methods based on more advanced cryptanalysis techniques—for example, differential and integral cryptanalysis. However, this section should give any forensic examiner a good basic understanding of cryptanalysis.

Tools

A number of tools can aid in cracking passwords and encrypted data. Remember that if the encryption was implemented correctly and is strong, you may not be able to crack it. But passwords can often be cracked (encrypted information less often). It is also possible to obtain keys or copies of information before encryption via a number of nontechnical means that fall in the category of **social engineering**, which includes going through the trash, also known as dumpster diving; lying to a person to obtain the keys, passwords, phrases, or unencrypted information; or even getting a job at the target company and stealing the desired information.

Rainbow Tables

In 1980, Martin Hellman described a cryptanalytic time-memory tradeoff, which reduces the time of cryptanalysis by using precalculated data stored in memory. Essentially, these types of password crackers work with precalculated hashes of all passwords available within a certain character space, be that a–z or a–zA–z or a–zA–Z0–9, etc. These files are called rainbow tables because they contain every letter combination “under the rainbow.” They are particularly useful when trying to crack hashes. Because a hash is a one-way function, the way to break it is to attempt to find a match. The attacker takes the hashed value and searches the rainbow tables seeking a match to the hash. If one is found, then the original text for the hash is found.

Popular hacking tools like Ophcrack depend on rainbow tables. Ophcrack is usually very successful at cracking Windows local machine passwords. The steps are very simple:

1. Download Ophcrack and burn the image to a CD.
2. Put the CD in the target computer and boot through the CD.
3. Wait as it boots as Linux grabs the Windows password file, then uses cracking tools to crack that file and produces a text file with usernames and passwords.

You can see Ophcrack in use in **FIGURE 5-12**. Note that, this is from a live machine, so some information has been redacted. Many forensics tools, such as OSForensics, provide mechanisms for you to create your own smaller, more focused rainbow tables. For example, you can enter every word you believe might be associated with a suspect, and a rainbow table can be generated from those words and variations of them. This makes a much smaller, thus faster, rainbow table.

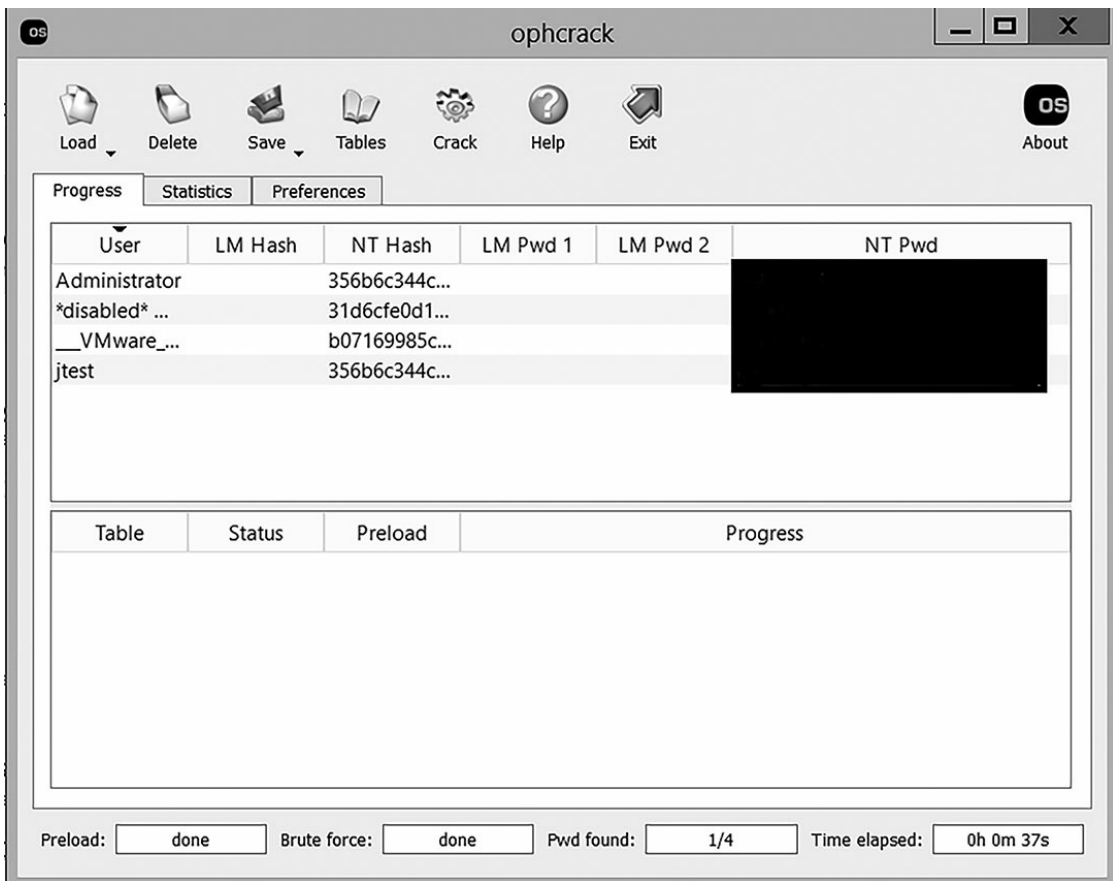


FIGURE 5-12 Ophcrack.

John the Ripper

John the Ripper is another password cracker that is very popular with both network administrators and hackers. It can be downloaded free of charge from <http://www.openwall.com/john/>. This product is completely command-line based and has no Windows interface. It enables the user to select text files for word lists to attempt cracking a password. Although John the Ripper is less convenient to use because of its command-line interface, it has been around for a long time and is well regarded by both the security and hacking communities. Interestingly, there is a tool available at <http://www.openwall.com/passwdqc/> that ensures your passwords cannot easily be cracked by John the Ripper.

Quantum Computing and Cryptography

It is beyond the scope of this chapter, or this book, to dive deeply into quantum computing; however, the topic has a substantial impact on cryptography. Therefore, it is necessary that you have at least a generalized knowledge of the topic. In this section, you

will be introduced to a very basic general overview of quantum computing and how it will change cryptography.

Quantum computers are simply computers that store data in quantum states rather than in traditional bits. These states can be the polarization of a photon, the energy level of an electron, or other quantum state. This storage is called qubit, as in “quantum bit.” While there are numerous news stories about quantum computing, it should be kept in mind that we still do not have a fully working quantum computer. The issue is something called decoherence. Put simply, quantum computers currently can maintain their state for only a short period of time. So processing data on a quantum computer is currently limited to short bursts of work.

What happens once the issues with decoherence (and a few other engineering issues) are addressed? When we have a fully functioning quantum computer, one that can maintain its state, this will have serious ramifications for current widely used asymmetric cryptography algorithms. It has been proven that quantum computers are really good at some tasks. Two relevant examples are factoring large integers into their prime factors and solving discrete logarithm problems. It just so happens that RSA security is based on the difficulty of factoring large integers into their prime factors. Diffie-Hellman (and variations like ElGamal and MQV) security is based on the difficulty of solving the discrete logarithm problem. When we have a fully working quantum computer, these algorithms will no longer be secure. That is a problem, because most online encrypted communication is currently using these algorithms. Fortunately, the National Institute of Standards and Technology (NIST) has been looking for a quantum-resistant cryptographic standard. That process is now in round three, and progressing nicely. You can find out more about the NIST project at <https://csrc.nist.gov/Projects/post-quantum-cryptography/post-quantum-cryptography-standardization>.

CHAPTER SUMMARY

This chapter introduced two complex topics: steganography and cryptography. Steganography is widely utilized to hide data, particularly from forensic examination. As you saw in this chapter, it is easy to implement and has even been used by terrorist organizations for covert communications.

Cryptography is used to systematically scramble information such that it can be unscrambled by use of a key. Scrambled information may be hidden, or hidden information may be scrambled, or steganography or encryption may be used by themselves.

This chapter is meant to provide a general overview of cryptography. Any truly good forensic examiner should be very familiar with the historical methods presented, and at least have a basic understanding of the modern symmetric and asymmetric cryptography algorithms as well as of some of the fundamentals of cryptanalysis.

KEY CONCEPTS AND TERMS

Asymmetric cryptography
Block cipher
Brute-force attack
Caesar cipher
Carrier
Channel
Cryptanalysis
Euler's Totient
Feistel function
Kasiski examination
Kerckhoffs' principle
Key space
Least significant bit (LSB)
Payload
Social engineering
Steganalysis
Steganography
Steganophony
Stream cipher
Substitution
Symmetric cryptography
Transposition
Vigenère cipher

CHAPTER 5 ASSESSMENT

1. The Caesar cipher is the oldest known encryption method.
 - A. True
 - B. False
2. An improvement on the Caesar cipher that uses more than one shift is called _____.
 - A. DES encryption
 - B. multialphabet substitution
 - C. IDEA
 - D. Triple DES
3. What type of encryption uses a different key to encrypt the message than it uses to decrypt the message?
 - A. Private key
 - B. Asymmetric
 - C. Symmetric
 - D. Secure
4. Which of the following is an asymmetric cryptography algorithm invented by three mathematicians in the 1970s?
 - A. PGP
 - B. DES
 - C. DSA
 - D. RSA
5. Which of the following encryption algorithms uses three key ciphers in a block system and uses the Rijndael algorithm?
 - A. DES
 - B. RSA
 - C. AES
 - D. NSA
6. What is the key length used for DES?

- A. 56
 - B. 64
 - C. 128
 - D. 256
7. Which of the following is an example of a multialphabet cipher?
- A. Caesar
 - B. Vigenère
 - C. Atbash
 - D. ROT13
8. How many rounds does DES have?
- A. 64
 - B. 56
 - C. 16
 - D. 4
9. Hiding messages inside another medium is referred to as _____.
- A. cryptography
 - B. cryptology
 - C. steganalysis
 - D. steganography
10. In steganography, the _____ is the data to be covertly communicated. In other words, it is the message you want to hide.
- A. payload
 - B. carrier
 - C. signal
 - D. channel
11. In steganography, the _____ is the stream or file into which the data is hidden.
- A. payload
 - B. carrier
 - C. signal
 - D. channel
12. The most common way steganography is accomplished is via _____.

- A. MSB
- B. ASB
- C. RSB
- D. LSB

References

1. Roy, R. (2020, May 7). Image stenography using Python. *Toward Data Science*. Retrieved from <https://towardsdatascience.com/hiding-data-in-an-image-image-steganography-using-python-e491b68b1372> on January 30, 2021.
2. Shankdar, P. (2020, July 8). Best tools to perform steganography [updated 2020]. InfoSec. Retrieved from <https://resources.infosecinstitute.com/topic/steganography-and-tools-to-perform-steganography/#gref> on January 28, 2021.
3. Nashat, D., & Mamdoah, L. (2019). An efficient steganographic technique for hiding data. *Journal of the Egyptian Mathematical Society*, 27. Retrieved from <https://link.springer.com/article/10.1186/s42787-019-0061-6> on January 28, 2021.
4. Security On Demand. (n.d.). Detecting steganography in your SOC [blog post]. Retrieved from <https://www.securityondemand.com/news-posts/detecting-steganography-in-your-soc/> on January 28, 2021.



CHAPTER 6

Recovering Data

© phyZick/Shutterstock

A computer user may make an effort to delete information. But the file or remnants of the information may still be available to the forensic examiner. This chapter reviews practical, hands-on steps that you can take to recover deleted data. It discusses undeleting files in Windows, Linux, and Mac OS. However, we will also discuss the computer science facts underlying deleted file recovery.

Chapter 6 Topics

This chapter covers the following topics and concepts:

- How to undelete data
- What you need to know about recovering information from damaged drives

Chapter 6 Goals

When you complete this chapter, you will be able to:

- Recover deleted files in Windows
- Recover deleted files in Linux
- Recover deleted files in Mac OS

- Recover files from damaged drives

Undeleting Data

It is common for people to delete files from their computers. This does not necessarily mean some nefarious intent; it can be simply deleting files that are no longer needed. It is a trivially easy task—and criminals who are not very technically savvy think that deleting a file will keep authorities from discovering it. So you should expect that evidence will frequently be deleted from computers you examine. For this reason, one of the most fundamental tasks a forensic examiner will conduct is retrieving deleted data.

This chapter does not dive into the specifics of the three major operating systems—Windows, Linux, and Mac OS. Instead, the focus is simply on recovering files from them. Just enough information about each operating system's file system as it relates to file - deletion and recovery is covered.

File Systems and Hard Drives

Let us begin by discussing traditional hard drives. These are drives that use platters to magnetically store data. While solid-state drives are becoming more and more common, traditional hard drives are still found in personal computers and servers. They are less common in laptops, and not used at all in tablets. Hard drives store data as a sector. For many years, a typical sector has been 512 bytes; however, modern hard drives use what is called the Advanced Format, which has 4,096-byte sectors. A sector is basically an area of one of the disk platters defined by two radii. Sectors are contiguous on a disk, and are defined by two radii on the platter. The hard drive views data in sectors; however, file systems look at clusters, not sectors. A cluster can be from 1 to 128 sectors. The clusters need not be contiguous sectors, as illustrated in [Figure 6-1](#). For example, a 10-sector cluster may have the sectors in different locations.

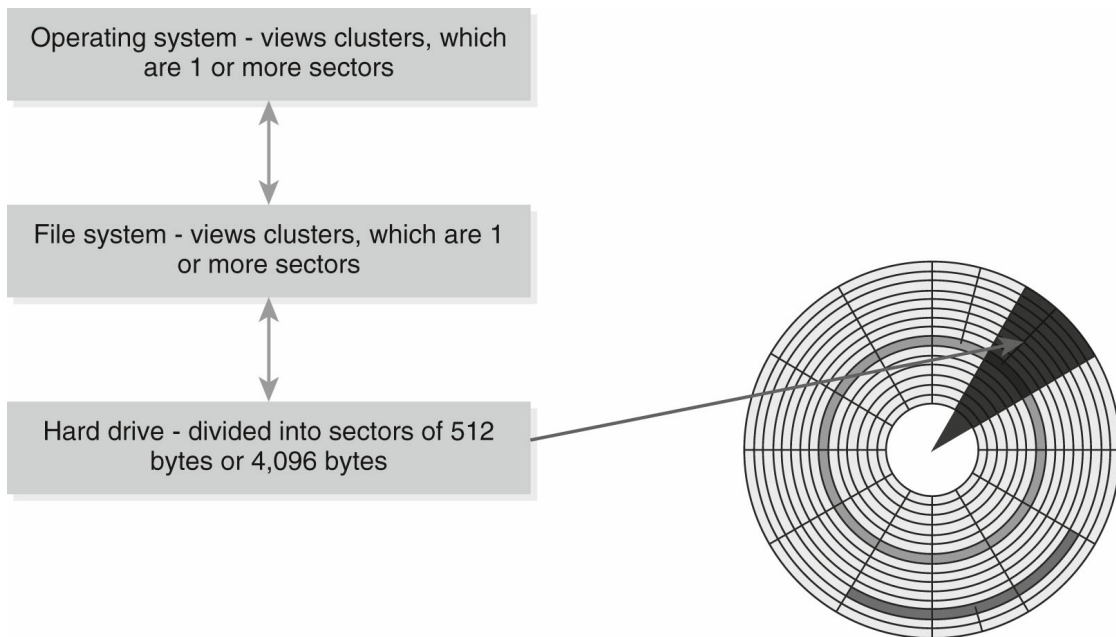


Figure 6-1 Clusters and sectors.



NOTE

The formal description of a group of sectors was changed from *cluster* to *allocation unit*; however, in most technical literature, the term cluster is still used.

Windows

Windows is a very common operating system. In fact, it would be quite a challenge to find any office that did not have any computers running Windows. PCs running Windows also account for the overwhelming majority of home computers. So recovering deleted Windows files is the first skill you learn in this chapter.

You can recover deleted files from the Windows operating system because of the way the file system works. Older versions of Windows use FAT (either FAT16 or FAT32), and newer versions (since Windows 2000) use NTFS. This section explores FAT and NTFS file systems in relationship to recovering deleted files. In both file systems, a table is used to map files to specific clusters where they are stored on the disk. Even today, with Windows 10, NTFS is the file system used in Microsoft Windows.

FAT

In FAT16 and FAT32, the table used to store cluster/file information is the file allocation table (FAT)—thus the name of the file system. The file allocation table is really a list of

entries that map to each cluster on the disk partition. Each entry records one of five things:

1. The cluster number of the next cluster for this file is recorded.
2. If this cluster is the end of a chain, then it has a special end of cluster chain (EOC) entry.
3. Bad clusters have a special entry in the file allocation table.
4. Reserved clusters have a special entry in the file allocation table.
5. Open or available clusters are also marked in the file allocation table.

When a file is deleted, the data is not actually removed from the drive. Rather, the FAT is updated to reflect that those clusters are no longer in use. If new information is saved to the drive, it may be saved to those clusters, overwriting the old information. What this means from a forensic point of view is that the more recently a file was deleted, the more likely it is that you will be able to recover the file. Over time, it becomes more likely that those clusters have had other information saved in them. In fact, the cluster may have been deleted and saved over several times. Because of this, recovering a deleted file is not always an all-or-nothing procedure. It is possible to recover just a portion of a file.

NTFS

NTFS is an acronym for New Technology File System. Starting with Windows 2000, NTFS has been the preferred file system for Windows operating systems. From a forensic point of view, two fundamental files that are part of NTFS are of most interest. These are the Master File Table (MFT), which some sources call the Meta File Table, and the cluster bitmap. The MFT describes all files on the volume, including filenames, time stamps, security identifiers, and file attributes, such as read-only, compressed, encrypted, and so on. This file contains one base file record for each file and directory on an NTFS volume. It serves the same purpose as the file allocation table does in FAT and FAT32. The cluster bitmap file is a map of all the clusters on the hard drive. This is an array of bit entries where each bit indicates whether its corresponding cluster is allocated/used or free/unused.

When files are deleted from an NTFS system, the process is similar to what occurs in FAT. However, there is one difference: Before the cluster is marked as available, it is first marked as “deleted,” which effectively moves it to the Recycle Bin. Note that *not a single bit* is actually deleted—the clusters are simply noted as being in the Recycle Bin. Before Windows Vista, the Recycle Bin resided in a hidden directory called RECYCLER. In Vista and beyond, the name of the directory was changed to \$Recycle.bin. Only when a user empties the Recycle Bin is the cluster marked as fully available. However, even at this point, nothing is actually deleted. The filename in the MFT is simply updated with a special character to signify to the computer that the file has been deleted. This means that at this point, one can completely recover the entire file. There are any number of file recovery utilities available for this purpose. Just as with FAT systems, clusters in an NTFS system are more likely to be overwritten as more time elapses after deletion.

With older versions of Windows (2000 and before), the recycle bin’s activities were

structured in a very specific manner. The default Recycle Bin configuration for a Windows computer is to move deleted files to a folder named \Recycler\%SID%\, where %SID% is the SID (Security Identifier) of the currently logged-on user. Every user on the system will have such a directory created the first time that the Recycle Bin is used. As well, each user will have a hidden file called INFO2 created the first time the Recycle Bin is used; its purpose is to keep track of the original location of deleted file(s)/folder(s), as well as file size and deletion time. This makes it possible to relate deleted files to specific users.

When you delete a file, the INFO2 list looks like this:

D%DriveLetter%_%IndexNumber%_%FileExtension%

The “D” stands for Drive.

%DriveLetter% is the drive that the file was on before it was deleted.

%IndexNumber% is an index number that is assigned to each file or folder that is sent to the Recycle Bin, indicating the order of deletion.

%FileExtension% is the original file extension; if the deleted item is a folder, there will be no extension.

Starting with Windows 7 and on through Windows 10, Microsoft did away with the INFO2 file. Starting with Vista, the Recycle Bin is located in a hidden directory named \Recycle.Bin\%SID%, where %SID% is the SID of the user who performed the deletion. When files are moved into the Recycle Bin, the original file is renamed to \$R followed by a set of random characters, but maintaining the original file extension. Also, a new file beginning with \$I, followed by the same set of random characters given to the \$R file and the same extension, is created; this file contains the original filename/path, original file size, and the date and time that the file was moved to the Recycle Bin. Note that all of the \$I files are exactly 544 bytes long. In Windows 7 and beyond, The I\$ structure is as follows:

- Bytes 0–7: \$I File header—always set to 01 followed by seven sets of 00.
- Bytes 8–15: Original file size—stored in hex, in little-endian format.
- Bytes 16–23: Deleted date/time stamp—represented in number of seconds since midnight, January 1, 1601. Use a program such as Decode, available at <http://www.digital-detective.co.uk/freetools/decode.asp>, to assist with figuring out the exact date/time, if you don’t want to do the math.
- Bytes 24–543: Original file path/name.

File systems view a cluster as entirely utilized if even one bit is used. To illustrate this, assume that a system has a sector size of 4,096 bytes. Then further assume that it is using a cluster size of 10 sectors. This means each cluster has a total of 40,960 bytes of storage. If the user saves a file that is 42,000 bytes in size, the file system will need to utilize two clusters. All 10 sectors of the first cluster are used, but only one sector of the

second cluster is used. From the file system's point of view, and thus the operating system's point of view, both clusters are completely used. This is illustrated in [Figure 6-2](#).

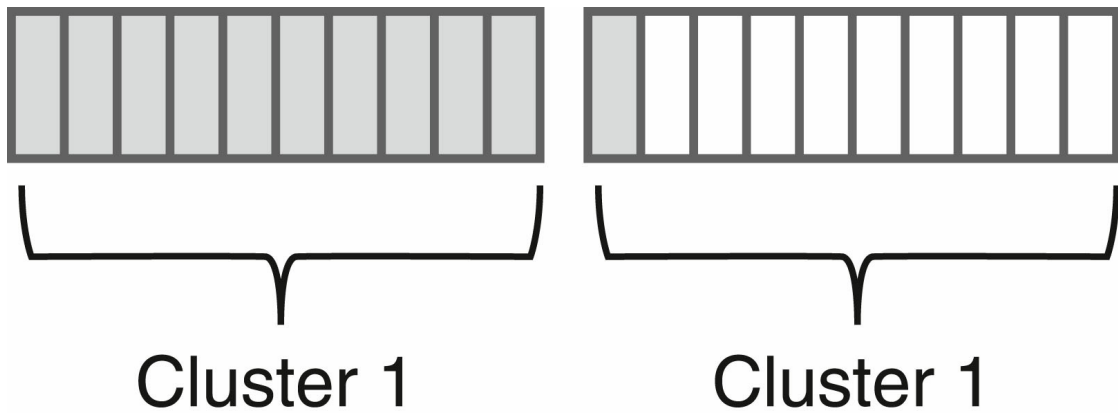


Figure 6-2 Windows clusters.

Windows Tools

There are a number of mechanisms for recovering deleted files. Many forensics books discuss this process in some detail. In *The Official EnCE: EnCase Certified Examiner Study Guide*,

Chapter 2 discusses file systems at length, and discusses how to recover deleted files using EnCase.¹ In the book *Computer Forensics: Hard Disk and Operating Systems: 2*, Chapter 1 deals with file systems and discusses how to recover deleted files.²

Chapter 2 of the book *The Basics of Digital Forensics: The Primer for Getting Started in Digital Forensics* discusses the recovery of deleted files.³

A number of tools are available to recover deleted files from Windows computers. This section introduces a few of these tools. You should definitely take the time to explore the various tools available and select the one you prefer. Simply using your favorite search engine to look for “how to recover deleted Windows files” will result in a number of tools you can try. Many are free, and those that are not usually have a trial version with which you can experiment.

DiskDigger

DiskDigger (<http://diskdigger.org/>) is an easy-to-use tool. It can be downloaded free of charge and is fully functional. But when recovering files in the free version, you have to recover them one at a time. If you pay for the commercial version, you can recover as many files at one time as you want. The interface is very easy to use. When you launch the program, you see a screen like the one shown in **Figure 6-3**.

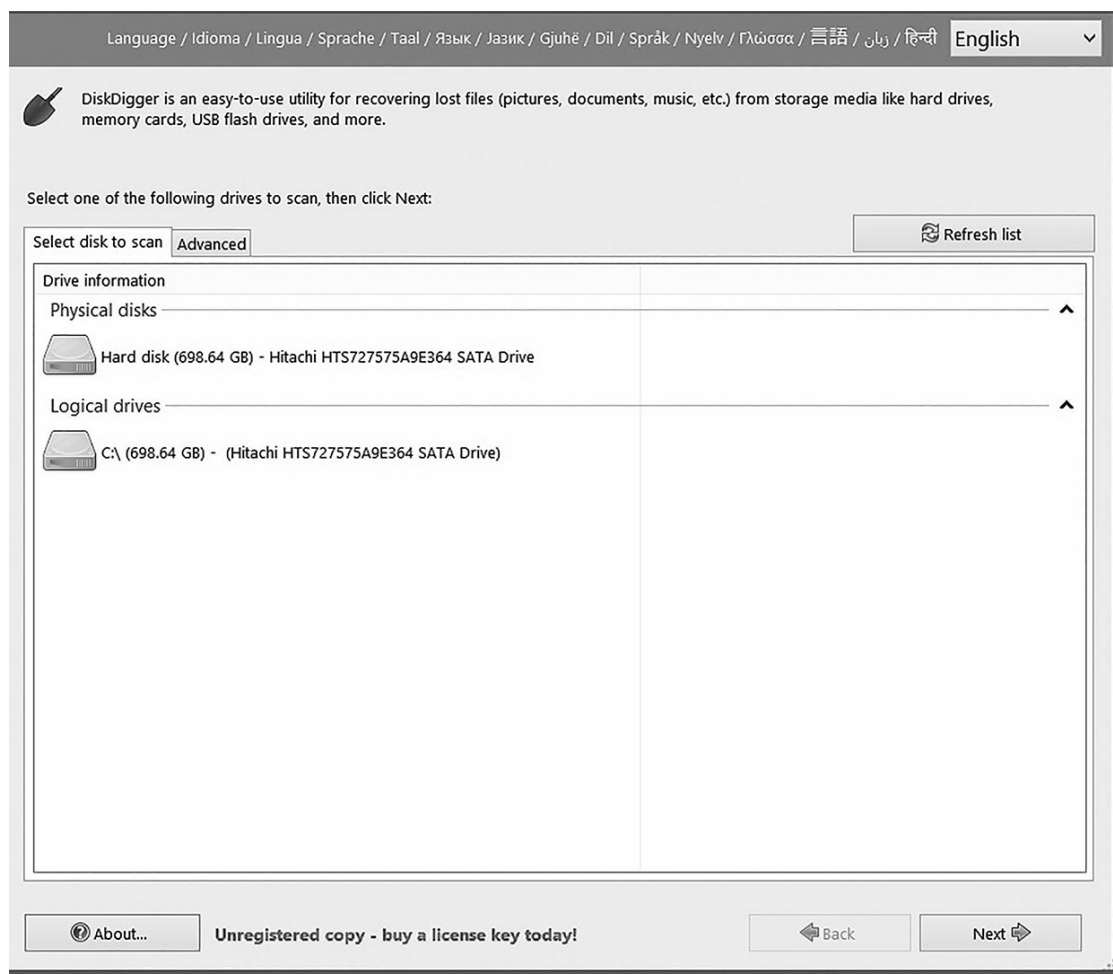


Figure 6-3 DiskDigger.

Then you select the drive you want to examine, and choose Dig Deep or Dig Deeper, as shown in **Figure 6-4**. The difference is the use of file carving.

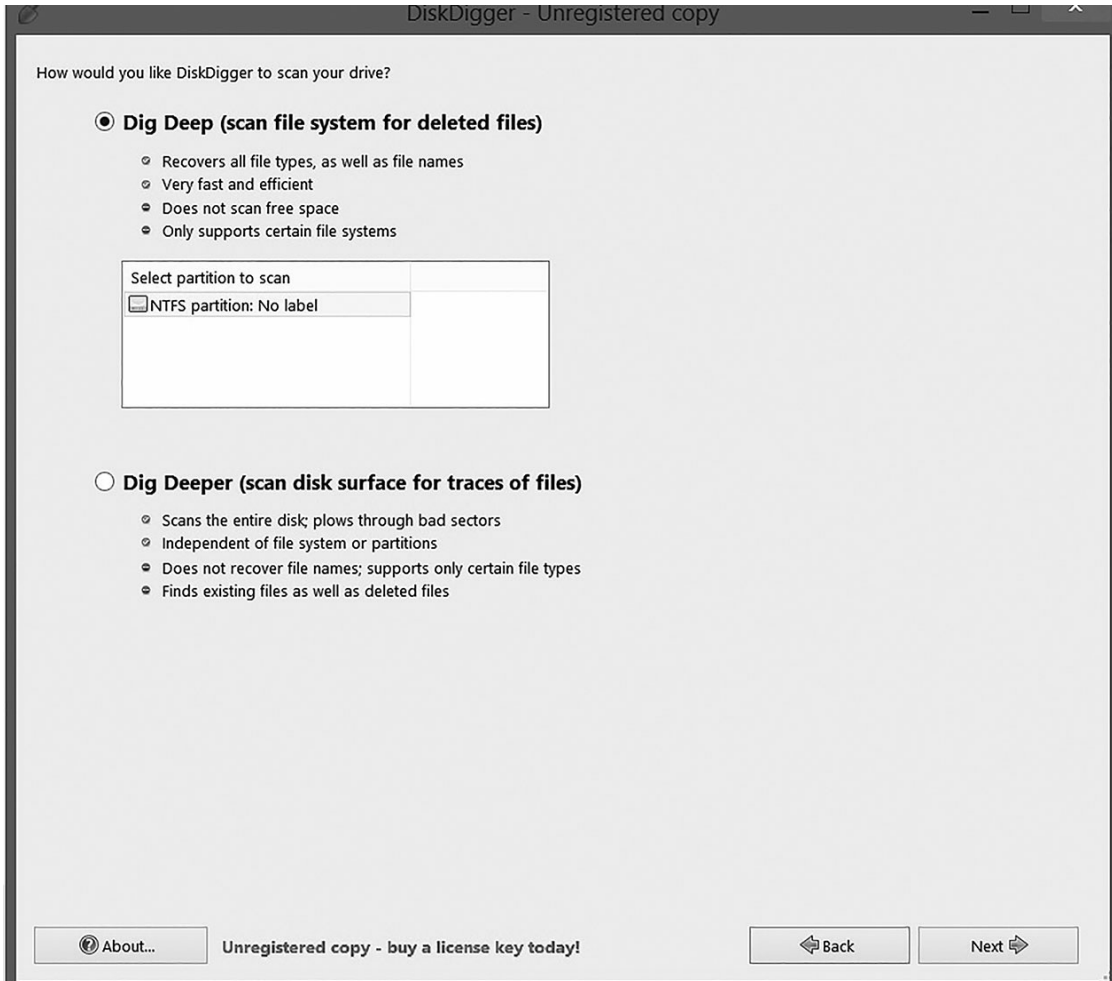


Figure 6-4 DiskDigger starting data recovery.

Once recovery is done, you will see a screen like the one shown in **Figure 6-5**. You can select any file and recover it. On your screen the files will be in color. For files in green, you should get the entire file back. Gray indicates a partial file, and red indicates very little of the file is left.

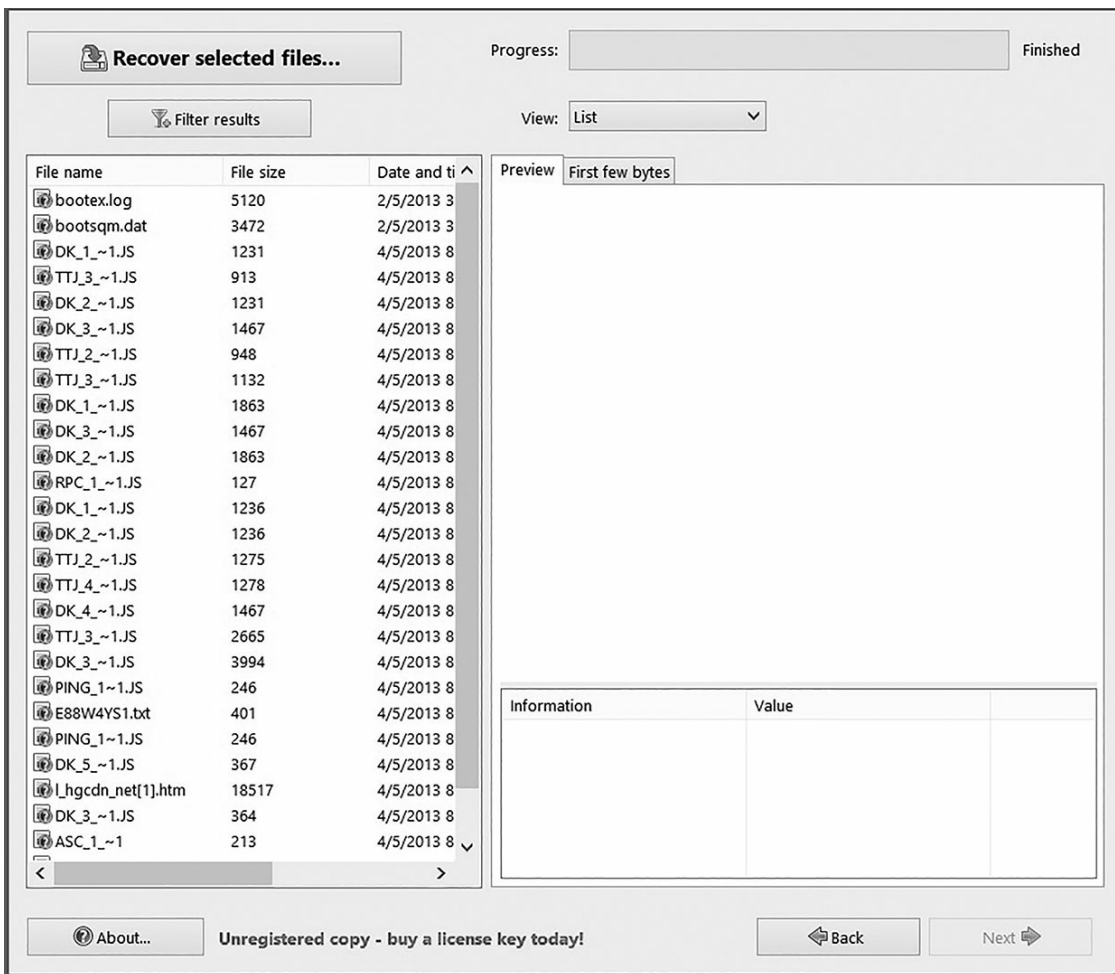


Figure 6-5 Recovering an individual file using DiskDigger.

Forensically Scrubbing a File or Folder

Many web pages report that the Department of Defense operating manual DOD 5220.22-M recommends that data be overwritten with random characters seven times to ensure it is completely wiped. That is accurate, but incomplete. There is actually a matrix of how to sanitize different types of media as described in [Table 6-1](#), which is based on the 2001 DOD 5220.22-M ECE recommendations.

TABLE 6-1 Forensically scrubbing a file or folder.

MEDIA	CLEAR	SANITIZE
MAGNETIC TAPE1		
Type I	a or b	a, b, or m

Type II	a or b	b or m
Type III	a or b	m
MAGNETIC DISK		
Bernoullis	a, b, or c	m
Floppies	a, b, or c	m
Nonremovable rigid disk	c	a, b, d, or m
Removable rigid disk	a, b, or c	a, b, d, or m
OPTICAL DISC		
Read many, write many	c	m
Read-only		m,n
Write once, read many (Worm)		m,n
MEMORY		
Dynamic random access memory (DRAM)	c or g	c, g, or m
Electronically alterable PROM (EAPROM)	l	j or m
Electronically erasable PROM (EEPROM)	l	h or m
Flash EPROM (FEPROM)	l	c then i, or m
Programmable ROM (PROM)	c	m
Magnetic core memory	c	a, b, e, or m
Magnetic plated wire	c	c and f, or m
Magnetic resistive memory	c	m
Non-volatile RAM (NOVRAM)	c or g	c, g, or m
Read-only memory ROM		m
Static random access memory (SRAM)	c or g	c and f, g, or m
EQUIPMENT		
Cathode ray tube (CRT)	g	q
PRINTERS		
Impact	g	p then g
Laser	g	o then g

- Degauss with a Type I degausser.
- Degauss with a Type II degausser.
- Overwrite all addressable locations with a single character.
- Overwrite all addressable locations with a character, its complement, and then a random character, and then verify.
- Overwrite all addressable locations with a character, its complement, and then a random character.

- f. Each overwrite must reside in memory for a period longer than the classified data resided.
- g. Remove all power, to include battery power.
- h. Overwrite all locations with a random pattern, all locations with binary zeros, and all locations with binary ones.
- i. Perform a full chip erase as per the manufacturer's data sheets.
- j. Perform i, then c, a total of three times.
- k. Perform an ultraviolet erase according to the manufacturer's recommendation.
- l. Perform k, but increase time by a factor of three.
- m. Destroy—disintegrate, incinerate, pulverize, shred, or melt.
- n. Destruction required only if classified information is contained.
- o. Run five pages of unclassified text (font test acceptable).
- p. Ribbons must be destroyed. Platens must be cleaned.
- q. Inspect and/or test screen surface for evidence of burned-in information. If present, the cathode ray tube must be destroyed.

WinUndelete

WinUndelete (<http://www.winundelete.com/download.asp>) is another tool that is relatively easy to use. When launched, it starts a wizard that first asks you to select what drive to recover. This is shown in **Figure 6-6**.

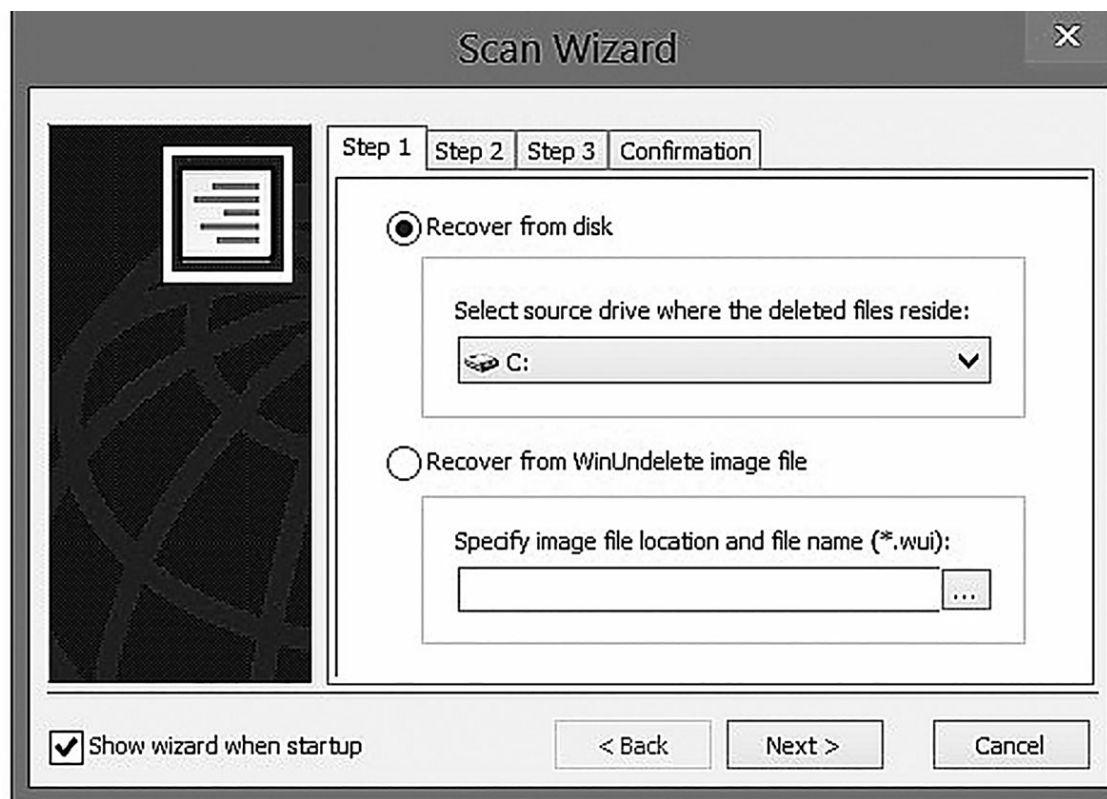


Figure 6-6 WinUndelete Wizard Step 1: selecting a drive.

Step 2 allows you to select the file types you want to recover. This is shown in [Figure 6-7](#).



Figure 6-7 WinUndelete Step 2: selecting file types.

The third step is to select a folder to place recovered files in. You can see this in [Figure 6-8](#).

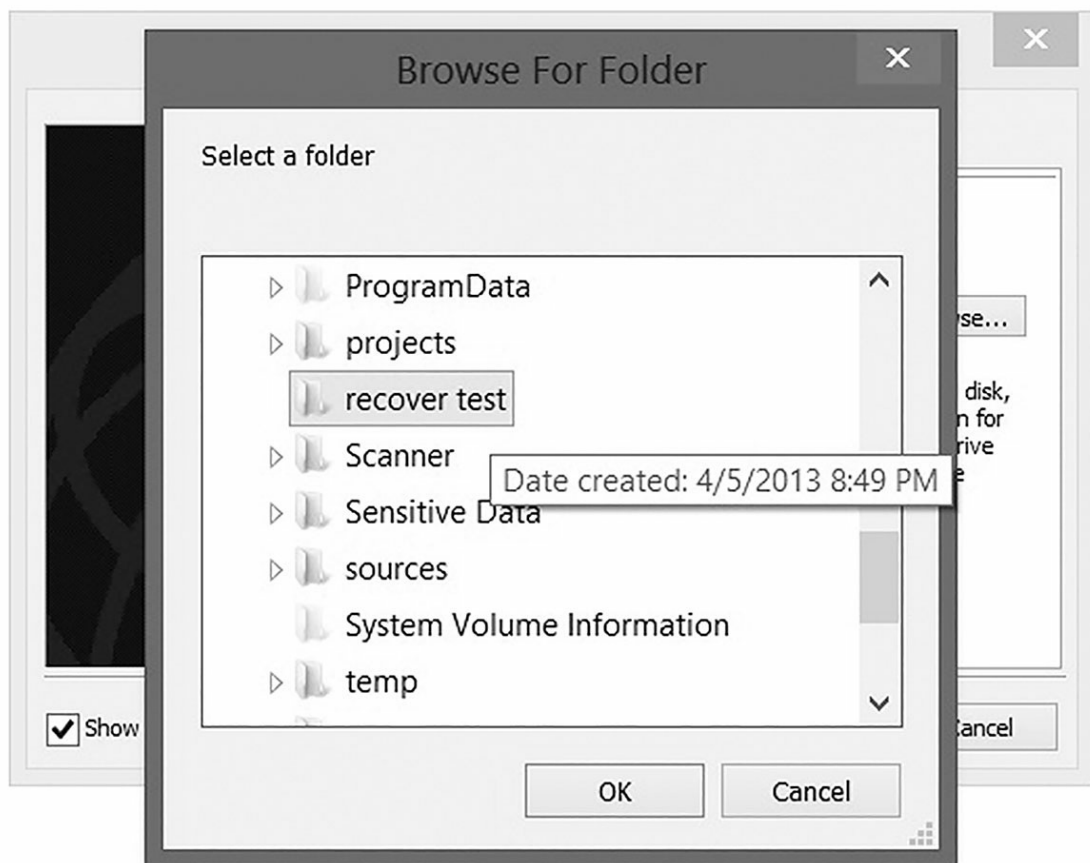


Figure 6-8 WinUndelete Step 3: selecting a restore file location.

When WinUndelete has completed running the recovery process, you can go to that folder to see the files.

FreeUndelete

FreeUndelete (<http://www.officerecovery.com/freeundelete/>) is free for personal use. There is a fee for commercial use. When you launch this program, the first screen requires you to select the drive from which you want to recover files. This is shown in [Figure 6-9](#).

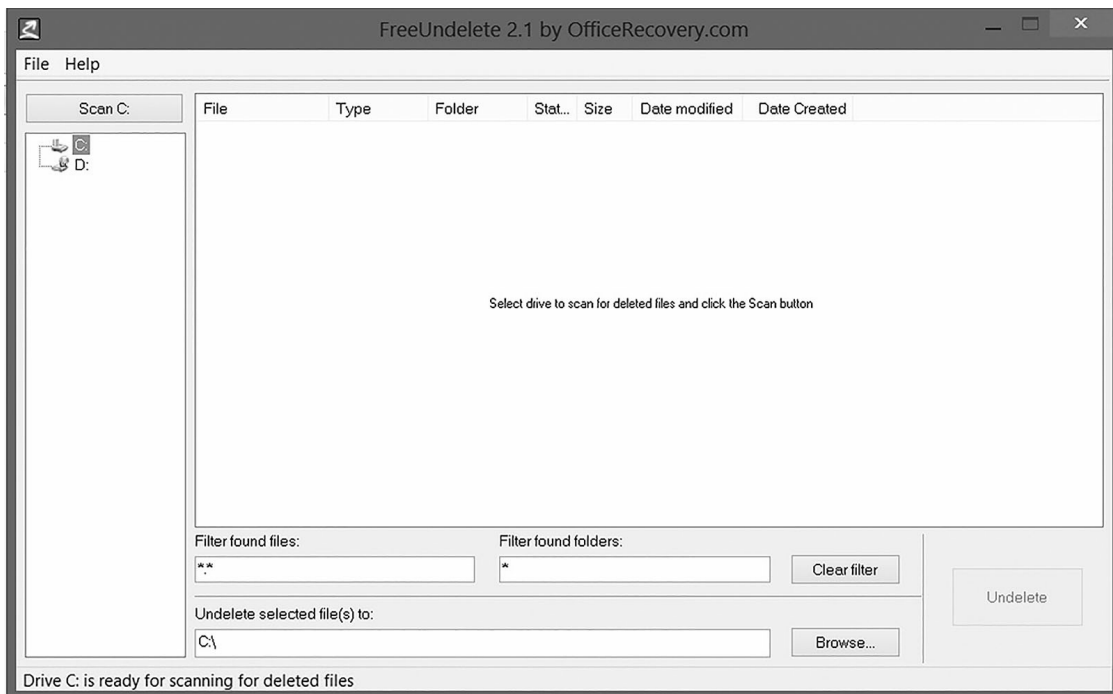


Figure 6-9 FreeUndelete selecting a drive.

Then you simply click the Scan button, and any files that can be fully or partially recovered will be listed.

OSForensics

OSForensics is a robust forensics tool. It also provides for undeletion. You can undelete from an image you have mounted, or from the live system. You will find “Deleted Files Search” on the menu on the left-hand side of the main OSForensics screen, as shown in [Figure 6-10](#).



Figure 6-10 OSForensics deleted files search.

The search result will display with color coding indicating how likely it is that you can recover a given file. Obviously, some files will be so fragmented that recovery is unlikely. You can see this in **Figure 6-11**.

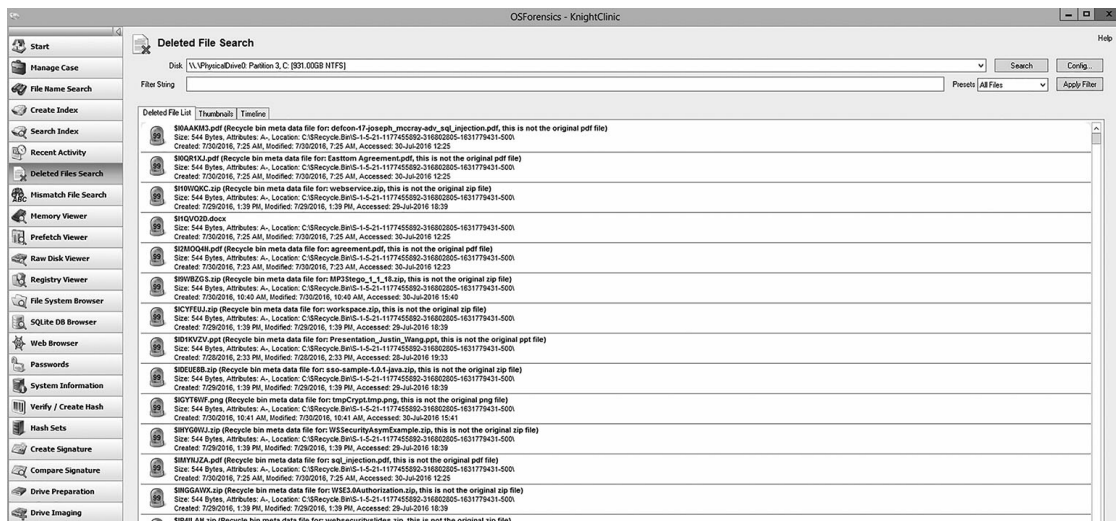


Figure 6-11 OSForensics deleted files results.

Autopsy

Another interesting tool is Autopsy, available at <https://www.autopsy.com/>. This is a free, open-source digital forensics tool. Like many forensics tools, it includes deleted file recovery. What is most interesting about it is that, when a disk image is loaded, it immediately begins recovering deleted files. This is important because so often evidence is found in deleted files. This can be seen in **Figure 6-12**.

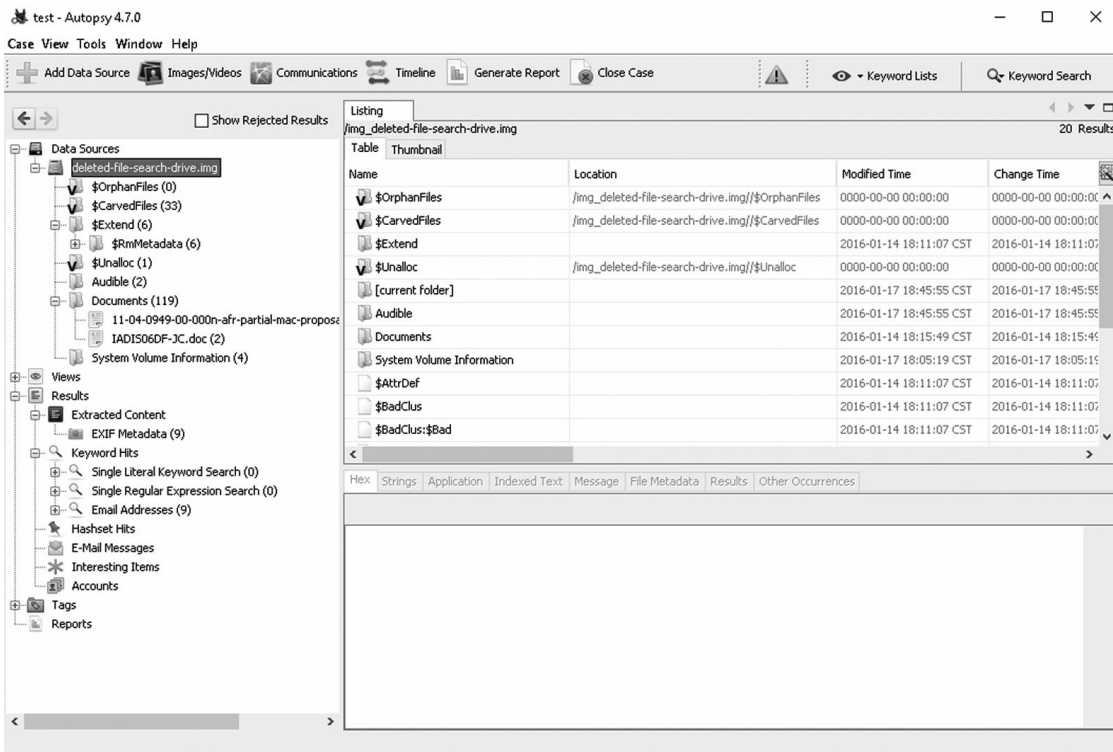


Figure 6-12 Autopsy recovering deleted files.

Autopsy is an easy-to-use forensics tool. It does not have all the advanced features of some commercial products. However, it is an excellent choice for a second forensic tool to perform validation on your findings. And given that it is open source, it is ideal for students to download and use for experimenting.

There are certainly other tools available for deleted file recovery. Most forensics tools, such as Guidance Software's EnCase and AccessData's Forensic ToolKit (FTK), can recover deleted files.

Linux

With Linux, you have the option of using prepackaged tools or some built-in Linux commands. In this section, you see both, but first you need to understand the extended file system (Ext) it uses. Linux can run on multiple file systems, but Ext is the most common. The most recent version of Ext is Ext4; however, many Linux distributions still use Ext3.

First, consider how Linux stores files. The content of files is stored in contiguous blocks. The exact size of these blocks depends on the parameters used with the command to create that partition (for example, `mke2fs` can be used to make Ext2 partitions). The size can be 1,024, 2,048, or 4,096 bytes. You can think of these blocks as something similar to the clusters in NTFS, though they are not exactly the same thing, just

related conceptually.

Hard drives that run Linux address blocks, or integer multiples of blocks, at a time. The specific block size is stored in the superblock. The entire partition is divided into an integral number of blocks, starting at 0.

Blocks are divided into groups. Each group uses one block as a bitmap to keep track of which block inside that group is allocated (used); thus, there can be at most 32,768 ($4,096 \times 3 = 32,768$) normal blocks per group. Another block is used as a bitmap for the number of allocated inodes. An **inode** is a data structure in the file system that stores all the information about a file except its name and its actual data. Inodes are data structures of 128 bytes that are stored in a table ($4,096 / 128 = 32$ inodes per block) in each group.

An inode can refer to a file or a folder/directory. In either case, the inode is really a link to the file. This is important because there are basically two types of links. The first type is the *hard link*. A hard link is an inode that links directly to a specific file. The operating system keeps a count of references to this link. When the reference count reaches zero, the file is deleted. In other words, you can have any number of names referencing a file, but if that number of references reaches zero (i.e., there is *no* name that references that file), then the file is deleted.

The second type of file link is called a *soft link* or *symbolic link*. In this case, the link is not actually a file itself, but rather a pointer to another file or directory. You can think of this as the same thing as a shortcut, such as you might find in Windows.

Because there are at most 32,768 bits in the bitmap, that means that there will be a maximum of 32,768 inodes per group, and thus 1,024 blocks ($32,768 / 32 = 1,024$) blocks in the inode table of each group. The actual size of the inode table is given by the actual number of inodes per group, which is also stored in the superblock.

The inodes in the inode table of each group contain metadata for each type of data that the file system can store. This type might be a symbolic link, in which case only the inode is sufficient; it might be a directory, a file, and so on. In the case of files and directories, the real data is stored in the file.

Manual Recovery

This method depends on manually recovering deleted files using Linux commands. It does not require external tools. Unfortunately, there are variations between the Linux distributions, so there is no guarantee that this process will work on your specific Linux installation.

The first step is to move the system to single-user mode. If this is a network system, you should probably notify network users first. This can be done with the `wall` command, which sends messages to all logged-in users.

Then, you can move to single-user mode, using the `init` command:

```
init 1
```

The Linux/UNIX command `grep` can be used to search for files, contents of files, and just about anything you may want to search for. The `grep` command is very flexible and quite popular with Linux users. For example, `grep -b 'search-text' /dev/partition > file.txt` will search for 'search-text' in a given partition and output the results to `file.txt`.

You can also use this syntax:

```
grep -a -B[size before] -A[size after] 'text' /dev/[your_
partition] > file.txt
```

Linux run levels determine at what level the operating system is running. The `init` command allows you to change the run level (TABLE 6-2).

TABLE 6-2 Using `init` to change run levels in Linux.

MODE	DIRECTORY	RUN LEVEL DESCRIPTION
0	/etc/rc.d/rc0.d	Halt
1	/etc/rc.d/rc1.d	Single-user mode
2	/etc/rc.d/rc2.d	Not used (user-definable)
3	/etc/rc.d/rc3.d	Full multiuser mode without GUI
4	/etc/rc.d/rc4.d	Not used (user-definable)
5	/etc/rc.d/rc5.d	Full multiuser mode with GUI
6	/etc/rc.d/rc6.d	Reboot

To recover a text file starting with the word *forensics* on /dev/sda2, you can try the following command:

```
# grep -i -a -B10 -A100 'forensics' /dev/sda2 > file.txt
```

In this case, `grep` is searching for this phrase, ignoring case, looking through binary files, and essentially looking to find the text, even if the file has a reference count of zero (i.e., has been deleted). Of course, if the file blocks have been overwritten enough times, then it will be unrecoverable.



NOTE

If you are unfamiliar with Linux, some of these commands might seem odd to you. It is recommended that if you are unfamiliar with an operating system, you leave forensics for that system to someone who is better qualified. However, given the number of open-source forensic tools that work with Linux, it is advised that you learn at least the fundamentals of Linux.

The extundelete Utility

The `extundelete` utility (<http://extundelete.sourceforge.net/>) works with both Ext3 and Ext4 partitions. This product works via shell commands, and they are relatively simple. For example, if you want to restore all deleted files from the sda4 partition, just use this command:

```
extundelete /dev/sda4 --restore-all
```

The website documents all the various options you can utilize with this tool.

FYI

A few `grep` flags of use in these searches:

- i—Ignore case distinctions in both the PATTERN and the input files; that is, it matches both uppercase and lowercase characters.
- a—Process a binary file as if it were text.
- B—Print number lines/size of leading context before matching lines.
- A—Print number lines/size of trailing context after matching lines.

Scalpel

This tool works with both Linux and Mac OS, and it is even possible to compile the source code to work in Windows. However, it is easiest to install and work with in Linux. For example, if you are using Ubuntu Linux, this is all it takes to install:

```
sudo apt-get install scalpel
```

Next is some text editing—the configuration file is `/etc/scalpel/scalpel.conf`. You will find that everything has been commented out—uncomment the specific file format that you want to recover. For example, if you want to recover deleted Zip files, then you need to uncomment the `.zip` file section in `scalpel.conf`.

Next, in a terminal, run the following command:

```
sudo scalpel [device/directory/file name] -o [output directory]
```

The output directory, in which you want to store recovered files, should be empty before running Scalpel; otherwise, you will get an error.

Mac OS

Starting with OS X, Mac OS is actually based on FreeBSD, which is a UNIX clone, much like Linux. In fact, if you go to a terminal window in Mac OS, what you actually get is a shell where you can run UNIX shell commands. This means that some of the techniques that work for Linux also work with Mac OS. However, there are also some tools you can use that are made specifically for Mac OS.

You should also be aware that Mac OS has its own file systems. Today, Mac OS uses HFS+, or Hierarchical File System Plus, and APFS, or Apple File System. HFS+ replaced the earliest Macintosh/Mac OS file system called HFS a little over 20 years ago. APFS replaced HFS+ when Apple released its Mac OS High Sierra in 2017. You can get details on HFS and HFS+ at <https://www.techrepublic.com/article/apfs-vs-hfs-which-apple-file-system-is-better/>.

MacKeeper

MacKeeper (<http://mackeeper.zeobit.com/recover-deleted-files-on-mac>) is a useful tool for recovering deleted files on an Apple computer. There is a free, fully functional trial version. Once you download and install this tool, you can recover files in just a few easy steps:

1. Open the Files Recovery tool. Select the volume where your lost files were and start the scan. This is shown in **Figure 6-13**.



Figure 6-13 MacKeeper Step 1.

2. Then select Undelete, shown in **Figure 6-14**.

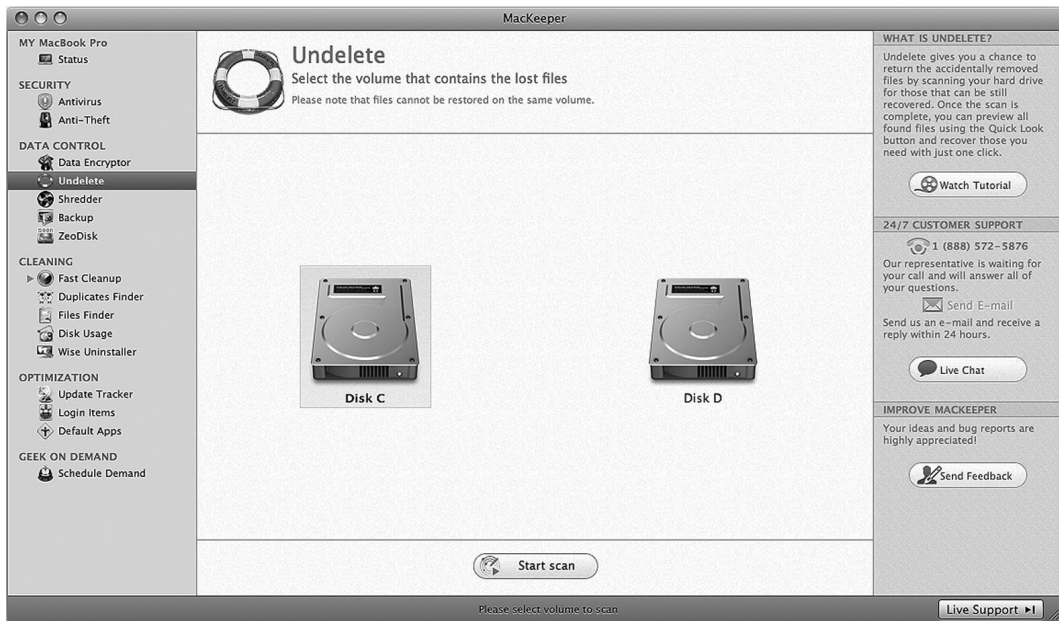


Figure 6-14 Files Recovery tool.

That is it. This tool is remarkably simple to use.

There are certainly other tools that can recover Mac OS deleted files. You should experiment with various tools and find the ones that are most useful for you. As always, you should be comfortable with a given operating system before attempting forensic analysis of that operating system.

Recovering Information from Damaged Media

A wide variety of failures cause **physical damage** to storage media. Compact discs (CDs) can have their metallic substrate or dye layer scratched. Hard disks can suffer any of several mechanical failures, such as head crashes and failed motors. Tapes can simply break. Physical damage always causes some data loss, and in many cases, the file system's logical structures sustain damage as well. This results in logical damage that must be dealt with before any files can be salvaged from the failed media.

FYI

A **clean room** is an environment that has a controlled level of contamination, such as from dust, microbes, and other particles.

End users can't repair most physical damage. Generally, they don't have the hardware or technical expertise required to make physical repairs. Further, end users' attempts to repair physical damage often increase the damage. Normally, you shouldn't attempt to repair physical media. You may try a number of techniques to recover data from damaged media. However, only organizations with specialized equipment and facilities, such as clean rooms, should attempt repair or enhanced data recovery.

Physical Damage Recovery Techniques

Recovering data from a hard drive should start with the assumption that, unless the case is visibly damaged, the drive itself is still operable. Today's hard disks are built to be rugged enough to protect against damage. Thus, when presented with a "failed hard drive," use the following techniques to evaluate the drive and retrieve needed data:

1. Remove the drive from the system on which it is installed and connect it to a **test system**—a compatible system that is functional. Make the connection without installing the drive but only connecting the data and power cables.
2. Boot the test system from its own internal drive. Listen to the failed drive to determine whether the internal disks are spinning. If the disks are spinning, it generally means the disk has not experienced a catastrophic failure. Therefore, you can likely recover the data.
3. Determine whether the failed drive is recognized and can be installed as an additional disk on the test system. If the drive installs, copy all directories and files to a hard drive on the test system. If a drive fails on one system but installs on another, the drive may be usable. The drive may have failed because of a power supply

failure, corruption of the operating system, malicious software, or some other reason. If you can operate the drive, run a virus check on the recovered data and test for directory and file integrity.

4. If the hard drive is not spinning or the test system does not recognize it, perform limited repair. You may be able to get the hard drive to start, and it may be recognized by the test system. If you can repair the drive, use specialized software to image all data bits from the failed drive to a recovery drive. Use the extracted raw image to reconstruct usable data. Try open-source tools such as DCFLdd (this is an enhanced version of the dd utility) to recover all data except for data in physically damaged sectors.
5. If necessary, send the device to data recovery specialists, who may be able to apply extraordinary recovery techniques.

It is possible that the data is deemed “lost,” and there will be no increased loss if you attempt local repair and fail. If so, you can try the following:

1. Remove the printed circuit board and replace it with a matching circuit board from a known healthy drive.
2. Change the read/write head assembly with matching parts from a known healthy drive.
3. Remove the hard disk platters from the original drive and install them into a known healthy drive.

Recovering Data After Logical Damage

Logical damage to a file system is more common than physical damage. Logical damage may prevent the host operating system from mounting or using the file system. Power outages can cause logical damage, preventing file system structures from completely writing information from memory to the storage medium. Even turning off a machine while it is booting or shutting down can lead to logical damage. Errors in hardware controllers—especially RAID (redundant array of inexpensive disks) controllers—and drivers and system crashes can have the same effect.

Logical damage can cause a variety of problems, such as system crashes or actual data loss. It can result in intermittent failures. It can also trigger other strange behavior, such as infinitely recursing directories and drives reporting negative free space remaining. Some programs can correct the inconsistencies that result from logical damage. Most operating systems provide a basic repair tool for their native file systems. Microsoft Windows has chkdsk, for example; Linux comes with the fsck utility; and Mac OS provides Disk Utility. A number of companies have developed products to resolve logical file system errors, such as the Sleuth Kit (<http://www.sleuthkit.org>). Third-party products may

be able to recover data even when the operating system's repair utility doesn't recognize the disk. TestDisk (<http://www.cgsecurity.org/wiki/TestDisk>) is one example. It can recover lost partitions and reconstruct corrupted partition tables.

Preventing Logical Damage

Journaling file systems, such as NTFS 5.0 and Ext3, help to reduce the incidence of logical damage. In the event of system failure, you can roll these file systems back to a consistent or stable state. The information most likely to be lost will be in the drive's cache at the time of the system failure.

Using a consistency checker should be a routine part of system maintenance. A consistency checker protects against file system software bugs and storage hardware design incompatibilities. For example, a disk controller may report that file system structures have been saved to disk, but the data is actually still in the write cache. If the computer loses power while this data is in the cache, the file system may be left in an inconsistent or unstable state. To avoid this problem, use hardware that does not report the data as written until it actually is written. Another solution is to use disk controllers with battery backups. When the power is restored after an outage, the pending data is written to disk. For greater protection, use a system battery backup to provide power long enough to shut down the system safely.

Logical Damage Recovery Techniques

Two techniques are common for recovering data after logical damage: consistency checking and zero-knowledge analysis. Use these techniques to either repair or work around most logical damage. However, applying data recovery software doesn't guarantee that no data loss will occur. For example, when two files claim to share the same allocation unit, one of the files is almost certain to lose data.

Consistency Checking

Consistency checking involves scanning a disk's logical structure and ensuring that it is consistent with its specifications. For instance, in most file systems, a directory must have at least two entries: a dot (.) entry that points to itself and a dot-dot (..) entry that points to its parent. A file system repair program reads each directory to ensure that these entries exist and point to the correct directories. If they do not, the program displays an error message, and you can correct the problem. Both chkdsk and fsck work in this fashion. However, consistency checking has two major problems:

- A consistency check can fail if the file system is highly damaged. In this case, the repair program may crash, or it may believe the drive has an invalid file system.
- The chkdsk utility might automatically delete data files if the files are out of place or unexplainable. The utility does this to ensure that the operating system can run properly. However, the deleted files may be important and irreplaceable user files.

The same type of problem occurs with system restore disks that restore the operating system by removing the previous installation. Avoid this problem by installing the operating system on a separate partition from the user data.

Zero-Knowledge Analysis

Zero-knowledge analysis is the second technique for file system repair. With zero-knowledge analysis, few assumptions are made about the state of the file system. The file system is rebuilt from scratch using knowledge of an undamaged file system structure. In this process, scan the drive of the affected computer, noting all file system structures and possible file boundaries. Then match the results to the specifications of a working file system.

Zero-knowledge analysis is usually much slower than consistency checking. You can use it, however, to recover data even when the logical structures are almost completely destroyed. This technique generally does not repair the damaged file system but allows you to extract the data to another storage device.

File Carving

When a file is only partially recovered, regardless of the file system, you can use file carving to attempt to recover the file. One popular file carving tool is Scalpel, which was discussed previously in this chapter. File carving, sometimes just called “carving,” is often used to recover data from a disk where there has been some damage or where the file itself is corrupt. Regardless of the name used, the purpose is to extract the data from a single file from the larger set of data—that is, the entire disk or partition. This is a common method of data recovery, particularly when the file metadata has been damaged.

Most file carving utilities operate by looking for file headers and/or footers, and then pulling out the data that is found between these two boundaries.

We previously discussed Scalpel as a possible file carving tool; another is carver-recovery, which is a free tool that also includes the source code for you to modify if you wish. It contains several utilities. The carver-recovery.exe simply allows you to select a drive image, and it will attempt to recover files. This is a broad-based tool for attempting to recover from an entire drive or partition.

Obviously, to effectively use file carving, one needs to be familiar with file headers and footers. It is beyond the scope of this book to discuss all file headers, but the hexadecimal values for some common files are shown here:

JPEG	FF D8
BMP	42 4D
EXE	4D 5A
GIF	47 49
MP3	49 44
PDF	25 50
ZIP	50 4B
PNG	89 50
WAV	52 49
AVI	52 49

CHAPTER SUMMARY

In this chapter, you learned the essentials of file recovery in the three major operating systems as well as different storage media. The most attention was given to Windows due to how widely it is used. It is important that you be comfortable with these undeletion techniques. You should also be familiar with how to utilize any undeletion functionality in your preferred forensic toolkit (such as EnCase or Forensic Toolkit).

KEY CONCEPTS AND TERMS

Clean room

Consistency checking

grep

Inode

Logical damage

Physical damage

Test system

Zero-knowledge analysis

CHAPTER 6 ASSESSMENT

1. Which of the following is the Linux equivalent of a shortcut?
 - A. Hard link
 - B. Symbolic link
 - C. Partial link
 - D. Faux link
2. What file system does Windows 10 use?
 - A. FAT
 - B. FAT32
 - C. NTFS
 - D. HPFS
3. What file system does Mac OS use?
 - A. HPFS
 - B. HFS+
 - C. NTFS
 - D. EXT3
4. Why can you undelete files in Windows 7?
 - A. Nothing is deleted; it is just removed from MFT.
 - B. Nothing is deleted; it is just removed from FAT.
 - C. Fragments might exist, even though the file is deleted.
 - D. You cannot.

Reference

1. Bunting, S. (2012). *EnCE: EnCase Computer Forensics: The Official EnCase Certified Examiner Study Guide*, 3rd ed. Indianapolis, IN: John Wiley & Sons.
2. International Council of Electronic Commerce Consultants (EC-Council). (2009). *Computer Forensics: Hard Disk and Operating Systems*. Boston, MA: Cengage Learning.
3. Sammons, J. (2012). *The Basics of Digital Forensics: The Primer for Getting Started in Digital Forensics*. Rockland, MA: Syngress Publishing.



CHAPTER 7

Incident Response

© phyZick/Shutterstock

In this chapter, you will learn about the relationship between incident response and forensics. When an incident occurs, be it a disaster or an intrusion, forensics may be the best method to discover what went wrong, and thus work to avoid it recurring. Forensics techniques also provide methods for recovering data in the event of a disaster. And it is always possible that the disaster was caused by a criminal act, leading to criminal prosecution, or an act of negligence that would warrant civil litigation.

It is common today to refer to digital forensics as digital forensics and incident response (DFIR). Consider a virus outbreak on a corporate network. It is quite possible that the actual creator of the virus will never be identified and prosecuted. However, it is important to know the extent of the virus's damage and how it entered the network. As an example, as early as 2015, there was a variant of the ransomware CryptoWall that not only encrypted files for ransom, but also placed spyware on the infected machine. Any incident response team that simply focused on getting the files unencrypted but did not perform forensic analysis of at least a few infected machines would not have been aware of the spyware. If any incident response does not include any forensics, it is entirely possible that you won't discover the secondary effect of any incident.

Some might object to using disaster recovery and incident response together. However, this is perfectly reasonable. Consider, what is a disaster? What is an incident? An incident is any negative event. Whether or not it is a disaster is a function of both how extensive the incident is and the perspective of the person involved. As an example, suppose you own a jewelry store. All of your business takes place in person. But you do have a website for marketing purposes. If that website is down for an entire day, it is an incident, but you probably don't consider it a disaster. However, imagine that instead you run an online sports memorabilia website. Your website is down for one full day, and it is a week before Christmas. That same incident, in a different context, has become a disaster. Differentiating

between *incident* and *disaster* is really an argument over semantics. You will approach any incident the same way you might approach a disaster; you just may abbreviate some steps.

Chapter 7 Topics

This chapter covers the following concepts and topics:

- Understanding disaster recovery
- Preserving evidence
- Adding forensics to the disaster recovery plan

Chapter 7 Goals

When you complete this chapter, you will be able to:

- Understand key disaster recovery terms such as BIA, MTD, BCP, and DRP
- Understand the phases of incident response
- Be able to integrate forensics into an incident response plan

Disaster Recovery

Disaster recovery, business continuity, and forensics have become closely related topics. You may think forensics only applies to criminal activities, and it often does. However, after an information technology–related disaster, forensic techniques may be the best method for determining what caused the disaster and avoiding it in the future. It is also possible that a disaster was instigated by the commission of a cybercrime, in which case the need for forensics is clear.

The forensics process really begins once an incident has been discovered, but it does not get fully under way until after the disaster or incident is contained. However, before you examine the forensic process for disasters, it would be a good idea to start with a basic understanding of disaster recovery. Containment is always the first priority in incident response. However, one must be careful not to damage any potential forensic evidence.

All organizations must plan for the possibility of some disaster occurring that disrupts normal operations. When narrowing the focus to just computer-related operations, there are a number of possibilities to consider. They include equipment failure, computer viruses, malicious hacking, insider data theft, and more. Of course, the usual disasters still apply, such as:

- Fire
- Flood
- Hurricane
- Tornado

However, those typically do not involve computer forensics. So for the purposes of this chapter, we will narrow our focus to only computer disasters, such as:

- Hard drive failure
- Network outage
- Malware infection
- Data theft or deletion
- Intrusion

Each of these activities can disrupt normal operations for the organization's computer systems, and therefore constitute a disaster. As was mentioned in the introduction, how you view the severity each of these will depend greatly on context. There are actually two plans most organizations have for responding to such disaster: the **Business Continuity Plan (BCP)** and the **Disaster Recovery Plan (DRP)**. A BCP is focused on keeping the organization functioning as well as possible until a full recovery can be made. A DRP is

focused on executing a full recovery to normal operations. For example, consider a scenario where a virus takes the main web server offline. A BCP would be concerned about what can be done to get minimal operations going until such time as the organization can be returned to full functionality—perhaps temporarily using an old server, one that may not be as robust but could provide minimal functionality. A DRP is focused on actually returning the organization to full functionality. In the scenario just described, this would be a full web server, equivalent to the failed server, back online and running at full capacity.

There are some federal standards for BCPs.

ISO 27001

ISO 27001 outlines requirements for information security management systems. This standard was first released in 2005 and revised in 2014. There was an update for Europe only in 2017 to meet the European Union's General Data Protection Regulation requirements. ISO 27001 is a very broad standard covering information security management in general. Section 14 addresses business continuity management.

NIST 800-34

This standard is entitled *Contingency Planning Guide for Information Technology Systems*—thus it is clearly related to business continuity and disaster recovery. This plan introduces some additional acronyms such as continuity of operations plan (COOP), critical infrastructure protection (CIP), and information system contingency plan (ISCP). COOP is focused solely on identifying mission-essential functions (MEF) and being able to sustain those for 30 days. NIST 800-34 defines CIP as “critical infrastructure and key resources (CIKR) [which] are those components of the national infrastructure that are deemed so vital that their loss would have a debilitating effect on the safety, security, economy, and/or health of the United States.”¹ ISCP is concerned with assessment and recovery of a system following some disruption. The plan includes a seven-step process for BCP and DRP projects. Those seven steps are:

1. **Develop the contingency planning policy statement.** A formal policy provides the authority and guidance necessary to develop an effective contingency plan.
2. **Conduct the business impact analysis (BIA).** The BIA is used to identify and prioritize information systems and components critical to supporting the organization's mission/business functions.
3. **Identify preventive controls.** Measures taken to reduce the effects of system disruptions can increase system availability and reduce contingency life-cycle costs.
4. **Create contingency strategies.** Thorough strategies ensure that the system may be recovered quickly and effectively following a disruption.

5. **Develop an information system contingency plan.** The contingency plan should contain detailed guidance and procedures for restoring a system based the system's security impact level and recovery requirements.
6. **Plan testing and training.** Ensure the BCP and DRP are tested and staff are trained in these plans.
7. **Plan maintenance.** The plan should updated frequently to remain current with system and organizational changes.

NFPA 1600

This is formally titled *Standard on Disaster/Emergency Management and Business Continuity Programs*. It was created by the U.S. National Fire Protection Association. The focus is clearly on responding to fire-related incidents. These typically won't involve digital forensics.

These standards provide a good overview of what should be covered in any BCP, and some (like NIST 800-34) are also applicable to DRPs. You should certainly consider reviewing these standards at some point in your career. For the purposes of forensic examination, you don't need to be an expert in disaster recovery; just a basic overview of the process is sufficient. The essential steps are outlined here.

Business Impact Analysis

Business impact analysis (BIA) is a process whereby the disaster recovery team contemplates likely disasters and what the impact each would have on the organization. For example, a company that ships goods to retail stores but does not sell directly to the public might be slightly impacted if its web server was down for a day. A company that sells directly to the public both in-store and online would be moderately impacted by such an outage. But a completely e-commerce company, one that only sells products online, would be severely impacted.

Usually, some sort of table is created listing the various disasters being planned for and the impact they would have on the organization. In more complex scenarios, the organization may be broken down into subsections, and the impact of each disaster on each piece of the organization is rated. Whether a plan goes into great detail or not, one item that must be considered is the **maximum tolerable downtime (MTD)**. That is how long can the system(s) be down before it is impossible for the organization to recover. Imagine your favorite e-commerce site goes down. You may be a loyal customer and wait for it to come back up. But as time goes on, fewer and fewer customers wait, and more money is lost, until it may reach a point that the company simply cannot recover. If the disaster recovery team knows the MTD for the organization as well as for portions of the organization, they can then prioritize the recovery plan.

Two other terms are related to maximum tolerable downtime. One is **mean time to repair (MTTR)**, which is sometimes called *mean time to recover*. This is the average time it takes to repair an item. The second term is **mean time to failure (MTTF)**. How long, on average, is it before a given device is likely to fail through normal use? These are important questions to answer when performing a BIA. If an organization cannot be without a given piece of equipment more than 14 days and still recover (that is, the MTD = 14 days), yet the MTTR is 7 days, that means you have only 7 days after a disaster to initiate repairs or the organization will be unable to recover.

MTD simply means how long a given system can be down without causing substantial long-term harm to the organization. With some disasters or incidents, MTD won't be an issue. For example, a hard drive failing on a server that is part of a cluster is unlikely to include the issue of MTD. The cluster has data duplicated, and one hard drive failing won't dramatically affect the organization. However, with respect to determining a computer MTD, there are a number of factors to take into account. One is the importance of that system to the organization. There are also some related numbers that need to be calculated. One of those is the **recovery point objective (RPO)**. That refers to how much data will be lost. Let's assume you do a backup of a critical database every hour. The most data that could be lost in a database failure is 59 minutes' worth. Is that a risk your organization can accept? Or is that too much? This is clearly related to the MTD. Another number is **recovery time objective (RTO)**. When a system is down, what is the target time to have it back up and running? Clearly, that RTO must be less than the MTD.

There are a few calculations commonly used in BIAs. The first is **single loss expectancy (SLE)**. This is calculated by multiplying the asset value times the exposure factor. This will make more sense with an example. Let us assume you have an e-

commerce site that generates \$10,000 per week. That is the asset value. Now, assume that if it is hit by a denial-of-service (DoS) attack, you can expect it to be down one full day (I am using easy numbers to make the math simple). Well, that is an exposure factor of 1/7, or about 0.142. So the calculation becomes:

$$SLE = AV * EF$$

or

$$SLE = \$10,000 * 0.142$$

$$SLE = \$1,428.57$$

Next, you need to determine the **annualized loss expectancy (ALE)**. Let's suppose that, based on past incident reports and statistics for businesses similar to yours, you expect three DoS attacks per year. That would be the **annual rate of occurrence (ARO)**, so your formula is now:

$$ALE = ARO * SLE$$

or

$$ALE = 3 * \$1,428.57$$

$$ALE = \$4,285.71$$

These numbers are used to calculate how much you should spend on mitigating the attack. Let us further assume that a vendor has a product that is guaranteed to reduce DoS attacks by 90%. That should roughly make your ALE only 10% of what it has been, or \$428.57. That sounds like a wonderful deal. But what if the product costs \$5,000 per year to license? That is more than your ALE. You can see how SLE and ALE help you to quantify loss and then how to allocate resources to mitigate losses.

Describing the Incident

It is necessary to describe any incident in order to analyze it. The description is not an ad hoc or subjective process. There are specific measurements that will help to describe any incident and will facilitate your forensic analysis.

Common Vulnerability Scoring System

A common method for scoring system vulnerabilities is the Common Vulnerability Scoring System (CVSS). The CVSS is widely used to classify vulnerabilities. This is an open industry standard that allows for the scoring of vulnerabilities based on severity. When responding to an incident, it is very helpful to describe the vulnerabilities that lead to the incident. When using CVSS, there are three groups of metrics: base, temporal, and environmental. The base group describes the basic characteristics of the vulnerability that are not determined by time (temporal) or environment. The metrics in this group are Attack Vector, Attack Complexity, Privileges Required, User Interaction, Scope, Confidentiality Impact, Integrity Impact, and Availability Impact.

The Attack Vector metric can be Network (N), Adjacent (A), Local (L), or Physical (P). Attack Complexity can be None (N), Low (L), or High (H). User Interaction can be None (N) or Required (R). The Scope metric captures whether a vulnerability in one vulnerable component impacts resources in components beyond its security scope. Its values can be Unchanged (U) or Changed (C). The Impact metrics (Confidentiality, Availability, or Integrity) are all rated as High (H), Low (L), or None (N). This allows you to understand the nature of vulnerabilities that facilitated the incident in question. It should be noted that CVSS v3.x introduced a new level, that of Critical, so the options are now Low, Medium, High, and Critical.

The Temporal Metric Group has three metrics: Exploit Code Maturity, Remediation Level, and Report Confidence. The Environmental Metric Group has four metrics: Modified Base Metrics, Confidentiality Requirement, Integrity Requirement, and Availability Requirement.

Exploit Code Maturity measures the likelihood of the vulnerability being attacked and is typically based on the current state of exploit techniques, exploit code availability, or active, “in-the-wild” exploitation. The possible ratings are Not Defined (X), High (H), Functional (F), Proof of Concept (P), and Unproven (U). The Remediation Level metric can be Not Defined (X), Unavailable (U), Workaround (W), Temporary Fix (T), or Official Fix (O). The Report Confidence metric indicates how confident we are in the details of the vulnerability. Its value can be Not Defined (X), Confirmed (C), Reasonable (R), or Unknown (U).

The values for the various metrics are summarized in **TABLE 7-1.**

TABLE 7-1 CVSS.

METRIC GROUP	METRIC NAME (AND ABBREVIATED FORM)	POSSIBLE VALUES	MANDATORY?
Base	Attack Vector (AV)	[N, A, L, P]	Yes
	Attack Complexity (AC)	[L, H]	Yes
	Privileges Required (PR)	[N, L, H]	Yes
	User Interaction (UI)	[N, R]	Yes
	Scope (S)	[U, C]	Yes
	Confidentiality (C)	[H, L, N]	Yes
	Integrity (I)	[H, L, N]	Yes
	Availability (A)	[H, L, N]	Yes
Temporal	Exploit Code Maturity (E)	[X, H, F, P, U]	No
	Remediation Level (RL)	[X, U, W, T, O]	No
	Report Confidence (RC)	[X, C, R, U]	No
Environmental	Confidentiality Requirement (CR)	[X, H, M, L]	No
	Integrity Requirement (IR)	[X, H, M, L]	No
	Availability Requirement (AR)	[X, H, M, L]	No
	Modified Attack Vector (MAV)	[X, N, A, L, P]	No
	Modified Attack Complexity (MAC)	[X, L, H]	No
	Modified Privileges Required (MPR)	[X, N, L, H]	No
	Modified User Interaction (MUI)	[X, N, R]	No
	Modified Scope (MS)	[X, U, C]	No
	Modified Confidentiality (MC)	[X, N, L, H]	No
	Modified Integrity (MI)	[X, N, L, H]	No
	Modified Availability (MA)	[X, N, L, H]	No

CVSS scoring is often represented as a string such as:

CVSS:3.1/S:U/AV:N/AC:L/PR:H/UI:N/C:L/I:L/A:N/E:F/RL:X

Understanding the vulnerabilities that a network faces and quantifying the threat they pose is important for incident response. CVSS is often used before an attack, to rank vulnerabilities in risk assessment. But it is also useful in the later stages of incident response to quantify what has occurred.

DREAD

DREAD is an acronym for Damage Potential, Reproducibility, Exploitability, Affected Users, and Discoverability. It is a mnemonic for risk rating using five categories. How much damage would an attack cause? In the case of incident response, the question is, how much damage *did* the attack cause? How easy is it for an attacker to reproduce this attack? How much effort is required to execute the attack? How many users will be impacted? And finally, how easy is it to discover the threat? DREAD asks what the likelihood of an attack is and what damage it would cause. DREAD is an effective model for evaluating the impact of an attack.

RMON

The Remote Network MONitoring (RMON) was developed by the Internet Engineering Task Force (IETF) in order to support network monitoring and protocol analysis. This might not seem like a useful tool for incident response, but it can be. It provides a standardized method of classifying network traffic. RMON is a standard monitoring specification that allows various network monitors to exchange network monitoring data.

The original version of RMON had 10 groups:

1. **Statistics:** real-time LAN statistics, e.g., utilization, collisions, CRC errors
2. **History:** history of selected statistics
3. **Alarm:** definitions for RMON SNMP traps to be set when statistics exceed defined thresholds
4. **Hosts:** host-specific LAN statistics, e.g., bytes sent/received, frames sent/received
5. **Hosts top N:** record of N most active connections over a given time period
6. **Matrix:** the sent–received traffic matrix between systems
7. **Filter:** defines packet data patterns of interest, e.g., MAC address or TCP port
8. **Capture:** collect and forward packets matching the Filter
9. **Event:** send alerts (SNMP traps) for the Alarm group
10. **Token Ring:** extensions specific to Token Ring

The original RMON was defined by RFC 2819. RMON2 was defined in RFC 4502. There have been modifications of RMON for specialized networks. For example, Remote Network Monitoring Management Information Base for High Capacity Networks, or HCRMON, was defined in RFC 3272. Remote Network Monitoring MIB Extensions for Switched Network, or SIMON, was defined in RFC 2613. Using this technique allows you to perform a “postmortem” analysis on network logs to determine when an attack began—and perhaps identify its source.

Mean Squared Deviation

The mean squared deviation (MSD) formula is relatively simple and provides insight into how any system deviates from expectations. This is sometimes referred to as the *mean squared error*. It essentially takes the square of the errors or deviations from expected/desired outcomes. This formula is shown in [FIGURE 7-1](#).

$$\text{MSD} = \frac{1}{n} \sum_{i=2}^n (y_i - T)^2$$

Figure 7-1 Mean square deviation formula.

In [Figure 7-1](#), y_i is the actual value and T is the target value. This is commonly used in many engineering disciplines. The metric is a positive integer. Interpreting it is quite simple: The closer to zero the MSD is, the more reliable the system in question is. It is sometimes the case that one takes the square root of the mean squared error, yielding the root mean squared deviation (or root mean squared error). This formula can also be used to provide a metric of the impact an incident had on a given system. How far did the system deviate from norm?

Mean Percentage Error

Closely related to the MSD is the mean percentage error (MPE) formula. The MPE is the arithmetic mean of errors from modeling. This metric compares expected values to actual values and calculates mean error. An error is defined as any deviation from the planned or expected value. This is critical in modeling, as it can be used to evaluate the efficacy of the model itself. The MPE formula is shown in [FIGURE 7-2](#).

$$\text{MPE} = \frac{100\%}{n} \sum_{t=1}^n \frac{a_t - f_t}{a_t}$$

Figure 7-2 Mean percentage error formula.

In [Figure 7-2](#), n is the number of different times for which the variable is forecast; a_t is the actual value of the quantity being forecast; and f_t is the forecast.

Essentially, this metric is describing the difference between expected values and the actual value. This is an effective way to measure the impact of an incident.

Ishikawa Diagram

Ishikawa diagrams are a commonly used engineering tool in failure mode and effects analysis (FMEA) in engineering. These are sometimes called “fish diagrams” because the defect is the fish’s head and the issues leading to the defect are branches or fish bones. A generic example of how to create an Ishikawa diagram is shown in [FIGURE 7-3](#).

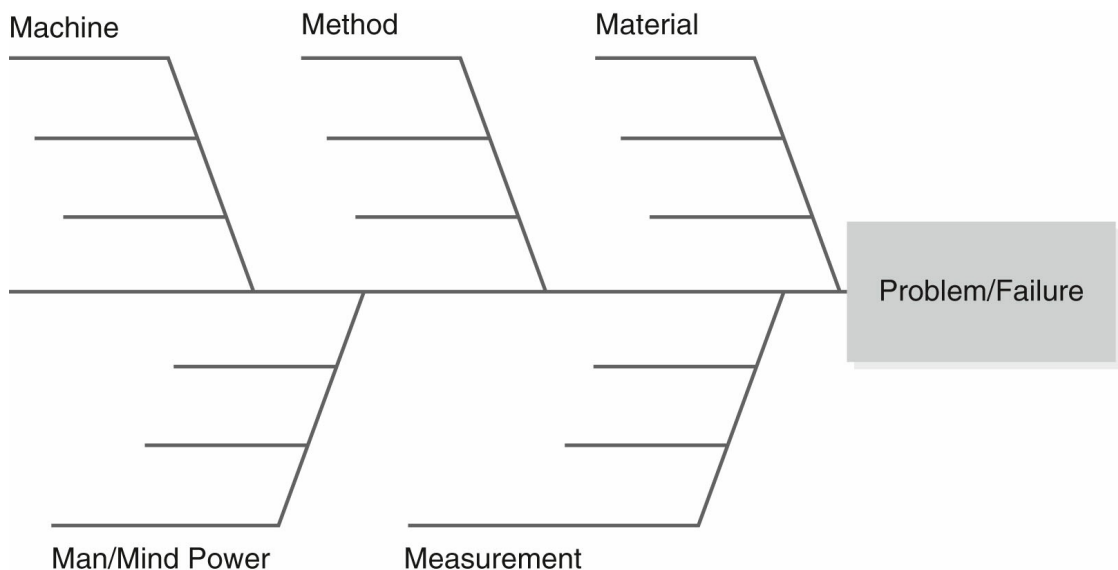


Figure 7-3 Ishikawa diagram.

This can be effective in tracing the root cause of an incident. Root cause analysis is an important aspect of incident response.

The Recovery Plan

The recovery plan consists of two parts. The ultimate goal is a complete recovery, and this is outlined in the disaster recovery plan. But unless that DRP is going to get the organization back up to full capacity within 24 hours or less, there will also be a need for a BCP, a plan for how to get at least minimal functionality until full recovery is accomplished. Both plans are based on the priorities that were established during the BIA phase.

Even though the DRP and the BCP don't have exactly the same goals, they do require the same questions to be asked:

- Do you have alternate equipment identified?
- If needed, do you have alternate facilities identified?
- Is there a mechanism in place for contacting employees, vendors, customers, etc., even if the primary means of communication are down?
- Is there offsite backup of the data?
- Can that backup be readily retrieved and restored?

When considering backups, and restoring backups, you need to think about what type of backups you have. While database administrators may use a number of different types of data backups, from a security point of view, there are three primary backup types we are concerned with:

- **Full**—all changes
- **Differential**—all changes since last full backup
- **Incremental**—all changes since last backup of any type

If you did a full backup, then just restore the last backup. However, if the backup strategy includes differential or incremental backups, and it probably will, then there will be additional backup data to restore.

There is another type of backup that is becoming more popular, called hierarchical storage management (HSM). HSM provides continuous online backup by using optical or tape “jukeboxes.” It appears as an infinite disk to the system, and can be configured to provide the closest version of an available real-time backup.



NOTE

Even though more organizations are going to electronic backups, it is important to

consider backup media rotation. Even with electronic backup, you don't have infinite storage and will eventually have to overwrite something. This necessitates overwriting and reusing media. There are two main approaches to this. One is the Tower of Hanoi, which is fairly complicated and thus rarely used. The more common approach is the Grandfather–Father–Son. To illustrate this, consider a server using traditional tape backup, which is backed up daily. Each daily backup is the son. At the end of the week, a weekly backup is made. That weekly backup is the father. Now the daily backups begin to be reused. At the end of the month, there is a monthly backup made. That is the grandfather, and then the weekly backups can begin to be reused. This is a simple and widely used system to reuse backup media.

The Post Recovery Follow-Up

Different disaster recovery textbooks will label this differently, but the content is the same: Now that the disaster is over and the organization has recovered, you have to find out what happened and why. This is where forensics comes into play. This phase is not necessarily about assigning blame; it is about discovering if the disaster was caused by some weakness in the system. That could be an act of negligence by an individual, or it could be a gap in policy. But if the root cause is not discovered and addressed, the chances of it occurring again are significant.

Incident Response

When an incident occurs, even if it does not rise to the level of a disaster, there needs to be an organized response. For example, if a single workstation is infected with a virus, this probably does not constitute a disaster. But if it is not responded to quickly, it may grow into a disaster as the virus spreads, so proper incident response is important.

There are some key steps that every incident response plan must include. These are outlined in this section. You will also find some sources refer to the six phases of incident response; others will list five or seven phases. The issue is not how finely you break out the steps, but that all necessary steps are done, and done at the appropriate time.

Detection

Obviously, you have to detect the incident before you can respond. However, at this initial stage, you don't have time to conduct a detailed analysis. You need to simply detect there is an incident, its basic nature, and what systems are affected, then go to containment. As an example, if you detect malware, then your initial goal is just to determine affected systems and contain them. Then you can go back and discover more details such as the type of malware, the damage it caused, how it got on the network, etc. This does not mean you won't do analysis. You absolutely will. But if you spend time here on analysis, the incident is still ongoing. If it is malware, the malware is still spreading.

Containment

The first step in the response is always to limit the incident. This means keeping it from impacting more systems. In the case of a virus, the goal is clear: Keep the virus from spreading. It is probably a good idea to have a policy in place that instructs users to disconnect their computer from the network, then call tech support, if they suspect they have a virus. This contains the virus and prevents it from spreading further.

Other incidents may not have such a clear containment path. For example, if there is an intruder getting into the web server, how is that contained? First, the web server itself is isolated from the rest of the network. Then you seek to prevent further intrusion. This can be done by changing passwords throughout the organization, on the assumption that the intruder might have compromised passwords.

While the specifics of containment might vary, the goal does not: Limit the spread of whatever the incident is, as much as possible. And this phase must occur before any others. It is vital that the incident's effects not spread further. This must be addressed before you attempt to eradicate the threat.

Eradication

Once the incident is contained, the next step is to eradicate the problem. In the case of malware, the issue is to remove the malware. In some cases, anti-malware tools such as Norton, Bit Defender, McAfee, Kaspersky, Windows Defender, or AVG can remove the malware. In other cases, the IT staff will need to manually remove the malware.

Other attacks are not so clear. For example, if the incident is an intruder infiltrating the network via an SQL injection, what does eradication entail? The first step is to fix whatever vulnerability allowed the intruder to infiltrate the network. In the case of SQL injection, it would involve correcting the flaws in the web page that allowed this attack to occur.

Regardless of the particular incident, eradication needs to be thorough. That means a comprehensive examination of what occurred and how far it reached. It is imperative to ensure that the issue is completely addressed.

This is the stage at which forensics must begin. If the incident is simply eradicated, it is likely that evidence will be eradicated. It is imperative that you begin collecting evidence prior to eradicating the incident. This may involve performing the forensic investigation prior to any eradication steps taking place. In some cases, it is just not possible to perform a full forensic investigation while keeping the systems on hold. In that case, simply image the drives involved so that a forensic investigation can be conducted at a later time.

Recovery

Recovery involves returning the affected systems to normal status. In the case of malware, that means ensuring the system is back in full working order with absolutely no presence of the malware. In many cases, this will involve restoring software and data from a backup source that has been verified to be free from the malware infection.

Follow-Up

The follow-up phase is another stage at which forensics plays a critical role. The IT team must determine how this incident occurred and what steps can be taken to keep this type of incident from reoccurring. Clearly, those decisions cannot be made without the input from the forensic examination. This is when we return to the analysis that we only briefly touched on in the detection phase. Now we have the time to carefully analyze and learn from the incident.



NOTE

This is one reason why corporations are becoming more interested in their IT security team including personnel with forensics training. Even if the goal is not to collect evidence for legal proceedings, the same forensics techniques can be utilized to determine the exact cause and extent of a computer security breach. And that information is absolutely essential for preventing future incidents.

One part of the follow-up is classifying the incident. There are several standards that require the incidents be reported to some authority, and those reports require some description and classification. As an example, the payment card industry requires its merchants to report security incidents involving cardholder data. This report should be issued whenever a breach is detected that violates the Payment Card Industry Data Security Standard (PCI DSS). The following are examples of the sorts of things that PCI identifies as methods to gain unauthorized access to systems and sensitive information:

- **SQL injection**—A technique that inserts modified SQL (Structured Query Language) into a website. This attack depends on the website allowing unfiltered input.
- **Malicious code or malware**—Programs (such as viruses, worms, Trojan horses, back doors, and spyware) added to a system without a user's knowledge. These programs can damage systems, delete files, encrypt files and demand ransom, or exfiltrate confidential data.
- **Insecure remote access**—Attacks gaining access through remote services. These vulnerabilities can allow an attacker to gain access to your network.
- **Insecure wireless**—Attacks accessing the network through wireless points of entry. Insecure wireless can allow an attacker to compromise servers, workstations, wireless security cameras, and even IoT devices.

Another example is the Federal Information Security Management Act (FISMA). The federal government uses the National Institute of Standards and Technology (NIST) Special Publication 800-61. This publication classifies incidents into the following events on a system or network:

- **Malicious code**—This is a broad category for all code that causes some harm, including computer viruses, Trojan horses, and spyware.
- **Denial of service**—An attacker crafting packets to cause networks and/or computers to crash.
- **Unauthorized access**—An exploit to gain access.
- **Inappropriate usage**—Any use of the computer that violates company policies. This can also facilitate other attacks. For example, visiting websites that are not allowed or inserting portable USB storage that is not approved can lead to malware getting onto the system.

It is important that during the follow-up phase of incident response, you accurately and completely document the nature of the attack. This will be useful in investigation as well as in taking steps to mitigate this threat in the future.

Preserving Evidence

An event is any observable occurrence within a system or network. This includes any activity on the network, such as when a user accesses files on a server or when a firewall blocks network traffic. Adverse events are events with a negative result or negative consequences. Attacks on systems are adverse events. Adverse events in this book are events that are computer security–related. They are not events caused by factors such as natural disasters and power failures.

A computer security incident is any event that violates an organization's security policies. This includes computer security policies, acceptable use policies, and standard security practices. The following are examples of computer security incidents:

- **Denial-of-service (DoS) attacks**—A DoS attack could result from an attacker sending specially crafted packets to a web server that cause it to crash. It could also result from an attacker directing hundreds of external compromised workstations to send many Internet Control Message Protocol (ICMP) requests to an organization's network. When the attack is from multiple sources, you refer to it as a distributed DoS (DDoS) attack.
- **Malicious code**—Malicious software, or malware, is any malicious code, such as viruses, worms, and Trojans. For example, a worm uses open file shares to quickly infect hundreds of systems in an organization. Employees may innocently introduce viruses into a network from their home computer on USB thumb drives. When they plug the USB drive into the work computer, the virus infects it.
- **Unauthorized access**—This includes any time someone accesses files they shouldn't be able to access. The access can be from someone within the organization, such as an employee, or from an external attacker. If you don't lock down shared files with appropriate permissions, users may stumble upon data they shouldn't see. If you don't secure databases used by web servers, attackers may be able to access sensitive customer data, such as credit card information, from anywhere on the internet.
- **Inappropriate usage**—Inappropriate usage could take a number of forms. For example, a user might provide illegal copies of software to others through peer-to-peer (P2P) file-sharing services. This same P2P software could cause data leakage resulting in private data from the user's computer being shared on the internet to anyone else using the same P2P software. Or a person might threaten another person through email.

Regardless of the specifics of the incident, it is critical that the evidence be preserved. Throughout this book, evidence preservation has been discussed. However, this topic takes on a new perspective in the case of incident response. The usual emphasis for corporate disaster recovery is simply a return to normal operations as soon as possible. Frequently, this is done at the expense of preserving forensic evidence. This can lead to many problems.

First and foremost, failure to preserve forensic information will prevent the IT team from effectively evaluating the cause of the incident and adjusting company policies and procedures to reduce the risk of such an incident being repeated. Even if the incident does not involve a crime, or the company simply does not wish to prosecute, forensic data plays an integral part in preventing future incidents.



NOTE

The issue of preserving evidence is very much the same as with non-computer crimes. Imagine that a person was murdered in a hotel room. What if the hotel focused only on returning the room to normal use, and immediately thoroughly cleaned the room and rented it to a new guest? This would destroy all physical evidence and make identifying and prosecuting the murderer extremely difficult. Unfortunately, an analogous situation frequently occurs with IT systems after a computer breach. In the haste to restore the systems to normal operations, the evidence is often destroyed.

There are also situations where the organization may not have initially thought a crime was committed, but further investigation reveals that a criminal act occurred. For example, a hard drive crash might initially be thought to be a normal failure of the device, but further examination uncovers malware that caused the hard drive to fail much sooner than it should have. If proper forensic procedures have not been followed, it may be impossible to prosecute or pursue civil litigation.

Adding Forensics to Incident Response

Realizing the importance of forensics in incident response is an important first step. But this realization still leaves the question of how to implement proper forensics procedures. There are specific steps that an IT department can take to intertwine forensic techniques with the company's incident response policies.

Forensic Resources

The first step is to identify forensic resources that the organization can utilize in case of an incident. No amount of policy changes will be effective if the company does not have access to forensically trained individuals. One approach an organization can take is to get basic forensics training for its own IT security staff. Many college computer-related degrees now include forensics courses, and most security-related degrees include at least an introductory forensics course. If no one on the company's IT security staff has had such training, it may be helpful to send staff members to be trained in computer forensics, perhaps to obtain one of the major forensics certifications.

Another option the organization can pursue is to identify an outside party that can respond to incidents with forensically trained personnel. In this case, part of incident planning would involve ensuring there is an agreement in place with a reliable forensics company or individual consultant. If this is the option an organization wishes to pursue, it is critical to ensure that the organization identified has both an appropriate level of competency and the necessary resources to respond to incidents.

Forensics and Policy

Once appropriate forensic resources have been identified, forensic methodology must be interwoven into the incident response policy for the organization. This means that all policies regarding disaster recovery and incident response will need to be updated.

The purpose of updating policies is to ensure that evidence is not destroyed in the process of recovering from an incident or disaster. For example, the policy regarding how to handle a malware infection would be modified so that as soon as the infection was contained, at least one infected machine would be imaged for forensic evidence, prior to the eradication of the malware. In the case of external intrusions, the policies would be changed to preserve all logs prior to full recovery.

It is likely that even if the IT security staff are not trained specifically in forensics, they have some basic knowledge of the field. The reason is that many security textbooks now include at least a chapter on basic forensics. Most of the general computer security certifications such as CompTIA Security+ and CISSP also include sections on basic forensics. Even if your staff lack the appropriate training to perform a forensic investigation, they should be trained well enough to know how to preserve evidence and avoid any alteration of the evidence.

CHAPTER SUMMARY

In this chapter, you learned about the fundamentals of disaster recovery, as well as how that process is impacted by computer forensics. The most important lesson from this chapter is that every organization must intertwine forensic evidence gathering with its disaster recovery and incident response policies. As soon as an incident is contained, and before it is eradicated, it is important to preserve the evidence. This evidence will be useful in gaining a better understanding of the causes of the incident, thus leading to better planning to avoid similar incidents in the future.

KEY CONCEPTS AND TERMS

Annualized loss expectancy (ALE)

Annual rate of occurrence (ARO)

Business Continuity Plan (BCP)

Business impact analysis (BIA)

Disaster Recovery Plan (DRP)

Hierarchical storage management (HSM)

Maximum tolerable downtime (MTD)

Mean time to failure (MTTF)

Mean time to recovery (MTTR)

Recovery point objective (RPO)

Recovery time objective (RTO)

Single loss expectancy (SLE)

CHAPTER 7 ASSESSMENT

1. What assesses potential loss that could be caused by a disaster?
 - A. Business Assessment (BA)
 - B. Business Impact Analysis (BIA)
 - C. Risk Assessment (RA)
 - D. Business Continuity Plan (BCP)
2. Which of the following focuses on sustaining an organization's business functions during and after a disruption?
 - A. Business Continuity Plan
 - B. Business Recovery Plan
 - C. Continuity of Operations Plan
 - D. Disaster Recovery Plan
3. Once an intrusion into your organization's information system has been detected, which of the following actions should be performed first?
 - A. Eliminate all means of intruder access.
 - B. Contain the intrusion.
 - C. Determine to what extent systems and data are compromised.
 - D. Communicate with relevant parties.
4. Business Continuity Plan development depends most on:
 - A. directives from senior management.
 - B. the Business Impact Analysis (BIA).
 - C. scope and plan initiation.
 - D. the skills of the BCP committee.

Reference

1. Swanson, M., Bowen, P., Phillips, A. W., Gallup, D., & Lynes, D. (2010). *Contingency Planning Guide for Federal Information Systems*. National Institute of Standards and Technology Special Publication 800-34. Gaithersburg, MD: NIST.



PART III

Branches of Digital Forensics

© phyZick/Shutterstock

CHAPTER 8 Windows Forensics

CHAPTER 9 Linux Forensics

CHAPTER 10 Mac OS Forensics

CHAPTER 11 Email Forensics

CHAPTER 12 Mobile Forensics

CHAPTER 13 Network Forensics

CHAPTER 14 Memory Forensics

CHAPTER 15 Trends and Future Directions



CHAPTER 11

Email Forensics

© phyZick/Shutterstock

A great many computer crimes involve email. In fact, many noncomputer crimes, and even civil litigation, can require extracting evidence from email. Electronic communication is so ubiquitous that email communications can often shed light on issues. In civil lawsuits, subpoenas for all email correspondence are common. But it is also possible to spoof email addresses and hide the real sender. It is important to be able to track and appropriately analyze emails.

Chapter 11 Topics

This chapter covers the following topics and concepts:

- How email clients and servers work
- Email headers
- How to trace emails
- Email server forensic examination
- Laws relevant to email forensics

Chapter 11 Goals

When you complete this chapter, you will be able to:

- Understand the functionality of email and email protocols
- Obtain the full email headers for a variety of email clients
- Read and understand the contents of email headers
- Trace email to its origin
- Work with email servers
- Understand the laws related to email investigations

How Email Works

You might already have a strong working knowledge of how email works. If you don't, this section provides a common base of knowledge, which allows you to get the most from this chapter. As with most aspects of digital forensics, it is very difficult to perform forensics without a basic knowledge of the underlying technologies.

Different types of devices and methods generate emails. Most commonly, a user composes a message on his or her computer or perhaps a tablet or phone, and then sends it to his or her mail server. At this point, the user's computer is finished with the job, but the mail server still has to deliver the message. A mail server is like an electronic post office—it sends and receives electronic mail. Most of the time, the mail server is separate from the computer where the mail was composed.

The sender's mail server forwards the message through the organization's network and/or the internet to the recipient's mail server. The message then resides on that second mail server and is available to the recipient. The software program used to compose and read email messages is the email client.

Depending on how the recipient's email client is configured, copies of the message may exist in a number of places. The recipient's and sender's computers, another electronic device such as a smartphone or a tablet, and the mail server or servers and their backups may all hold copies of the message. In addition, any of the servers that relay the message from the sender to the recipient may retain a copy of the email message. This is shown in **FIGURE 11-1**.

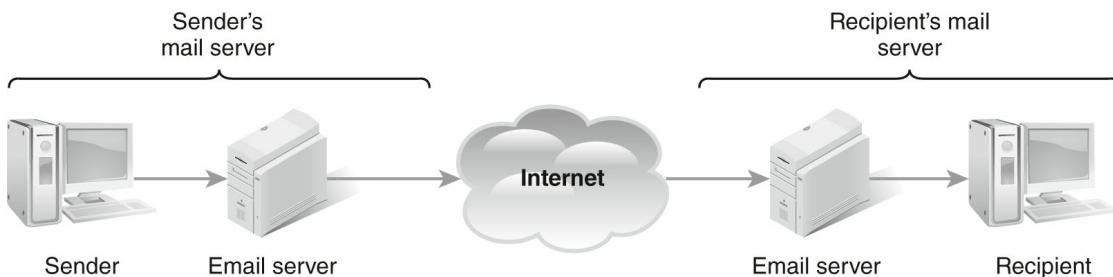


FIGURE 11-1 Delivering email.

The number of relay “hops” may be only one if the sender and recipient are on the same network. Transmitting a message to a remotely located recipient might require many hops.

A forensic investigation of email might reveal information such as the following:

- Email messages related to the investigation
- Email addresses related to the investigation
- Sender and recipient information
- Information about those copied on the email

- Content of the communications
- Internet Protocol (IP) addresses
- Date and time information
- User information
- Attachments
- Passwords
- Application logs that show evidence of spoofing

FYI

Consider in how many places an email might be saved. It could be saved on the sender's machine, on the recipient's machine, on either the sender's or recipient's email server, or both, and on backup media for either server. If you consider the many places an email could reside, that should indicate to you that it is rare that an email is ever truly deleted. It may be quite hard to find, but it probably exists somewhere. This is one reason why email forensics is so important.

It is also important to keep in mind that the content of email can be very important even in non-computer crime cases. Given how common email communications are, it should not surprise you to find that criminals often communicate via email. Some crimes, like cyberstalking, usually include an email element. Other crimes, such as drug trafficking and terrorism, can also utilize email communication.

In financial crimes, such as insider trading, as well as in discrimination lawsuits, email is often a critical piece of evidence. Keep in mind that the sender and perhaps even the recipient may have deleted the email. But it could still reside on an email server or in the backup media for that server.

Today it is also common for people to utilize completely web-based email services. This can include Gmail, Hotmail, and similar services. When that is the situation, there may not be any local storage of email files. One will need to log into the email service in order to analyze emails. Gmail and similar services do not provide any mechanism to retrieve an email if it has been deleted from the trash folder. At that point, it is unrecoverable from the mailbox. In some cases a subpoena may be issued to the service provider, and it may search backups for the missing email.

Email Protocols

The **Simple Mail Transfer Protocol (SMTP)** is a protocol used to send email. SMTP typically operates on port 25. For many years, **Post Office Protocol version 3 (POP3)** was the only means for retrieving email. POP3 operates on port 110. However, POP3 has been largely replaced by the **Internet Message Access Protocol (IMAP)**. IMAP operates on port 143. One advantage of IMAP over POP3 is it allows the client to download only the email headers to the machine, so that the user can choose which messages are to be

downloaded completely. This is particularly useful for smartphones and any wireless devices where bandwidth may be at a premium. Another advantage is that the emails stay on the server, allowing the user to check email from multiple devices. IMAP is defined by the standard RFC 3501. IMAP was designed to permit management of an email box by multiple email clients.

Each of these email protocols also has a secure version that is encrypted with the Transport Layer Security (TLS) Protocol. For SMTP, the secure alternative is SMTPS on port 465. For POP3, the secure version functions on port 995. And for IMAP, the secure version operates on port 993.

Faking Email

Criminals may send fake email messages. Some of them use email programs that strip the message header from the message before delivering it to the recipient. Or they may bury the message header within the email program. In other cases, the “From:” line in a message header is fake.

In addition to manipulating the email header, perpetrators may simply set up a temporary, bogus email account. For example, free email accounts, as offered by Yahoo!, Gmail, and Hotmail, are easy to set up, and you can use any desired and available name.

Spoofing

Spoofing involves making an email message appear to come from someone or someplace other than the real sender or location. The email sender uses a software tool that is readily available on the internet to cut out his or her IP address and replace it with someone else’s IP address. However, the first machine to receive the spoofed message records the machine’s real IP address. Thus, the header contains both the faked IP and the real IP address—unless, of course, the perpetrator is clever enough to have also spoofed his or her actual IP address.

Anonymous Remailing

Anonymous remailing is another attempt to throw tracing or tracking attempts off the trail. A suspect who uses anonymous remailing sends an email message to an anonymizer. An anonymizer is an email server that strips identifying information from an email message before forwarding it with the anonymous mailing computer’s IP address.

FYI

The issue of spoofing emails, IP addresses, and similar identifying information brings up the question of the sophistication of computer criminals. Email spoofing is just like any other crime. There are a few very sophisticated criminals—and a host of unsophisticated criminals. The more sophisticated a criminal, the harder it is to find evidence. For example, if you wanted to send an email that you did not want traced to you, you could start by finding a free, public Wi-Fi in an area at least one hour from your home. Then you could spoof both your IP address and your network’s media access control (MAC) address. Finally, you could send the email through an anonymous email account set up for that purpose. It is, however, very common for

criminals to actually send emails from their own computers without even bothering to spoof their IP address or MAC address. In addition, keep in mind that email address spoofing is only one kind of spoofing. In this section, you also saw MAC and IP spoofing.

To find out who sent remailed email, try to look at any logs maintained by remailer or anonymizer companies. However, these services frequently do not maintain logs. In addition, you can closely analyze the message for embedded information that might give clues to the user or system that sent the message.

There are many websites that let someone send an email and choose any “From” address he or she wants. Here are just a few:



NOTE

TOR, <https://www.torproject.org/>, is an anonymous network of proxy servers. You can use the TOR network to send any sort of network traffic, including emails. This makes tracing the traffic back to its source extremely difficult.

- <http://sendanonymousemail.net/>
- <https://www.5ymail.com/>
- <http://send-email.org/>

Valid Emails

It is also very common for an email to arrive—often from a trusted friend, colleague, or family member—that is valid in every respect except for the content of the message. The email passes all of the normal validity checks, such as header structure and content, and even comes from a known, nonspam email server that is not blacklisted with any of the blacklist services such as SPAM Cop. However, the message is suspect and the website uniform resource locator (URL) pointed to is usually a hacker or phishing site. The message may read something like “Wow! Check out this great website: www.hackersite.com.” (Note the www.hackersite.com is a fictitious URL to demonstrate the concept.) These messages usually contain no hidden URLs, pictures, or attachments and are very short. However, clicking the URL can unleash all sorts of malicious software or other negative results.

Email Headers

One of the first things to learn about emails is that they have headers. The header for an email message tells you a great deal about the email. The standard for email format, including headers, is RFC 2822. It is important that all email uses the same format. That is why you can send an email from Outlook on a Windows 8 PC and the recipient can read it from a Hotmail account on an Android phone that runs Linux—because all email programs use the same email format, regardless of what operating system they run on.

Make sure that any email you offer as evidence includes the message, any attachments, and the full email header. The header keeps a record of the message's journey as it travels through the communications network. As the message is routed through one or more mail servers, each server adds its own information to the message header. Each device in a network has an Internet Protocol (IP) address that identifies the device and can be resolved to a location address. A forensic investigator may be able to identify IP addresses from a message header and use this information to determine who sent the message.

Most email programs normally display only a small portion of the email header along with a message. This usually is information that the sender puts in the message, such as the "To" address, subject, and body of the message. You can view and examine the full header record by using tools available in the email client.

An email investigation begins with a review of an email message followed by a detailed examination of the message header information. Look at the header in more detail to find additional information associated with the email message. The message header provides an audit trail of every machine through which the email has passed.



NOTE

RFC 2822 supplements the older RFC 822 with a few notable enhancements. RFC 822 was originally designed for the standard for text messages sent over the ARPANET network, which was the precursor to the modern internet. You can check out <http://tools.ietf.org/html/rfc822> for more details.

Consider the specifications for email format given in RFC 2822:

- The message header must include at least the following fields:
From—The email address and, optionally, the name of the sender
Date—The local time and date when the message was written
- The message header should include at least the following fields:
Message-ID—An automatically generated field
In-Reply-To—The message-ID of the message that this is a reply to; used to link

related messages together

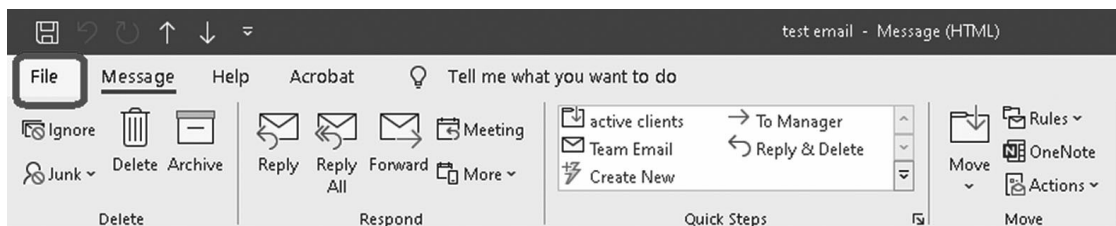
RFC 3864 describes message header field names. Common header fields for email include the following:

- **To**—The email address and, optionally, name of the message's primary recipient(s)
- **Subject**—A brief summary of the topic of the message
- **Cc**—Carbon copy; a copy is sent to secondary recipients
- **Bcc**—Blind carbon copy; a copy is sent to addresses added to the SMTP delivery list while the Bcc address remains invisible to other recipients
- **Content-Type**—Information about how the message is to be displayed, usually a Multipurpose Internet Mail Extensions (MIME) type
- **Precedence**—Commonly with values "bulk," "junk," or "list"; used to indicate that automated "vacation" or "out of office" responses should not be returned for this mail, for example, to prevent vacation notices from being sent to all other subscribers of a mailing list
- **Received**—Tracking information generated by mail servers that have previously handled a message, in reverse order (last handler first)
- **References**—Message-ID of the message to which this is a reply
- **Reply-To**—Address that should be used to reply to the message
- **Sender**—Address of the actual sender acting on behalf of the author listed in the From field

There is a wealth of information in these headers so examining them is very important.

Getting Headers in Outlook 2019

First, open the email, then select File and then Info, as shown in **FIGURE 11-2**. Then select Properties and you will be able to view the headers, as shown in **FIGURE 11-3**.



test email

CE Chuck Easttom <chuck@chuckeasttom.com>
To: chuckeasttom@gmail.com

i Follow up.

A test email from me to me

Dr. ChuckEasttom
MBA, M.Ed., MSSE., Ph.D., D.Sc. IEEEESM, ACMSSM
www.ChuckEasttom.com
chuck@chuckeasttom.com

FIGURE 11-2 Outlook 2019 headers Step 1.

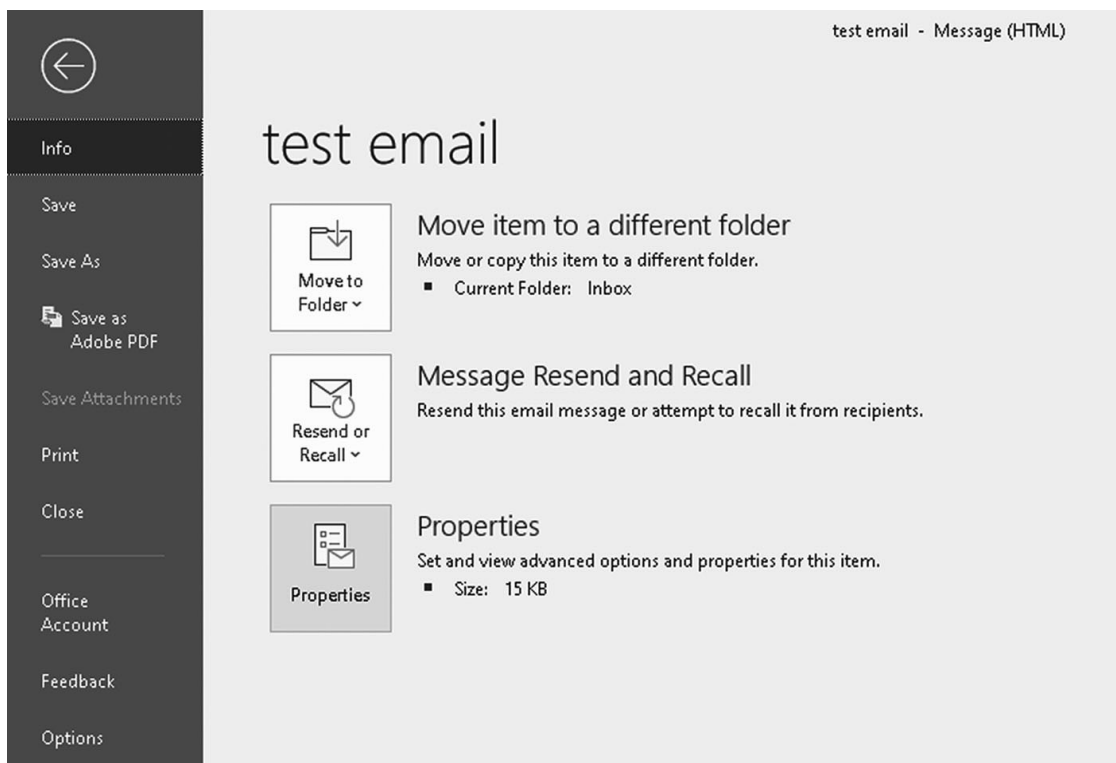


FIGURE 11-3 Outlook 2019 headers Step 2.

It is often helpful to copy the header information and paste it to a text file for analysis. You can see it is relatively easy to view the headers using Outlook. Older versions of Outlook have a different method to get to headers. With Outlook 2007 and 2010, there are two methods:

- **Method #1**—Right-click the message in the folder view, and then choose Options.
- **Method #2**—In an open message, choose View and then Options.

With either method, you'll see the internet headers portion of the Message Options dialog box. Regardless of the version of Outlook you have and the method you use to view the headers, the headers appear similarly to what is shown in **FIGURE 11-4**.

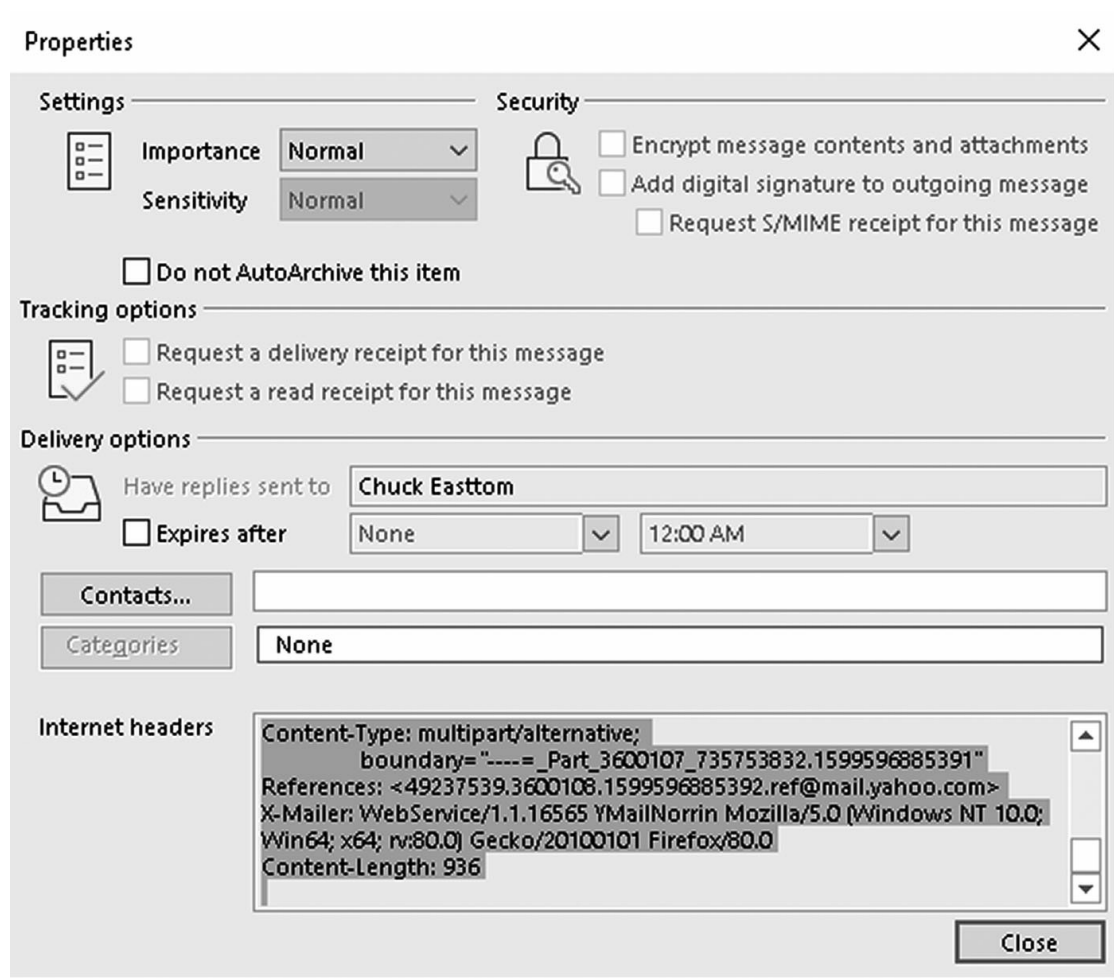


FIGURE 11-4 Outlook headers.

Getting Headers from Yahoo! Email

If you are working with Yahoo! email, then first open the message. On the lower right, there is a link named view raw headers, shown in **FIGURE 11-5**.

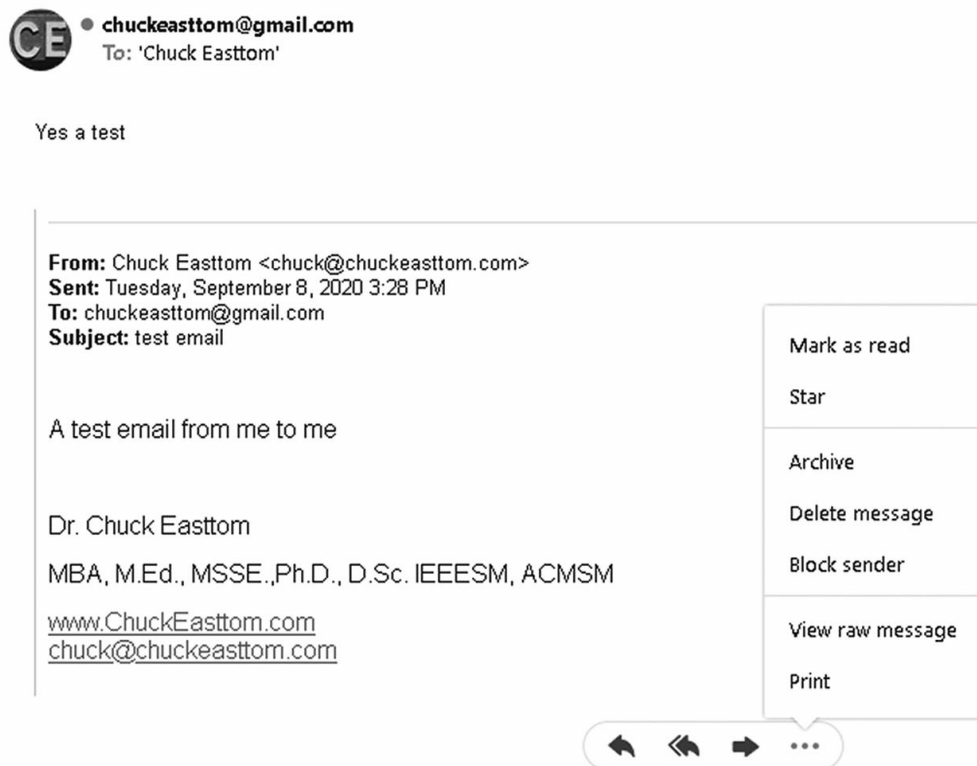


FIGURE 11-5 Finding Yahoo! headers.

If you click on that link, you can see the headers for that email, shown in **FIGURE 11-6**.

```

Received: from 10.201.234.73
  by atlas103.ptnr.mail.bf1.yahoo.com with HTTP; Tue, 8 Sep 2020 20:35:13 +0000
Return-Path: <chuckeasttom@gmail.com>
Received: from 209.85.161.46 (EHLO mail-ool-f46.google.com)
  by 10.201.234.73 with SMTPS; Tue, 8 Sep 2020 20:35:13 +0000
X-Originating-Ip: [209.85.161.46]
Received-SPF: pass (domain of gmail.com designates 209.85.161.46 as permitted sender)
Authentication-Results: atlas103.ptnr.mail.bf1.yahoo.com;
  dkim=pass header.i=@gmail.com header.s=20161025;
  spf=pass smtp.mailfrom=gmail.com;
  dmarc=success (p=NONE,sp=QUARANTINE) header.from=gmail.com;
X-Apparently-To: chuck@chuckeasttom.com; Tue, 8 Sep 2020 20:35:13 +0000
X-YMailISG: xic9Xw4WLDu8xypveTiDbiiud9vU3O8ghKCVuFz14KpNkae.
  OH26hvwP810APDs1.BT2j260cINEFG58r12YKCoFKrKXdcQqVIW6ELbPt5uw1
  Q90IXQd20kY43czPeeRZ_hAo2i0rNteb.51aPBTWPaohhRquiX5dCOHJbWXXG
  tcGzGHPBUeJfsWRvNXOjVKBV7k1buUquzupjCWXnUOROa2mYDORDQRps.tUB
  ytK70SeFpKZDtCjop_Nzt.jq6aJonCXstT3kzot8fZ54T3nyq4og7lhCzFu5
  X2GDfTzqcoleXVP5EtMu5inUF7uvPHpqFDqku.aNKqHxk25N7WeGGQhPoFlE
  fLKJJP40NEeZgvv1VL73.1YZmp72KXInxg2G_A02N4XMzztRSQ.8JW8T9mpm
  bHBbXmH2yOU.9grvDwt_U5CdZnf_GOJesiyCNiFoCwmcVsr6xc9MtxBFxGd
  Gwy6H2DbcaYZboV6PBsjA9h65.agDiC7SXAY5oGV3Bs1..yszfWhEzyesK1C
  md2mm_4NIjnulUbNC7Z6925Pk1pfw5Nj4gVWszuuJDL7QIy3iZGD_i2Vs8k3
  d1I18N3Mz0lu2WhZ5GUm4RPSpjExo75FuYgHXjSJ.RtXLYMlitgEzyQjmf7
  s_dc0diN5vr4BYSdbJ.hJfOGWxgkXLuNn8PZvHGrPlmV5rxHs050DjvpjQ15
  qIhe3I87sYhXv_rbuwlEq8seYi5F2x2.nrGjalh6gK2Qu_B59sQSRcnrX_7G
  81B1cWByOYxth9tQv2G1B0yJ2FbI7X8fjiSgmqZ1QcDvwt1_zoicwtxoTW6r
  HCkpRyhNYhLFyJAgzy8ut3DiJoqx4UX1hPP1o2dBM_k1Oz2wT36OjipqK95J
  BjXdKBkrceFxB5yH0vX9cDOG2VumEaGlj5u4IXMacc2VyyB9mQp1lphytMNI
  QtjOAT4WITviHSc0139AaCOYMRRO1VH74LMX.rjsCSTegFGj8vWFNRsQUgv
  lR3pRhq7BX9RiOBNG_C7ex8fh5uakdgghPxxKMOOwgMChrvqE8jggYjg1gusD
  t51._OjbNPLW.OUSD4zGomViZsgOYLLGdqexmy86HntVBfW.8drQzYmtlPG_
  nPi7CU1kQu4F9GjGslqacZeVFR0E_5m8KK5_Ti24WfWCnuGts15DLvWMyOGZ
  5QYKk5yKI78_7Rsw7Lg-
Received: by mail-ool-f46.google.com with SMTP id r4so610910oq.7
  for <chuck@chuckeasttom.com>; Tue, 08 Sep 2020 13:35:13 -0700 (PDT)
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed;
  d=gmail.com; s=20161025;
  h=from:to:references:in-reply-to:subject:date:message-id:mime-version
  :thread-index:content-language;
  bh=boAGrQPSNJryuOCwUjXpa7cGiMkXG/elwSE6NOjM1us=;
  b=ug8aHS/q3MrPC1aEuV6J/4azqRyMFwaN/q24QKeF5rPLne1D2UjdQnQpaVfTgkmhww
  RfuHL/q3E1FSGSnqH+rM4nWW3LclEGMHqgrr32g6NKX0x55E+GYWGZxtRtaoN7jTApW1
  4qo+JeJNjZaoGhtaBIJ3wPTBJSg7WF6Ih959lekplFOvmBO3IW1+5hxsQOM3Hm+cp355
  VAvw8zw8zqt/NBep3kGM3kJDYQzt+2vH6H57z/OCGsKb3zdsxQPqIQ3NmCtvLvFnVO6d
  gYOBVZymtbDdcfIhbiqk/FuXmlioIf+KFUwG66GJ2MgrrVv1wNwXKX4e4KEAdk6xtbCtu
  vdUA==
X-Google-DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed;
  d=1e100.net; s=20161025;
  h=x-gm-message-state:from:to:references:in-reply-to:subject:date

```

FIGURE 11-6 Viewing Yahoo! headers.

Getting Headers from Gmail

Viewing email headers in Gmail is fairly simple; just follow these steps:

1. Log on to Gmail.

2. Open the message for which you want to view headers.
3. Look for the ⋮ and click it (**FIGURE 11-7**).
4. Select Show Original.

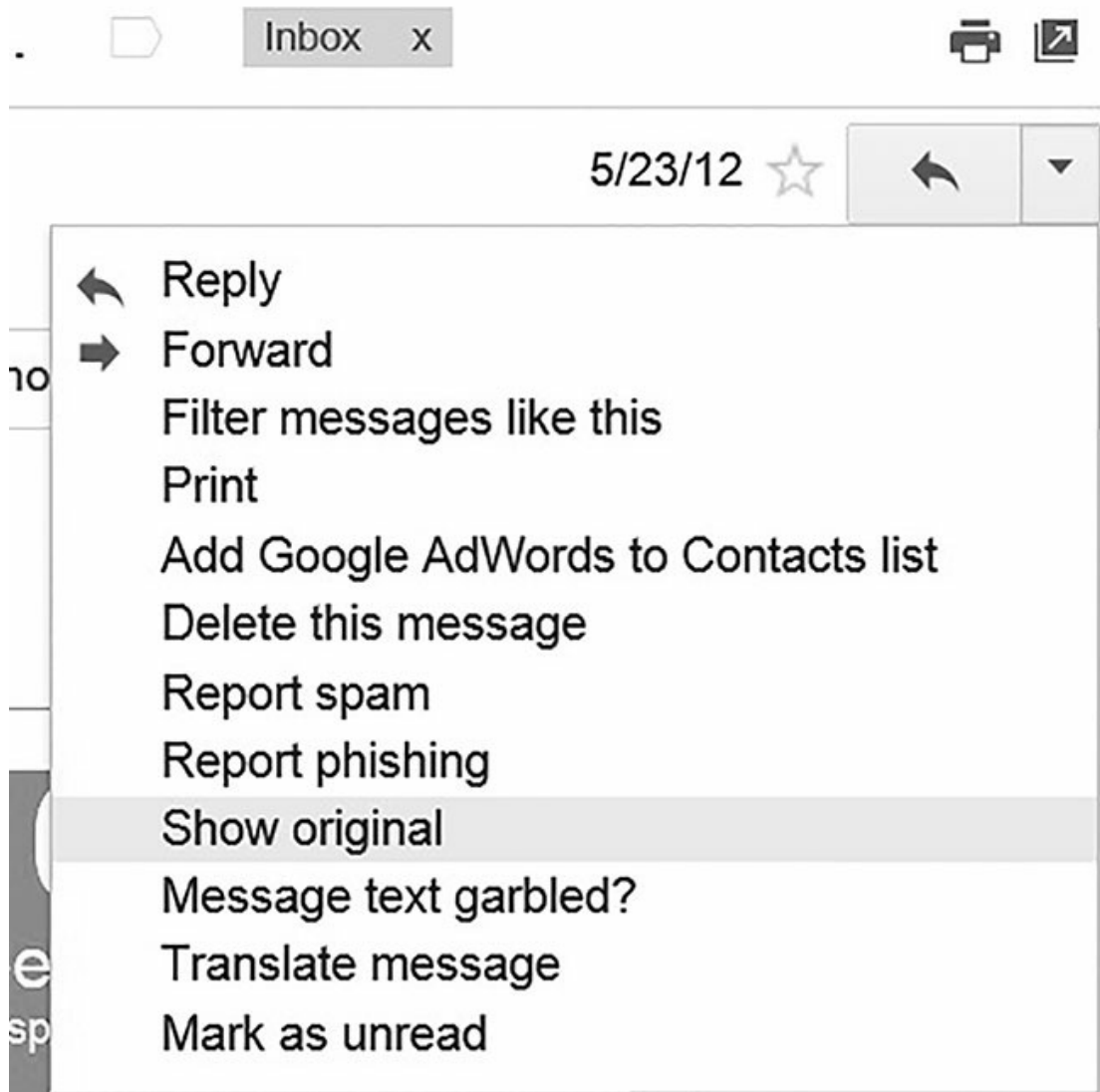


FIGURE 11-7 Finding Gmail headers.

The headers appear in a separate window and look similar to **FIGURE 11-8**.


```

Delivered-To: chuckeasttom007@gmail.com
Received: by 10.182.25.137 with SMTP id c9csp84759obg;
    Wed, 23 May 2012 13:58:23 -0700 (PDT)
Return-Path: <3b0-9Tw8KD4Ykn6yln2-xylozv8qyyqvo.myvmr4muok233ywAAHqwkvs.myv@scoutcamp.bounces.google.com>
Received-SPF: pass (google.com: domain of 3b0-9Tw8KD4Ykn6yln2-xylozv8qyyqvo.myvmr4muok233ywAAHqwkvs.myv@scoutcamp.bounces.google.com designates 10.50.40
Authentication-Results: mr.google.com; spf=pass (google.com: domain of 3b0-9Tw8KD4Ykn6yln2-xylozv8qyyqvo.myvmr4muok233ywAAHqwkvs.myv@scoutcamp.bounces.g
Received: from mr.google.com ([10.50.40.230])
    by 10.50.40.230 with SMTP id a6mr20555688igl.2.1337806703082 (num_hops = 1);
    Wed, 23 May 2012 13:58:23 -0700 (EDT)
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed;
    d=google.com; s=20120113;
    h=date:from:to:cc:subject:reply-to:x-google-ads-sender:message-id
    :x-trak-extra-language:mime-version:content-type;
    bh=XekTgcS1lYskFAHQThJcm7aGSzICw8DGRTelhcUe8M8=;
    b=H6cb7OD+xtuyUrc1NCdWh+e3H1jphF1N1B0431WP2SkZuYqn3BT/2XJ2maJ1F+7A0
    g716xr4Q/avpquw01OCy2KfRQVBEZxTnD90f6hdyHje/9G1Mau/YS+LrDbYh1WmgKqJ
    nV9CMQyJAJlc0FKaQAOcd9EIDqJ8elnTgan8U+xl8OUcKtL83R4rauiXIObnpd8rDF3t
    ykwmzC42LXNELs53FCjM+Abn/geyxEB4wKmaFmvpXbBOUUC8S1bzs6PqgURKj112V1Xb
    rcvDOazwpdghL1FRND8a9PfFvZRHZwtPnL3thYqdljmKBJ/vE1vVV9XMHGbe1j9StGy6
    1PNA==
Date: Wed, 23 May 2012 20:58:23 +0000
Received: by 10.50.40.230 with SMTP id a6mr11939917igl.2.1337806703051;
    Wed, 23 May 2012 13:58:23 -0700 (EDT)
From: Google AdWords <adwords-noreply@google.com>
To: chuckeasttom007@gmail.com
Cc:
Subject: =?utf-8?q?Only_days_left_to_get_?=24100_?=26_tips_from_Google_AdWords=2E_En?=
    =?utf-8?q?ds_May_31=2E?=?
Reply-To: adwords-noreply@google.com
X-Google-Ads-Sender: auto_adsense_emails
Message-ID: <29060e2c.1337806701.000000.53518.1.EN_US.2f59020b@google.com>
X-Trak-Extra-Language: EN_US
MIME-Version: 1.0
Content-Type: multipart/alternative; boundary="=0825779531=

```

FIGURE 11-8 Viewing Gmail headers.

Other Email Clients

A vast number of email clients are available for people to use. It is not beneficial to you to go through each and every one separately. By now, you should be noticing some similarities in the processes. However, you can see the basic steps for many of these clients in this section.

Hotmail

Hotmail is similar to Gmail:

1. Select Inbox from the menu on the left.
2. Right-click the message for which you want to view headers and select View Message Source.
3. The full headers will appear in a new window.

Apple Mail

Apple Mail is pretty straightforward:

1. Open Apple Mail.
2. Click on the message for which you want to view headers.
3. Go to the View menu.
4. Select Message, then Long Headers.
5. The full headers will appear in the window below your Inbox.

You can get a list of other email clients from Google Support at

<http://support.google.com/mail/answer/22454?hl=en>.

Of course, you can always use your favorite search engine to search for the email client you are using. It is usually quite easy to find out how to view headers.

Email Files

Local storage archives are any archives that have an independent archive format from a mail server. Examples of these types of archives include the following:

- .pst (Outlook)
- .ost (Offline Outlook Storage)
- .mbx or .dbx (Outlook Express)
- .mbx (Eudora)
- .emi (common to several email clients)

You need to know how to find these files and how to view them. For example, in Outlook, a clever criminal might have a second .pst file containing email messages that he loads only when committing his nefarious activities. If his computer is seized and you simply look in Microsoft Outlook, you won't see any incriminating evidence. If you search the suspect drive and find an additional .pst file, you can easily mount it in Outlook by selecting File, Open, and Open Outlook Data File, as shown in **FIGURE 11-9**.

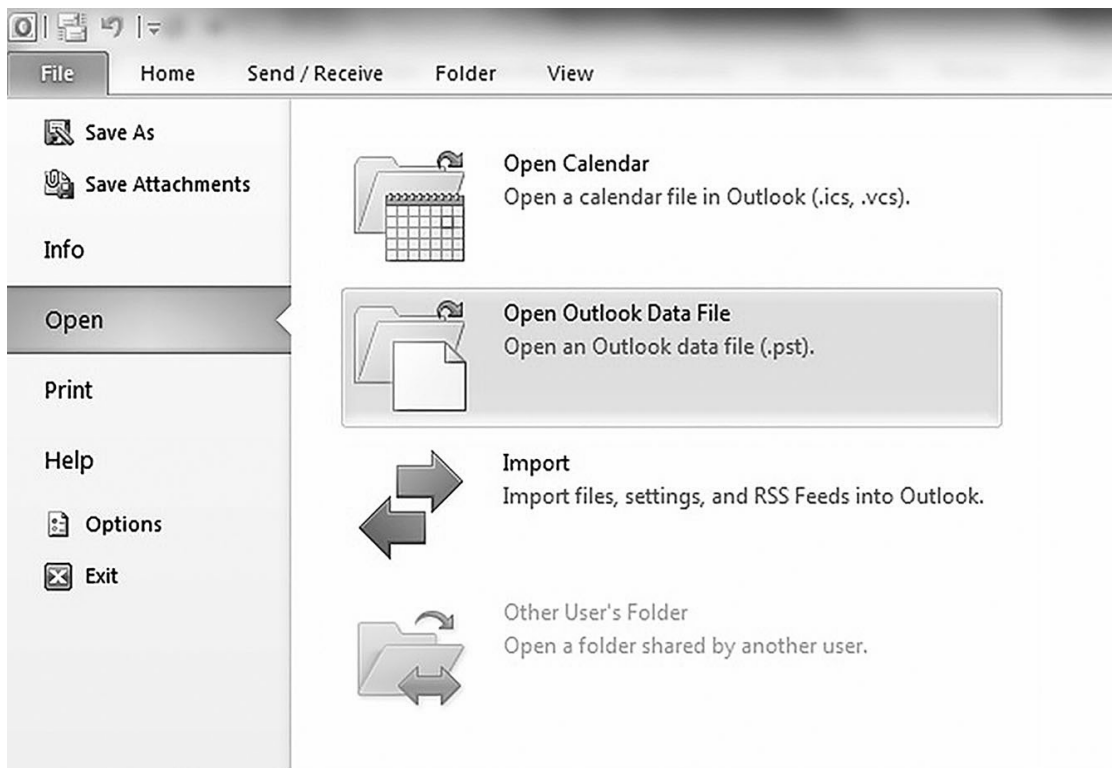


FIGURE 11-9 Opening a .pst file in Outlook.

There are tools that allow you to convert from one email file format to another. For example, the accused's email file could be an EML file, but you use Outlook. It would be helpful to translate that file into an Outlook .pst format. Transend Migrator (<http://www.transend.com/>) is a tool that will do this for you.

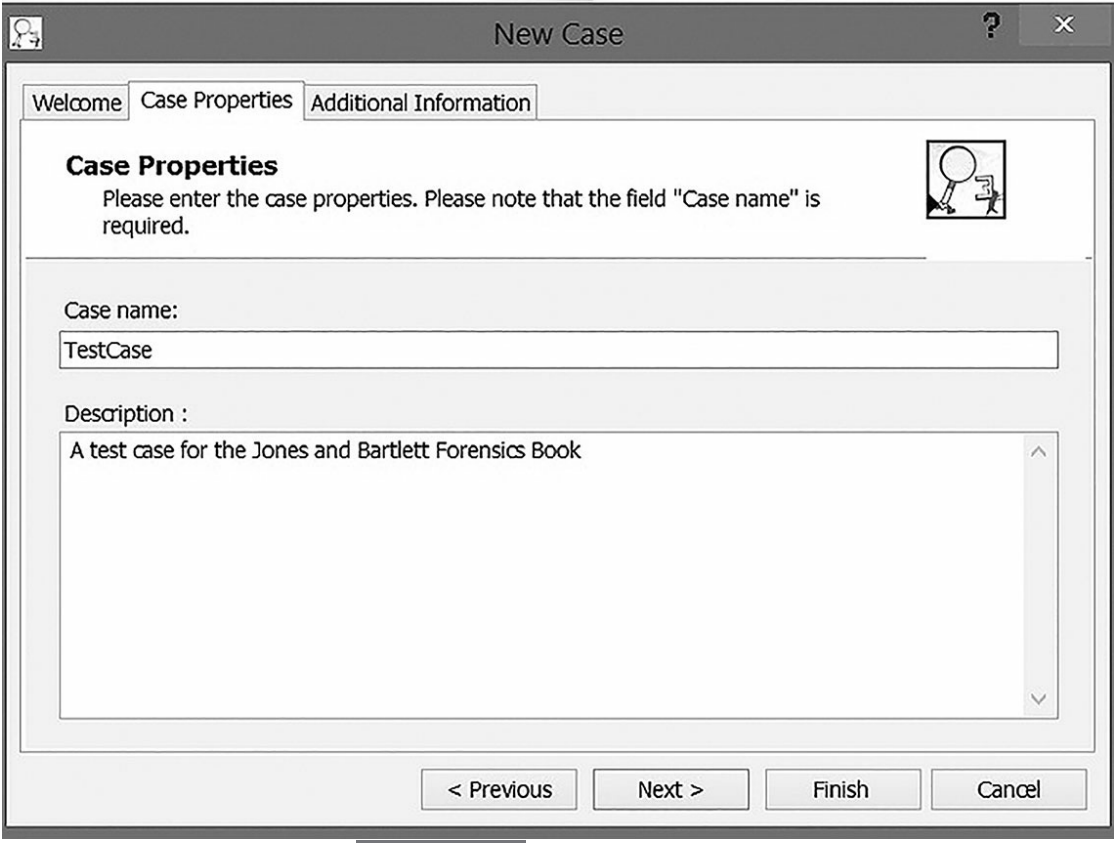
In addition, a number of forensic tools can examine the email files for you. A few examples include the following:

- **Paraben's Email Examiner**—This tool is meant specifically to analyze email. It is available at <https://paraben.com/email-forensics/>.
- **Guidance Software's EnCase**—This is a general-purpose forensic tool. You can find more information about EnCase at <http://www.guidancesoftware.com>.
- **AccessData's Forensic Toolkit (FTK)**—This is another general-purpose forensic tool. You can find more details about FTK at <https://accessdata.com/products-services/forensic-toolkit-ftk>.
- **PassMark's OSForensics** is a general-purpose forensics tool that can find and examine emails on a suspect drive image. You can learn more at <http://www.osforensics.com/>.

- **LibPST package**—This is an open source tool. You can get this tool from <http://www.five-ten-sg.com/libpst/>.

Paraben's Email Examiner

Although there are many tools available that may be used with email forensics, this tool is exclusively for email forensics, so it merits a closer look. Paraben works like the more complete forensic suites (Forensic Toolkit and EnCase) in that evidence is grouped by case. When you first start Paraben, you select New and then create a new case, as shown in **FIGURE 11-10**.



The screenshot shows a Windows-style dialog box titled "New Case". It has three tabs: "Welcome", "Case Properties", and "Additional Information". The "Case Properties" tab is selected. Inside this tab, there is a section titled "Case Properties" with a sub-instruction: "Please enter the case properties. Please note that the field 'Case name' is required." Below this, there is a text input field labeled "Case name:" containing the text "TestCase". Underneath that is a text area labeled "Description :" containing the text "A test case for the Jones and Bartlett Forensics Book". At the bottom of the dialog, there are four buttons: "< Previous", "Next >", "Finish", and "Cancel".

FIGURE 11-10 A new Paraben case.

Paraben will also associate information about the investigator with the case information. This is shown in **FIGURE 11-11**.

The screenshot shows a software window titled "New Case" with a standard Windows-style title bar (minimize, maximize, close buttons). Inside the window, there are three tabs: "Welcome", "Case Properties", and "Additional Information". The "Additional Information" tab is currently selected. Below the tabs, there is a section header "Additional Information" followed by a paragraph: "Please enter additional information. This information is not required and can be filled any time through the Properties pane." To the right of this text is a small icon of a magnifying glass over a document. Below this, there are several input fields arranged in two columns. The left column contains: "Investigator name:" with a dropdown menu showing "Chuck Easttom"; "Phone:" with a dropdown menu showing "214-555-5555"; "Address:" with an empty dropdown menu; and "Comments:" with a large text area. The right column contains: "Agency/Company:" with a dropdown menu showing "CEC"; "Fax:" with a dropdown menu showing "214-555-5551"; and "E-mail:" with an empty dropdown menu. At the bottom of the window, there are four buttons: "< Previous", "Next >", "Finish", and "Cancel".

New Case

Welcome Case Properties **Additional Information**

Additional Information

Please enter additional information. This information is not required and can be filled any time through the Properties pane.

Investigator name: Agency/Company:

Chuck Easttom CEC

Phone: Fax:

214-555-5555 214-555-5551

Address: E-mail:

Comments:

< Previous Next > Finish Cancel

FIGURE 11-11 The investigator.

Next, you select the type of email database you are going to be working with. The major email clients are all represented, as you can see in **FIGURE 11-12**.

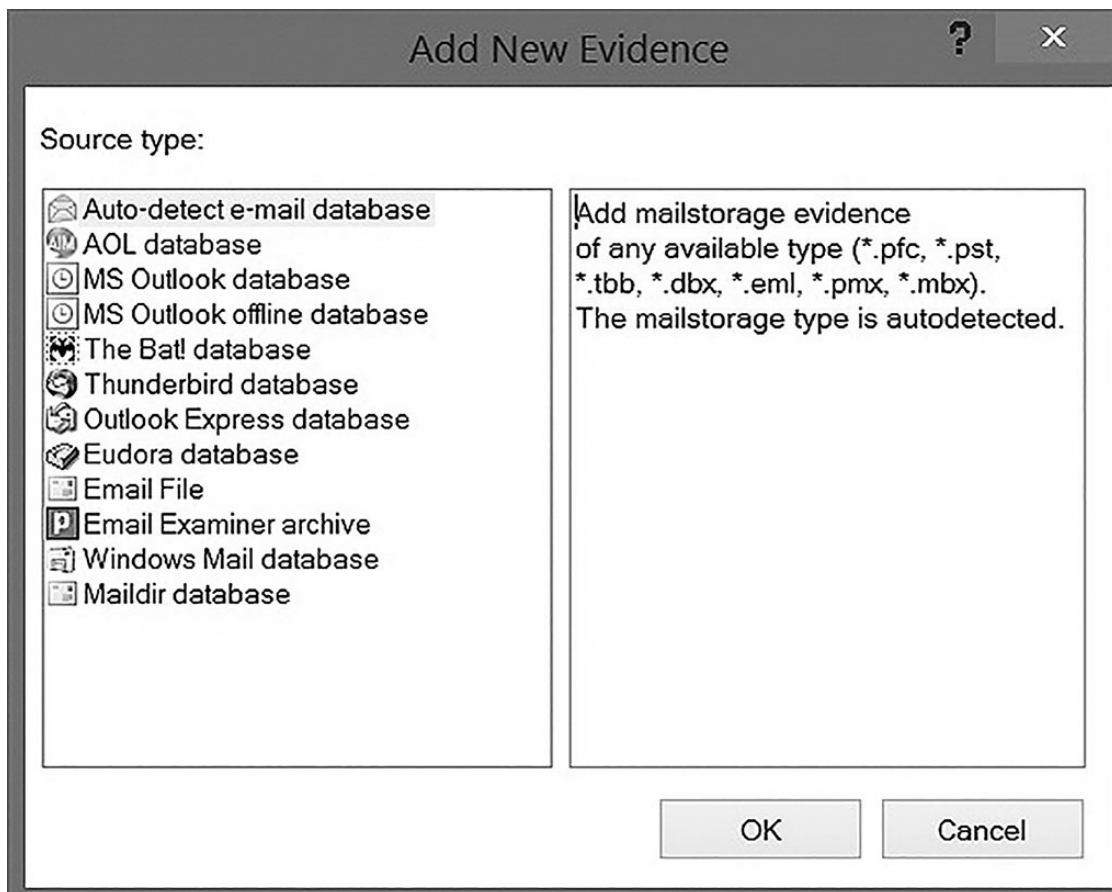


FIGURE 11-12 Select your email database.

At this point, you select the database you want to work with, and it is added to the case. From within Paraben, you can sort, search, scan, and otherwise work with the email data. Paraben can also generate reports of the data showing whatever data is most relevant to your case—or all the email data, if you prefer.

ReadPST

ReadPST is a program made available as part of the libPST package. You can find the ReadPST main page at <https://linux.die.net/man/1/readpst>. You will need to download and compile it because it is not available in precompiled format. Once you have done so, you can run it and use it to examine PST files.

ReadPST will first convert the PST into RFC-compliant Unix mail. You can access the extracted mail and attachments with any standard Unix mail client. If you have access to Microsoft Outlook, there is no need to use ReadPST.

Tracing Email

Email tracing involves examining email header information to look for clues about where a message has been. This will be one of your more frequent responsibilities as a forensic investigator. You will often use audits or paper trails of email traffic as evidence in court. Many investigators recommend use of the `tracert` command. However, because of the dynamic nature of the internet, `tracert` does not provide reliable, consistent, or accurate routing information for an email. To prove this, you can simply compare the routing from the email header to the results shown by `tracert`. The results are likely different, and the greater the distance between sender and receiver, the bigger the difference between the theoretical `tracert` results and the results determined from the actual routing information embedded in the header.

It may be useful to determine the ownership of the source email server for a message. If you need to manually find out to whom a given IP address is registered, a number of WHOIS databases are available on the web. Here are just a few:

- <http://www.whois.net>
- <http://www.networksolutions.com/whois/index.jsp>
- <http://www.who.is>
- <http://www.internic.net/whois.html>
- <http://cqcounter.com/whois/>

After a suspect comes to the authorities' attention, your organization may ask you to monitor that person's traffic. For example, administrators might request security checks on an employee who appears to be disgruntled or who has access to sensitive information. This employee's email logs and network usage may, for example, show him or her sending innocent family photos to a Hotmail account, but no traffic coming back from that Hotmail account. These seemingly innocent photos might carry steganographically hidden messages, and so provide evidence of the employee's part in corporate espionage.

Forensic email tracing is similar to traditional gumshoe detective work. It involves looking at each point through which an email passed. You work step by step back to the originating computer and, eventually, the perpetrator.

Email Server Forensics

At some point, you need to check the email server. Both the sender and the recipient could have deleted the relevant emails, but there is a good chance a copy is still on the email server. Many servers have a retention policy, which may be governed by law in certain industries. When you examine an email server, be aware that there are a variety of email server programs that could be in use. Microsoft Exchange is a very common server. Lotus Notes and Novell GroupWise are also popular email server products.

The file extensions associated with the most widely used email server software are listed here:

- Exchange Server (.edb)
- Exchange Public Folders (pub.edb)
- Exchange Private Folders (priv.edb)
- Streaming Data (priv.stm)
- Lotus Notes (.nsf)
- GroupWise (.db)
- GroupWise Post Office Database (wphost.db)
- GroupWise User Databases (userxxx.db)
- Linux Email Server Logs/var/log/mail.*

Obviously, tools like Forensic Toolkit and EnCase allow you to add these files to a case and to work with them. You can also manually examine these files provided that you have access to the relevant software (for example, Exchange or Lotus Notes).

Email and the Law

There are specific laws in the United States that are applicable to email investigations. It is critical that you be aware of the relevant laws. Failure to adhere to the legal guidelines can render evidence inadmissible.

The Fourth Amendment to the U.S. Constitution

If an email message resides on a sender's or recipient's computer or other device, the Fourth Amendment to the U.S. Constitution and state requirements govern the seizure and collection of the message. Determine whether the person on whose computer the evidence resides has a reasonable expectation of privacy on that computer. The Fourth Amendment requires a search warrant or one of the recognized exceptions to the search warrant requirements, such as consent from the device owner.

The Electronic Communications Privacy Act

If an internet service provider (ISP) or any other communications network stores an email, retrieval of that evidence must be analyzed under the Electronic Communications Privacy Act (ECPA). The ECPA creates statutory restrictions on government access to such evidence from ISPs or other electronic communications service providers.

The ECPA requires different legal processes to obtain specific types of information:

- **Basic subscriber information**—This information includes name, address, billing information including a credit card number, telephone toll billing records, subscriber's telephone number, type of service, and length of service. An investigator can obtain this type of information with a subpoena, court order, or search warrant.
- **Transactional information**—This information includes websites visited, email addresses of others with whom the subscriber exchanged email, and buddy lists. An investigator can obtain this type of information with a court order or search warrant.
- **Content information**—An investigator who has a search warrant can obtain content information from retrieved email messages and also acquire unretrieved stored emails.
- **Real-time access**—To intercept traffic as it is sent or received, an investigator needs to obtain a wiretap order.

The CAN-SPAM Act

The CAN-SPAM Act of 2003 was the first law meant to curtail unsolicited email, often referred to as *spam*. However, the law has many loopholes. For example, you do not need permission before sending an email. This means that unsolicited email—what most people consider spam to be—is not prohibited. The second issue is that it applies only to commercial emails—messages that are trying to sell some product or service. Therefore, mass emailings for political, religious, or ideological purposes are not covered by the CAN-SPAM Act.

The only requirement of CAN-SPAM is that the sender must provide some mechanism whereby the receiver can opt out of future emails and that method cannot require the receiver to pay in order to opt out.

The law defines commercial email as “any electronic mail message the primary purpose of which is the commercial advertisement or promotion of a commercial product or service (including content on an Internet website operated for a commercial purpose).” This means that any mass emails that have no commercial purpose are not covered by this law.

All commercial email is required to offer ways for the recipient to opt out. Those methods must meet the following guidelines:

- A visible and operable unsubscribe mechanism is present in all emails.
- Consumer opt-out requests are honored within 10 days.
- Opt-out lists, also known as suppression lists, can be used only for compliance purposes, and cannot be sold to other vendors/senders.

There are also restrictions on how the sender can acquire the recipient's email address and how the sender can actually transmit the email. Those requirements are as follows:

- A message cannot be sent through an open relay.
- A message cannot be sent to a harvested email address.
- A message cannot contain a false header.

This is important because these are the methods often used by people who send spam email. Spam is one crime that obviously lends itself to email forensics. Tracking down the original sender of the email is the first step in investigating spam. Unfortunately, the email is sometimes sent from offshore sites or relayed through an innocent third party's servers. This makes prosecuting spam very difficult, and even if a judgment is obtained, in most cases it is impossible to enforce.

18 U.S.C. 2252B

You might be at least somewhat familiar with the laws already discussed in this chapter. However, this law is less well known. To begin, read the actual law. *Findlaw.com* (2013) provides details of the law as follows:

- a. Whoever knowingly uses a misleading domain name on the Internet with the intent to deceive a person into viewing material constituting obscenity shall be fined under this title or imprisoned not more than 2 years, or both.
- b. Whoever knowingly uses a misleading domain name on the Internet with the intent to deceive a minor into viewing material that is harmful to minors on the Internet shall be fined under this title or imprisoned not more than 4 years, or both.
- c. For the purposes of this section, a domain name that includes a word or words to indicate the sexual content of the site, such as “sex” or “porn,” is not misleading.
- d. For the purposes of this section, the term “material that is harmful to minors” means any communication, consisting of nudity, sex, or excretion, that, taken as a whole and with reference to its context—
 - 1. predominantly appeals to a prurient interest of minors;
 - 2. is patently offensive to prevailing standards in the adult community as a whole with respect to what is suitable material for minors; and
 - 3. lacks serious literary, artistic, political, or scientific value for minors.
- e. For the purposes of subsection (d), the term “sex” means acts of masturbation, sexual intercourse, or physical contact with a person’s genitals, or the condition of human male or female genitals when in a state of sexual stimulation or arousal.

This law is about perpetrators who attempt to hide the pornographic nature of their website, often to make it more accessible to minors. This is a very serious concern, and one that sometimes arises in child predator cases.

The Communication Assistance to Law Enforcement Act

The Communication Assistance to Law Enforcement Act (CALEA), not to be confused with the law enforcement standards certification of the same name, is a U.S. wiretapping law passed in 1994.

CALEA’s purpose is to allow law enforcement and intelligence agencies to lawfully conduct electronic surveillance. It requires that telecommunications carriers and manufacturers of telecommunications equipment modify and design their equipment, facilities, and services to ensure that they have built-in surveillance capabilities, allowing federal agencies to monitor all telephone, broadband internet, and VoIP traffic in real time. CALEA is widely used, and a basic awareness of CALEA should be a part of every forensic investigator’s base knowledge.

The Foreign Intelligence Surveillance Act

The **Foreign Intelligence Surveillance Act (FISA)** of 1978 is a U.S. law that prescribes procedures for the physical and electronic surveillance and collection of “foreign intelligence information” between foreign powers and agents of foreign powers, which may include American citizens and permanent residents suspected of espionage or terrorism. The law does not apply outside the United States but may be encountered by a forensic investigator in researching intelligence even if it does not specifically regard espionage or terrorism. The law is an important part of many agencies’ approaches to information gathering. It has been amended frequently, so it is important to stay current on the latest revisions and court cases.

The USA PATRIOT Act

The **USA PATRIOT Act** of 2001 incorporates in its name a 10-letter acronym standing for **U**niting (and) **S**trengthening **A**merica (by) **P**roviding **A**ppropriate **T**ools **R**equired (to) **I**ntercept (and) **O**bstruct **T**errorism. The act was passed into law as a response to the terrorist attacks of September 11, 2001. It significantly reduced restrictions on law enforcement agencies’ gathering of intelligence within the United States; expanded the Secretary of the Treasury’s authority to regulate financial transactions, particularly those involving foreign individuals and entities; and broadened the discretion of law enforcement and immigration authorities in detaining and/or deporting immigrants suspected of terrorism and related acts. The law also expanded the definition of terrorism to include domestic terrorism, thus enlarging the number of activities to which the USA PATRIOT Act’s expanded law enforcement powers can be applied.

In May 2011, President Barack Obama signed the PATRIOT Sunsets Extension Act of 2011, which is a four-year extension of three key provisions in the USA PATRIOT Act: roving wiretaps, searches of business records, and conducting surveillance of individuals suspected of terrorist-related activities who are not linked to terrorist groups, and so are known as lone wolves. The USA PATRIOT Act gives law enforcement dramatically enhanced powers for information gathering and should be a part of a comprehensive knowledge base for any forensic investigator.

CHAPTER SUMMARY

In this chapter, you learned the process of email forensics. You examined email headers, learned about file formats, and worked with a few email tools. You also learned about laws relevant to email forensics. You should be very comfortable with the material in this chapter because email evidence is common to many cases.

KEY CONCEPTS AND TERMS

Anonymous remailing

Foreign Intelligence Surveillance Act (FISA)

Internet Message Access Protocol (IMAP)

Post Office Protocol version 3 (POP3)

Simple Mail Transfer Protocol (SMTP)

Spoofing

USA PATRIOT Act

CHAPTER 11 ASSESSMENT

1. What is the file format .edb used with?
 - A. GroupWise
 - B. Microsoft Exchange
 - C. Microsoft Outlook
 - D. Linux email
2. IMAP uses port 143.
 - A. True
 - B. False
3. Which of the following types of mass emails are *not* covered by the CAN-SPAM Act?
 - A. Emails advertising products
 - B. Emails advertising legal services
 - C. Emails advertising a church event
 - D. Emails advertising stock prices
4. What is the .ost file format used for?
 - A. Microsoft Outlook mailbox
 - B. Microsoft Outlook offline storage
 - C. Microsoft Lotus Notes
 - D. Microsoft Outlook Express
5. Lotus Notes uses the following file format.
 - A. mbx
 - B. pst
 - C. ost
 - D. nsf